RQF LEVEL 5



NITCS501

NETWORKING AND INTERNET TECHNOLOGIES

Cyber Security

TRAINEE'S MANUAL

October, 2024

CYBER SECURITY

KOICA Korea International Cooperation Agency

TQUM TVET Quality Management Project

2024

AUTHOR'S NOTE PAGE (COPYRIGHT)

The competent development body of this manual is Rwanda TVET Board ©, reproduce with permission.

All rights reserved.

- This work has been produced initially with the Rwanda TVET Board with the support from KOICA through TQUM Project
- This work has copyright, but permission is given to all the Administrative and Academic Staff of the RTB and TVET Schools to make copies by photocopying or other duplicating processes for use at their own workplaces.
- This permission does not extend to making of copies for use outside the immediate environment for which they are made, nor making copies for hire or resale to third parties.
- The views expressed in this version of the work do not necessarily represent the views of RTB. The competent body does not give warranty nor accept any liability
- RTB owns the copyright to the trainee and trainer's manuals. Training providers may reproduce these training manuals in part or in full for training purposes only. Acknowledgment of RTB copyright must be included on any reproductions. Any other use of the manuals must be referred to the RTB.

© Rwanda TVET Board

Copies available from:

- *HQs: Rwanda TVET Board-RTB*
- *Web: www.rtb.gov.rw*
- **KIGALI-RWANDA**

Original published version: October 2024

ACKNOWLEDGEMENTS

The publisher would like to thank the following for their assistance in the elaboration of this training manual:

Rwanda TVET Board (RTB) extends its appreciation to all parties who contributed to the development of the trainer's and trainee's manuals for the TVET Certificate V in Networking and Internet Technologies, specifically for the module "NICS501: CYBER SECURITY".

We extend our gratitude to KOICA Rwanda for its contribution to the development of these training manuals and for its ongoing support of the TVET system in Rwanda.

We extend our gratitude to the TQUM Project for its financial and technical support in the development of these training manuals.

We would also like to acknowledge the valuable contributions of all TVET trainers and industry practitioners in the development of this training manual.

The management of Rwanda TVET Board extends its appreciation to both its staff and the staff of the TQUM Project for their efforts in coordinating these activities.

This training manual was developed:

Under Rwanda TVET Board (RTB) guiding policies and directives

Under Financial and Technical support of

COORDINATION TEAM

RWAMASIRABO Aimable
MARIA Bernadette M. Ramos
MUTIJIMA Asher Emmanuel

PRODUCTION TEAM

Authoring and Review

HANYURWIMFURA Dieudonne

NEMEYIMANA Jean Baptiste

Validation

TUYIZERE Vital

MANISHIMWE Yves

HABIYAMBERE Daniel

Conception, Adaptation and Editorial works

HATEGEKIMANA Olivier

GANZA Jean Francois Regis

HARELIMANA Wilson

NZABIRINDA Aimable

DUKUZIMANA Therese

NIYONKURU Sylvestre

BYUKUSENGE Protais

Formatting, Graphics, Illustrations, and infographics

YEONWOO Choe
SUA Lim
SAEM Lee
SOYEON Kim
WONYEONG Jeong
MANISHIMWE Marc

Financial and Technical support

KOICA through TQUM Project

TABLE OF CONTENT

AUTHOR'S NOTE PAGE (COPYRIGHT)----iii
ACKNOWLEDGEMENTS----iv
TABLE OF CONTENT ----vii
ACRONYMS----ix
INTRODUCTION ---- 1
MODULE CODE AND TITLE: NITCS501 CYBER SECURITY ---- 2
Learning Outcome 1: Assess security Risks and Vulnerabilities ---- 3
Key Competencies For Learning Outcome 1: Assess Security Risks And Vulnerabilities4
Indicative content 1.1: Introduction to Cyber Security---- 6
Indicative content 1.2: Describe Cyber Threats---- 15
Indicative content 1.3: Describe Cyber Vulnerabilities---- 23
Indicative content 1.4: Cyber Attacks and Techniques---- 27
Indicative content 1.5: Identification of Asset in Cyber security---- 32
Indicative content 1.6: Definition of Security Policies and Frameworks ---- 38
Indicative content 1.7: Cyber security Frameworks and Standards ---- 42
Indicative content 1.8: Identification of security risks and Vulnerability ---- 48
Learning outcome 1 end assessment ---- 68
References---- 72
Learning Outcome 2: Implement Security Measures----73
Key Competencies For Learning Outcome 2: Implement Security Measures ---- 74
Indicative content 2.1: Implementation of Access Control Mechanisms ---- 77
Indicative content 2.2: Implementation of User Authentiquassions Mechanisms ---- 90
Indicative content 2.3: Implementation of Autorisation Mechanisms ----102
Indicative content 2.4: Implementation of Access Request and Approval Workflow 144
Indicative content 2.5: Deployment of Firewalls and IDS/IPS ----149
Indicative content 2.6: Isolate Critical Systems ----160
Indicative content 2.7: Encrypt Sensitive Data for Protection----168
Indicative content 2.8 : Management of encryption keys----180
Indicative content 2.9: Update Endpoint Security for maintenance ----184
Indicative content 2.10: Implement Device Management Policies----192
Indicative content 2.11 : Apply Security Patches for Security Management----195

Learning outcome 2 end assessment ---------- 204
References ---------- 210
Learning Outcome 3: Perform Monitoring and Detection ---------- 211
Key Competencies for Learning Outcome 3: Perform monitoring and detection ----- 212
Indicative content 3.1 : Security Threats Monitoring ---------- 214
Indicative content 3.2: Applying Monitoring Techniques and Threat Intelligence ---- 225
Indicative content 3.3: Conducting Methodical Threat Hunting with Intelligence Feeds ---------- 230
Indicative content 3.4: Monitoring Network and System Logs ---------- 236
Indicative content 3.5: Systems Scanning and Penetration Testing ---------- 249
Learning outcome 3 end assessment ---------- 260
References ---------- 265
Learning Outcome 4: Perform Incident Response and Recovery ---------- 266
Key Competencies for Learning Outcome 4: Perform Incident Response and Recovery ---------- 267
Indicative content 4.1: Developing Incident Response Plan ---------- 271
Indicative content 4.2: Developing Incident Recovery Plan ---------- 284
Indicative content 4.3: Identification of Security Incident ---------- 291
Indicative content 4.4: Isolation of Affected System ---------- 302
Indicative content 4.5. Conducting Methodical Forensic Analysis ---------- 310
Indicative content 4.6. Restoring System and Data ---------- 320
Learning outcome 4 end assessment ---------- 330
References ---------- 336

ACRONYMS

ACL: Access Control List

BIA: Business Impact Analysis

CIA: Confidentiality, Integrity, and Availability

DAC: Discretionary Access Control

DDoS: Distributed Denial of Service

DR/BCP: Disaster Recovery/Business Continuity Planning

GDPR: General Data Protection Regulation

HIPAA: Health Insurance Portability and Accountability Act

IDS: Intrusion Detection System

IoC: Indicator of Compromise

IPS: Intrusion Prevention System

ISO: International Organization for Standardization.

MAC: Mandatory Access Control

MFA: Multi-Factor Authentication

NIST: National Institute of Standards and Technology

NMAP: Network Mapper

RBAC: Role-based Access Control

RPO: Recovery Point Objective

RTB: Rwanda TVET Board

RTO: Recovery Time Objective

SFA: Single Factor Authentication

SIEM: Security Information and Event Management

SSL: Secure Sockets Layer

SSO: Single Sign-On

TLS: Transport Layer Security

TQUM Project: TVET Quality Management Project

INTRODUCTION

This trainee's manual includes all the knowledge and skills required in Network and internet technologies specifically for the module of **"Cyber security".** Trainees enrolled in this module will engage in practical activities designed to develop and enhance their competencies. The development of this training manual followed the Competency-Based Training and Assessment (CBT/A) approach, offering ample practical opportunities that mirror real-life situations.

The trainee's manual is organized into Learning Outcomes, which are broken down into indicative content that includes both theoretical and practical activities. It provides detailed information on the key competencies required for each learning outcome, along with the objectives to be achieved.

As a trainee, you will start by addressing questions related to the activities, which are designed to foster critical thinking and guide you toward practical applications in the labor market. The manual also provides essential information, including learning hours, required materials, and key tasks to complete throughout the learning process.

All activities included in this training manual are designed to facilitate both individual and group work. After completing the activities, you will conduct a formative assessment, referred to as the end learning outcome assessment. Ensure that you thoroughly review the key readings and the 'Points to Remember' section.

MODULE CODE AND TITLE: NITCS501 CYBER SECURITY

Learning Outcome 1: Assess Security Risks and Vulnerabilities
Learning Outcome 2: Implement Security Measures
Learning Outcome 3: Perform Monitoring and Detection
Learning Outcome 4: Perform Incident Response and Recovery


****
OK

Indicative contents
1.1 Introduction to Cyber Security
1.2 Describe Cyber Threats
1.3 Describe Cyber Vulnerabilities
1.4 Cyber Attacks and Techniques
1.5 Identification of Asset in Cyber security
1.6 Definition of Security Policies and Frameworks
1.7 Cyber security Frameworks and Standards
1.8 Identification of security risks and Vulnerability

Key Competencies For Learning Outcome 1: Assess Security Risks And Vulnerabilities

Knowledge	Skills	Attitudes
• Description of Cyber Security. • Description of cyber threats. • Description of Cyber Vulnerabilities and risks. • Identification of Cyber Attack and Techniques. • Classification of assets used in cyber security. • Identification of Security Policies, Frameworks and Standards.	• Analyzing Common Cyber Attack and Techniques. • Assessing security risks • Reporting security issues based to Security Assessment	• Having team spirit while working with others. • Being responsible. • Being organized to achieve the required result. • Having Curiosity. • Being Accountable • Being resilience. • Attention to details



Duration: 20 hrs

Learning outcome 1 objectives:



By the end of the learning outcome, the trainees will be able to:

1. Describe clearly cyber security based on security policies.
2. Describe correctly Cyber threats in cyber security.
3. Identify correctly the cyber vulnerabilities and risks in cyber security.
4. Identify properly Cyber-attacks and techniques in cyber security.
5. Identify correctly cyber security assets based on types and valuation.
6. Describe properly Security Policies, Frameworks, and Standards in Cyber security.
7. Identify correctly Vulnerability and security risks according to the security
8. Assess correctly vulnerability in Cyber security.
9. Report correctly security issues based to Security Assessment



Resources

Equipment	Tools	Materials
• Computers	• Wireshark • Nessus • NMAP • OpenVAS • Air crack	• Internet

Indicative content 1.1: Introduction to Cyber Security

Duration: 2 hrs

Theoretical Activity 1.1.1: Description of Cyber Security

Tasks:

1: Answer the following questions:

i. Describe cyber security.
ii. What are the difference between cyber threats and attacks?
iii. Give importance of cyber security in the digital age
iv. Discuss The evolving landscape of cyber threats
v. Discuss on key terminology and concepts of cyber security such as Threat, Vulnerability, Attack, Malware, Phishing, Ransomware, Firewall, Encryption, Authentication, Intrusion Detection System (IDS), Security Incident, Cybersecurity Policy.
vi. What is confidentiality, integrity, and availability (CIA triad)
vii. What are Cyber security roles and responsibilities

2: Present your group's findings on the discussed topics.

3: Ask clarification if any

4: Read the key readings 1.1.1.

Key readings 1.1.1.:

Description of Cyber Security

1. Cyber Security Overview

Cybersecurity is the practice of protecting computers, networks, programs, and data from unauthorized access, damage, or theft. It encompasses a wide range of technologies, processes, and practices designed to safeguard digital information and ensure the integrity, confidentiality, and availability of data.

Understanding Cyber Threats and Attacks

Cyber threats refer to potential dangers or risks that arise from vulnerabilities in computer systems, networks, or digital infrastructures.

These threats can encompass various malicious activities, including hacking, malware infections, data breaches, and unauthorized access to sensitive information. Cyber threats can originate from individuals, organized groups, or even state-sponsored entities, and they continuously evolve as technology advances.

Cyber-attacks, on the other hand, are deliberate and malicious actions taken to exploit vulnerabilities in computer systems, networks, or digital devices with the intent of causing harm, stealing data, disrupting operations, or gaining unauthorized access. Cyber-attacks can take many forms, such as malware attacks (including viruses, worms, ransomware), denial-of-service (DoS) attacks, phishing, social engineering, and more. The goal of a cyber-attack is typically to compromise the confidentiality, integrity, or availability of digital assets or services.

The key difference between cyber threats and cyber-attacks lies in their nature and stage of development. Cyber threats represent the broader spectrum of potential risks and vulnerabilities in the digital realm, including both known and unknown dangers.

Cyber-attacks, on the other hand, are specific instances where those threats are realized, and malicious actions are taken to exploit vulnerabilities for nefarious purposes. In essence, cyber threats are the precursors or potential scenarios, while cyber-attacks are the actualized manifestations of those threats.

Cyber threats and attacks encompass a wide range of malicious activities aimed at exploiting vulnerabilities in computer systems, networks, and data. The threats and attacks include Malware, Phishing, Ransomware, Denial-of-Service (DoS) and Distributed Denial-of-Service (DDoS) Attacks, Man-in-the-Middle (MitM) Attacks, SQL Injection, Zero-Day Exploits, and Insider Threats.

Real-world examples

A. **Cyber Threat:** Imagine you have a house with several entry points like doors and windows. Knowing that there are burglars in the area who might try to break in, you recognize the possibility of a break-in (cyber threat). This awareness is similar to understanding that there are potential vulnerabilities in your computer systems or networks that could be exploited by cybercriminals.

B. **Cyber Attack:** Now, suppose one night someone actually attempts to break into your house by picking the lock on your back door. This is an actualized attempt to exploit a vulnerability (cyber-attack). They're actively trying to breach your security measures to gain unauthorized access.

In this analogy, the cyber threat is the general knowledge or awareness that your house could be targeted by burglars, whereas the cyber-attack is the specific incident where someone tries to break in through a particular vulnerability. The threat exists regardless of whether an attack occurs, but an attack is the realization of that threat into action.

1.2. Importance of cyber security in the digital age

In the digital age, cybersecurity is of paramount importance due to several key factors:

1. Protection of Sensitive Information: With the increasing digitization of personal, financial, and business data, cybersecurity measures are necessary to safeguard sensitive information from unauthorized access, theft, or manipulation.

2. Prevention of Financial Loss: Cybersecurity helps prevent financial losses associated with data breaches, ransomware attacks, fraud, and theft of financial information. Effective cybersecurity measures can mitigate the financial impact of cyber-attacks on individuals, businesses, and organizations.

3. Preservation of Privacy: Cybersecurity measures protect individuals' privacy by ensuring that personal data remains confidential and is not exploited or misused by unauthorized parties. Privacy breaches can lead to identity theft, harassment, or reputational damage.

4. Maintenance of Trust and Reputation: Maintaining trust and a positive reputation is essential for businesses and organizations in the digital age. Effective cybersecurity practices demonstrate a commitment to protecting customer data and can help preserve trust and credibility with stakeholders.

5. Business Continuity and Operational Resilience: Cybersecurity measures are critical for ensuring business continuity and operational resilience. Cyber-attacks can disrupt business operations, leading to downtime, loss of productivity, and reputational damage. Robust cybersecurity measures help mitigate these risks and enable organizations to recover quickly from cyber incidents.

6. Compliance with Regulations and Legal Requirements: Many industries and jurisdictions have specific cybersecurity regulations and legal requirements that organizations must comply with. Failure to implement adequate cybersecurity measures can result in legal and financial consequences, including fines, lawsuits, and regulatory sanctions.

7. Protection Against Emerging Threats: As cyber threats continue to evolve and become more sophisticated, effective cybersecurity measures are essential for protecting against emerging threats such as ransomware, phishing, insider threats, and zero-day exploits. Continuous monitoring, threat intelligence, and proactive security measures are necessary to stay ahead of evolving cyber threats.

In summary, cybersecurity is essential in the digital age to protect sensitive information, prevent financial losses, preserve privacy, maintain trust and reputation, ensure business continuity, comply with regulations, and protect against emerging cyber threats. Investing in robust cybersecurity measures is crucial for individuals, businesses, and organizations to mitigate risks and secure their digital assets and operations.

1.3. The evolving landscape of cyber threats

In the context of cyber security, "landscape" refers to the overall environment or terrain, metaphorically representing the various elements, factors, and dynamics that shape the field of cybersecurity threats. It encompasses, the types of threats, the actors involved, the methods used, and the vulnerabilities present in digital systems and networks.

The landscape of cyber threats is in a constant state of evolution, propelled by advances in technology, changes in cybercrime tactics, and geopolitical tensions. Advanced Persistent Threats (APTs) orchestrated by nation-state actors, ransomware attacks targeting organizations of all sizes, and supply chain compromises are just a few examples of the sophisticated threats facing modern digital environments. Additionally, the proliferation of Internet of Things (IoT) devices and operational technology (OT) systems has expanded the attack surface, while social engineering tactics like phishing continue to exploit human vulnerabilities.

To navigate this complex landscape, organizations must adopt a proactive and multi-layered approach to cybersecurity. This includes implementing robust threat intelligence programs, conducting regular risk assessments, and investing in technologies and processes to detect and respond to emerging threats effectively. Collaboration between public and private sector entities, information sharing, and ongoing education and training are essential components of a comprehensive cybersecurity strategy aimed at mitigating the risks posed by evolving cyber threats.

2. Cyber security Fundamentals

2.1 Key Terminology and Concepts in Cybersecurity

In cybersecurity, grasping fundamental terms and concepts is vital for safeguarding digital assets and countering threats. From spotting vulnerabilities and thwarting attacks to implementing measures and handling incidents, understanding key terms is crucial. This guide offers an overview of essential cybersecurity terminology, providing insights into the language and principles behind protecting information systems, networks, and data.

1. Threat: Any potential danger that can exploit vulnerabilities in a system or network to compromise data, disrupt operations, or cause harm.

2. Vulnerability: Weaknesses or flaws in a system or network that can be exploited by threats to compromise security.

3. Attack: An unauthorized attempt to bypass security controls and exploit vulnerabilities in a system or network to compromise data, gain unauthorized access, or disrupt operations.

4. **Malware:** Malicious software designed to infiltrate, damage, or steal data from a computer system or network. Common types include viruses, worms, Trojans, ransomware, spyware, and adware.
5. **Phishing:** A type of cyber-attack that involves tricking individuals into revealing sensitive information, such as passwords, credit card numbers, or personal data, by posing as a legitimate entity through email, text messages, or fake websites.
6. **Ransomware:** A type of malware that encrypts a victim's files or entire system and demands a ransom payment in exchange for decryption keys.
7. **Firewall:** A network security device or software that monitors and controls incoming and outgoing network traffic based on predetermined security rules to prevent unauthorized access and protect against cyber-attacks.
8. **Encryption:** The process of converting plaintext data into ciphertext using cryptographic algorithms to protect the confidentiality and integrity of data during transmission or storage.
9. **Authentication:** The process of verifying the identity of users, devices, or entities accessing a system or network to prevent unauthorized access.
10. **Authorization:** The process of granting or restricting access to resources, services, or information based on the authenticated identity and permissions of users, devices, or entities.
11. **Intrusion Detection System (IDS):** A security technology that monitors network or system activities for signs of unauthorized access, misuse, or security policy violations and alerts security personnel or triggers automated responses.
12. **Patch Management:** The process of regularly applying updates, patches, and security fixes to software, operating systems, and firmware to address known vulnerabilities and mitigate security risks.
13. **Security Incident:** Any event or occurrence that compromises the confidentiality, integrity, or availability of data, systems, or networks and requires investigation or remediation to prevent further damage or mitigate risks.
14. **Cybersecurity Policy:** A set of rules, procedures, guidelines, and best practices established by an organization to govern and ensure the security of its information assets, systems, and networks.

Understanding these key concepts is essential for developing and implementing effective cybersecurity strategies and measures to protect against cyber threats and vulnerabilities.

2.2 Principles of confidentiality, integrity, and availability (CIA triad)

The CIA triad, consisting of confidentiality, integrity, and availability, is a foundational framework in cybersecurity that guides efforts to protect information systems, networks, and data.

Here's a brief overview of each principle:

i. **Confidentiality:** Confidentiality ensures that sensitive information is accessible only to authorized individuals or entities. This principle aims to prevent unauthorized access, disclosure, or exposure of confidential data. Measures such as encryption, access controls, authentication mechanisms, and data classification help enforce confidentiality by restricting access to sensitive information and ensuring that it remains private and secure.

ii. **Integrity:** Integrity ensures that data remains accurate, consistent, and trustworthy throughout its lifecycle. This principle focuses on protecting data from unauthorized modification, alteration, or corruption. Techniques such as checksums, digital signatures, hash functions, and access controls help maintain data integrity by detecting and preventing unauthorized changes or tampering. By ensuring the reliability and trustworthiness of data, integrity helps maintain the overall quality and credibility of information systems and processes.

iii. **Availability:** Availability ensures that information and resources are accessible and usable when needed by authorized users. This principle emphasizes the importance of ensuring continuous access to critical services, systems, and data, even in the face of disruptions, failures, or attacks. Measures such as redundancy, fault tolerance, disaster recovery planning, and security controls help maximize availability by minimizing downtime, mitigating disruptions, and ensuring timely access to resources. By ensuring the reliability and accessibility of information and services, availability supports the uninterrupted operation of business processes and critical functions.

In summary, the CIA triad provides a framework for addressing key objectives in cybersecurity: maintaining confidentiality to protect sensitive information, preserving integrity to ensure data accuracy and trustworthiness, and maximizing availability to ensure timely access to resources and services. By adhering to these principles, organizations can establish a strong foundation for effectively managing risk, protecting assets, and maintaining the security and resilience of their information systems and operations.

2.3 Cyber security roles and responsibilities

Cybersecurity roles and responsibilities encompass a diverse range of tasks and functions aimed at protecting information systems, networks, and data from cyber threats. Here's a brief overview of common cybersecurity roles and their responsibilities:

i. **Chief Information Security Officer (CISO):** The CISO is responsible for overseeing the organization's overall cybersecurity strategy and managing its cybersecurity program. Responsibilities include risk management, policy development,

compliance, incident response planning, and collaboration with senior management to ensure alignment with business goals.

ii. **Security Analyst:** Security analysts are responsible for monitoring and analyzing security events, alerts, and logs to detect and respond to potential threats and incidents. They investigate security breaches, conduct forensic analysis, and implement security controls to mitigate risks and vulnerabilities.

iii. **Security Engineer:** Security engineers design, implement, and maintain security solutions and infrastructure to protect against cyber threats. Responsibilities may include configuring firewalls, intrusion detection systems, encryption mechanisms, and access controls, as well as conducting security assessments and vulnerability testing.

iv. **Incident Response Team:** Incident response teams are responsible for coordinating and managing the response to cybersecurity incidents, such as data breaches, malware infections, or unauthorized access. Responsibilities include identifying, containing, eradicating, and recovering from security incidents, as well as conducting post-incident analysis and remediation.

v. **Security Architect:** Security architects design and build secure IT architectures and systems that meet business requirements while effectively mitigating cybersecurity risks. Responsibilities include defining security requirements, designing security controls, evaluating technologies, and ensuring compliance with security standards and best practices.

vi. **Security Operations Center (SOC) Analyst:** SOC analysts monitor and analyze security events and alerts in real-time to identify and respond to potential security incidents. Responsibilities may include triaging alerts, conducting investigations, coordinating with incident response teams, and providing recommendations for enhancing security posture.

vii. **Security Awareness Trainer:** Security awareness trainers educate employees and stakeholders about cybersecurity best practices, policies, and procedures to promote a culture of security awareness within the organization. Responsibilities include developing training materials, delivering presentations, conducting phishing simulations, and measuring effectiveness through awareness assessments.

viii. **Compliance Officer:** Compliance officers ensure that the organization adheres to relevant cybersecurity laws, regulations, and industry standards. Responsibilities include assessing compliance requirements, implementing controls to address regulatory obligations, conducting audits and assessments, and reporting on compliance status to senior management and regulatory authorities.

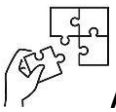
In summary, cybersecurity roles and responsibilities are diverse and multifaceted, encompassing various functions such as strategy development, risk management, incident response, security operations, architecture design, compliance, and

awareness training. Collaboration among these roles is essential for effectively managing cybersecurity risks and protecting against evolving cyber threats.



Points to Remember

- **Cybersecurity** refers to the practice of protecting systems, networks, and programs from digital attacks, theft, and damage
- **Cyber threats** are potential dangers arising from vulnerabilities in computer systems, networks, or digital infrastructures, often involving hacking, malware, and data breaches. While **Cyber-attacks** are deliberate, malicious actions that exploit these vulnerabilities to steal data, disrupt operations, or gain unauthorized access.
- Importance of cyber security in the digital age are Protection of Sensitive Information, Prevention of Financial Loss, Preservation of Privacy, Maintenance of Trust and Reputation, Business Continuity and Operational Resilience, Compliance with Regulations and Legal Requirements, Protection against Emerging Threats.
- The cyber threat landscape is constantly evolving due to technological advancements, shifting cybercrime tactics, and geopolitical factors, with threats like APTs, ransomware, and supply chain attacks becoming more sophisticated. The rise of IoT and operational technology systems has expanded the attack surface, while social engineering tactics continue to exploit human vulnerabilities
- Cyber security key terminology and concepts are Threat, Vulnerability, Attack, Malware, Phishing, Ransomware, Firewall, Encryption, Authentication, Intrusion Detection System (IDS), Security Incident, Cybersecurity Policy
- The CIA triad provides a framework for addressing key objectives in cyber security: maintaining confidentiality to protect sensitive information, preserving integrity to ensure data accuracy and trustworthiness, and maximizing availability to ensure timely access to resources and services.
- Cyber security roles and responsibilities are diverse and multifaceted, encompassing various functions such as strategy development, risk management, incident response, security operations, architecture design, compliance, and awareness training



Application of learning 1.1.

GOLI School is an educational institution. As part of the IT security team at GOLI School, which uses an IoT-based facial recognition system to manage child pickups, you have recently received reports of suspicious activity. The school administration has asked you to provide basic information on cyber threats and attacks, the importance of cybersecurity in the digital age, the evolution of the cyber threat landscape, key cybersecurity terminology and concepts, the CIA triad, and cybersecurity roles and responsibilities for each user.

Indicative content 1.2: Describe Cyber Threats

Duration: 2 hrs

Theoretical Activity 1.2.1: Introduction to Cyber Threats

Tasks:

1: Work in groups to answer the following questions:

i. Define Cyber Threats
ii. Give importance of Cyber Threat Awareness
iii. What is Evolving Landscape of Cyber Threats?
iv. Identify Types of Cyber

2: Present your group's findings on the discussed topics.

3: Ask clarification if any

4: Read the key readings 1.2.1.

Key readings 1.2.1.:

Describe cyber threat

1. Introduction to Cyber Threats

Cyber threats encompass a wide range of malicious activities aimed at exploiting vulnerabilities in computer systems, networks, and data. These threats can originate from various sources, including individuals, criminal organizations, hacktivists, and even nation-states. From simple phishing attacks to complex malware and ransomware campaigns, cyber threats pose serious risks to individuals, businesses, and governments worldwide.

1.1 Definition of cyber threat

Cyber threats refer to malicious activities or risks aimed at exploiting vulnerabilities in computer systems, networks, and data. These threats can encompass a wide range of malicious actions, including malware infections, phishing attacks, ransomware campaigns, and unauthorized access to sensitive information. Cyber threats pose significant risks to individuals, businesses, and governments by compromising the confidentiality, integrity, and availability of digital assets and infrastructure.

1.2 Importance of cyber threat awareness

Cyber threat awareness is crucial in today's digital age due to the pervasive and evolving nature of cyber threats. Here's why it's important:

i. **Risk Mitigation:** Awareness empowers individuals and organizations to identify potential cyber threats, enabling them to take proactive measures to mitigate risks and protect their digital assets.

ii. **Vulnerability Awareness:** Understanding common cyber threats helps users recognize vulnerabilities in their systems and networks, allowing them to implement security measures to address these weaknesses effectively.

iii. **Prevention of Attacks:** Awareness of phishing scams, malware, and other cyber threats helps users recognize suspicious activities and avoid falling victim to cyber-attacks, reducing the likelihood of successful breaches.

iv. **Data Protection:** Awareness of cyber threats promotes best practices for safeguarding sensitive information, such as using strong passwords, encrypting data, and regularly updating security software, thereby enhancing data protection efforts.

v. **Business Continuity:** For organizations, cyber threat awareness is essential for maintaining business continuity. By understanding potential threats and implementing robust cybersecurity measures, businesses can minimize disruptions caused by cyber-attacks and ensure uninterrupted operations.

vi. **Financial Loss Prevention:** Cyber-attacks can result in significant financial losses due to data breaches, theft of intellectual property, and damage to reputation. Awareness of cyber threats helps individuals and organizations mitigate financial risks by investing in appropriate security measures and incident response plans.

vii. **Compliance Requirements:** Many industries and jurisdictions have specific cybersecurity regulations and compliance requirements. Cyber threat awareness enables organizations to stay compliant with these regulations, avoiding potential legal and financial consequences.

- **Protecting Personal Privacy:** Individuals need to be aware of cyber threats to protect their personal privacy online. Understanding the risks associated with sharing sensitive information and using secure online practices helps safeguard personal data from unauthorized access and misuse.

Overall, cyber threat awareness is essential for promoting a culture of cybersecurity, where individuals and organizations are proactive in identifying, mitigating, and responding to cyber threats effectively.

1.3. The Evolving Landscape of Cyber Threats

The landscape of cyber threats is continuously evolving due to advancements in technology, changes in attacker tactics, and the expanding attack surface. Here's a brief overview:

- **Increased Sophistication:** Cybercriminals are becoming more sophisticated in their techniques, using advanced malware, social engineering tactics, and encryption methods to evade detection and bypass security measures.
- **Targeted Attacks:** Instead of indiscriminate attacks, cybercriminals are increasingly launching targeted attacks against specific individuals, organizations, or industries. These attacks are often tailored to exploit specific vulnerabilities or steal valuable data.
- **Ransomware Proliferation:** Ransomware attacks have surged in recent years, with cybercriminals encrypting victims' data and demanding ransom payments for decryption keys. The rise of ransomware-as-a-service (RaaS) platforms has made it easier for less skilled attackers to carry out these attacks.
- **Supply Chain Attacks:** Attackers are targeting the supply chain to infiltrate organizations indirectly. By compromising third-party vendors or suppliers, attackers can gain access to their clients' networks and launch attacks from within, making detection and attribution more challenging.
- **IoT Vulnerabilities:** The proliferation of Internet of Things (IoT) devices has introduced new vulnerabilities, as many IoT devices lack robust security features and are often connected to networks without proper protection. Attackers can exploit these vulnerabilities to launch large-scale attacks or gain unauthorized access to sensitive data.
- **Cloud Security Challenges:** The adoption of cloud computing presents new security challenges, as organizations transition their data and applications to cloud environments. Misconfigurations, unauthorized access, and data breaches are among the common risks associated with cloud computing.
- **Nation-State Threats:** Nation-state actors are increasingly engaging in cyber espionage, sabotage, and disruption activities against other countries, organizations, and critical infrastructure. These attacks can have significant geopolitical implications and often involve highly sophisticated tactics and techniques.
- **Emerging Technologies:** New technologies such as artificial intelligence (AI), machine learning, and quantum computing introduce both opportunities and risks in cybersecurity. While AI and machine learning can enhance threat detection and response capabilities, they can also be leveraged by attackers to automate attacks and evade traditional security defenses.

In summary, the evolving landscape of cyber threats is characterized by increasing sophistication, targeted attacks, ransomware proliferation, supply chain

vulnerabilities, IoT and cloud security challenges, nation-state threats, and the impact of emerging technologies. Staying informed about these trends and implementing robust cybersecurity measures are essential for mitigating risks and protecting against evolving cyber threats.

1.4. Types of Cyber Threats

Malware threats, including viruses, worms, and Trojans, are malicious software programs designed to infiltrate and damage computer systems or steal sensitive information.

- **Viruses:** Viruses attach themselves to legitimate programs or files and replicate when executed, spreading to other files and systems. They can cause various damages, from data corruption to system instability.
- **Worms:** Worms are standalone malicious programs that replicate and spread across networks without needing to attach to other files. They exploit vulnerabilities in network protocols to propagate rapidly, often causing widespread damage and consuming network resources.
- **Trojans:** Trojans disguise themselves as legitimate software to trick users into downloading and executing them. Once installed, Trojans can perform a range of malicious activities, such as stealing sensitive information, installing backdoors for remote access, or conducting denial-of-service attacks.

- **Ransomware Threats**

Ransomware is a type of malicious software designed to deny access to a computer system or data until a ransom is paid. It typically encrypts files on the victim's system, rendering them inaccessible, and then demands payment, often in cryptocurrency, in exchange for a decryption key or to prevent the release of sensitive information.

- **A Distributed Denial of Service (DDoS) attack**

Is a malicious attempt to disrupt the normal functioning of a targeted server, service, or network by overwhelming it with a flood of internet traffic. Unlike traditional denial-of-service attacks, which typically originate from a single source, DDoS attacks involve multiple compromised devices or systems, often distributed across the internet and controlled by the attacker. These compromised devices are commonly referred to as "botnets."

Types of Attacks: DDoS attacks can take various forms, including:

◆ **Volumetric Attacks:** These flood the target with a high volume of traffic, such as UDP or ICMP packets, consuming all available bandwidth.

◆ **Protocol Attacks:** These exploit weaknesses in network protocols (e.g., SYN flood, ICMP flood) to exhaust server resources and disrupt communication.

Application Layer Attacks: These target specific applications or services, such as HTTP,

◆ DNS, or FTP, by overwhelming them with a large number of legitimate-looking requests, making it difficult to distinguish between legitimate and malicious traffic.

Mitigation: Defending against DDoS attacks requires a combination of proactive measures, including:

◆ **Network Filtering:** Employing firewalls, routers, and intrusion detection/prevention systems to filter and block malicious traffic.

◆ **Content Delivery Networks (CDNs):** Using CDNs to distribute traffic and absorb DDoS attacks closer to their source, mitigating the impact on the target server.

◆ **Rate Limiting:** Implementing rate-limiting mechanisms to restrict the volume of incoming requests from individual IP addresses or networks.

◆ **DDoS Protection Services:** Utilizing specialized DDoS protection services offered by internet service providers or third-party vendors to detect and mitigate attacks in real-time.

Overall, DDoS attacks continue to be a significant threat to online businesses and organizations, requiring proactive measures and ongoing vigilance to mitigate their impact effectively.

- **Insider threats**

Insider threats refer to security risks that originate from within an organization, typically involving current or former employees, contractors, or business partners who have access to sensitive information or systems. These individuals may intentionally or unintentionally misuse their access privileges to compromise the confidentiality, integrity, or availability of data or systems. Insider threats can manifest in various forms:

◆ **Malicious Insider:** This type of insider threat involves individuals who deliberately misuse their access to steal sensitive information, sabotage systems, or cause harm to the organization. Motivations may include financial gain, revenge, ideology, or coercion.

◆ **Careless or Negligent Insider:** Not all insider threats are malicious; some result from employees or individuals who inadvertently compromise security through negligence, carelessness, or lack of awareness. This could involve actions such as falling victim to phishing scams, using weak passwords, or mishandling sensitive data.

◆ **Compromised Insider:** In this scenario, insiders may become unwitting participants in a security breach due to external coercion or exploitation by malicious actors. For example, an employee whose credentials are stolen or

compromised could inadvertently facilitate unauthorized access to systems or data.

◆ **Unintentional Insider:** Sometimes, insiders may unintentionally cause security breaches due to errors or mistakes in their work. This could include misconfigurations, accidental data disclosures, or unintended actions that lead to system vulnerabilities.

Insider threats pose significant challenges for organizations because insiders often have legitimate access to sensitive systems and information, making their activities harder to detect compared to external threats. Mitigating insider threats requires a combination of technical controls, such as access controls, monitoring systems, and encryption, along with non-technical measures like employee training, awareness programs, and establishing clear policies and procedures for handling sensitive data. Additionally, organizations may implement user behavior analytics and insider threat detection solutions to identify suspicious activities and mitigate risks proactively.

- **Social engineering attacks**

Social engineering attacks are manipulative tactics used by cybercriminals to deceive individuals into divulging confidential information, performing actions, or providing access to systems or data. Unlike traditional hacking methods that rely on exploiting technical vulnerabilities, social engineering exploits human psychology and relies on building trust or exploiting human weaknesses to achieve malicious objectives. Here are some common types of social engineering attacks:

◆ **Phishing:** Phishing attacks involve sending deceptive emails, text messages, or instant messages that appear to come from a legitimate source, such as a bank, government agency, or reputable company. These messages typically contain urgent requests or enticing offers, prompting recipients to click on malicious links, download infected attachments, or disclose sensitive information like login credentials or financial details.

◆ **Spear Phishing:** Spear phishing is a targeted form of phishing that involves customizing messages to specific individuals or organizations, often using information gathered from social media, company websites, or previous interactions. By personalizing the messages, attackers increase the likelihood of success and make it harder for recipients to discern the malicious intent.

◆ **Pretexting:** Pretexting involves creating a fabricated scenario or pretext to trick individuals into divulging sensitive information or performing certain actions. This could include impersonating a trusted authority figure, such as a company executive, IT support technician, or government official, and using persuasion techniques to obtain confidential data or access to systems.

◆ **Baiting:** Baiting attacks entice victims with the promise of something desirable, such as free software, music downloads, or movie streaming, in exchange for their personal information or login credentials. These attacks often involve the distribution of infected USB drives, CDs, or other physical media, as well as enticing online advertisements or fake download links.

◆ **Tailgating:** Also known as piggybacking, tailgating involves gaining unauthorized physical access to restricted areas by following an authorized person through access-controlled doors or checkpoints without proper authentication. Attackers may impersonate employees, delivery personnel, or maintenance workers to blend in and bypass security measures.

◆ **Quid Pro Quo:** Quid pro quo attacks involve offering a service, benefit, or reward in exchange for sensitive information or access to systems. For example, an attacker posing as a technical support representative may offer assistance with a fake IT problem in exchange for login credentials or remote access to the victim's computer.

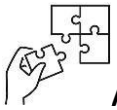
Social engineering attacks exploit human psychology and trust, making them highly effective and difficult to defend against solely with technical solutions. Mitigating social engineering risks requires a combination of security awareness training, employee education, strong authentication measures, robust access controls, and vigilance in verifying the authenticity of communications and requests.

- **Zero-day exploits**

Zero-day exploits refer to vulnerabilities in software or hardware that are unknown to the vendor or developer, making them highly valuable to attackers. These vulnerabilities can be exploited to gain unauthorized access to systems, steal data, or launch other malicious activities. Because they are unknown, there are typically no patches or fixes available, hence the term "zero-day" - there are zero days of protection. Attackers often keep such exploits secret, selling them on the black market or using them for targeted attacks. Security researchers and organizations work to discover and patch these vulnerabilities before they can be exploited by malicious actors.

Points to Remember

- Cyber threats refer to malicious activities or risks aimed at exploiting vulnerabilities in computer systems, networks, and data
- Importance of cyber threat awareness are Risk Mitigation, Vulnerability Awareness, Prevention of Attacks, Data Protection, Business Continuity, Financial Loss Prevention and Protecting Personal Privacy.
- The landscape of cyber threats is continuously evolving due to advancements in technology, changes in attacker tactics, and the expanding attack surface
- Types of Cyber Threats Are Malware Threats Viruses, Worms and Trojans, Phishing Attacks, Ransomware Threats, DDoS (Distributed Denial of Service) Attacks, Insider Threats, Social Engineering Attacks and Zero-Day Exploits



Application of learning 1.2.

H.D Company Ltd has experienced unusual network activity and Unusual Traffic. As you are a cybersecurity analyst, you are tasked to Describe of Cyber Threats, explain Importance of Cyber Threat Awareness, describe evolving Landscape of Cyber Threats and explain all cyber threats and damage they can course to computer systems.

Indicative content 1.3: Describe Cyber Vulnerabilities

Duration: 2 hrs

Theoretical Activity 1.3.1 Description of Cyber Vulnerabilities.

Tasks:

1. Answer the following questions:
   i. Describe vulnerability system in cyber security
   ii. Describe significance for identifying vulnerabilities in Cyber security
   iii. Differentiate Software from Hardware vulnerabilities.
   iv. Discuss on Common Vulnerabilities (Misconfigured Security Settings, Unpatched Software, Weak Passwords and Authentication, Lack of Encryption, Inadequate Access Controls, Software and Hardware Flaws)
2: Present your group's findings on the discussed topics.
3: Ask clarification if any

4: Read the key readings 1.3.1.

Key readings 1.3.1

Describe Cyber Vulnerabilities

1. Introduction to Vulnerabilities

- **Definition of Vulnerabilities**

  Vulnerabilities in cybersecurity refer to weaknesses or flaws in computer systems, networks, software, or hardware that can be exploited by attackers to compromise security. These vulnerabilities may arise due to software bugs, misconfigurations, design flaws, or other factors, and they can potentially enable unauthorized access, data breaches, system compromises, or other forms of cyber-attacks. Identifying and mitigating vulnerabilities is crucial for maintaining the integrity, confidentiality, and availability of digital assets and protecting against potential security breaches.

- **Significance of Identifying Vulnerabilities**

  Identifying vulnerabilities in cybersecurity is crucial as it allows organizations to proactively address potential weaknesses in their systems, networks, and software before they can be exploited by attackers. By systematically identifying vulnerabilities through security assessments, penetration testing, and

vulnerability scanning, organizations can assess their overall security posture and prioritize remediation efforts. This proactive approach helps prevent security breaches, data leaks, and system compromises, reducing the risk of financial losses, reputational damage, and legal liabilities associated with cyber-attacks. Additionally, identifying vulnerabilities enables organizations to comply with regulatory requirements, industry standards, and best practices for cybersecurity, enhancing their resilience against evolving threats and ensuring the confidentiality, integrity, and availability of their digital assets. Overall, the significance of identifying vulnerabilities lies in its role in strengthening cybersecurity defenses, mitigating risks, and safeguarding against potential cyber threats.

- **Vulnerabilities in Software and Hardware**

Vulnerabilities in software and hardware represent weaknesses or flaws that can be exploited by attackers to compromise security.

In software, vulnerabilities often arise due to coding errors, design flaws, or insufficient testing during development. **Common types of software vulnerabilities include buffer overflows, injection flaws (such as SQL injection or cross-site scripting), authentication bypasses, and insecure configurations.** These vulnerabilities can allow attackers to execute arbitrary code, gain unauthorized access, steal sensitive information, or disrupt system operations.

On the other hand, vulnerabilities in hardware may stem from design flaws, manufacturing defects, or weaknesses in the implementation of security features. Hardware vulnerabilities can include **backdoors, firmware vulnerabilities, side-channel attacks, and hardware-based exploits.** Exploiting these vulnerabilities can enable attackers to compromise system integrity, intercept communications, or bypass security controls at a lower level than software vulnerabilities.

Manufacturers and developers need to prioritize security in the design and production of hardware and software products to minimize the risk of vulnerabilities that could be exploited by attackers.

2. Common Vulnerabilities

- **Misconfigured Security Settings**

Misconfigurations in system or application settings, such as weak passwords, open ports, or outdated patches, can leave systems vulnerable to attacks. These errors, often caused by human oversight, allow unauthorized access or data breaches. Regular security reviews and adherence to best practices help mitigate these risks.

- **Unpatched Software**

  Software without the latest security updates is at risk from known vulnerabilities that attackers can exploit. Regular patch management ensures that systems remain protected from such vulnerabilities, improving overall security.

- **Weak Passwords and Authentication**

  Simple or easily guessable passwords are vulnerable to attacks. Weak authentication increases risks of unauthorized access. Organizations should enforce strong passwords, implement multi-factor authentication (MFA), and educate users on password security.

- **Lack of Encryption**

  Failing to encrypt sensitive data exposes it to interception and unauthorized access. Organizations should use encryption for data in transit and at rest to ensure privacy, confidentiality, and regulatory compliance.

- **Inadequate Access Controls**

  Insufficient access controls allow unauthorized users to gain access to sensitive resources. Implementing role-based access, enforcing least privilege, and conducting regular access reviews improve security by limiting access to authorized personnel only.

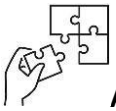
- **Software and Hardware Flaws**

  Vulnerabilities in software code or hardware design can be exploited by attackers to gain control or steal data. Addressing these flaws through security assessments, updates, and secure development practices reduces the risk of breaches.



Points to Remember

- Vulnerabilities in cybersecurity refer to weaknesses or flaws in computer systems, networks, software, or hardware that can be exploited by attackers to compromise security
- Identifying vulnerabilities in cybersecurity is crucial as it allows organizations to proactively address potential weaknesses in their systems, networks, and software before they can be exploited by attackers
- Software vulnerabilities often result from coding errors, design flaws, or insecure configurations, while hardware vulnerabilities may arise from design defects, backdoors, or firmware weaknesses.
- Common Vulnerabilities are Misconfigured Security Settings, Unpatched Software, Weak Passwords and Authentication, Lack of Encryption, Inadequate Access Controls Software and Hardware Flaws



Application of learning 1.3.

A GT healthcare organization has experienced a significant data breach, exposing sensitive patient information to unauthorized individuals. Upon investigation, it becomes apparent that a combination of security vulnerabilities and misconfigurations allow the attackers to gain access to the network and exfiltrate data. You are requested by CEO to Describe Vulnerabilities, Provide Significance of Identifying Vulnerabilities, Explain Common Vulnerabilities Software and Hardware Vulnerabilities and highlight impact of vulnerabilities on patient data and healthcare operations.

Indicative content 1.4: Cyber Attacks and Techniques

Duration: 2 hrs

Theoretical Activity 1.4.1: Identification of Cyber Attack and its Techniques

Tasks:

1. Answer the following questions:
   i. Definition of Cyber Attacks
   ii. What are Goals, Objectives and motivation Behind Cyber Attacks
   iii. Explain Common Cyber Attack Techniques (Malware Attacks, Social Engineering Attacks, Web Application Attacks, Denial of Service (DoS) and Distributed Denial of Service (DDoS) Attacks, Insider Attacks, SQL Injection Attack)
2: Present your group's findings on the discussed topics.
3: Ask clarification if any

4: Read the key readings 1.4.1.

Key readings 1.4.1

Cyber Attacks and Techniques

1 Introduction to Cyber Attacks

1.1 Definition of Cyber Attacks

Cyber-attacks refer to malicious activities or actions carried out by individuals or groups with the intent to compromise the security, integrity, or availability of computer systems, networks, or data. These attacks encompass a broad range of tactics and techniques, including but not limited to malware infections, phishing scams, ransomware campaigns, denial-of-service (DoS) attacks, social engineering tactics, and exploitation of software vulnerabilities.

The primary objectives of cyber-attacks may include gaining unauthorized access to sensitive information, disrupting operations, causing financial harm, or compromising the confidentiality, integrity, or availability of digital assets.

1.2 Goals, objectives, and Motivations Behind Cyber Attacks

Cyber-attacks encompass a wide range of malicious activities with diverse goals, objectives, and motivations. The overarching goal of a cyber-attack is typically to compromise the security, integrity, or availability of computer systems, networks, or data for various purposes. The specific objectives and motivations behind cyber-attacks can vary depending on the attackers' intentions, capabilities, and resources. Some common goals, objectives, and motivations behind cyber-attacks include:

i. **Financial Gain:** Many cyber-attacks are carried out with the goal of monetary profit. Attackers may steal sensitive financial information, such as credit card numbers or bank account credentials, to commit fraud, identity theft, or ransomware extortion.

ii. **Espionage and Intelligence Gathering:** State-sponsored cyber-attacks often aim to steal classified or sensitive information from government agencies, military organizations, or private companies for espionage purposes. This information may include intellectual property, trade secrets, or diplomatic communications.

iii. **Political or Ideological Motives:** Hacktivist groups or individuals may carry out cyber-attacks to promote political agendas, protest against perceived injustices, or raise awareness about social issues. These attacks may target government agencies, corporations, or organizations perceived as adversaries.

iv. **Disruption and Sabotage:** Some cyber-attacks are conducted with the intent to disrupt or sabotage the operations of businesses, organizations, or critical infrastructure. These attacks may aim to cause financial losses, reputational damage, or service outages.

v. **Personal Vendettas or Revenge:** In some cases, individuals or groups may carry out cyber-attacks as a form of revenge or retaliation against specific individuals, organizations, or entities that they perceive as having wronged them.

vi. **Curiosity or Challenge:** Some cyber-attacks may be motivated by curiosity, the desire for recognition, or the thrill of the challenge. These attacks may target high-profile or well-protected systems simply to demonstrate the attacker's skills or prowess.

Understanding the motivations behind cyber-attacks is crucial for developing effective cybersecurity strategies and defenses to protect against evolving threats. By identifying potential adversaries and their motives, organizations can better assess their risk exposure and implement appropriate measures to mitigate the impact of cyber-attacks.

1.3 Common Cyber Attack Techniques

1. Malware Attacks: Malware is malicious software designed to damage, infiltrate, or disable computers and networks. It includes **viruses, worms, ransomware, and spyware.**

2. Social Engineering Attacks: Social engineering involves manipulating individuals to divulge confidential information or perform specific actions, usually through deception or trickery. Include **Phishing**, **Spear Phishing, Pretexting, Baiting.**

3. Web application attacks: Web application attacks are cyber-attacks targeting vulnerabilities in web applications, which are software applications accessed through web browsers over the internet. These attacks exploit weaknesses in the application's code, configuration, or design to compromise security, steal data, or disrupt services. Common types of web application attacks include:

◆ **SQL Injection (SQLi):** Attackers inject malicious SQL code into input fields or parameters to manipulate or retrieve data from the application's database. SQL injection can lead to data breaches, data manipulation, or unauthorized access to the underlying server.

◆ **Cross-Site Scripting (XSS):** Attackers inject malicious scripts into web pages viewed by other users, allowing them to execute arbitrary code in the context of the victim's browser. XSS attacks can be used to steal cookies, session tokens, or sensitive information from users.

◆ **Cross-Site Request Forgery (CSRF):** Attackers trick authenticated users into executing unauthorized actions on a web application, typically by embedding malicious requests in legitimate web pages or emails. CSRF attacks can result in unauthorized transactions, data manipulation, or account takeover.

◆ **Session Hijacking:** Attackers steal or manipulate session tokens or cookies to impersonate authenticated users and gain unauthorized access to their accounts or sensitive information.

◆ **File Upload Vulnerabilities:** Attackers exploit insecure file upload functionalities to upload malicious files, such as malware or scripts, to the server. This can lead to remote code execution, data breaches, or server compromise.

4. Denial of Service (DoS) and Distributed Denial of Service (DDoS) Attacks: DoS and DDoS attacks aim to overwhelm systems, networks, or websites with excessive traffic or requests, rendering them unavailable to users.

◆ **DoS (Denial of Service)**: A single source floods a target system with traffic, preventing legitimate users from accessing it.

◆ **DDoS (Distributed Denial of Service)**: Multiple systems, often part of a botnet, attack a target simultaneously, making the attack more difficult to mitigate.

5. Insider Attacks: Insider attacks occur when individuals within an organization exploit their authorized access to carry out malicious activities. These attacks can be intentional or unintentional.

6. SQL Injection Attacks An SQL Injection attack involves injecting malicious SQL queries into a web application's input fields to manipulate or gain unauthorized access to the database.

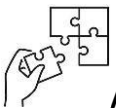
Attack Process: Attackers exploit vulnerable input fields to insert malicious code that allows them to access, modify, or delete database content.

7. Zero-Day Exploits: A zero-day exploit targets a previously unknown vulnerability in software or hardware, for which no patch or fix exists at the time of the attack.
Nature of Zero-Day Attacks: Since the vulnerability is unknown, the system remains exposed until the vendor can release a patch.
Attackers may have different goals, from financial gain to political activism, but each attack poses significant risks to security, data, and operations. Implementing strong cybersecurity measures, including timely patching, user education, and monitoring, helps mitigate these threats.



Points to Remember

- Cyber-attacks refer to malicious activities or actions carried out by individuals or groups with the intent to compromise the security, integrity, or availability of computer systems, networks, or data
- Cyber Attacks Goals, Objectives and Motivations Behind Cyber Attacks are Financial Gain, Espionage and Intelligence Gathering, Political or Ideological Motives, Disruption and Sabotage, Personal Vendettas or Revenge and Curiosity or Challenge
- Common Cyber Attack Techniques are Malware Attacks, Social Engineering Attacks, Web Application Attacks, Denial of Service (DoS) and Distributed Denial of Service (DDoS) Attacks, Insider Attacks, SQL Injection Attacks and Zero-Day Exploits



Application of learning 1.4.

An international financial services firm, XYZ Financial, has recently been hit by a series of cyber-attacks targeting its internal systems and customer data. Upon further investigation, it was discovered that the attackers employed a range of sophisticated techniques, leading to significant disruption in services and potential data compromise. The company's leadership has asked you to provide a comprehensive overview of the nature of cyber-attacks, their goals, motivations, and common techniques used by attackers.

Indicative content 1.5: Identification of Asset in Cyber security

Duration: 4 hrs

Theoretical Activity 1.5.1: Classification of assets used in cyber security

Tasks:

1. Answer the following questions:
   i. Define Assets in the context of cyber security
   ii. What are Importance of identifying and protecting assets
   iii. What is The role of assets in risk assessment and risk management?
   iv. Differentiate Types of Cyber Security Assets
   v. Describe Cyber Security Asset Valuation
   vi. Identify Data Security as the most sensitive asset
2: Present your group's findings on the discussed topics.
3. Ask clarification if any

4: Read the key readings 1.5.1.

Key readings 1.5.1

Identification of Asset in Cyber security

1 Introduction to Cyber Security Assets

Cybersecurity assets refer to any resources, systems, data, or individuals that contribute to the operation and success of an organization and require protection from cyber threats. These can include hardware, software, information, intellectual property, personnel, and even an organization's reputation.

In cybersecurity, **assets** are anything valuable to an organization that must be protected from cyber threats. Identifying and safeguarding these assets is crucial for ensuring the integrity, confidentiality, and availability of data and resources.

1.1 Importance of identifying and protecting assets

The identification and protection of assets are vital for several reasons:

- **Preventing Loss**: Protecting assets ensures that critical data and resources are safeguarded from theft, damage, or destruction.
- **Compliance**: Organizations must protect certain types of assets to comply with legal, regulatory, or industry standards (e.g., data protection laws).
- **Business Continuity**: Identifying and securing key assets ensures that an organization can maintain operations during and after cyber incidents.

- **Risk Mitigation**: By understanding their most valuable assets, organizations can prioritize efforts to defend against potential threats.

1.2 The role of assets in risk assessment and risk management

Assets play a critical role in the **risk assessment** and **risk management** process. By identifying assets and their vulnerabilities, organizations can:

- **Assess risks**: Determine which assets are most at risk and the potential impact of security breaches.
- **Prioritize resources**: Focus security efforts and investments on protecting high-value or high-risk assets.
- **Implement controls**: Apply appropriate security measures, such as encryption, access controls, or backups, to protect assets.

2. Types of Cyber Security Assets

Cybersecurity assets can be categorized into several types, each requiring specific protection measures.

A. Digital Assets

Digital assets include data, software, and systems that are critical for the operation and success of an organization. These assets are often the primary target of cyber-attacks.

Examples:

- Customer databases
- Business applications and software
- Cloud-based resources
- Backups and archives

Protection Methods: Encryption, access control, regular software updates, secure backups.

B. Physical Assets

Physical assets refer to the hardware and devices that store, process, or transmit digital information. These can be compromised through theft, damage, or tampering.

Examples:

- Servers, desktops, laptops, and mobile devices
- Networking equipment (routers, switches, firewalls)
- Data centers

Protection Methods: Physical security (locked rooms, surveillance), device encryption, access restrictions.

C. Human Assets

Human assets are the people within an organization, such as employees,

contractors, and partners, who have access to systems and information. They are both valuable resources and potential vulnerabilities.

Examples:

- IT administrators, cybersecurity personnel
- General employees with access to sensitive data
- Third-party service providers

Protection Methods: Security awareness training, least privilege access, multi-factor authentication (MFA), and background checks.

D. Intellectual Property Assets

Intellectual property (IP) assets include proprietary information and knowledge that provide an organization with a competitive edge. Cybercriminals often target IP to steal or exploit for financial or strategic gain.

Examples:

- Trade secrets, patents, and proprietary algorithms
- Product designs and manufacturing processes
- Research and development data

Protection Methods: Strong access controls, encryption, secure communication channels, and legal protections like patents and copyrights.

E. Reputation Assets

Reputation assets encompass the public perception and trust that an organization has built over time. While intangible, reputation is one of the most valuable assets, as a data breach or cyber-attack can severely damage it.

Examples:

- Customer trust and brand loyalty
- Industry standing and partnerships
- Public relations and social media presence

Protection Methods: Incident response planning, data breach notification protocols, PR crisis management, and cybersecurity certifications.

Cybersecurity Asset Valuation

Asset valuation is a process that helps organizations assign a value to their assets, which is critical for risk management and decision-making in cybersecurity.

1. Methods for Assigning Value to Cybersecurity Assets

◆ **Qualitative Valuation**: Involves ranking assets based on their perceived importance or impact to the organization.

Examples: Customer databases may be ranked higher in value due to regulatory requirements

◆ **Quantitative Valuation**: Assigns a monetary value to assets by calculating the potential financial impact of their loss or damage.

Examples: The cost of replacing equipment, potential fines from data breaches, or the cost of recovery after an attack.

2. Considerations for Determining the Value of Assets in Different Contexts

◆ **Business Impact**: Assessing the business function an asset supports (e.g., customer data for an e-commerce platform).

◆ **Regulatory Compliance**: Assets that involve regulated data (e.g., personal information) may carry additional financial or legal liabilities if compromised.

◆ **Revenue Generation**: Some assets directly impact revenue, such as sales databases or e-commerce systems, which need to be prioritized for protection.

◆ **Recovery Costs**: Considering how expensive it would be to replace or recover assets after a security incident.

3. The Impact of Asset Valuation on Risk Assessment and Resource Allocation

◆ **Risk Prioritization**: High-value assets receive priority in risk assessments, with the focus on implementing stronger controls to protect them.

◆ **Budgeting and Resource Allocation**: Valuation helps direct cybersecurity budgets toward protecting assets that have the greatest potential impact if compromised.

◆ **Decision Making**: Valuation informs the type of security investments (e.g., firewalls, endpoint protection, employee training) an organization should focus on.

Data Security as the Most Sensitive Asset

1. Data Security Overview

Data security refers to the measures and practices that protect data from unauthorized access, theft, corruption, or misuse. Data is often considered the most sensitive asset because of its value to both organizations and attackers.

2. Data States

Data exists in three states, and each state requires specific protection mechanisms:

◆ **Data at Rest**: Data stored on physical or cloud-based storage.

Protection Methods: Encryption, access control, and secure storage.

◆ **Data in Transit**: Data being transmitted between devices or networks.

Protection Methods: Secure protocols (e.g., SSL/TLS), encryption, and VPNs.

◆ **Data in Use**: Data actively being processed by applications.
Protection Methods: Secure processing environments, memory encryption.

3. Data Security Controls

Encryption: Encrypting data at rest and in transit to protect it from unauthorized access.
Access Controls: Implementing least privilege principles and multi-factor authentication.
Backup Solutions: Regularly backing up critical data to mitigate data loss from cyber incidents.
Data Loss Prevention (DLP): Tools that prevent unauthorized access or transfer of sensitive data.

4. Special Security Considerations for Big Data

Big data presents unique challenges for security due to the volume, variety, and velocity of the data being processed. Key considerations include:

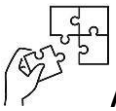
1. **Scalability**: Security controls must scale to protect large amounts of data.
2. **Anonymization and Privacy**: Big data may involve personal data, requiring privacy-focused measures like data masking and anonymization.
3. **Real-Time Monitoring**: The velocity of big data requires real-time security monitoring to detect and respond to threats.



Points to Remember

- Assets Refer to any resources or entities that have value and are critical to the operations and security of an organization.
- Importance of identifying and protecting assets: Identifying and protecting assets is fundamental to help organizations safeguard their information, maintain operational efficiency, and manage risks effectively like Mitigates Risks, Ensures Compliance, Optimizes Resource Management and Protects Sensitive Information etc..
- The role of assets in risk assessment and risk management: Identifying Risks, Evaluating Impact, Assessing Threats and Vulnerabilities, Implementing Controls, Monitoring and Maintenance, Risk Mitigation Strategies and Documentation and Reporting.
- Types of Cyber Security Assets are Digital assets, Physical assets, Human assets, Intellectual property assets and Reputation assets

- Methods for assigning value to cyber security assets: Is a critical step in effective risk management and resource allocation using Quantitative Methods, Qualitative Methods and Hybrid Methods.
- Considerations for determining the value of assets in different contexts : Determining the value of cybersecurity assets involves multiple considerations based on the business, regulatory, security, operational, intellectual property, human resource, and reputation contexts.
- The impact of asset valuation on risk assessment and resource allocation: It helps prioritize risks, allocate budgets and resources appropriately, and make informed decisions about security measures and incident response. By understanding the value of assets, organizations can ensure that their cybersecurity efforts are aligned with their strategic objectives and that critical assets receive the protection and resources they need to mitigate risks effectively.
- Definition of data Security Refers to the practices, technologies, and policies designed to protect data from unauthorized access, corruption, or theft throughout its lifecycle. Data that is stored on physical media or in databases and is not actively being accessed or transmitted.



Application of learning 1.5.

As part of your cybersecurity training, you are required to identify and evaluate the various types of assets within an organization. Your job is to analyze the assets in the context of cybersecurity, determine their importance, and suggest ways to protect them. You will also be expected to assess the value of these assets and how they impact the overall risk management strategy of the organization. Pay special attention to data security, as it is considered the most sensitive asset, and consider any special challenges related to big data.

Indicative content 1.6: Definition of Security Policies and Frameworks

Duration: 2 hrs

Theoretical Activity 1.6.1: **Identification of Security Policies and Frameworks**

Tasks:

1. Answer the following questions:
    i. Describe Data Security Policies
    ii. What are Data Security Roles for Data Governance and Data Privacy Principles
2: Present your group's findings on the discussed topics.
3: Ask clarification if any.

4: Read the key readings 1.6.1.

Key readings 1.6.1

1.6 Definition of Security Policies and Frameworks

Security policies are formal guidelines created by organizations to safeguard their digital assets, systems, and data from cyber threats. These policies ensure that the organization maintains the confidentiality, integrity, and availability of its information.

Security frameworks, on the other hand, are structured methodologies consisting of best practices to help manage cybersecurity risks and ensure effective implementation of security policies

1.6.1 Data Security Policies

Data security policies provide rules for safeguarding sensitive information. They encompass guidelines for data classification, storage, transmission, and management throughout its lifecycle.

1.6.2 Criteria for each policy

Criteria for Effective Security Policies

Clear and Concise: Policies should be easy to understand and free of ambiguity.
Comprehensive: Policies should cover all aspects of information security, including physical, technical, and administrative controls.
Enforceable: Policies should be practical and enforceable, with clear consequences for non-compliance.
Regularly Reviewed and Updated: Policies should be reviewed and updated periodically to reflect changes in technology, threats, and business requirements.

1.6.3 Data Classification Policies

Data classification policies focus on categorizing data based on sensitivity. Data is classified as public, internal, confidential, or restricted, depending on its importance and the level of protection it requires. Organizations use these classifications to implement appropriate access controls and ensure compliance with legal and regulatory standards.

1.6.4 Data Storage Policies

Data storage policies govern how data should be stored securely. These policies typically mandate encryption for sensitive data at rest, control who has access to stored information, and outline procedures for secure data backup and recovery to ensure business continuity in case of emergencies.

1.6.5 Data Transmission Policies

Data transmission policies focus on protecting data as it moves across networks. Organizations must use secure channels such as HTTPS or SSL/TLS for transmitting sensitive information. Additionally, authentication measures and data integrity checks ensure that only authorized parties can access and modify transmitted data.

1.6.6 Data Lifecycle Policies

These policies manage data from creation to disposal. They outline how data is **generated**, the **retention period** based on legal or operational needs, and **secure disposal** methods once the data is no longer required. Proper lifecycle management reduces the risk of unauthorized access and ensures compliance with privacy regulations.

1.6.7 Data Governance

Data Governance involves establishing clear ownership, accountability, and control over data within an organization. It includes defining roles and responsibilities for managing and protecting data, ensuring data is managed according to policies, and making decisions on data usage.

1.6.8. Data Privacy Principles

Data privacy principles ensure that personal or sensitive data is handled responsibly. These principles include:

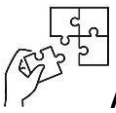
- **Lawfulness**: Data is collected and processed according to legal standards.
- **Transparency**: Individuals are informed about how their data is used.
- **Data Minimization**: Only the necessary amount of personal data is collected and processed.

- **Accountability**: Organizations are responsible for adhering to privacy principles.



Points to Remember

- Data Security Policies: These are guidelines that help protect sensitive information from unauthorized access, changes, or theft. They cover different aspects of how data should be handled, including how it is classified, stored, and transmitted. The goal of these policies is to make sure that data is secure at all times and that only authorized people can access or modify it.
- Data Classification Policies focus on sorting data into categories like public, private, or confidential, to determine how sensitive it is and how it should be protected, Data Storage Policies ensure data is safely stored, whether on physical devices or in the cloud, using methods like encryption and regular backup, Data Transmission Policies make sure data is protected when being sent over the internet or other networks, usually by using encryption or secure connections.
- Data governance in Cyber security: Refers to the management of data availability, usability, integrity, and security within an organization, data governance involves the implementation of policies, procedures, and controls to ensure that data is protected from unauthorized access, misuse, or loss while maintaining compliance with relevant laws and regulations.
- Data privacy principles: Refers to the protection of personal information and ensuring that individuals' data is collected, processed, and stored in a manner that respects their privacy rights. Data privacy principles guide organizations in handling personal data responsibly and in compliance with privacy laws and regulations.



Application of learning 1.6.

DTech Corporation has experienced a significant data breach, exposing sensitive customer information to unauthorized individuals. Upon investigation, it becomes apparent that a combination of weak data management policies and practices allow the attackers to gain access to the data. So, as a Cyber security admin identify root cause risks related to data management.

Indicative content 1.7: Cyber security Frameworks and Standards

Duration: 2 hrs

Theoretical Activity 1.7.1: Identification so security frameworks and standards

Tasks:

1. Answer the following questions:
   i. What are Importance of Frameworks and Standards
   ii. Describe Key Cyber Security Frameworks and their implementation (NIST Cyber Security Framework, ISO/IEC 27001 and 27002, Centre for Internet Security CIS Controls)
   iii. Describe the following Compliance Standards: GDPR, HIPAA and Industry-specific compliance requirements
2: Present your group's findings on the discussed topics.
3: Ask clarification if any

4: Read the key readings 1.7.1.

Key readings 1.7.1

Cybersecurity Frameworks and Standards

Cybersecurity frameworks provide guidelines and best practices to help organizations implement effective security strategies, manage risks, and comply with regulations.

1. Importance of Frameworks and Standards

Cybersecurity frameworks and standards are crucial because they:

- **Improved Security Posture:** A cybersecurity framework provides a structured approach to managing cybersecurity risks, which can help organizations to improve their overall security posture.

2. **Reduced Risk:** By adopting a cybersecurity framework, organizations can identify and mitigate cybersecurity risks more effectively, reducing the likelihood of a successful cyberattack.

3. **Compliance:** Many cybersecurity frameworks are aligned with regulatory requirements, making it easier for organizations to comply with industry-specific regulations.

4. **Consistency:** A cybersecurity framework provides a consistent approach to managing cybersecurity risks across an organization, ensuring that all departments and employees are following the same guidelines and best practices.

2. Key Cybersecurity Frameworks and Their Implementation

NIST Cybersecurity Framework (CSF)

The NIST (National Institute of Standards and Technology) Cybersecurity Framework is a widely recognized framework developed to help organizations manage and reduce cybersecurity risks. It provides a common language for understanding, managing, and reducing cybersecurity risks based on industry standards and best practices.

Key Components:

- **Five Core Functions**: The NIST CSF is built around five core functions: Identify, Protect, Detect, Respond, and Recover.
- **Identify**: Understand the business environment, identify risks, and assess vulnerabilities to manage cybersecurity risks effectively.
- **Protect**: Implement safeguards such as access controls and awareness training to protect critical assets and data.
- **Detect**: Implement tools and processes to detect security events and incidents as they occur.
- **Respond**: Create an incident response plan to contain, mitigate, and recover from cybersecurity events.
- **Recover**: Develop and implement plans to restore operations and services after a cybersecurity incident.

Implementation:

Risk Assessment: Organizations begin by assessing their current cybersecurity risks and identifying key areas of vulnerability.

Tailored Approach: The framework is flexible and can be customized to suit organizations of different sizes and industries.

Continuous Improvement: Organizations are encouraged to continually assess their cybersecurity posture, update controls, and refine their processes to adapt to emerging threats.

The NIST CSF is used across various industries and government sectors to provide a structured and repeatable approach to cybersecurity risk management.

2. **ISO/IEC 27001 and 27002**

ISO/IEC 27001 and 27002 are international standards for information security management systems (ISMS) that provide a systematic approach to managing

sensitive company information to ensure its confidentiality, integrity, and availability. ISO/IEC 27001 outlines the requirements for establishing, implementing, and maintaining an ISMS, while ISO/IEC 27002 offers specific guidance on implementing security controls.

Key Components:

ISO/IEC 27001: Focuses on implementing an ISMS, which includes risk management processes, security policies, and continual improvement mechanisms. It helps organizations protect their information by applying a risk management framework.

ISO/IEC 27002: Provides practical guidance on selecting and implementing security controls. It includes guidelines for specific security domains like access control, cryptography, physical security, and incident response.

Implementation:

Risk Assessment: Organizations begin by identifying potential risks and vulnerabilities that could impact the security of their information assets.

Security Controls: Based on the risk assessment, organizations select appropriate security controls from ISO/IEC 27002 to mitigate the identified risks.

Compliance and Certification: ISO/IEC 27001 is often used by organizations to achieve certification, demonstrating their commitment to information security. Audits are performed to verify compliance with the standard.

Continuous Monitoring: Organizations are required to continually monitor their ISMS, review security controls, and ensure ongoing improvements to remain compliant and secure.

ISO/IEC 27001 and 27002 are commonly implemented by organizations seeking a global benchmark for their information security practices and to ensure compliance with various regulatory requirements.

3. **Center for Internet Security (CIS) Controls**

The CIS Controls are a set of best practices designed to help organizations improve their cybersecurity defenses by focusing on key areas that are most effective against known attacks. The controls are organized into three categories: Basic, Foundational, and Organizational.

Key Components:

CIS Controls Categories:

- **Basic Controls**: These are essential controls that all organizations should implement as a starting point, such as inventorying and controlling hardware and software assets, securing configurations, and ensuring continuous vulnerability management.

- **Foundational Controls**: These include access control, malware defenses, and data recovery capabilities.
- **Organizational Controls**: These focus on governance, monitoring, and incident response capabilities to ensure robust security.

Implementation:

- **Prioritization**: The CIS Controls are implemented based on their priority and effectiveness in defending against common cyber threats. Organizations typically begin with Basic Controls and then progress to Foundational and Organizational Controls as their security posture matures.
- **Assessment**: Organizations conduct a security assessment to understand where they stand relative to the CIS Controls and prioritize remediation efforts.
- **Control Implementation**: Specific security controls, such as secure configurations, regular software updates, and robust access control mechanisms, are deployed based on organizational needs.
- **Ongoing Monitoring**: Continuous monitoring and regular reviews are key to maintaining security according to the CIS Controls.

The CIS Controls are widely used by organizations as they offer a practical, prioritized, and actionable approach to cybersecurity, focusing on preventing the most common and impactful attacks.

3 Compliance Standards

Compliance standards in cybersecurity ensure that organizations follow specific rules and guidelines to protect sensitive data and maintain security. These standards often vary based on the industry, location, and the type of data being handled. Below are explanations of three significant compliance standards: GDPR, HIPAA, and industry-specific compliance requirements.

1.1. GDPR (General Data Protection Regulation)

The GDPR is a European regulation designed to protect personal data and ensure individuals' privacy. It requires organizations to implement privacy-focused policies, including data protection by design, breach notification, and individual data rights like access and deletion requests. Non-compliance can result in heavy fines, making GDPR one of the strictest data protection laws in the world.

1.2. HIPAA (Health Insurance Portability and Accountability Act)

HIPAA is a U.S. regulation that sets national standards for protecting sensitive patient health information. It requires healthcare providers and related entities to implement strong security controls to protect health information from

unauthorized access, including technical safeguards like encryption and physical safeguards for protecting data storage devices.

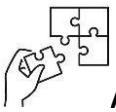
1.3. Industry-Specific Compliance Requirements

Different industries have specific compliance standards, such as PCI DSS for payment card transactions and FISMA for federal information systems. These standards enforce rigorous security measures, ensuring that organizations handling sensitive data in these sectors follow best practices for security and data protection.



Points to Remember

- Importance of Frameworks and standards: Are essential for managing cybersecurity and data protection effectively. They provide structured approaches, best practices, and specific criteria that help organizations implement consistent, effective security measures and organizations can enhance their security posture, ensure compliance, and protect their information assets more effectively.
- NIST Cyber security Framework: Is a set of guidelines developed by the National Institute of Standards and Technology (NIST) to help organizations manage and reduce cybersecurity risk.
- ISO/IEC 27001 and 27002: Are international standards developed by the International Organization for Standardization (ISO) and the International Electro technical Commission (IEC) that provide a framework for establishing, implementing, maintaining, and improving information security management systems (ISMS).
- Internet Security CIS Controls: Are a set of best practices developed by the Center for Internet Security (CIS) to help organizations improve their cybersecurity posture. The controls are designed to be actionable and provide a prioritized approach to cybersecurity.
- GDPR (General Data Protection Regulation): Provides comprehensive data protection rules for organizations handling personal data of EU citizens, focusing on data subject rights and compliance requirements.
- HIPAA (Health Insurance Portability and Accountability Act): Establishes privacy and security standards for handling health information in the U.S., focusing on protected health information and safeguard requirements.
- Industry-specific compliance requirements: Vary by sector and address unique regulatory and security needs, ensuring organizations meet specific industry standards and regulations.



Application of learning 1.7.

Your task is to evaluate the importance and implementation of cybersecurity frameworks and standards for a given organization. Start by explaining why cybersecurity frameworks and standards are essential for managing risks and ensuring robust security practices. Focus on key frameworks such as the NIST Cybersecurity Framework, ISO/IEC 27001 and 27002, and the Centre for Internet Security (CIS) Controls. Assess how each framework can be implemented effectively within the organization. Additionally, review compliance standards such as GDPR, HIPAA, and other industry-specific requirements, noting how they affect the organization's security policies and practices. Prepare a report detailing your findings and recommendations on implementing these frameworks and standards to enhance the organization's cybersecurity posture.

Indicative content 1.8: Identification of security risks and Vulnerability

Duration: 4 hrs

Theoretical Activity 1.8.1: Description of Cyber Vulnerabilities and risks

Tasks:

1. Answer the following questions:
   i. Describe Security risks and Vulnerabilities assessment
   ii. What are Goals and Objective of Assessment
   iii. Explain Asset Identification & Classification
   iv. What are categories of data
   v. Describe Threat Identification
   vi. Describe Security risks and Vulnerabilities assessment
   vii. What are Goals and Objective of Assessment
   viii. Explain Asset Identification & Classification
   ix. What are categories of data
   x. Describe Threat Identification
   xi. What are types of Assessment tools
   xii. Explain Vulnerabilities Assessment techniques
   xiii. Describe Security assessment techniques
   xiv. Explain Risk Assessment Methodologies
   xv. Describe Risk Prioritization
2: Present your group's findings on the discussed topics.
3: Ask clarification if any.

4: Read the key readings 1.8.1.

Key readings 1.8.1

Identification of security risks and Vulnerability

1. Introduction to Security Risks and Vulnerabilities Assessment

Security risks and vulnerabilities assessment involves identifying, analyzing, and evaluating potential threats and weaknesses within an organization's infrastructure, systems, and data. The goal is to detect and address these vulnerabilities before they can be exploited by malicious actors.

Goals and Objectives of Assessment:

- Identify security gaps and weaknesses.

- Evaluate the potential impact of security threats.
- Ensure compliance with regulatory requirements.
- Prioritize risks for remediation.

2. Asset Identification & Classification

Asset Identification Overview: Assets are any resources, including hardware, software, data, and personnel, that have value to an organization and must be protected. Properly identifying and classifying assets helps prioritize their protection.

Asset Inventory: A comprehensive list of all organizational assets, including their current status, value, and security requirements.

Asset Management: Ensures that all assets are appropriately monitored, maintained, and secured throughout their lifecycle.

Asset Identification Standards:

- **ISO 27001 Standard**: A global standard for managing information security, which includes asset identification.
- **Industry-Specific Standards**: Such as NIST (National Institute of Standards and Technology) and CIS (Center for Internet Security) guidelines.

Asset Identification Best Practices

Regular updates to the asset inventory and classification to ensure accurate risk assessment.

3. Data Classification

Data classification involves categorizing data based on its sensitivity, importance, and the level of protection required.

◆ **Categorizing Data Assets**: Organizing data into categories such as confidential, sensitive, or public, based on its value and legal obligations.

◆ **Data Labeling and Classification Standards**: Data labeling and classification standards refer to the structured processes and guidelines that organizations use to categorize and tag data based on its sensitivity, value, and the level of protection required. These standards ensure that data is appropriately handled, stored, and secured according to its classification.

◆ **Data Retention and Disposal Policies**: Policies that determine how long data is stored and when and how it is securely disposed of after its useful life.

1.8.4 Threat Identification

Threat Intelligence

Threat Intelligence involves gathering and analyzing information about current or potential threats to help protect systems from cyber attacks. It helps security teams understand who the attackers are, what methods they use, and what specific risks they pose.

Threat Modelling

Threat Modeling is a method used to predict potential attacks on a system and figure out how to protect against them. It helps identify vulnerabilities before attackers can exploit them.

- I**dentify Assets**: Determine what critical systems or data need protection.
- **Attack Vectors**: Analyze how an attacker could compromise the system.
- **Risk Assessment**: Determine the potential damage from each threat.
- **Mitigation**: Implement security controls to reduce the risk.

1.8.5 Vulnerability Assessment

Types of Assessment tools

◆ **Network Scanners:** These tools scan networks to identify devices, open ports, and vulnerabilities. Examples include Nmap, Nessus, and OpenVAS.

◆ **Vulnerability Scanners: T**hese tools scan systems for known vulnerabilities, often using databases of vulnerabilities like Common Vulnerabilities and Exposures (CVEs). Examples include Nessus, OpenVAS, and Qualys.

◆ **Web Application Scanners:** These tools specifically target web applications, identifying vulnerabilities like SQL injection, cross-site scripting (XSS), and cross-site request forgery (CSRF). Examples include Burp Suite, Acunetix, and OWASP ZAP.

◆ **Configuration Assessors: T**hese tools compare a system's configuration against predefined security standards or best practices. Examples include CIS Benchmarks and SCAP.

◆ **Credentialed Scanners:** These tools require authentication credentials to assess vulnerabilities within protected networkties Assessment techniques

Vulnerability Assessment Techniques

◆ **Automated scanning:** Using vulnerability scanners to identify known vulnerabilities.

◆ **Manual testing:** Manually testing systems for vulnerabilities, often using techniques like fuzzing and penetration testing.

◆ **Risk assessment:** Evaluating the potential impact of vulnerabilities on the organization.

◆ **Configuration auditing:** Comparing system configurations against security standards.

◆ **Third-party assessments:** Hiring external experts to conduct vulnerability assessments.



Theoretical Activity 1.8.2: Documentation vulnerability assessment report



Tasks:

1. Answer the following questions:
    i. What is assessment report?
    ii. What is Risk Register?
    iii. Describe Documentation of Assessment reports?
    iv. Describe Remediation and Mitigation Strategies?
2: Present your group's findings on the discussed topics.
4: Ask clarification if any.

5: Read the key readings 1.8.2.

Key readings 1.8.2

Documentation vulnerability assessment report

1.Conducting Penetration Testing

Penetration Testing (pen testing) is a method used to identify vulnerabilities in a system, application, or network by simulating a cyber attack. The goal is to evaluate security and recommend improvements.

6 Steps to a Penetration Test

Pre-Engagement Interactions: In this initial phase, the penetration tester gathers



extensive information about the target system, such as network structure, operating systems, and user accounts. This data informs the objectives and scope of the test, ensuring the focus is on systems critical to security. Scoping is essential as it identifies which systems need assessment and considers how data flows in and out of the organization.

Reconnaissance: The tester prioritizes areas to examine based on insights from the pre-engagement phase, customer objectives, and previous breaches. This phase involves scanning to identify open ports and analyze network traffic, helping uncover potential entry points for attackers.

Vulnerability Identification: This phase focuses on discovering vulnerabilities using the data collected during reconnaissance. Testers evaluate the exploitability of these vulnerabilities, often consulting resources like the National Vulnerability Database (NVD) to assess risk based on the Common Vulnerability Scoring System

(CVSS).

Exploitation: Here, testers attempt to exploit identified vulnerabilities to gain unauthorized access or perform malicious actions. Caution is crucial to avoid damaging the system during simulated attacks.

Post-Exploitation: This phase aims to document sensitive data, configurations, and relationships with other network devices that could allow further access. Testers may set up methods for future access as part of this evaluation.

Reporting: The final phase involves creating a comprehensive report detailing the findings from the test. This report includes a list of vulnerabilities, their impact on the organization, and remediation suggestions to enhance security. A well-structured report helps organizations understand their security risks and plan appropriate actions to mitigate them.

2. Types of Penetration Testing

Black Box Testing: The tester has no prior knowledge of the system's architecture, simulating the perspective of an external attacker.

White Box Testing: The tester has full knowledge of the system, including access to source code and architecture details. This approach allows for more thorough testing.

Gray Box Testing: The tester has partial knowledge of the system, striking a balance between black and white box testing. This is often more realistic for internal threats.

3. Security assessment techniques

3.1. Vulnerability Scanning

Vulnerability scanning involves using automated tools to identify known vulnerabilities in systems, applications, and networks. These tools scan for weaknesses based on databases like Common Vulnerabilities and Exposures (CVEs). By identifying vulnerabilities, organizations can prioritize mitigation efforts and prevent potential attacks.

3.2. Penetration Testing

Penetration testing simulates a real-world attack to assess a system's resilience. Ethical hackers attempt to exploit vulnerabilities to gain unauthorized access. This technique helps organizations identify weaknesses that could be exploited by malicious actors.

3.3. Risk Assessment

Risk assessment is the process of evaluating the likelihood and potential impact of security threats. By identifying assets, threats, vulnerabilities, and calculating risk, organizations can prioritize mitigation efforts and allocate resources effectively.

3.4. Threat Modeling

Threat modeling involves analyzing potential threats and their impact on a system. By identifying assets, threats, vulnerabilities, and analyzing how threats could

exploit vulnerabilities, organizations can develop strategies to mitigate risks.

3.5. Incident Response Testing

Incident response testing evaluates the effectiveness of an organization's incident response plan. By simulating a security incident, organizations can identify weaknesses in their response capabilities and make necessary improvements.

3.6. Compliance Auditing

Compliance auditing ensures that an organization is complying with relevant security regulations and standards. By reviewing security practices and policies against standards like HIPAA, GDPR, or PCI DSS, organizations can identify areas for improvement and avoid penalties.

3.7. Configuration Auditing

Configuration auditing verifies that systems and devices are configured according to security best practices.By comparing system configurations against security standards, organizations can identify and address misconfigurations that could be exploited.

3.8. Security Awareness Training

Security awareness training educates employees about security best practices and helps prevent human error. By providing training on topics like phishing, password security, and data handling, organizations can reduce the risk of insider threats and improve their overall security posture.

4. Risk Assessment Methodologies

Risk Assessment Methodologies are systematic approaches used to evaluate and prioritize risks within an organization. There are three primary types of methodologies:

1. **Quantitative Risk Assessment**: This method uses numerical values to quantify risk. It typically involves calculating potential losses in monetary terms. For example, organizations may evaluate the likelihood of a threat occurring and its potential impact, allowing them to compute a risk score.

2. **Qualitative Risk Assessment**: This approach focuses on the subjective evaluation of risks based on expert judgment and experience. Risks are often categorized as low, medium, or high based on their potential impact and likelihood. Qualitative assessments help organizations understand the context of risks without requiring extensive numerical data.

3. **Semi-Quantitative Risk Assessment**: This method combines elements of both quantitative and qualitative assessments. It assigns numeric values to qualitative ratings, creating a more flexible approach to risk evaluation.

Calculating Risk Scores: Risk is calculated based on the likelihood and potential impact of threats.

Risk Thresholds and Tolerance Levels: Determines the acceptable level of risk and

when action is required.

5. Risk Prioritization

Risk Prioritization is crucial for effective risk management. This process involves:

1. **Prioritizing Identified Risks**: Risks are ranked based on their severity (potential impact) and likelihood (probability of occurrence). This helps organizations focus on the most critical risks first.

2. **Establishing Risk Treatment Plans**: For each prioritized risk, organizations develop plans to mitigate, transfer, accept, or avoid the risks based on their risk appetite and business objectives.

3. **Aligning Risk Prioritization with Business Objectives**: Ensuring that risk management strategies are in line with overall business goals is vital for effective resource allocation and risk mitigation.

6. Security Assessment Reporting and Documentation

Effective reporting and documentation are essential components of the security assessment process. This includes:

1. **Course Content**: Outlining the topics covered during the assessment to provide context.

2. **Assessment Reports**: Detailed documents that summarize the findings of the security assessment, including vulnerabilities, risk levels, and recommended actions.

3. **Risk Register**: A comprehensive log that tracks identified risks, their assessments, and treatment plans. Templates can be used to standardize entries for consistency and clarity.

4. **Documentation of Assessment Reports**: Maintaining organized records of all assessments conducted, findings, and remediation efforts helps ensure accountability and provides a reference for future assessments.

7. Remediation and Mitigation Strategies

Remediation and Mitigation Strategies are essential for addressing identified risks. Key aspects include:

1. **Remediation Planning**: Developing actionable plans to fix vulnerabilities and mitigate risks identified during assessments. This may involve implementing technical fixes, policy changes, or procedural improvements.

2. **Security Controls Implementation**: Putting in place necessary security controls, such as firewalls, intrusion detection systems, and access controls, to protect against identified threats.

Continuous Assessment and Improvement: Security is not a one-time effort.

Organizations must regularly reassess their security posture, update their risk assessments, and refine their strategies based on evolving threats and vulnerabilities.



Practical Activity 1.8.3: Identifying security risks and Vulnerability



Task:

1: Perform the following activity.

Schools need to identify the vulnerabilities present in their computer networks and understand the associated risks. Your task is to assess and identify these vulnerabilities along with the potential risks they pose to the network and its data and provide Documentation of Assessment reports.

2. Present your findings.
4: Listen carefully to the trainer feedback.

5: Ask any questions you have or clarify any doubts related to the content presented or discussed.

6: Read the key readings 1.8.3.



Key readings 1.8.3

Using Protocol analysers as tools

Wireshark

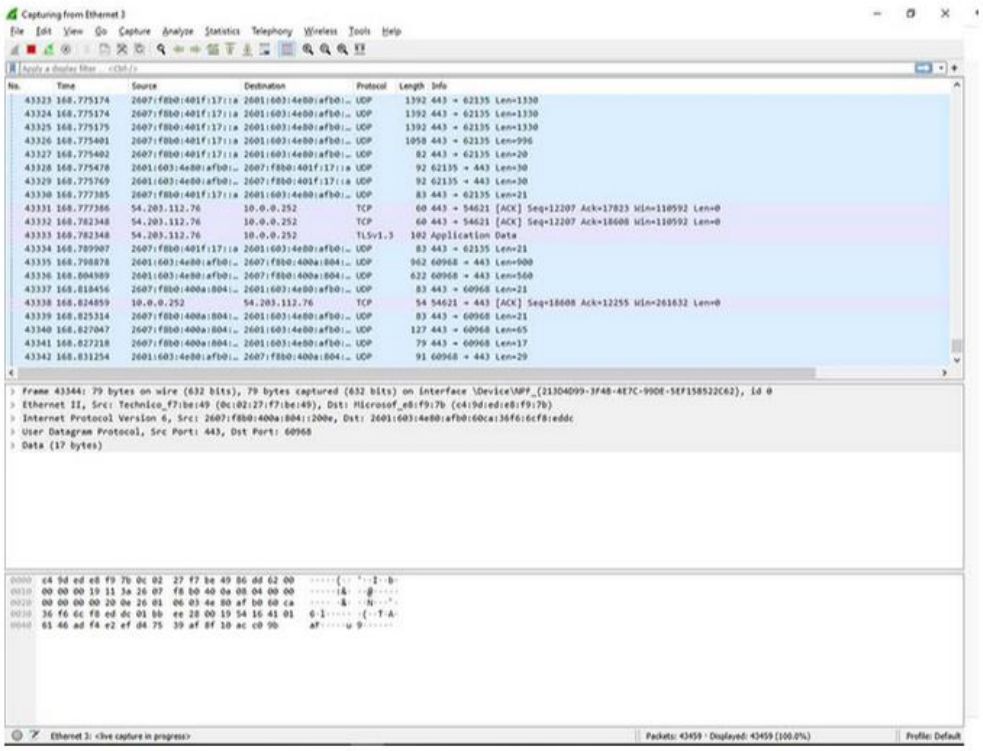
Wireshark is a network protocol analyzer, or an application that captures packets from a network connection, such as from your computer to your home office or the internet. Packet is the name given to a discrete unit of data in a typical Ethernet network.

Wireshark is the most often-used packet sniffer in the world. Like any other packet sniffer, Wireshark does three things:

A. **Packet Capture:** Wireshark listens to a network connection in real time and then grabs entire streams of traffic – quite possibly tens of thousands of packets at a time.

B. **Filtering:** Wireshark is capable of slicing and dicing all of this random live data using filters. By applying a filter, you can obtain just the information you need to see.

C. **Visualization:** Wireshark, like any good packet sniffer, allows you to dive right into the very middle of a network packet. It also allows you to visualize entire conversations and network streams.



Viewing a packet capture in wireshark

If you're a Windows operating system user, download the version appropriate for your particular version. If you use Windows 10, for example, you'd grab the 64-bit Windows installer and follow the wizard to install. To install, you'll need administrator permissions.

1. Install and Set Up the Protocol Analyzers

If you have a Linux system, you'd install Wireshark using the following sequence (notice that you'll need to have root permissions):

$ sudo apt-get install wireshark

$ sudo dpkg-reconfigure wireshark-common

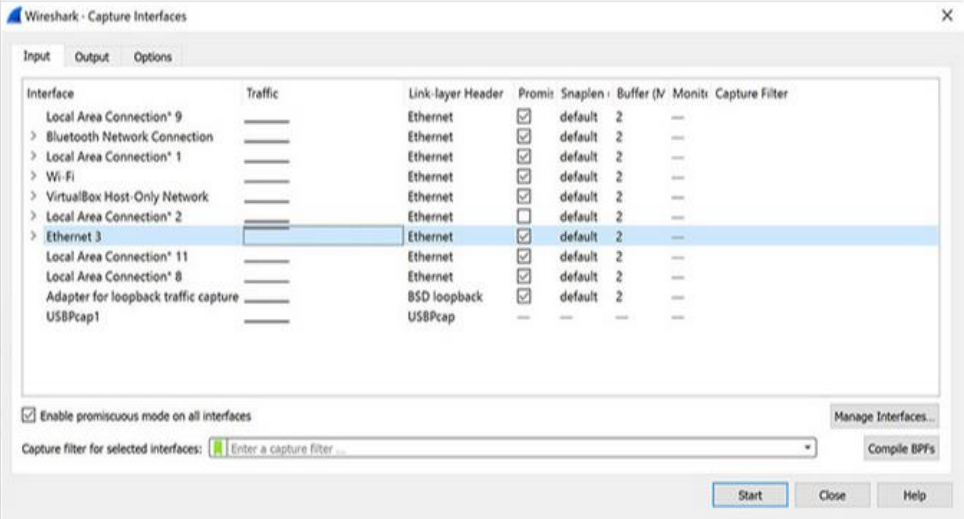
$ sudo usermod -a -G wireshark $USER

$ newgrp wireshark

Once you have completed the above steps, you then log out and log back in, and then start Wireshark:

$ wireshark &

2. Capture Network Traffic



Once you've installed Wireshark, you can start grabbing network traffic. But remember: To capture any packets, you need to have proper permissions on your computer to put Wireshark into promiscuous mode.

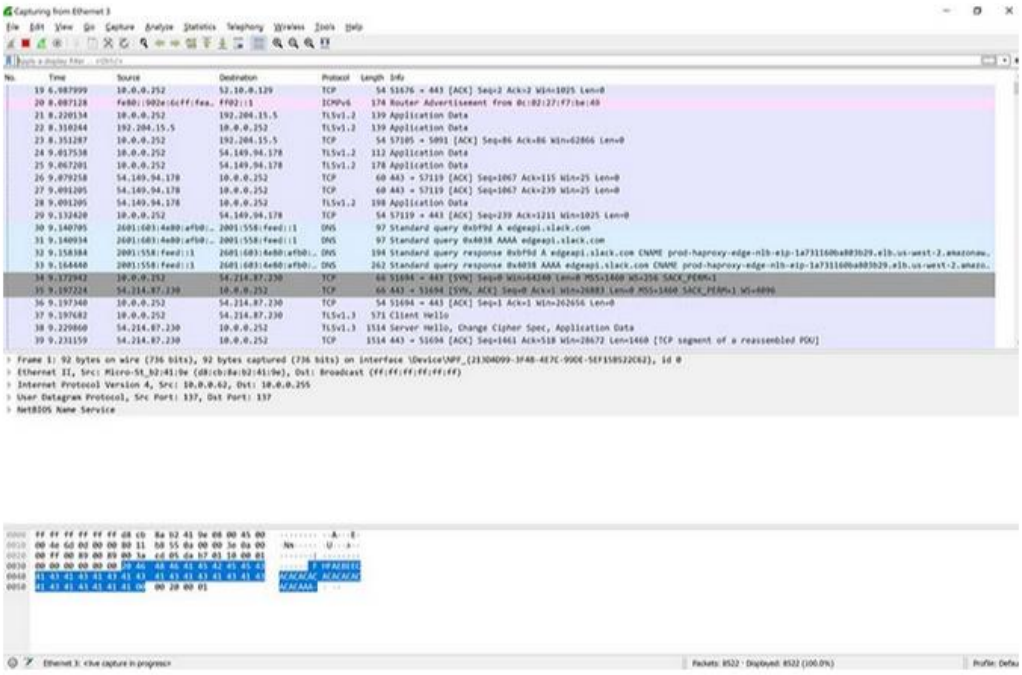
- In a Windows system, this usually means you have administrator access.
- In a Linux system, it usually means that you have root access.

As long as you have the right permissions, you have several options to actually start the capture. Perhaps the best is to select Capture >> Options from the main window. This will bring up the Capture Interfaces window,

This window will list all available interfaces. In this case, Wireshark provides several to choose from.

For this example, we'll select the Ethernet 3 interface, which is the most active interface. Wireshark visualizes the traffic by showing a moving line, which represents the packets on the network.

Once the network interface is selected, you simply click the Start button to begin your capture. As the capture begins, it's possible to view the packets that appear on the screen



Once you have captured all the packets that you want, simply click the red, square button at the top. Now you have a static packet capture to investigate.

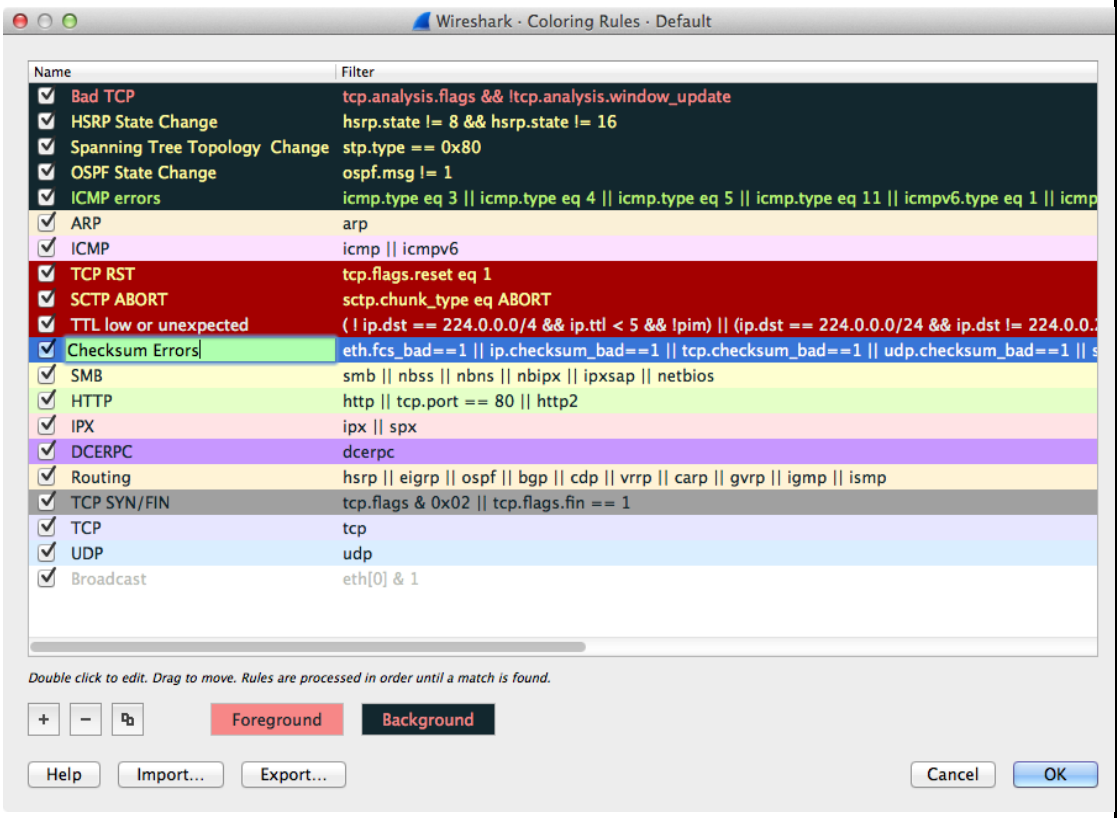
3. Analyze the Captured Traffic

Now that you have some packets, it's time to figure out what they mean. Wireshark tries to help you identify packet types by applying common-sense color coding. The table below describes the default colors given to major packet types.

Color in Wireshark	Packet Type
Light purple	TCP
Light blue	UDP
Black	Packets with errors
Light green	HTTP traffic
Light yellow	Windows-specific traffic, including Server Message Blocks (SMB) and NetBIOS
Dark yellow	Routing

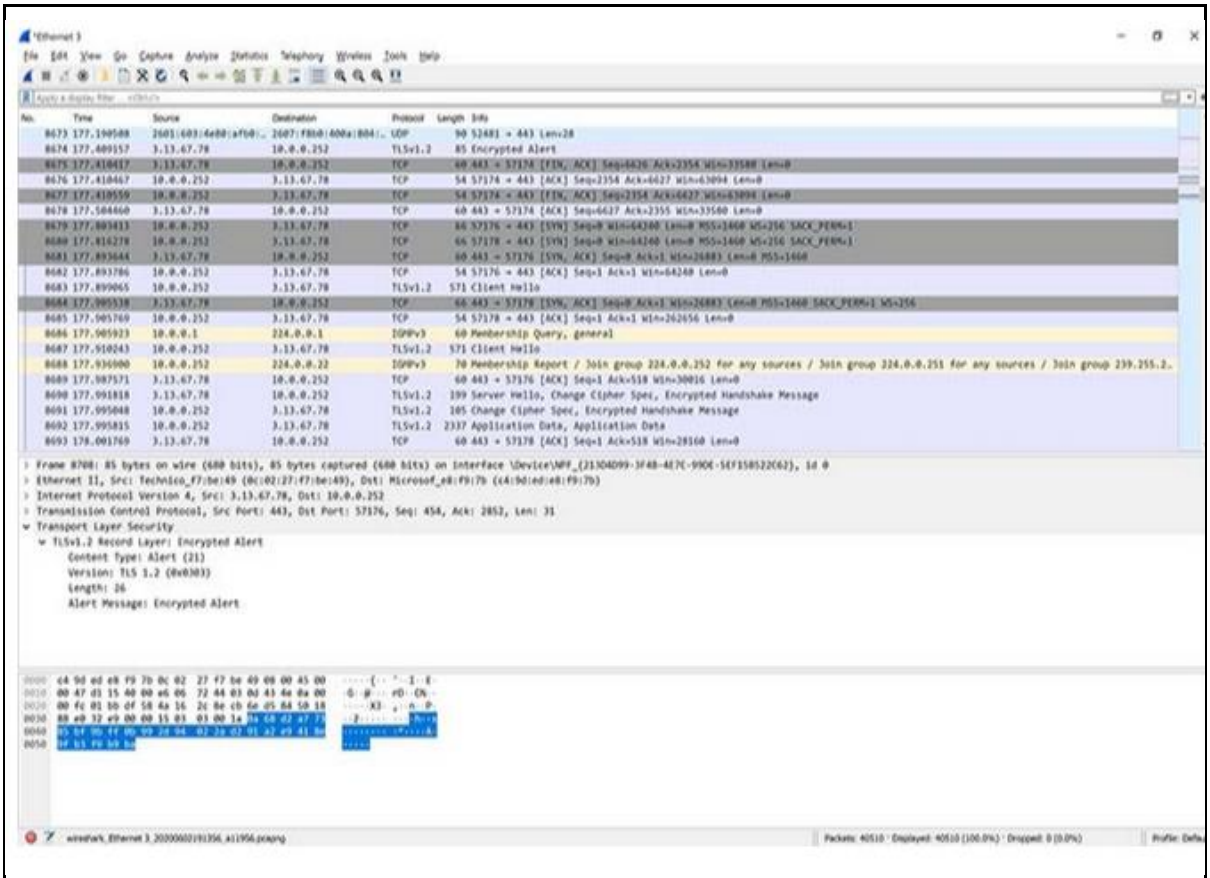
Dark gray	TCP SYN, FIN and ACK traffic

The default coloring scheme is shown below in Figure 6. You can view this by going to View >> Coloring Rules.



You can even change the defaults or apply a custom rule. If you don't want any coloring at all, go to View, then click Colorize Packet List. It's a toggle, so if you want the coloring back, simply go back and click Colorize Packet List again. It's possible, even, to colorize specific conversations between computers.

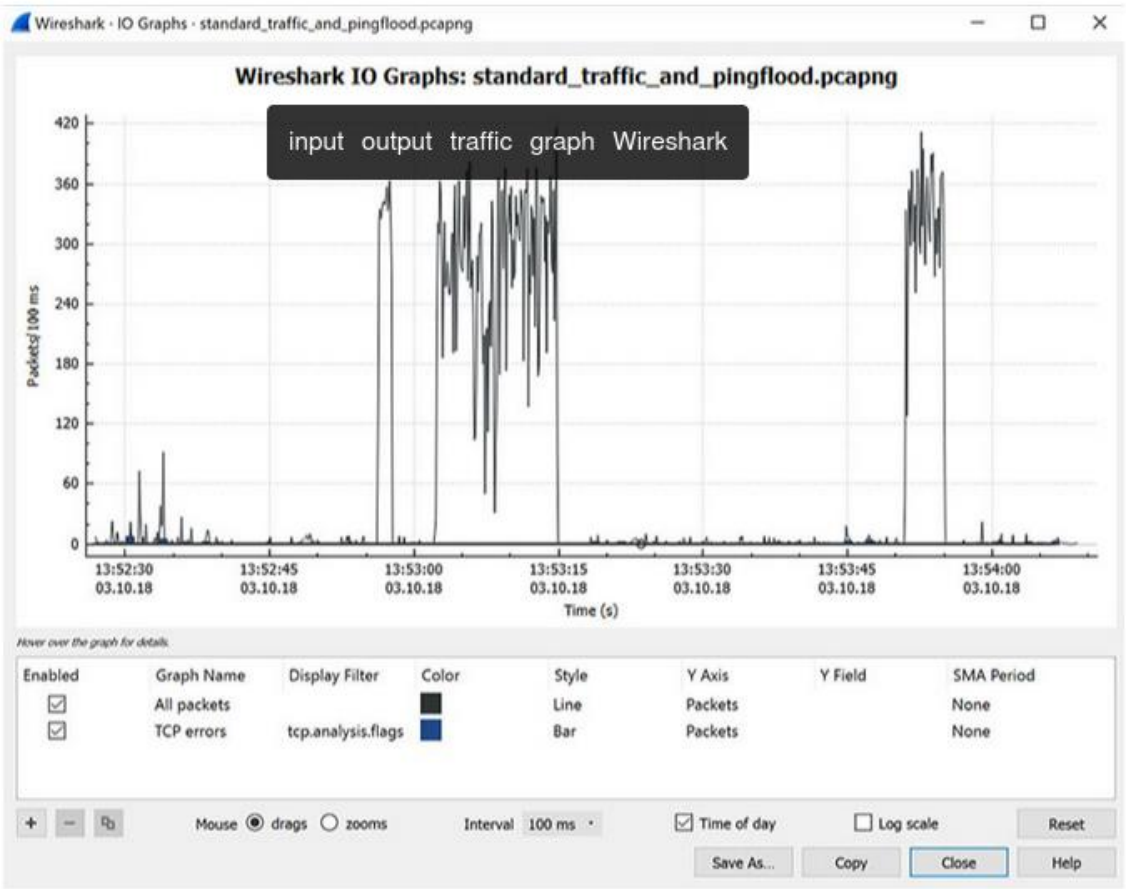
In Figure 7 below, you can see standard UDP (light blue), TCP (light purple), TCP handshake (dark gray) and routing traffic (yellow).



4. Identify Vulnerabilities

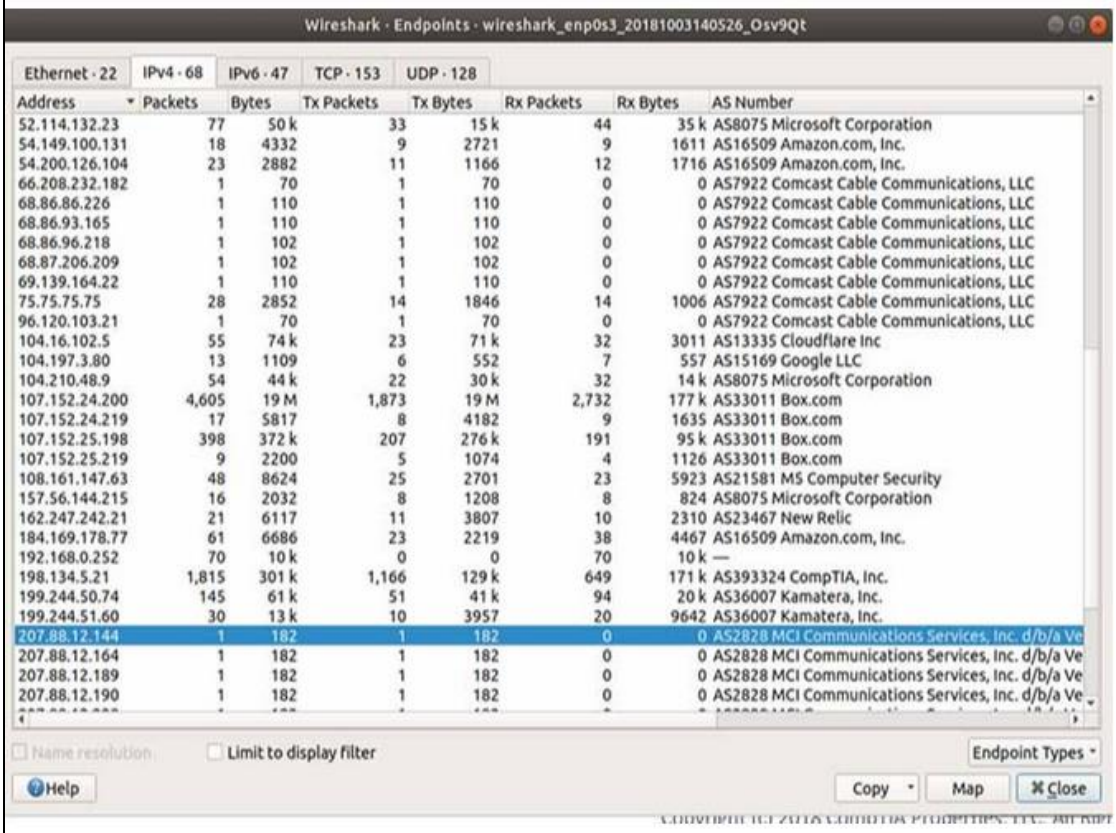
. However, you're not limited to just interpreting by color. It's possible to view the input/output (I/O) statistics of an entire packet capture.

In Wireshark, just go to Statistics >> I/O Graph, and you'll see a graph similar to the one shown in Figure 8.



5. Assess Corresponding Risks

This particular graph is showing typical traffic generated by a home office. The



spikes in the graph are bursts of traffic that were caused by generating a Distributed Denial of Service (DDoS) attack using a few Linux systems.

In this case, three major traffic bursts were generated. Many times, cybersecurity pros use Wireshark as a quick and dirty way to identify traffic bursts during attacks. It's also possible to capture the amount of traffic generated between one system and another. If you go to Statistics and then select Conversations, you will see a summary of conversations between end points, as shown below in Figure 9.

6. Implement Monitoring

In the above case, Wireshark was used to see if an old piece of equipment from MCI communications that was running on a client's network could be traced.

It turned out that the client didn't know this device was even on the network. Thus, it was removed, helping to make the network a bit more secure.

Notice, also, that this network connection is experiencing a lot of traffic to Amazon (administering a server in AWS at the time) and Box.com (using Box for system backup at the time).

In some cases, it is even possible to use Wireshark to identify the geographic location of source and destination traffic. If you click on the Map button at the bottom of the screen (shown in Figure 9 above), Wireshark will show you a map (Figure 10), providing its best guess of the location of the IP addresses you've identified.

2. Snort

Snort is an open-source network intrusion detection and prevention system (IDS/IPS) that monitors network traffic and identifies potentially malicious activities on Internet Protocol (IP) networks. Organizations can implement Snort using a rule-based language that combines protocol-, signature-, and anomaly-based inspection methods to detect malicious packets in network traffic and block potential attack vectors.

Snort Use Cases

Snort is primarily used by organizations looking for a platform-agnostic IDS/IPS to secure their networks against emerging threats. Companies turn to Snort for:

- Real-time network traffic monitoring
- Protocol analysis
- Content matching; collates rules by protocol, ports, and then by those with content and without
- Operating system (OS) fingerprinting
- Compatibility with any OS

8.Provide Remediation Recommendations

Snort Rule Types

Snort does not evaluate rules in the order they appear in the config file; instead, it reviews them based on the rule type, which specifies the action to take when Snort finds a packet that matches the rule criteria.

The five basic rule types in Snort are:

- **Alert rules:** Snort generates an alert when a suspicious packet is detected.
- **Block rules:** Snort blocks the suspicious packet and all subsequent packets in the network flow.

```
Commencing packet processing (pid=2968)
11/02-09:03:29.162290  [**] [1:10000005:0] SYN attack [**] [Priority: 0] {TCP} 1
92.168.43.160:1314 -> 65.55.252.93:443
11/02-09:03:32.165652  [**] [1:10000005:0] SYN attack [**] [Priority: 0] {TCP} 1
92.168.43.160:1314 -> 65.55.252.93:443
11/02-09:03:38.167767  [**] [1:10000005:0] SYN attack [**] [Priority: 0] {TCP} 1
92.168.43.160:1314 -> 65.55.252.93:443
11/02-09:03:50.236649  [**] [1:10000005:0] SYN attack [**] [Priority: 0] {TCP} 1
92.168.43.160:1315 -> 65.55.252.93:443
11/02-09:03:53.237057  [**] [1:10000005:0] SYN attack [**] [Priority: 0] {TCP} 1
92.168.43.160:1315 -> 65.55.252.93:443
11/02-09:03:59.237305  [**] [1:10000005:0] SYN attack [**] [Priority: 0] {TCP} 1
92.168.43.160:1315 -> 65.55.252.93:443
11/02-09:04:40.937200  [**] [1:10000005:0] SYN attack [**] [Priority: 0] {TCP} 1
92.168.43.160:1317 -> 104.27.178.119:443
11/02-09:04:41.086718  [**] [1:10000005:0] SYN attack [**] [Priority: 0] {TCP} 1
92.168.43.160:1318 -> 99.86.17.102:443
11/02-09:04:41.106720  [**] [1:10000005:0] SYN attack [**] [Priority: 0] {TCP} 2
409:4055:001c:754c:cd31:af1c:4201:e5c6:1319 -> 2404:6800:4002:0807:0000:0000:000
0:2003:443
11/02-09:04:41.492120  [**] [1:10000005:0] SYN attack [**] [Priority: 0] {TCP} 2
409:4055:001c:754c:cd31:af1c:4201:e5c6:1320 -> 2404:6800:4002:0807:0000:0000:000
0:2003:443
11/02-09:04:41.873168  [**] [1:10000005:0] SYN attack [**] [Priority: 0] {TCP} 1
92.168.43.160:1321 -> 163.53.78.110:443
11/02-09:04:43.783248  [**] [1:10000005:0] SYN attack [**] [Priority: 0] {TCP} 1
92.168.43.160:1316 -> 104.27.178.119:443
11/02-09:05:34.428584  [**] [1:10000005:0] SYN attack [**] [Priority: 0] {TCP} 2
```

- **Drop rules:** Snort drops the packet as soon as the alert is generated.
- **Logging rules:** Snort logs the packet as soon as the alert is generated.
- **Pass rules:** Snort ignores the suspicious packet and marks it as passed.

Detection of Network Scanning Attack with Snort IDS
https://www.nitttrchd.ac.in/imee/Labmanuals/SNORT-%20Network%20Intrusion%20Detection%20System.pdf



Points to Remember

Description of Cyber Vulnerabilities and risks

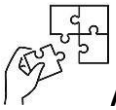
- Security risks and vulnerabilities assessment involves finding and analyzing weaknesses in an organization's systems and data. The goal is to spot these vulnerabilities before attackers can exploit them.
- The main objectives are to identify security gaps, assess potential threats, comply with regulations, and prioritize risks for fixing. This helps protect the organization from potential attacks.
- Asset identification is about recognizing all the valuable resources an organization has, like hardware, software, and data. By classifying and listing these assets, organizations can ensure they are properly protected. Asset management involves keeping track of assets and maintaining their security. Standards like ISO 27001 and NIST help guide this process.
- Data classification involves organizing data based on how sensitive it is and the level of protection it needs. Data can be classified as confidential, sensitive, or public to ensure it is handled securely. Labeling and classification standards help guide how data is stored, accessed, and disposed of. Policies also outline how long data is kept and when it should be securely deleted.
- Threat identification gathers information about potential cyber threats and helps security teams understand who might attack and how. Threat modeling is a way to predict attacks and find ways to protect against them. It involves identifying critical assets, assessing how they might be attacked, and evaluating the risk. Mitigation strategies are then applied to reduce the risks.

Documentation vulnerability assessment report

- Assessment Reports**:** Detailed documents that summarize the findings of the security assessment, including vulnerabilities, risk levels, and recommended actions.
- Risk Register: A comprehensive log that tracks identified risks, their assessments, and treatment plans. Templates can be used to standardize entries for consistency and clarity.
- Documentation of Assessment Reports**:** Maintaining organized records of all assessments conducted, findings, and remediation efforts helps ensure accountability and provides a reference for future assessments.
- Putting in place necessary security controls, such as firewalls, intrusion detection systems, and access controls, to protect against identified threats.

Steps to identify vulnerabilities and risks and document assessment report in the school's computer network.

1. Install and Set Up the Protocol Analyzers
2. Capture Network Traffic
3. Analyze the Captured Traffic
4. Identify Vulnerabilities
5. Assess Corresponding Risks
6. Implement Monitoring
7. Document Vulnerabilities and Risks
8. Provide Remediation Recommendations



Application of learning 1.8.

ZAYO Company has recently faced growing concerns about potential cyber threats, and you have been tasked with conducting a full security assessment, identifying risks, and implementing strategies for remediation and continuous improvement.



Learning outcome 1 end assessment

Written assessment

SECTION I. Choose the letter corresponding to the correct answers

1. The primary purpose of cybersecurity is:

a) To ensure data confidentiality, integrity, and availability
b) To monitor user behavior online
c) To limit access to the internet

2. What is cyber-threat?

a) Any action intended to harm a system
b) A harmless computer bug
c) A computer that is slow to respond
d) A legitimate activity that poses no risk to systems

3. Which of the following is an example of malware?

a) Phishing
b) Trojan
c) Brute force attack
d) Social engineering

4. What type of attack floods a network or server with massive amounts of traffic to disrupt services?

a) SQL Injection
b) Ransomware
c) DDoS (Distributed Denial of Service)
d) Insider Threat

5. Phishing attacks typically aim to do which of the following?

a) Destroy hardware
b) Trick users into revealing personal or sensitive information
c) Encrypt data for ransom
d) Disable system firewalls

6. What is a zero-day exploit?

a) A vulnerability that has been known for years
b) A software flaw that is publicly known and patched
c) A vulnerability that is exploited before the developer is aware of it
d) A virus that attacks zero computer

7. Which of the following is NOT considered a common cyber vulnerability?

a) Misconfigured security settings
b) High-speed internet connection
c) Weak passwords
d) Unpatched software

8. Which term refers to an attack where an unauthorized user gains access to sensitive systems?

a) Denial of Service
b) Phishing
c) SQL Injection
d) Social Engineering

9. Which of the following assets are considered intellectual property assets?

a) Financial records
b) Patents and trademarks
c) Network infrastructure
d) Physical buildings

10. Why is it important to identify cyber vulnerabilities?

a) To ensure faster internet speeds
b) To detect and fix weaknesses before they are exploited by attackers
c) To improve user interface design
d) To increase the cost of software development

11. What is the primary goal of data security policies?

a) To allow unrestricted access to data
b) To establish guidelines for protecting sensitive data
c) To eliminate the need for data encryption
d) To monitor physical assets only

12. Which of the following describes a ransomware attack?

a) Attackers demand a ransom to unlock encrypted data
b) Attackers overload a system with traffic
c) Attackers inject malicious code into a website
d) Attackers steal hardware

13. Which principle in the CIA triad ensures that data can only be accessed by authorized users?

a) Confidentiality
b) Integrity
c) Availability
d) Accessibility

14. What type of cyber attack involves tricking individuals into revealing confidential information through manipulation?

a) Denial of Service (DoS)
b) Ransomware
c) Social Engineering
d) SQL Injection

SECTION II. Match the cybersecurity frameworks and standards in column A with their

correct description in column B

Answers	COLUMN A	COLUMN B
. ……	1. **NIST Cybersecurity Framework (CSF)**	A. A European regulation designed to protect personal data and ensure privacy, with a focus on data protection by design and individual rights like access and deletion.
……	2. I**SO/IEC 27001 and 27002**	B. A U.S. regulation that sets standards for protecting patient health information, requiring encryption and physical safeguards for data storage.
……	3. **Center for Internet Security (CIS) Controls**	C. Provides a common language for understanding and managing cybersecurity risks with five core functions: Identify, Protect, Detect, Respond, and Recover.
……	4. **GDPR (General Data Protection Regulation)**	D. A global benchmark for information security, focusing on implementing and maintaining an information security management system (ISMS) with risk management processes and continual improvement mechanisms.
. …….	5. **HIPAA (Health Insurance Portability and Accountability Act)**	E. Enforces rigorous security measures specific to certain industries, like PCI DSS for payment card transactions and FISMA for federal information systems.
. ……	6. **Industry-Specific Compliance Requirements**	F. A set of prioritized, actionable security controls organized into three categories: Basic, Foundational, and Organizational, to help defend against known attacks.

SECTION III. Read the statement below and answer by TRUE if it is correct or FALSE if it is incorrect

1. Asset management refers to the process of identifying, classifying, and managing all assets within an organization**.**

2. A vulnerability assessment aims to exploit security weaknesses in a system rather than identify them.

3. ISO 27001 provides a standard for asset identification and management.

4. Threat modeling involves categorizing data assets based on their value to the organization.

5. Penetration testing is a type of security assessment technique used to identify and exploit

vulnerabilities in a system.
6. Risk assessment methodologies can include quantitative, qualitative, or semi-quantitative approaches to evaluate risks.
7. The goal of a risk assessment is solely to calculate risk scores without determining risk tolerance levels.
8. Data retention and disposal policies are part of a data classification process that ensures sensitive data is stored and disposed of correctly.
9. A risk register is a document that records identified security risks, along with their assessment and treatment plans.
10. Continuous assessment and improvement are not necessary once security controls have been implemented.

Practical assessment

C&A Technologies is a rapidly growing technology firm based in Kigali, Rwanda. Over the last five years, the company has expanded its operations, establishing three branches in different districts: the first branch in Huye District, the second in GICUMBI District, and the third in Rubavu District. C&A Technologies specializes in software development and offers various online services to its clients. Due to the company's expansion, sensitive data such as customer information, payment details, and intellectual property is accessed from multiple locations. Recently, the organization has experienced several security incidents, including unauthorized access to customer data, credit card information breaches, and potential exposure of proprietary software code. These vulnerabilities have led to significant financial losses and a decrease in customer trust. As a cyber-security engineer, you are tasked to Analyze vulnerability available in their network and corresponding security risks and Reporting security issues based to Security Assessment.



References

Andress, J. (2014). The Basics of Cybersecurity: A Practical Guide for Security Professionals. Syngress.

Graham, R. (2020). Cyber Security for Executives: A Practical Guide. Springer.

ISO/IEC 27001:2013. (2013). Information technology – Security techniques – Information security management systems – Requirements. International Organization for Standardization (ISO).

Miller, M. (2021). Cybersecurity for Dummies. Wiley.

NIST Special Publication 800-53 Rev. 5. (2020). Security and Privacy Controls for Information Systems and Organizations. National Institute of Standards and Technology (NIST).

CrowdStrike. (n.d.). *Cybersecurity 101: Fundamentals of Cybersecurity Topics*. Retrieved from https://www.crowdstrike.com/en-us/cybersecurity-101/

Virginia Cyber Range. (n.d.). *Understanding Cyber Threats and Vulnerabilities*. Retrieved from https://www.virginiacyberrange.org/courseware/k-12-uncurated-content/understanding-cyber-threats-and-vulnerabilities-59-65-

IT Governance USA. (n.d.). *Cybersecurity Risk Assessment*. Retrieved from https://www.itgovernanceusa.com/cyber-security-risk-assessments

National Cyber Security Centre. (n.d.). *The Fundamentals and Basics of Cyber Risk*. Retrieved from https://www.ncsc.gov.uk/collection/risk-management/the-fundamentals-and-basics-of-cyber-risk


ACCESS
AUONTROLL
FIREWALK
ACCESS
MECHNIUMS
USER
AUTHENTICATION
METHOMS
INTUSION
DETECTION
PREVENTION
UTWER
AUTEGECATION
DEVICE
MANAGEMENT
INTRUSION
DEVICE
DETECTION/
/PREVENTION
DEVICE
MANAGEMENT

Indicative contents

2.1 Implementation of Access Control Mechanisms
2.2 Implementation of User Authentication Mechanisms
2.3 Implementation of Authorization Mechanisms
2.4 Implementation of Access Request and Approval Workflow
2.5 Deployment of Firewalls and IDS/IPS
2.6 Isolate Critical Systems
2.7 Encrypt Sensitive Data for Protection
2.8 Manage Encryption Keys
2.9 Update Endpoint Security for Maintenance
2.10 Implement Device Management Policies
2.11 Apply Security Patches for Security Management

Key Competencies For Learning Outcome 2: Implement Security Measures

Knowledge	Skills	Attitudes
• Description of Role-Based access control(RBAC) • Description of Access Request and Approval Workflow • Description Single Factor Authentication (SFA) • Description Multi-Factor Authentication (MFA) • Description Single Sign-On (SSO) • Description of network segmentation • Identification of Critical Systems • Description of Firewalls • Description of IDS • Description of IPS • Description of Encryption in cyber security • Identification of Sensitive Data	• Configuring Role-Based access control(RBAC) in a system • Implementing User Authentication mechanisms • Implementing Authorization Mechanisms • Implementing Access Request and Approval Workflow • Deploying Firewall and IDS/IPS • Developing a Network Segmentation Plan • Implementing network segmentation measures • Isolating Critical Systems • Implementing data encryption • Updating Endpoint Security for Maintenance • Implementing device management policies	• Attention to Detail • Responsibility • Accountability • Team Spirit • Curiosity • Resilience • Adaptability

• Description Data Encryption Policies • Description of data Encryption Implementation • Description of management of encryption keys	• Testing and deployment security management	



Duration: 70 hrs

Learning outcome 2 objectives:



By the end of the learning outcome, the trainees will be able to:

1. Implement properly access control mechanisms to manage user privileges and protect resources.
2. Implement properly user authentication methods to ensure secure login and system access.
3. Implement correctly authorization mechanisms to control access to resources based on user roles and permissions.
4. Apply access request and approval workflows for better security governance.
5. Describe the process of isolating critical systems to prevent unauthorized access or cyber threats.
6. Deploy correctly firewall and IDS/IPS solutions to detect and prevent unauthorized access and potential threats.
7. Isolate properly critical system from affected system.
8. Encrypt properly sensitive data for protection, ensuring data integrity and confidentiality in transit and at rest.
9. Identify the principles of encryption key management and its importance in securing sensitive data.
10. Update properly endpoint security for future maintenance.
11. Implement correctly device management policies used in cybersecurity.
12. Apply correctly security patches for security management.



Resources

Equipment	Tools	Materials
• Client Computers • Server Machine • Routers • Switches • Firewalls • IPS/IDS	• Snort • FreeIPA • Cisco packet tracer • Virtualization software	• Internet Access

Indicative content 2.1: Implementation of Access Control Mechanisms

Duration: 6 hrs

Theoretical Activity 2.1.1: Description of Access Control Mechanisms

Tasks:1

1: Answer the following questions:

i. What is Role-Based Access control (RBAC)?

ii. Describe Key RBAC Principles and Key Concepts in RBAC

iii. What are Benefits and Advantages of RBAC?

iv. Describe Role Definition and Description

v. Describe Role Assignment

vi. Describe Criteria Role Hierarchy and Inheritance

vii. Describe RBAC Implementation in IT Systems

viii. VIII. Explain RBAC Policy Design

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 2.1.1.

Key readings 2.1.1.:

Implementation of Access Control Mechanisms

Access control mechanisms govern how users interact with systems and data within an organization. One widely adopted model is **Role-Based Access Control (RBAC)**, which assigns permissions based on users' roles rather than on individual identity.

1 Description of Role-Based Access Control (RBAC)

Introduction to Role-Based Access Control (RBAC)

RBAC is a security approach that restricts system access to authorized users based on their assigned roles within an organization. Each role has specific permissions

and access rights to systems, files, and applications.



Key RBAC Principles

- **Separation of Duties (SoD):** Critical tasks are divided among multiple roles to reduce the risk of unauthorized access or fraud.
- **Least Privilege:** Users are granted only the minimum level of access required to perform their job functions.
- **Role Assignment:** Access is based on job roles, not individual identity, reducing the complexity of managing user permissions.
- **Role Authorization:** Roles are authorized according to the organization's policies, ensuring consistency and compliance.

Key Concepts in RBAC

- **Role:** A collection of permissions tied to job functions or responsibilities within the organization.
- **Permission:** The approval to perform certain actions or access resources.
- **User:** Individuals or entities that interact with the system. A user is assigned one or more roles based on their job requirements.
- **Session:** A session maps users to their active roles during interaction with the system.

Benefits and Advantages of RBAC

Benefits of RBAC

1. **Enhanced Security:** RBAC minimizes the risk of unauthorized access by granting users only the permissions necessary for their roles, reducing the potential for security breaches.
2. **Simplified Access Management:** RBAC streamlines administration by assigning and revoking permissions at the role level rather than individually to users, making access management more efficient and less prone to errors.

3. **Scalability:** RBAC is highly adaptable to organizational growth and changes, allowing for easy creation of new roles, modification of existing roles, and assignment of users to roles as needed.
4. **Compliance with Regulations:** RBAC helps organizations comply with regulatory requirements and industry standards by ensuring that access rights align with organizational policies and regulations, facilitating audits and demonstrating compliance.
5. **Increased Productivity:** RBAC enables efficient collaboration and task execution by providing users with the necessary permissions to perform their roles effectively, reducing delays and bureaucratic hurdles.
6. **Separation of Duties:** RBAC supports the principle of separation of duties by assigning conflicting roles or permissions to different users, preventing conflicts of interest, reducing the risk of fraud, and enhancing accountability.
7. **Centralized Control:** RBAC offers centralized control over access management, allowing administrators to define and enforce access policies consistently across the organization, improving visibility and accountability.
8. **Auditing and Reporting:** RBAC systems include auditing and reporting capabilities to track and monitor user access, permissions, and role changes, helping identify security incidents, policy violations, or unauthorized access attempts.

2 Defining User Roles and Permissions

Role Definition and Description

Roles should be defined according to the specific tasks and responsibilities within the organization. A role describes the access privileges necessary for an individual to perform their job. For example, roles such as "HR Manager," "System Administrator," and "Data Analyst" will each have different levels of access and permissions.

Role Assignment Criteria

Roles are assigned based on job function, authority level, and responsibility. Factors such as departmental needs, seniority, and required access to sensitive data are considered in role assignment. It is essential to ensure that each user is only assigned the roles they need to fulfill their duties.

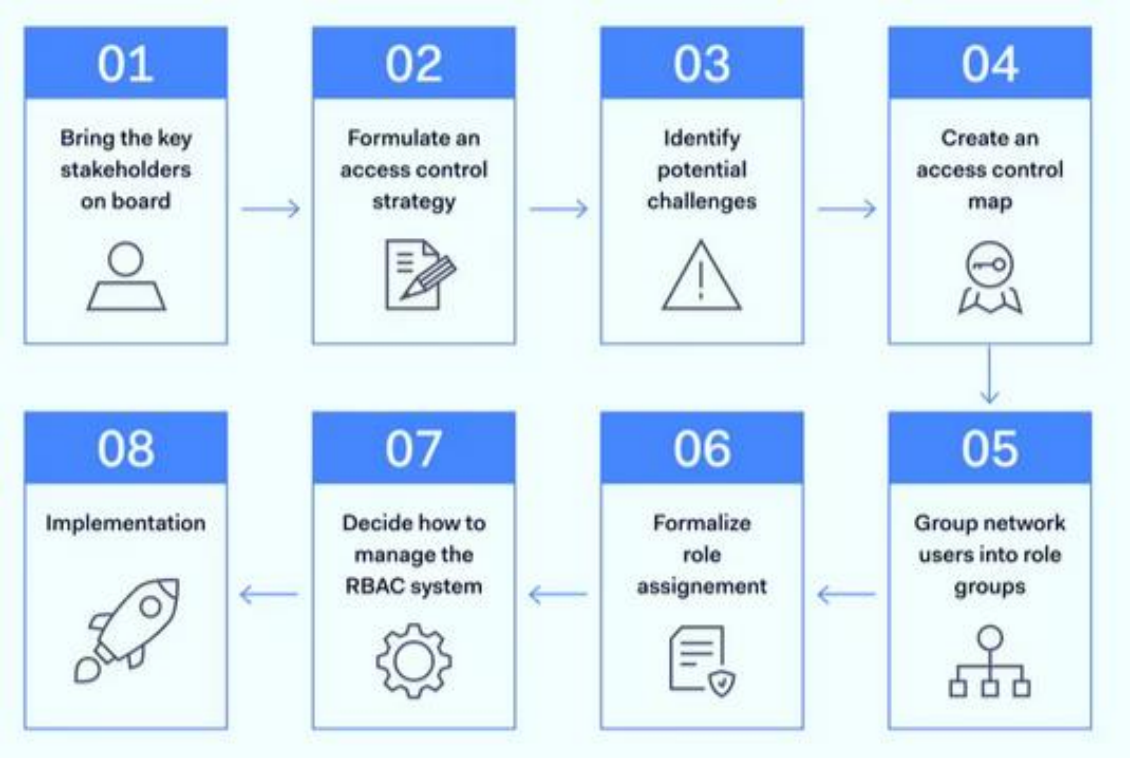
Role Hierarchy and Inheritance

RBAC supports hierarchical roles where higher-level roles inherit the permissions of lower-level roles. For example, a "Manager" role might inherit permissions from the "Employee" role, allowing managers to perform tasks employees can while also gaining additional privileges. This hierarchy helps to simplify role administration and reduces redundancy.

Configuring RBAC in a System

RBAC Implementation in IT Systems

The process below sets out a typical route to a robust access control setup. It provides a good starting point for RBAC implementation.



Step 1: Bring the key stakeholders on board

Creating a solid RBAC setup starts with **communication.** The implementation team should bring all department managers into the conversation. And they need to explain how role-based access works. Security teams rely on other departments to define role groups and necessary access rights. So smooth communication is essential.

Step 2: Formulate an access control strategy

The next step is creating a clear implementation plan. Think about what role RBAC will play within your organization. Are there any critical assets that require enhanced protection? Is the organization likely to expand, adding new hires, locations, or cloud-hosted assets?

It is important to **define the desired outcome of the project.** For example, your goal could be "a role-based access control system with automated provisioning and off-boarding, and scope to add additional controls for confidential data."

Step 3: Identify potential challenges

Look for any possible obstacles to RBAC implementation. This could include inconsistent use of multi-factor authentication or the use of multiple operating system formats. Managing access for users based on-premises or at home can also be problematic.

Regulatory compliance is also vital. Role-based access controls should meet

regulatory standards and help you achieve your regulatory aims.

Step 4: Create an access control map

Create a catalog of assets that require access controls. Include cloud and on-premises applications, email servers, every financial and customer database, confidential employee records, and cloud collaboration tools that employees use.

Step 5: Group network users into role groups

Role groups are collections of users with similar access privileges. **In an ideal world, RBAC setups feature the smallest possible number of roles**. This makes managing privileges easier and reduces the scope for human error. But organizations are complex. Balance simplicity with the user needs to define roles that function properly. One way to find the right balance is by adopting a two-strand approach. Enlist departmental managers to suggest roles that meet the needs of their workforce. At the same time, IT teams can monitor access patterns. This makes it possible to detect groups of workers that need the same access rights.

Step 6: Formalize role assignment

Use the information gathered from your earlier analysis to populate the RBAC system with functional roles. **Apply the principle of least privilege to minimize the access rights of each user group**. Roles should only have access to the resources that users need. The system should deny access to all other assets.

This is why information gathering is so important. For example, IT teams need to know which Salesforce users have write and delete permissions, and who can only read or search customer database records.

Step 7: Decide how to manage the RBAC system

Before role-based access control systems go live, it's important to **create RBAC management policies.** Explain how administrators will audit roles to prevent role explosion and avoid privileges creep. Schedule compliance audits to prove that access controls are functioning as designed.

Governance is also important. **Define who is responsible for generating and maintaining roles.** Ensure no single person has the ability to approve administrative privileges. And communicate security policies to all network users.

Step 8: Implementation

Roll out RBAC systems slowly and **check for any problems during the implementation process.** Extend access controls to a single department at first, and use this first stage as a chance to fix any issues before full rollout.

RBAC is a learning process. Don't expect frictionless operation immediately. Access controls always have teething problems in the first few months of operation.

Be attentive to feedback from individual users and managers. It should quickly become clear if roles have been improperly assigned. If the planning phase was carefully managed, minor changes should be required and nothing more.

RBAC Policy Design

RBAC policies should be carefully designed to align with organizational goals and security requirements. Key steps include:

- **Identifying Role Requirements:** Determine the roles needed within the organization and map these to the necessary permissions.
- **Defining Permission Boundaries:** Clearly outline what actions and resources each role can access, ensuring adherence to the principle of least privilege.
- **Documenting and Auditing:** Maintain records of role definitions, assignments, and changes to ensure accountability and compliance with security regulations.

Best Practices for RBAC Implementation

- Regularly review and update role assignments to reflect any changes in job responsibilities or organizational structure.
- Monitor role usage and conduct audits to ensure roles are properly enforced and users do not possess unnecessary privileges.
- Implement automated tools to streamline RBAC management, reducing manual errors and administrative overhead.



Practical Activity 2.1.2: Implement RBAC in a System



Task: 1

1: Referring to the previous theoretical activity (2.1.1) you are requested to perform the following activity.

Your school currently facing challenges in managing access permissions manually, leading to excessive permissions, unnecessary access to sensitive data, and difficulty in audit. To solve this issue, they decide to implement RBAC using their existing IT infrastructure with the open-source tool **FreeIPA**

2: Read the key readings 2.1.2

Key readings 2.1.2.:

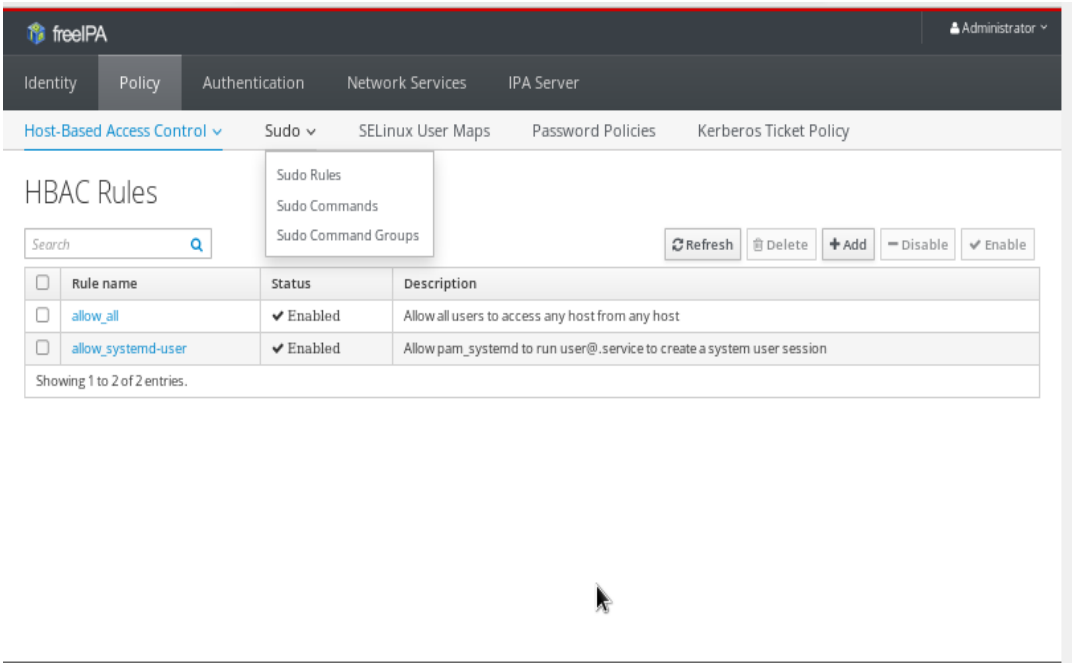
Configuring RBAC in a System

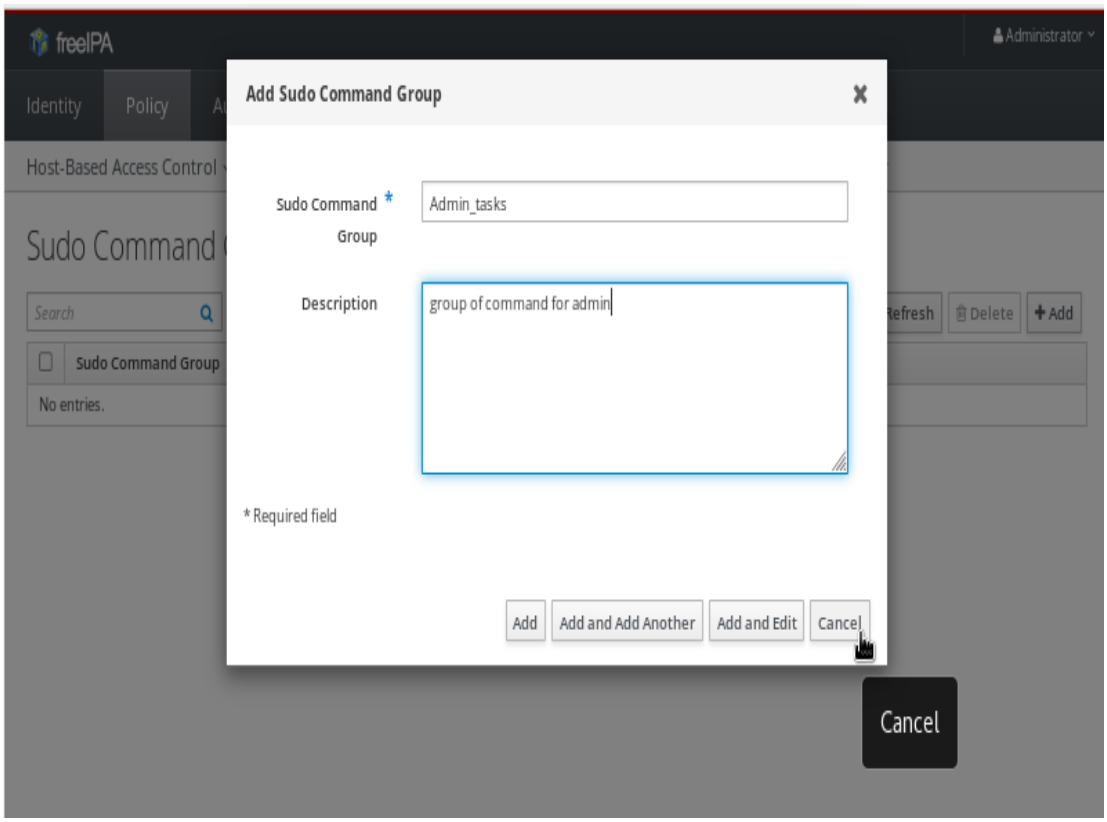
RBAC Implementation in IT Systems

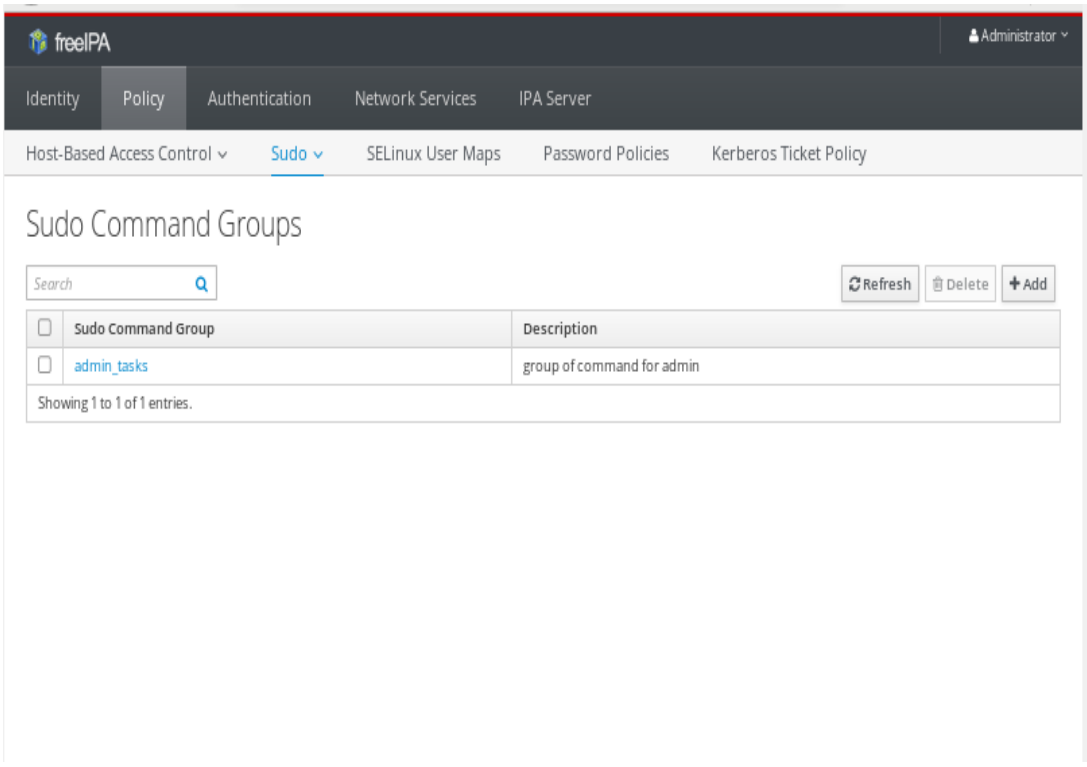
RBAC can be implemented in various IT systems, such as operating systems, databases, and enterprise applications. The configuration of RBAC in a system typically involves:

Step 1: Defining roles and permissions based on system requirements.

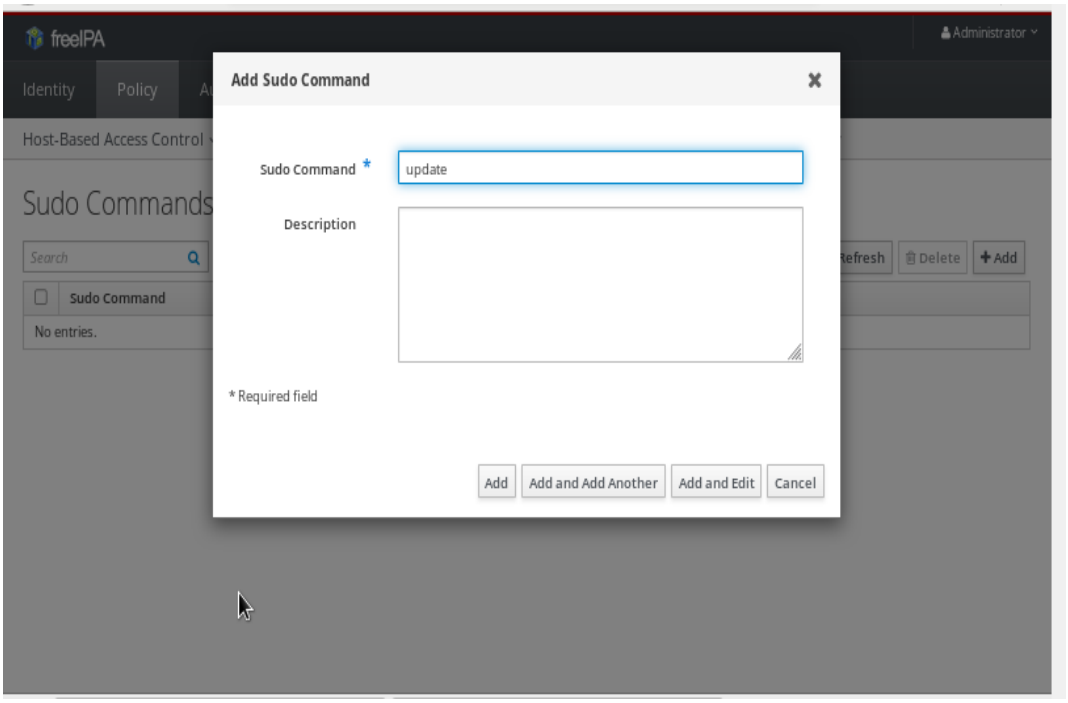
Create Sudo command groups in policy




freeIPA
Administrator
Identity
Policy
Host-Based Access Control
Sudo Command
Search
Sudo Command Group
No entries.
Refresh
Delete
Add
Add Sudo Command Group
Sudo Command Group *
Admin_tasks
Description
group of command for admin
* Required field
Add
Add and Add Another
Add and Edit
Cancel
Cancel

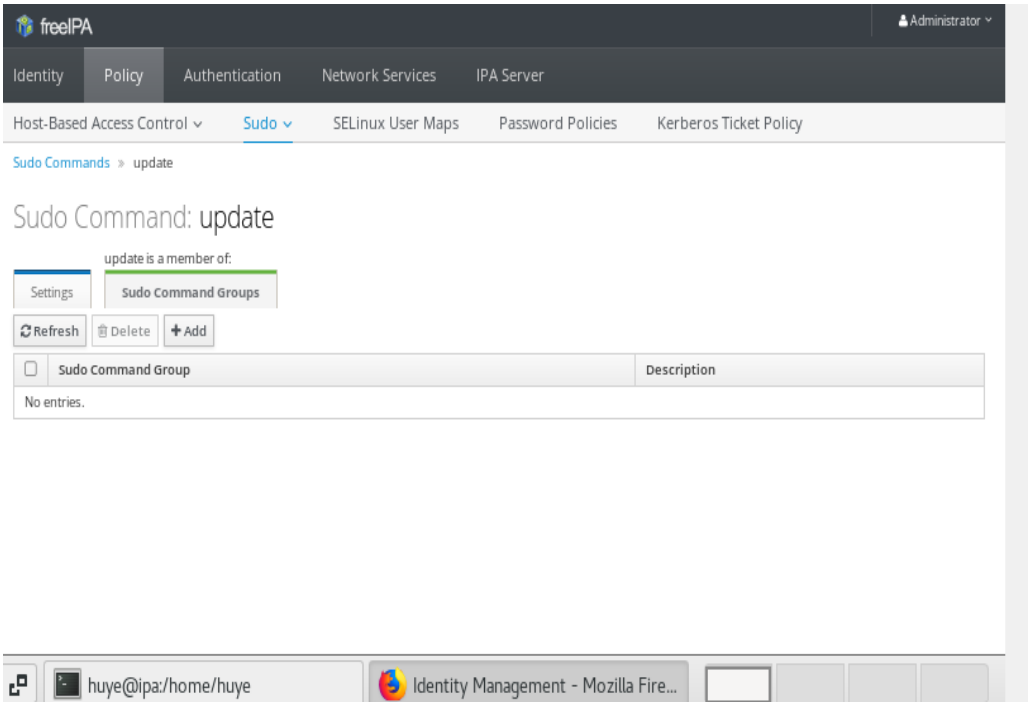

freeIPA
Administrator
Identity
Policy
Authentication
Network Services
IPA Server
Host-Based Access Control
Sudo
SELinux User Maps
Password Policies
Kerberos Ticket Policy
Sudo Command Groups
Search
Refresh
Delete
Add
Sudo Command Group
Description
admin_tasks
group of command for admin
Showing 1 to 1 of 1 entries.

Step 2: Create Commands

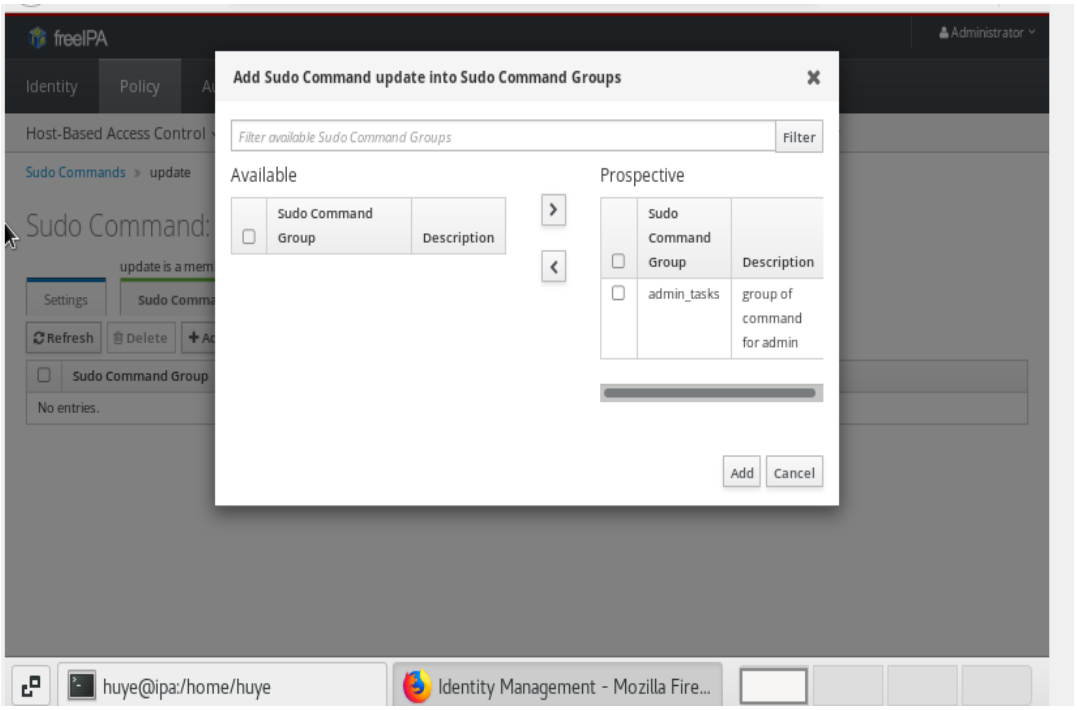


Add command into command group

=>click on your command and click on sudo command group



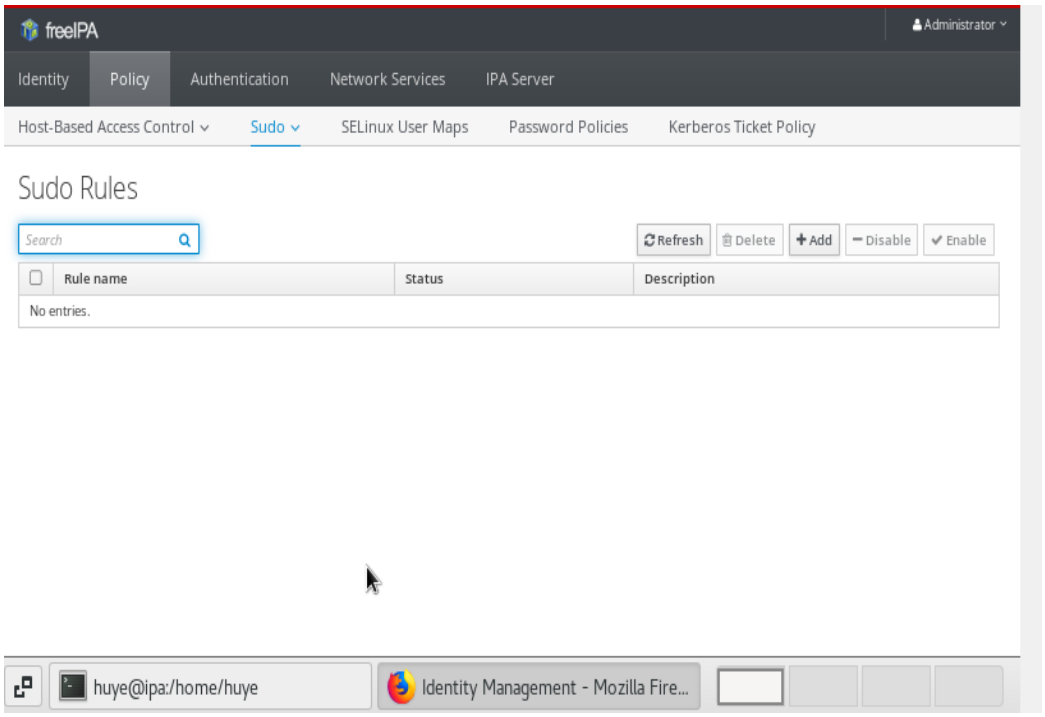
=>Click add



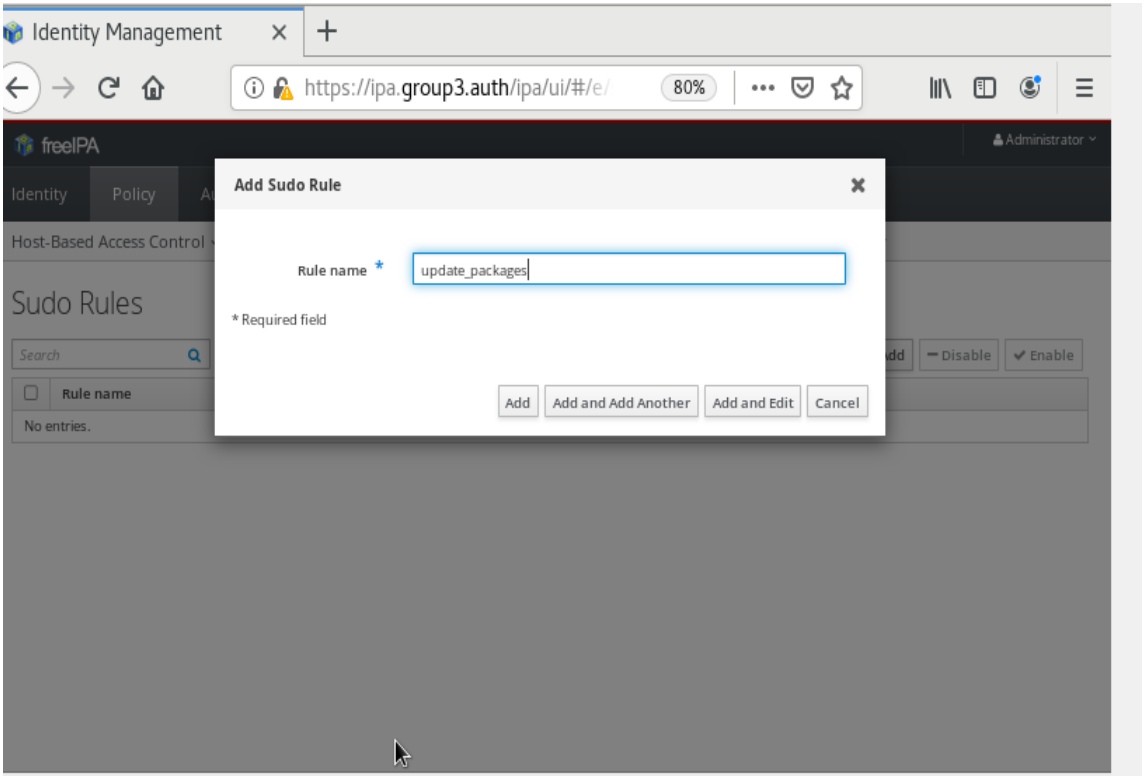
- Move **admin_tasks** from available to Prospective and click add

Step 3: Assigning users to appropriate roles.

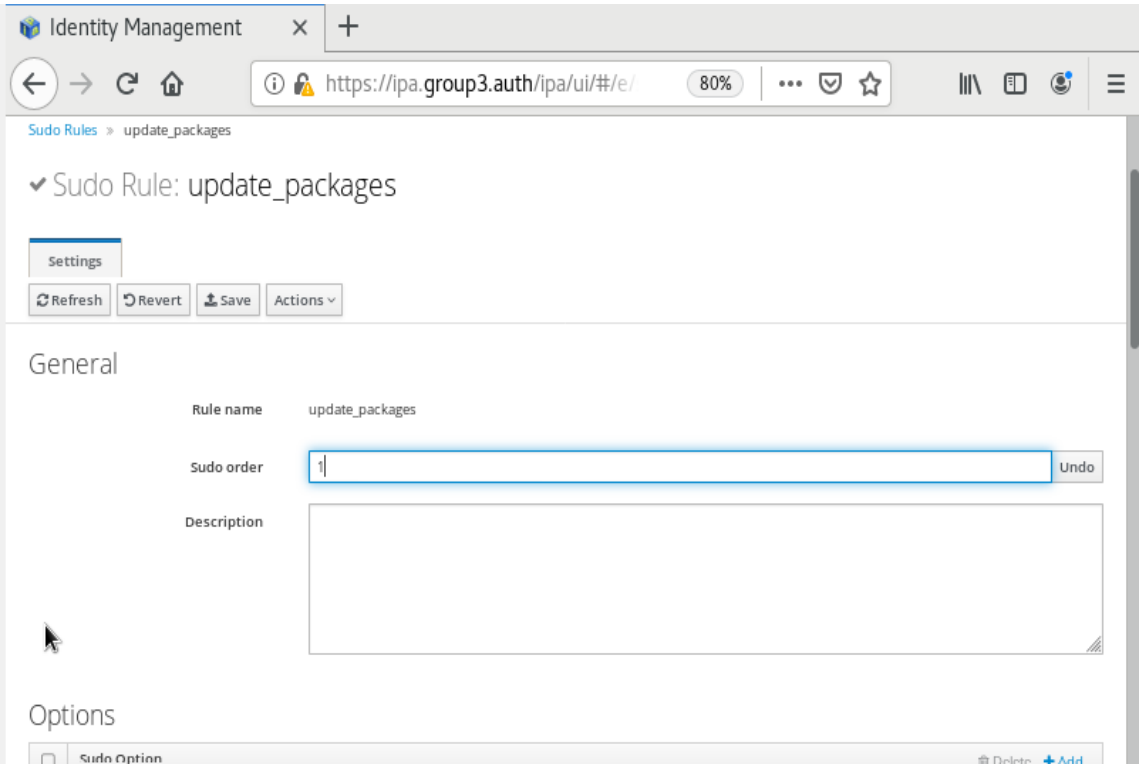
Click on sudo and click on sudo rules



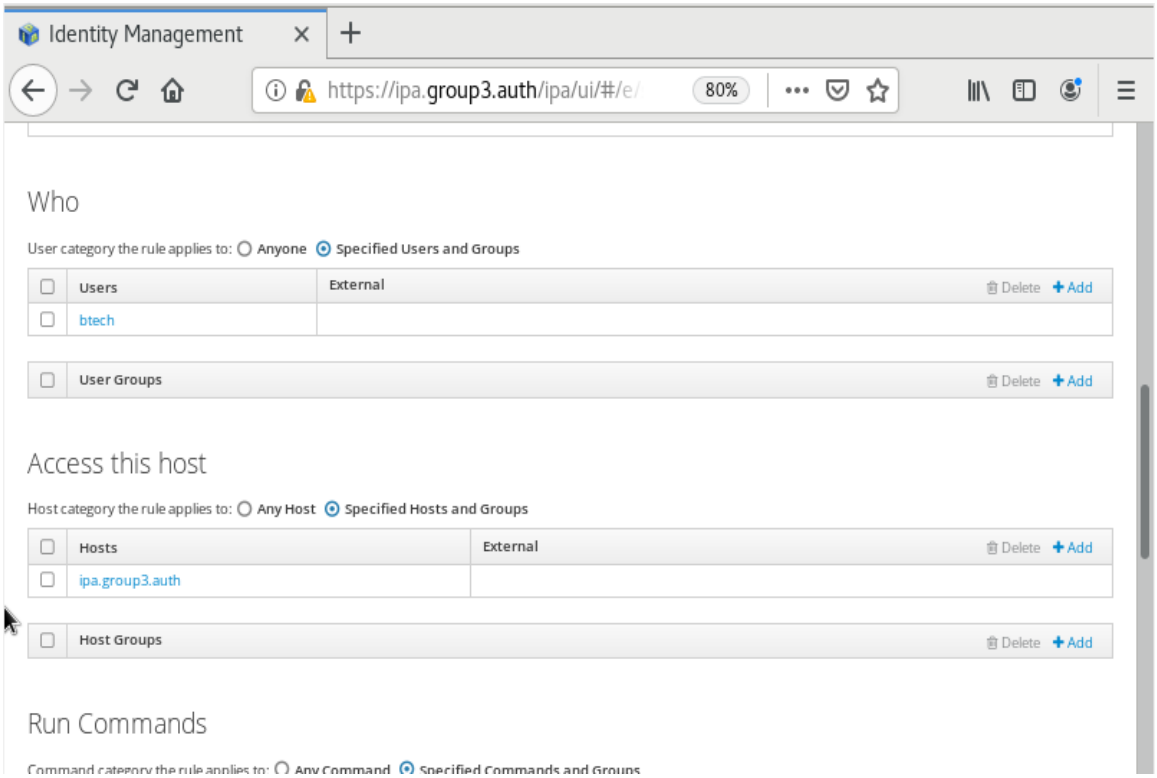
Click add and enter rules name and click add



Enter required field /enter sudo order

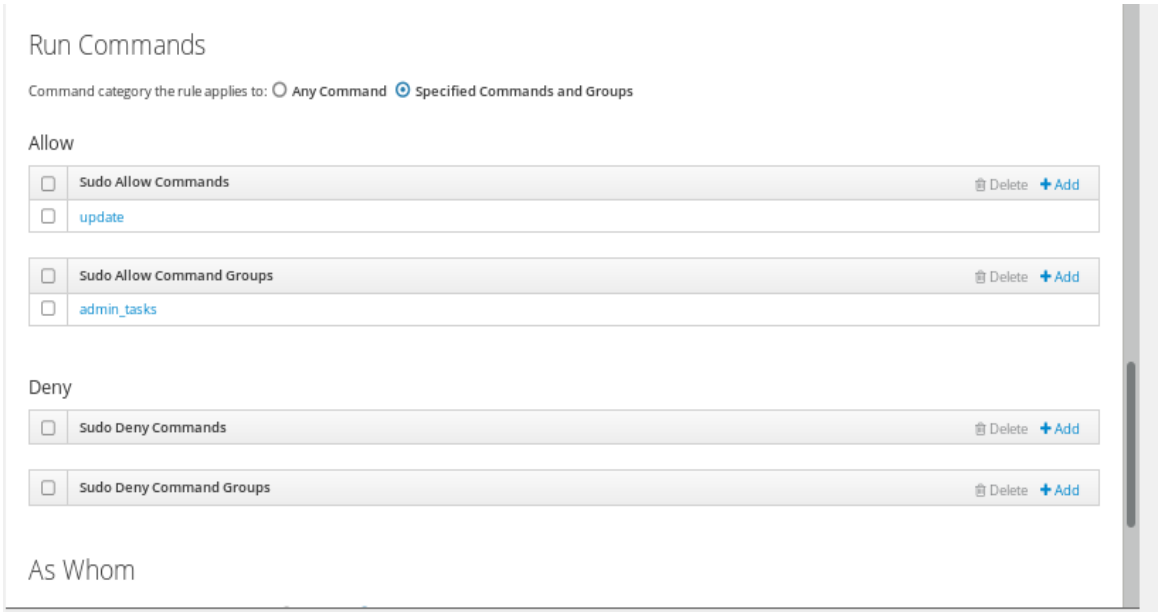


Specify user to access and host to access sudo rules from



Step 4: Establishing policies for granting and revoking roles

Choose deny or allow and choose command or command group to deny or allow





Points to Remember

Description of Access Control Mechanisms

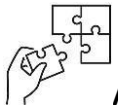
- Access control mechanisms manage how users access systems and data within an organization. Role-Based Access Control (RBAC) is a common method that grants access based on users' roles instead of individual identity.
- Key principles of RBAC include separating duties, granting only necessary access (least privilege), assigning access based on roles, and ensuring roles align with organizational policies.

- Advantages of RBAC are Enhanced Security, Simplified Access Management, Scalability, Compliance with Regulations, Increased Productivity, Separation of Duties, Centralized Control.

- User roles and permissions is central to RBAC. Roles are created based on specific tasks or responsibilities, and users are assigned roles according to their job needs.

  While configuring RBAC using FreeIPA tools you follow the following steps:
  Step 1: Defining roles and permissions based on system requirements.
  Step 2: Create Commands
  Step 3: Assigning users to appropriate roles.

  Step 4: Establishing policies for granting and revoking roles



Application of learning 2.1.

ISH Inc. is a medium-sized software company with multiple departments such as Engineering, Sales, HR, and IT Support. The organization is currently facing challenges in managing access permissions manually, leading to excessive permissions, unnecessary access to sensitive data, and difficulty in audit. To solve this issue, they decide to implement RBAC using their existing IT infrastructure with the open-source tool FreeIPA.

Indicative content 2.2: Implementation of User Authentiquassions Mechanisms

Duration: 6 hrs

Theoretical Activity 2.2.1: Description of Single Factor Authentication (SFA)

Tasks:1

1: Answer the following questions:

i. Describe Password-Based Authentication
ii. Describe Biometric Authentication
iii. Describe Token-Based Authentication

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 2.2.1.

Key readings 2.2.1

Implementation of User Authentication Mechanisms

1. Single Factor Authentication (SFA) Implementation

Single Factor Authentication (SFA) is the simplest form of authentication, where only one factor is required to authenticate

1.1. Password-Based Authentication:

Users provide a username and a password to gain access to systems. Password-based authentication is the most common form of SFA



Implementation:

- Use secure password storage (e.g., hashing algorithms like bcrypt, scrypt, or PBKDF2).
- Implement password policies (e.g., minimum length, complexity, expiration periods).
- Enable password recovery mechanisms (using security questions or email-based verification).

1.2. Biometric Authentication:

Biometric authentication uses unique biological characteristics (e.g., fingerprints, facial recognition, or retina scans) to verify user identity.



Implementation:

- Integrate biometric sensors or devices (e.g., fingerprint scanners, cameras for facial recognition).
- Use biometrics APIs or services to manage the registration and verification processes.
- Store biometric data securely

1.3. Token-Based Authentication:

Token-based authentication uses a physical or digital token (e.g., hardware tokens or OTPs generated by apps) to authenticate users.



Implementation:

- Distribute hardware tokens or enable software token generators (e.g., Google Authenticator).
- Implement token expiration and renewal mechanisms.
- Integrate token-based authentication with existing systems using APIs.

Theoretical Activity 2.2.2: Description of Multi Factor Authentication (MFA)

Tasks

1: Answer the following questions:

I. What is Introduction to MFA

II. What are Components of MFA

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 2.2.2.

Key readings 2.2.2

Implementation of User Authentication Mechanisms

1. Multi-Factor Authentication (MFA) Implementation

Multi-Factor Authentication (MFA) is a security measure that requires users to present multiple forms of authentication to verify their identity. Unlike Single-Factor Authentication (SFA), which relies on just one credential (like a password), MFA adds additional layers of security, making it much harder for unauthorized users to gain access to systems or accounts.



For example, a user may provide a password (something they know) and a one-time code sent to their phone (something they have).

2. Components of MFA

The components of MFA are grouped into three main categories, often referred to as **factors**:

1. **Something You Know**: This is knowledge-based information that only the user should be aware of. The most common example is a password or a PIN (Personal Identification Number).
2. **Something You Have**: This factor involves a physical or digital item that the user possesses. Examples include:
    - Hardware tokens (e.g., security key fobs)
    - Software tokens (e.g., OTP generators like Google Authenticator)
    - Smart cards or mobile devices
3. **Something You Are**: This is based on the user's unique biological traits. Examples include:
    - Fingerprint scans
    - Facial recognition
    - Retina or iris scans
    - Voice recognition

Difference Between Single-Factor Authentication and Multi-Factor Authentication

Single-Factor Authentication	Multi-Factor Authentication
In single-factor authentication, the process of authentication is much simpler	In multi-factor authentication, the process of successful authentication can be complex.

There is a risk to security.	There is no risk of security.
There is a chance of information getting stolen	There is no the chance, for the information to get stolen.
There is a risk of a keylogger who can steal passwords and more.	There is no risk of keylogger activity.
The user is not in full control.	The user is in full control.
There is a chance of user password getting captured by the keylogger.	There is no risk of data getting captured through keylogger.
There is a chance of a phishing attack, where the attacker may deceive the user to enter the password or user id.	In multi-factor authentication, a phishing attack will not accomplish its purpose.
Example of Single-factor authentication- **Steps:** 1. Password authentication by the online service entered by user.	Example of Multi-factor authentication- **Steps:** 1. **Knowledge-** Entered Username and Password 2. **Possession-** Entered Pin from mobile app 3. **Inherence (Biometrics)-** Fingerprint verified

Theoretical Activity 2.2.3: Description of Single Sign-On (SSO) Solutions

Tasks

1: Answer the following questions:

I. Describe SSO Overview

II. What are Advantages and Challenges of SSO ?

III. Describe SSO Implementation Considerations.

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 2.2.3.

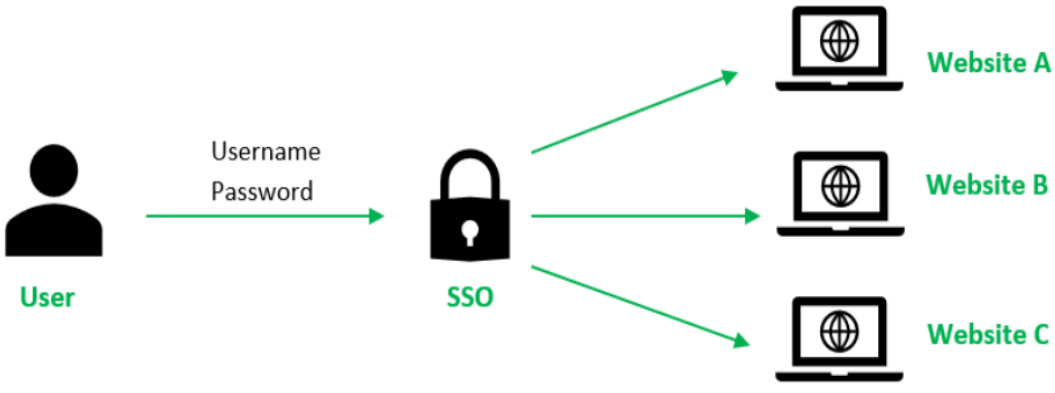
Key readings 2.2.3

Implementation of User Authentication Mechanisms

1. Single Sign-On (SSO) Solutions

SSO Overview

Single sign-on (SSO) is an authentication solution that allows users to securely authenticate to multiple applications and websites using a single set of credentials. For example, logging in to your Google account once will allow you to access Google applications such as Google Docs, Gmail, and Google Drive.



2. Advantages and Challenges of SSO

Advantages	Challenges
1. Improved User Experience:	1. **Single Point of Failure**: If the

Users need to remember only one set of credentials, which reduces login fatigue. **2. Centralized Authentication**: Authentication is managed through a central IdP, making it easier to enforce security policies and monitor access. **3. Reduced Helpdesk Costs**: Fewer forgotten passwords result in fewer helpdesk calls for password resets.	SSO service is compromised or goes down, access to multiple applications is affected. 2. **Complex Configuration**: Implementing SSO across different platforms and systems may require complex configuration and integration work. 3. **Security Risks**: A successful compromise of the SSO credentials can give attackers access to multiple systems.

3. SSO Implementation Considerations

1. Choose an SSO Solution:

a. Popular SSO solutions include:

i. **Cloud-based**: Okta, Azure Active Directory, Google Identity.

ii. **On-premise**: FreeIPA, Keycloak, Microsoft AD FS.

b. Choose based on organizational needs, infrastructure (cloud vs. on-premise), and supported protocols (SAML, OAuth, OpenID Connect).

2. Integrate Identity Providers (IdP) and Service Providers (SP):

a. Ensure that the SSO system supports the necessary authentication protocols (e.g., SAML for web applications, OpenID Connect for APIs).

b. Configure trust relationships between the IdP and SPs, ensuring they accept tokens or assertions issued by the IdP.

3. Configure SSO Policies:

a. Define user groups and access policies, ensuring only authorized users can access specific applications.

b. Implement MFA for critical services or sensitive applications within the SSO framework.

4. User Provisioning and Deprovisioning:

a. Automate user account creation and removal across multiple systems using the SSO platform.

b. Ensure that users who leave the organization or change roles have their access removed or updated in all connected applications.

5. Monitor and Audit:

a. Regularly audit the SSO system for security and performance.

b. Monitor authentication logs for suspicious activities or failed login attempts

across applications.

4. Advantages of Single Sign-On (SSO)

- **Enhanced User Experience:** SSO simplifies the login process for users by enabling them to access multiple applications or services with a single set of credentials, reducing the need to remember and manage multiple passwords.
- **Improved Productivity:** With SSO, users can quickly access the resources they need without repeatedly entering login credentials, leading to increased efficiency and productivity.
- **Enhanced Security:** SSO can improve security by enforcing stronger authentication methods, such as multi-factor authentication (MFA), and centralizing access control, making it easier to monitor and manage user access across all connected applications.
- **Reduced Password Fatigue:** By eliminating the need to remember multiple passwords for different applications, SSO reduces password fatigue and the likelihood of users resorting to insecure password practices, such as using weak or easily guessable passwords.



Practical Activity 2.2.4: Implementing of User Authentication mechanisms



Tasks

1: Perform the following activity.

The school need to enhance its security due to increasing cyber threats. Initially relying on Single Factor Authentication (SFA) through passwords. To strengthen security, they need to implement Multi-Factor Authentication (MFA), requiring users to verify their identity using multiple methods, like passwords and biometrics. Use FreeIPA to enable Multi-Factor Authentication (MFA) for school users.

2. Present your findings.
4: Listen carefully to the trainer feedback.

5: Ask any questions you have or clarify any doubts related to the content presented or discussed.

6: Read the key readings 2.2.1.



Key readings 2.2.1

Implementing MFA

Step 1: Enable OTP Authentication for FreeIPA

- **Log in to FreeIPA Web UI:**

1. Open your web browser and navigate to the FreeIPA Web UI (e.g., https://ipa.example.com).
2. Log in using the **admin** credentials.

- **Go to Authentication Settings**:

1. On the left-hand menu, click **IPA Server**.
2. Select **Configuration** from the drop-down menu.

- **Enable OTP Authentication**:

1. Scroll down to the section labeled **User Authentication Types**.
2. In the **Enabled User Authentication Types** field, select both **password** and **OTP**. This ensures that users must authenticate with a password and a one-time password (OTP).
3. Click **Save** to apply these settings.

Step 2: Configure OTP Tokens for Users

Now that FreeIPA is set up to require MFA, you need to configure OTP tokens for individual users.

- **Select a User**:
    - Go to the **Identity** section on the left-hand side.
    - Click **Users** to see the list of all users.
    - Click on the user you want to enable OTP for.
- **Add an OTP Token**:
    - In the user's profile, go to the **OTP Tokens** tab.
    - Click **Add** to create a new OTP token for the user.
- **Generate OTP Token**:
    - In the **New OTP Token** window, you can either manually add a token (if you already have one) or generate a new one automatically.
    - Choose the type of OTP token (usually **TOTP**, which stands for Time-based One-Time Password).
    - Click **Generate Token** to automatically generate the secret key for the OTP token.
- **Display QR Code for OTP Setup**:
    - Once the token is generated, the system will show a **QR code** and a **secret key**.
    - Ask the user to open their OTP authenticator app (Google Authenticator, FreeOTP, etc.) on their

mobile device and scan the QR code.
    - Alternatively, the user can manually enter the secret key in their authenticator app if the QR code scan fails.
- **Save OTP Token**:
    - Once the user has scanned the QR code, click **Save** in the FreeIPA GUI to apply the OTP token for that user.

Step 3: Test MFA Configuration

Before rolling out MFA to all users, it's important to test the configuration to ensure everything works as expected.

- **Log Out and Log in as the User**:
    - Log out of the FreeIPA Web UI.
    - Try logging back in using the user account for which OTP has been configured.
- **MFA Authentication**:
    - Enter the user's **password** as the first factor.
    - You will be prompted for a **second authentication factor**, which is the OTP.
    - Open the user's OTP authenticator app and enter the 6-digit OTP code displayed on the app.
- **Successful Authentication**:
    - If the password and OTP are correct, the user will successfully log in.
    - If there are issues, double-check the OTP token setup and ensure the time on the mobile device is synchronized with the FreeIPA server.



Points to Remember

Description of Single Factor Authentication (SFA)

- Single-Factor Authentication (SFA) Implementation involves using just one method of authentication to verify a user's identity.
- Password-Based Authentication: This is the most common form of SFA, where users log in using a username and password.
- Biometric Authentication: Uses unique biological characteristics, such as fingerprints or facial recognition, for authentication.
- Token-Based Authentication: Users are authenticated via physical or digital tokens, such as hardware tokens or app-generated OTPs.

Description of Multi Factor Authentication (MFA)

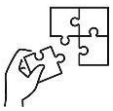
- Multi-Factor Authentication (MFA) is a security process that enhances protection by requiring users to provide multiple forms of identification to access systems or accounts
- MFA's key components are divided into three categories: "Something You Know," such as a password or PIN; "Something You Have," like hardware tokens or mobile apps generating one-time passcodes; and "Something You Are," involving biometric data such as fingerprints or facial recognition

Description of Single Sign-On (SSO) Solutions

- Single Sign-On (SSO) is an authentication solution that enables users to access multiple applications and websites using a single set of credentials.
- SSO offers several advantages, such as improving user experience by reducing the number of credentials to remember, centralizing authentication to make security enforcement easier, and lowering helpdesk costs by reducing password reset requests.
- Challenges, including creating a single point of failure, requiring complex configuration across different systems, and increasing security risks if SSO credentials are compromised, potentially giving attackers access to multiple systems.

Steps to Implement Multi-Factor Authentication (MFA) with FreeIPA to enable MFA

Step 1: Enable OTP Authentication for FreeIPA
Step 2: Configure OTP Tokens for Users
Step 3: Test MFA Configuration



Application of learning 2.2.

ABC Company need to enhance its security due to increasing cyber threats. Initially relying on Single Factor Authentication (SFA) through passwords. To strengthen security, they need to implement Multi-Factor Authentication (MFA), requiring users to verify their identity using multiple methods, like passwords and biometrics. Use FreeIPA to enable Multi-Factor Authentication (MFA) for school users.

Indicative content 2.3: Implementation of Autorisation Mechanisms

Duration: 6 hrs

Theoretical Activity 2.3.1: Description of Authorization Mechanisms

Tasks:

1: Answer the following questions:

I. Describe Permission Models?

II. Describe Access Control Lists (ACLs)

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 2.3.1

Key readings 2.3.1

Description of Authorization Mechanisms

Authorization mechanisms are crucial in managing and controlling who has access to specific resources within a system. By implementing various permission models and techniques, organizations can effectively enforce security policies to ensure data confidentiality, integrity, and availability



Access Control Mechanisms determine who can access what resources, under what conditions, and with what level of privileges. They are designed to prevent unauthorized access, protect against data breaches, and enforce security policies.

There are various types of Access Control Mechanisms that can be implemented, depending on the specific requirements and security needs of a system. Some common types include:

- Role-Based Access Control (RBAC): This mechanism assigns access permissions based on the roles and responsibilities of users within an organization. It ensures that users only have access to the resources necessary for their job functions.
- Discretionary Access Control (DAC): DAC allows owners of resources to determine access permissions and control who can access their resources. It provides a high level of flexibility but also requires careful management.
- Mandatory Access Control (MAC): MAC enforces access policies based on predefined rules and labels. It is commonly used in environments where data confidentiality is critical, such as government or military systems.

Implementing Access Control Mechanisms involves a combination of authentication and authorization processes. Authentication verifies the identity of a user, while authorization determines the actions and resources a user is allowed to access.

By implementing Access Control Mechanisms, developers can ensure that only authorized users can access sensitive data and resources, reducing the risk of

unauthorized access and data breaches. It is important to regularly review and update access policies, implement multi-factor authentication, and monitor and audit access control systems to maintain a robust security posture.

1. Role-Based Access Control (RBAC)

Role-Based Access Control (RBAC) is a widely used Access Control Mechanism that assigns access permissions based on predefined roles and responsibilities. It provides a flexible and scalable approach to access control, making it suitable for organizations of all sizes.

In RBAC, access permissions are associated with specific roles within an organization. Users are then assigned to one or more roles based on their job functions. This simplifies the management of access control by allowing administrators to assign permissions to roles rather than individual users.

RBAC offers several benefits:

- Simplified Administration: RBAC reduces the administrative burden of managing individual user permissions. Access can be easily granted or revoked by assigning or removing roles.
- Granular Access Control: RBAC allows for fine-grained control over access permissions. Different roles can be created to reflect different levels of privileges, ensuring that users only have access to the resources necessary for their roles.
- Scalability: RBAC is highly scalable, making it suitable for organizations that experience growth or changes in their workforce. New roles can be added or modified without affecting existing access permissions.
- Security and Compliance: RBAC helps enforce security policies and ensure compliance with regulatory requirements. By assigning access permissions based on roles, RBAC reduces the risk of unauthorized access and data breaches.

Implementing RBAC involves defining roles, associating permissions with roles, and assigning users to roles. Regularly reviewing and updating role assignments is important to ensure that access permissions remain aligned with organizational needs.

2. Discretionary Access Control (DAC)

Discretionary Access Control (DAC) is an Access Control Mechanism that allows resource owners to have control over access permissions. In DAC, owners can determine who can access their resources and what level of access they have.

With DAC, access decisions are based on the discretion of the resource owner. The owner has the authority to grant or deny access to their resources, and they can also delegate access control to other users.

Key features of DAC include:

- Flexibility: DAC provides a high level of flexibility, as it allows resource owners to make access control decisions based on their own judgment and criteria.
- Ownership-based Access: DAC is based on the concept of ownership, where the owner of a resource has the authority to control access to it.
- Access Control Lists (ACLs): DAC often uses Access Control Lists (ACLs) to specify access permissions for individual resources. An ACL is a list that associates users or groups with specific access rights.

While DAC offers flexibility, it also poses challenges in terms of centralized management and maintaining consistent access control across an organization. It requires careful planning and coordination to ensure that access permissions are properly assigned and revoked when necessary.

DAC is commonly used in environments where individual resource owners need control over their resources, such as personal computers, file systems, and certain collaborative systems. It is not suitable for highly regulated environments where centralized control and consistent access policies are required.

Implementing DAC involves defining resource ownership, establishing access control lists, and ensuring that resource owners have the necessary tools and knowledge to manage access permissions effectively.

3. Mandatory Access Control (MAC)

Mandatory Access Control (MAC) is an Access Control Mechanism that enforces access policies based on predefined rules and labels. It is commonly used in

high-security environments where data confidentiality and integrity are critical, such as government or military systems.

In MAC, access decisions are based on the classification and sensitivity of the resources and the security clearances of the users. It operates on a hierarchical model, where access is granted or denied based on the security level of the user and the sensitivity level of the resource.

Key features of MAC include:

- Label-Based Access Control: MAC uses labels to define the security levels of users and resources. Labels can include classifications such as Top Secret, Secret, and Unclassified.
- Security Clearances: Users are assigned security clearances based on their level of trust and access requirements.
- Strict Enforcement: MAC strictly enforces access policies, ensuring that users can only access resources with the appropriate security clearances.

While MAC provides a high level of security, it can be complex to implement and manage. It requires a centralized authority to define and enforce access policies, and it may limit the flexibility and agility of the system.

MAC is suitable for environments where data confidentiality and integrity are of utmost importance, such as classified information systems or systems handling sensitive customer data. It ensures that only authorized users with the necessary security clearances can access sensitive resources.

Implementing MAC involves defining security classifications, assigning security clearances, and configuring the system to enforce access policies based on these classifications and clearances.

4. Access Control List

A network access control list (ACL) is made up of rules that either allow access to a computer environment or deny it. In a way, an ACL is like a guest list at an exclusive club. Only those on the list are allowed in the doors. This enables administrators to ensure that, unless the proper credentials are presented by the device, it cannot gain access.



There are two basic kinds of ACLs:

- **Filesystem ACLs**: These work as filters, managing access to directories or files. A filesystem ACL gives the operating system instructions as to the users that are allowed to access the system, as well as the privileges they are entitled to once they are inside.
- **Networking ACLs**: Networking ACLs manage access to a network. To do this, they provide instructions to switches and routers as to the kinds of traffic that are allowed to interface with the network. They also dictate what each user or device can do once they are inside.

Types of Access Control Lists

Access control lists can be approached in relation to two main categories:

A. Standard ACL

An access-list that is developed solely using the source IP address. These access control lists allow or block the entire protocol suite. They don't differentiate between IP traffic such as UDP, TCP, and HTTPS. They use numbers 1-99 or 1300-1999 so the router can recognize the address as the source IP address.

B. Extended ACL

An access-list that is widely used as it can differentiate IP traffic. It uses both source and destination IP addresses and port numbers to make sense of IP traffic. You can also specify which IP traffic should be allowed or denied. They use the numbers 100-199 and 2000-269

Feature	Discretionary Access Control (DAC)	Mandatory Access Control (MAC)	Role-Based Access Control (RBAC)
Control	Resource owners control access to their resources.	Central authority or security policy governs access.	Access is based on roles assigned by administrators.
Flexibility	High flexibility; resource owners can modify access easily.	Low flexibility; access is strictly based on policies.	Moderately flexible; changes are made by adjusting roles.
Security	Less secure; risk of accidental or unauthorized sharing.	High security; access is strictly controlled by policies.	Secure; users inherit permissions based on roles.
Access Decision Basis	Decided by the resource owner.	Based on security classification (e.g., top secret, confidential).	Based on roles assigned to users (e.g., Admin, Employee).
Use Case	Personal computers, small systems with trusted users.	Military, government, high-security environments.	Large organizations with structured roles and responsibilities.
Complexity of Management	Simple for small environments, but hard to scale.	Complex; managed by central security policy.	Moderate; scalable for large organizations.
Granularity of Control	User-defined, but can become difficult to manage.	Very granular; based on strict classifications.	Role-based; easier to manage across large groups of users.
Risk of Privilege Escalation	High risk due to decentralized control.	Low risk; permissions cannot be easily changed by users.	Moderate risk if roles are not properly managed.

Practical Activity 2.3.2: Implementing of Authorization Mechanisms

Tasks

1: Perform the following activity.

A school needs to restrict access to its webpage, allowing only staff users while denying access to student users. The Access Control List (ACL) should be configured correctly to permit staff members to access the website while ensuring that students are denied access.

2. Present your findings.

4: Listen carefully to the trainer feedback.

5: Ask any questions you have or clarify any doubts related to the content presented or discussed.

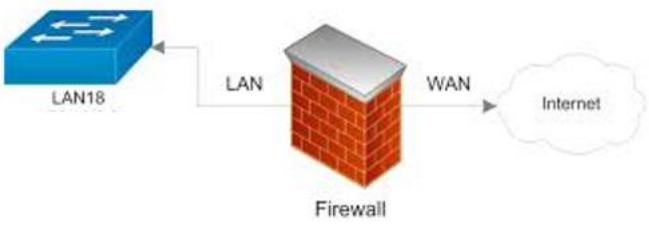
6: Read the key readings 2.3.2.

Key readings 2.3.2

Sense project is a **free network firewall distribution**, based on the FreeBSD operating system with a custom kernel and including third party free software packages for additional functionality.

Pfsense as Firewall

One of the primary functions performed by pfSense® software is **filtering traffic, deciding which traffic to pass or block** between networks.

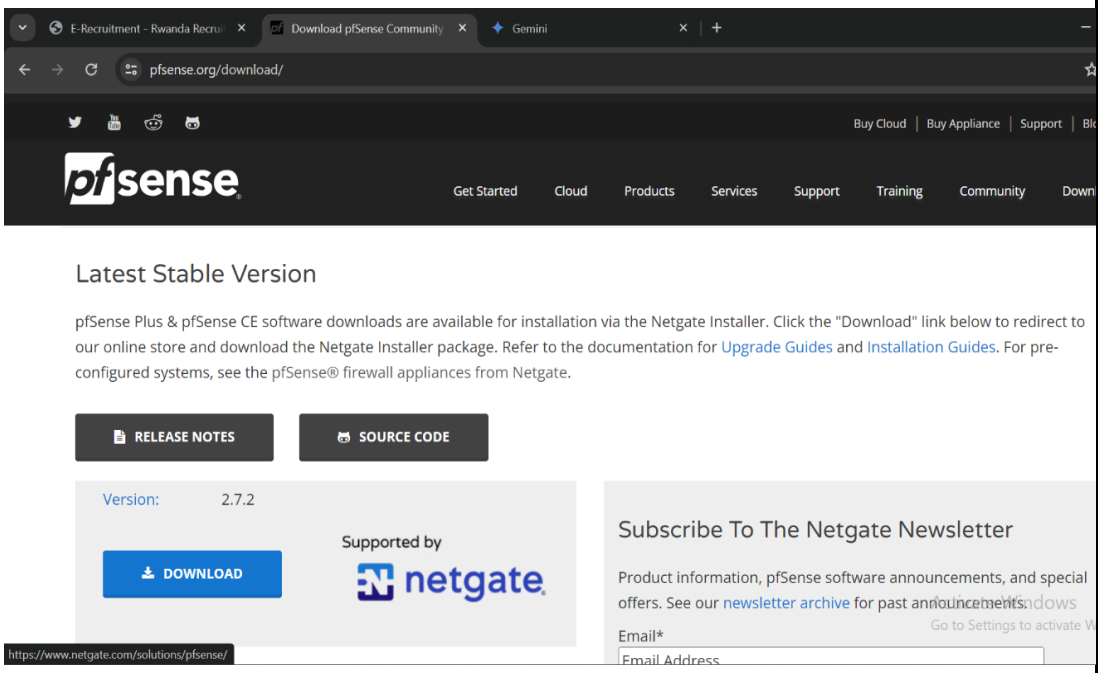


Filtering traffics

- **Ingress Filtering:** refers to the concept of firewalling traffic entering a network from an external source such as the Internet
- **Egress Filtering:** refers to the concept of firewalling traffic initiated inside the local network, destined for a remote network such as the Internet.

Preparation

Download pfSense: Head over to the pfSense download page [download pfsense iso] and choose the appropriate version (amd64 is recommended for most users). Download the image file which is typically a .iso file.



Install VirtualBox: If you haven't already, download and install VirtualBox from the official website [virtualbox org].

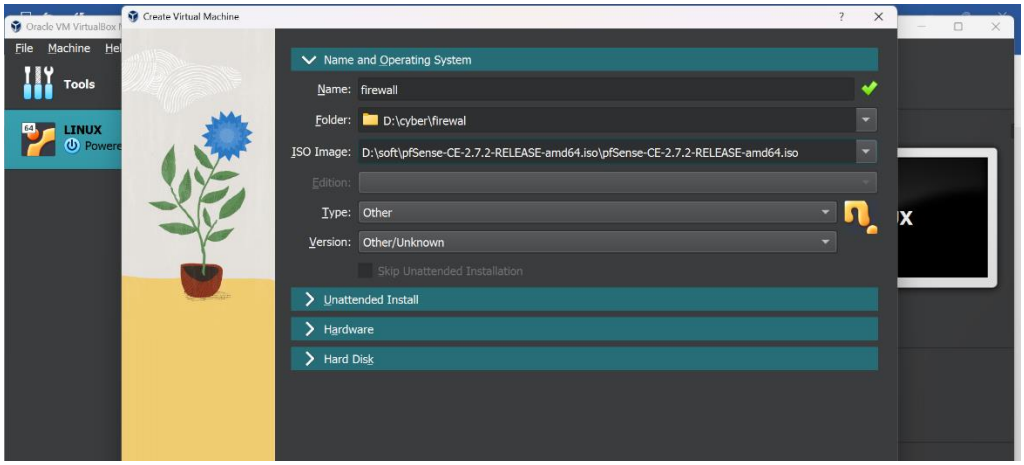
➢ **I**

nstallation

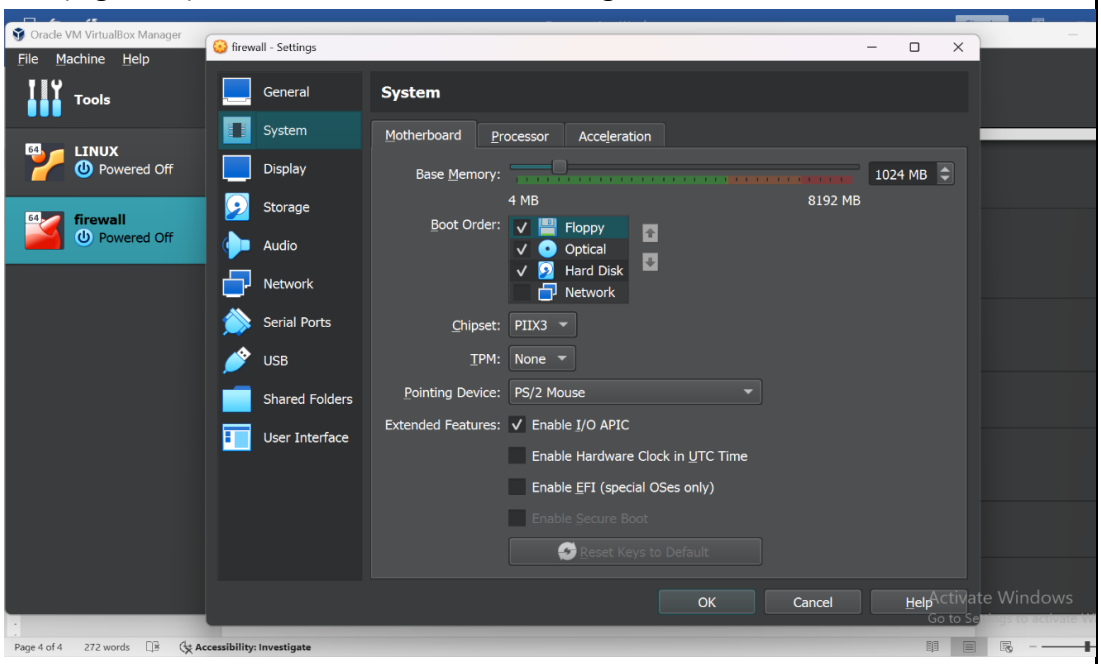
Our Install Guide will guide you through your virtualization tools, the initial pfSense configuration, and installing the pfSense software to your hard drive.

Step 1: Launch VirtualBox and click on "**New**" to create a new virtual machine.

Provide VM Details: Assign a name to your VM (e.g., firewall) and choose the machine type as "BSD" with "FreeBSD 64-bit" version. Click "Next" to proceed.

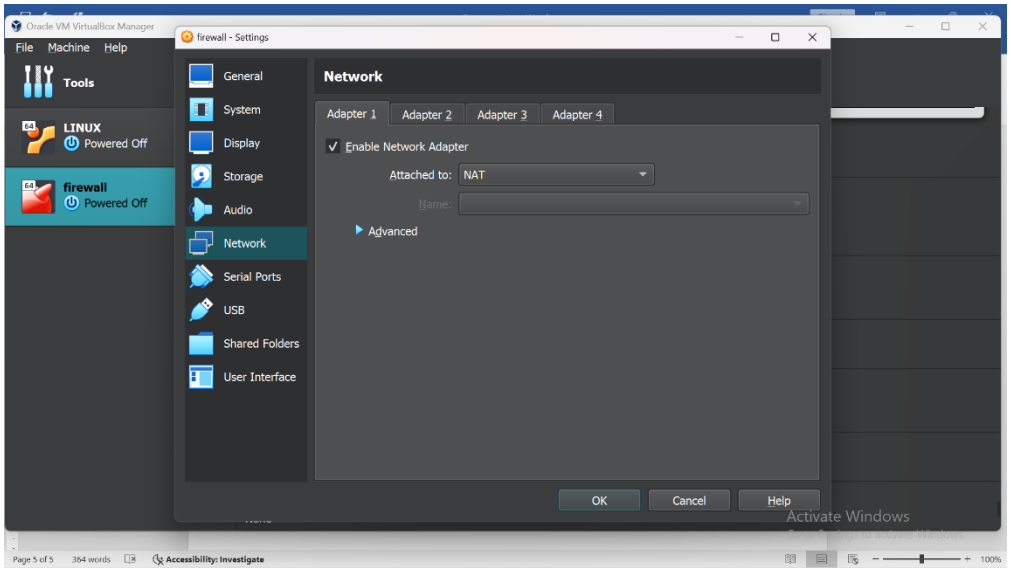


Step 2: Allocate Memory: A minimum of 1GB of RAM is recommended for pfSense, Create Virtual Hard Disk: Choose "Create a virtual hard disk now" and click "Create." In the storage type selection, choose "VDI (VirtualBox Disk Image)" set the desired disk size (e.g., 8GB). Click "Create" to finish creating the virtual hard disk.

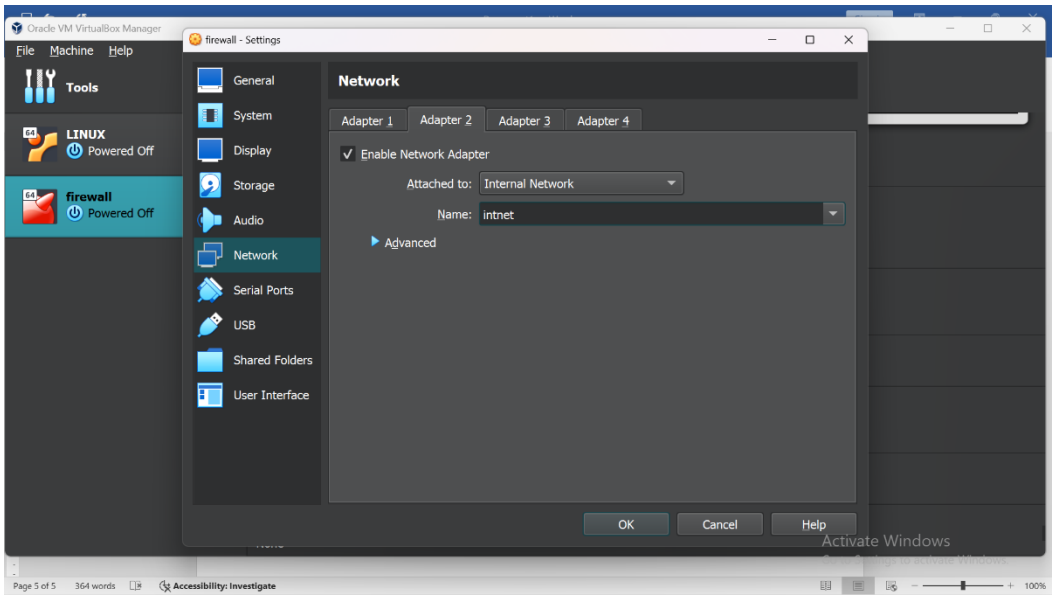


Step 3: Configuring pfSense Network Settings

Go the firewall virtual machine right click on “setting” Go the "Network" section and make sure "**Adapter 1**” Attached to "**NAT Adapter**" for the adapter you want pfSense to use to connect to your physical network.

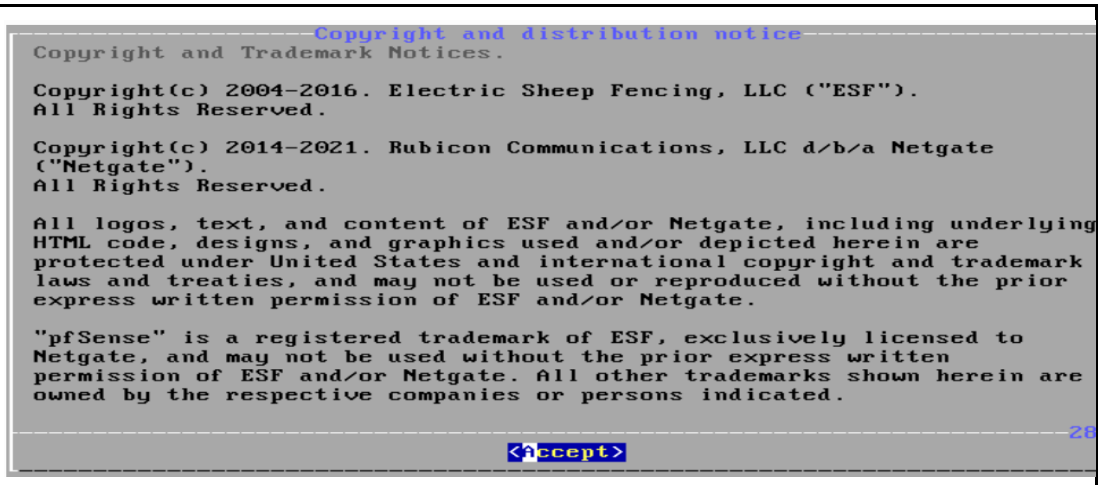


And also make sure the **"Adapter 2"** Attached to "**internal network**" Adapter for the adapter. Click "OK" to save the settings.



Step 4: Installing pfSense

Read the terms carefully. Use the Page Down and Page Up keys to display additional license text. Press Enter to **Accept** the terms and proceed.



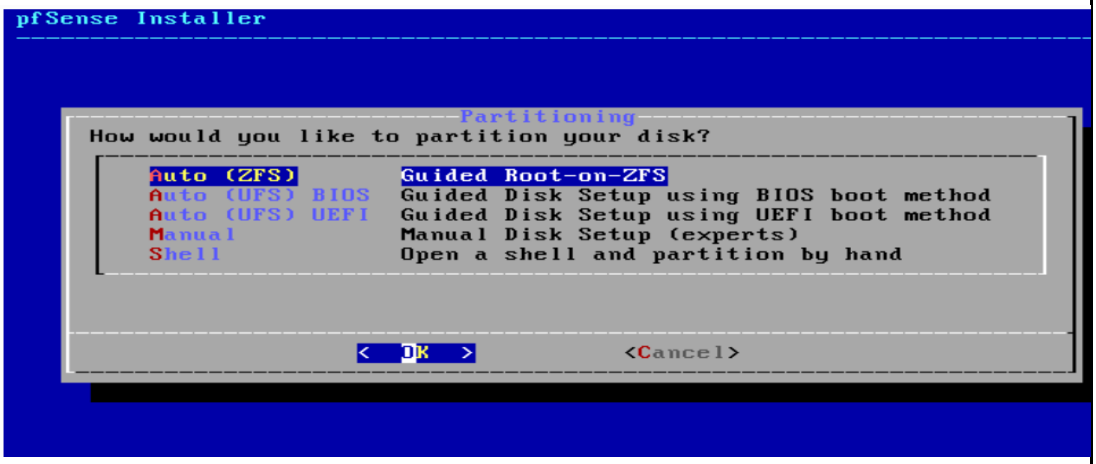
First, the installer prompts to launch rescue options or start the **Install** process.



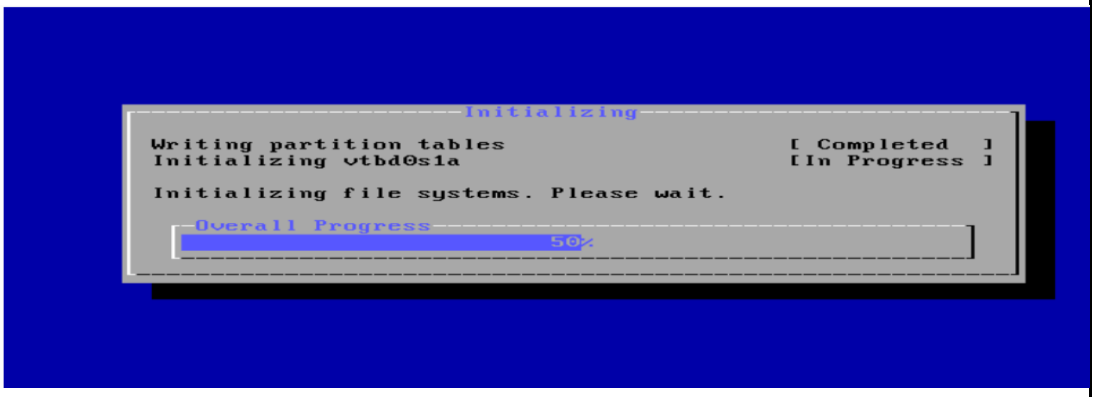
Keymap Selection screen selects the keyboard layout used by the installer. press Enter to select **Continue with default Keymap**.



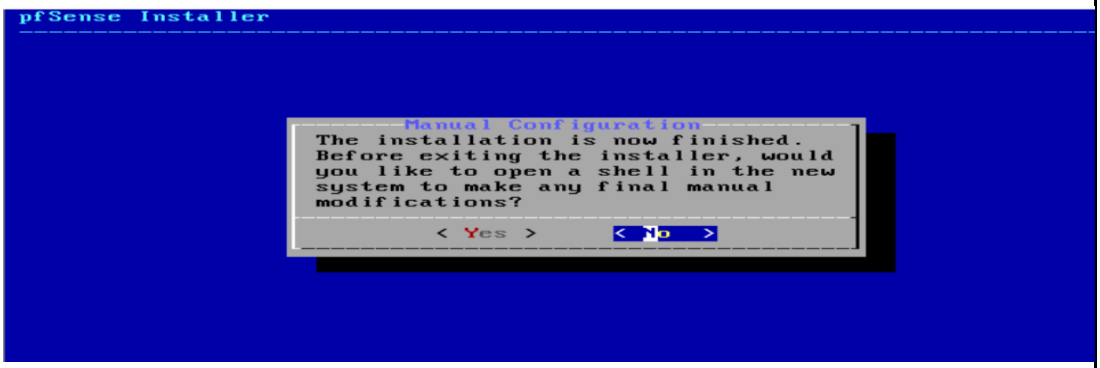
The **Partitioning** step selects the filesystem for the firewall's target disk.



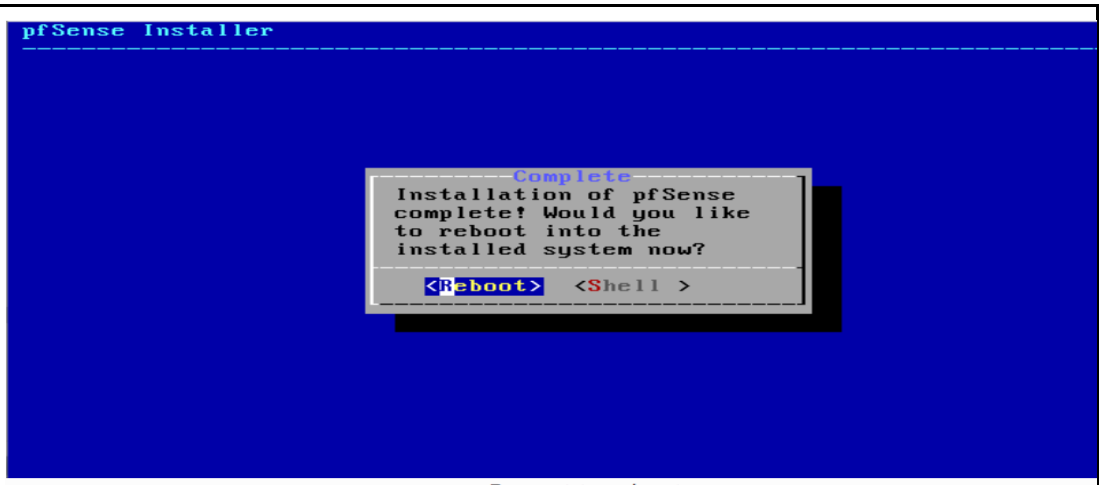
wait, and have a few sips of coffee while the installation process formats the drive(s) and copies pfSense software files to the target disk(s).



Installation is now finished, before exiting the installer, you can open the shell by pressing **"YES"**



Select **Reboot** to restart the firewall



Prompt to reboot

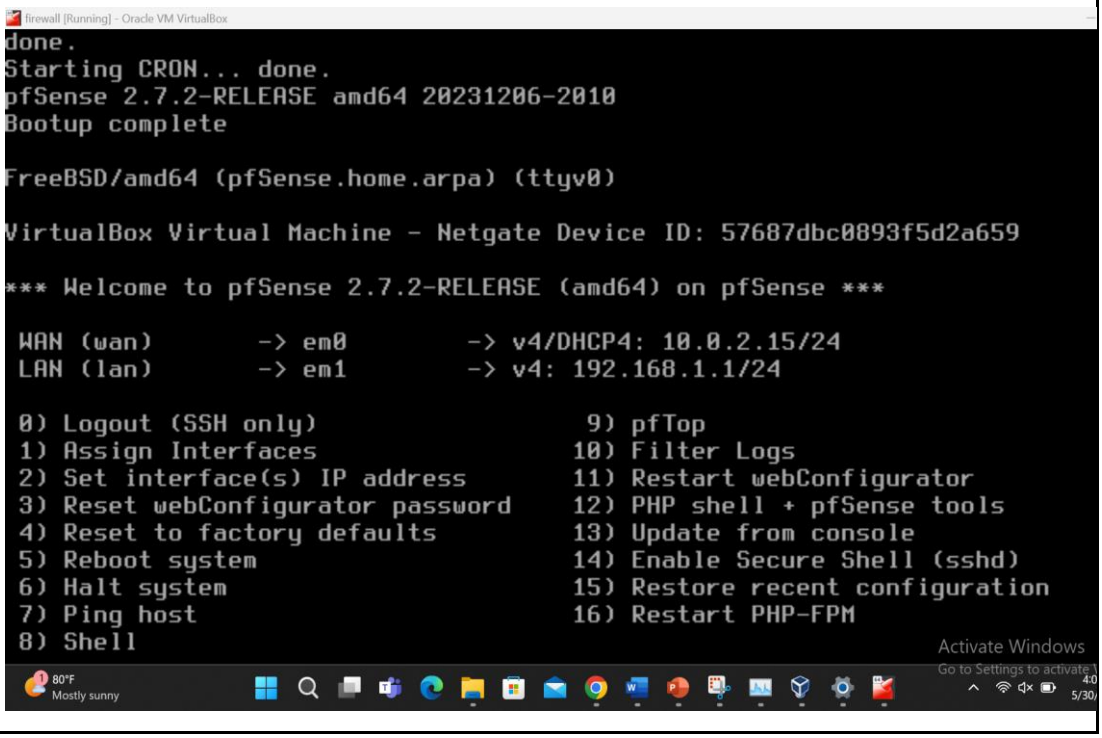
Remove the installation media from the firewall during the reboot, when the hardware is starting back up but before it boots from the disk.

***Congratulations*, the installation is complete**!

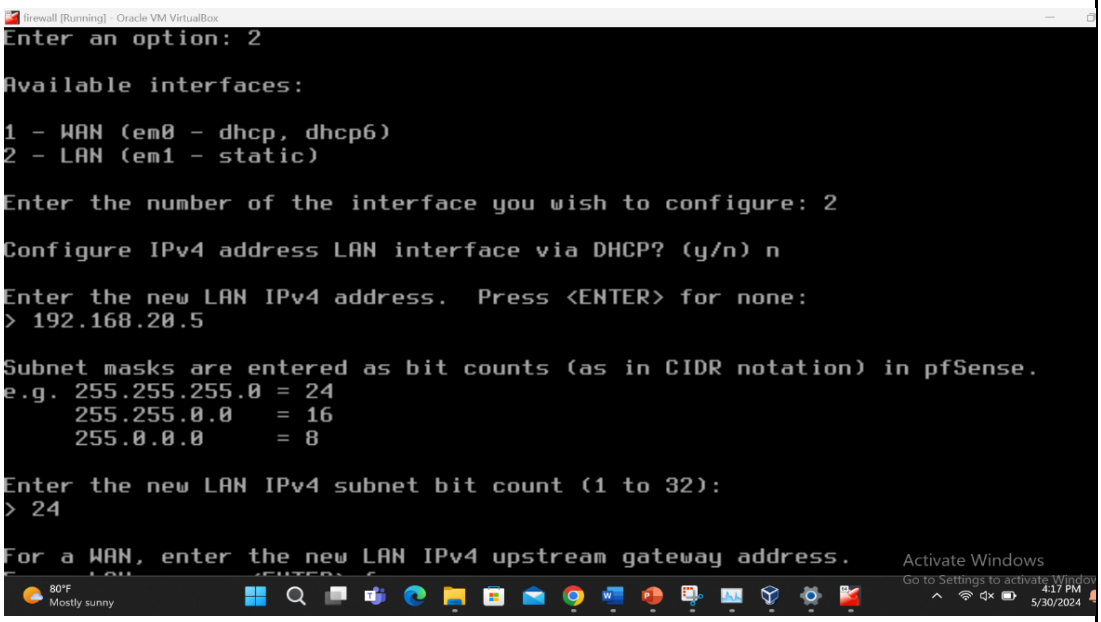
➢ **Configuring pfSense network interfaces using the shell**

Step 1: Boot up your pfSense virtual machine. The Console Menu, you'll see a menu with various options.

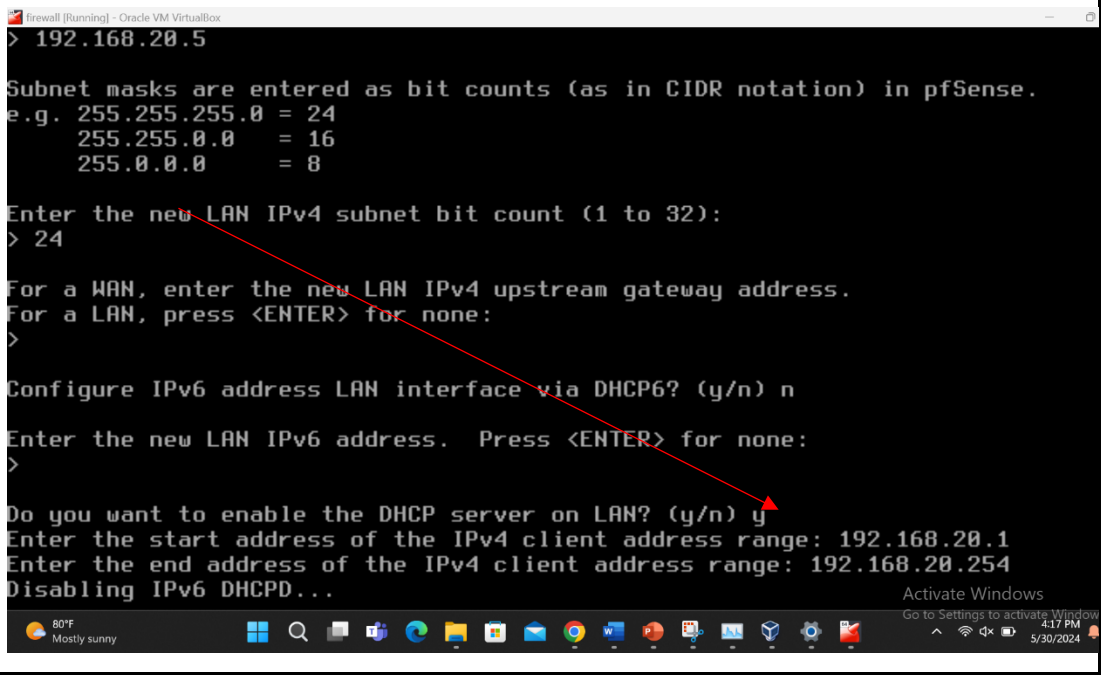
By default, **WAN interface** implies the physical network from the NAT adapter while **LAN interface** implies the internal Network to be shared to the client



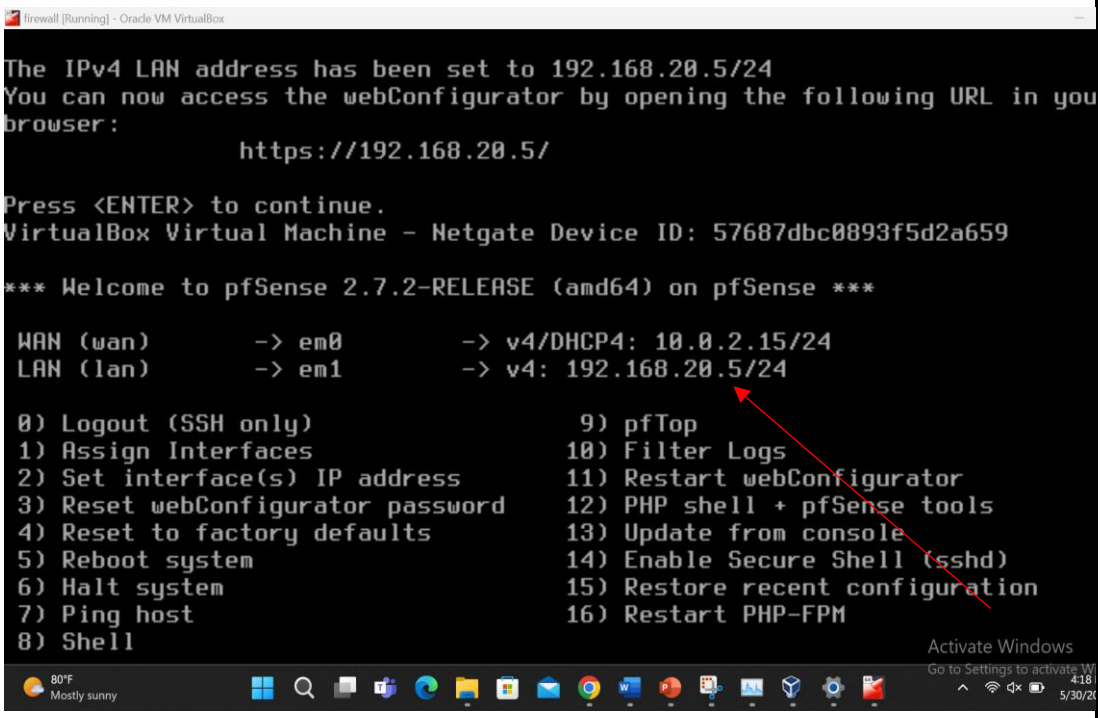
Step 2: Modifying the LAN interface configuration with the actual gateway address provided through the shell with the new address in network address range of (192.168.20.0/24)
Enter option **2** of LAN and don't allow LAN to use DHCP and enter the new LAN IPV4 address let take **192.168.20.5** as the default address on LAN interface, with subnet masks of **/24**.



Step 3: Enabling the DHCP server on LAN by providing the start address and end address based on your network range address (192.168.20.0/24)

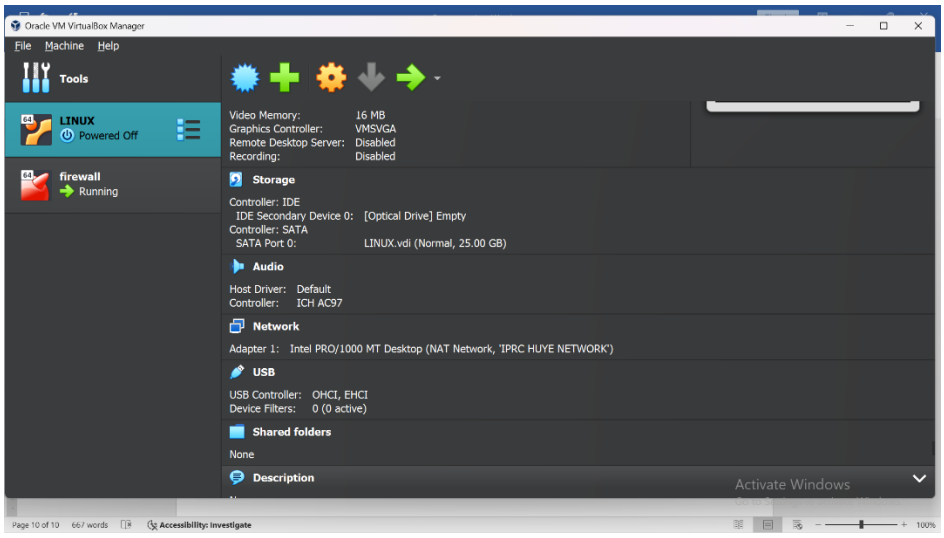


After the configuring the LAN network and DHCP server, the LAN interface had change with the new Ip address (192.168.20.5/24)

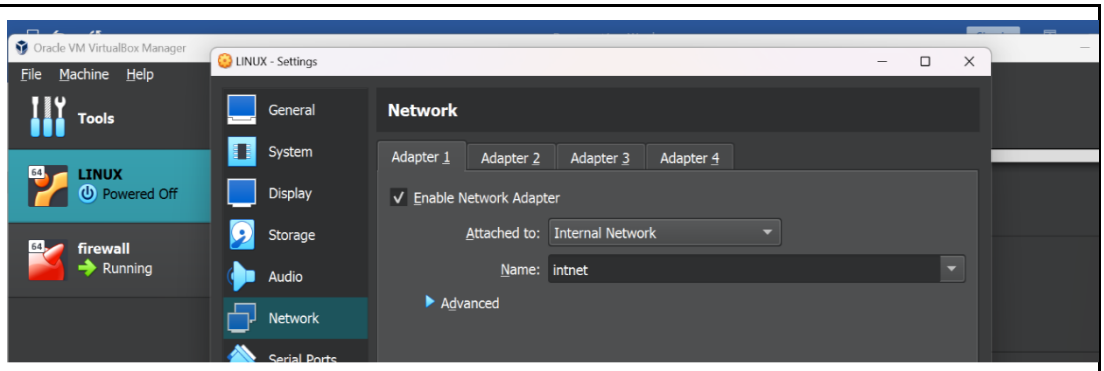


- **Accessing the pfsense using the web interface and making further configuration.**

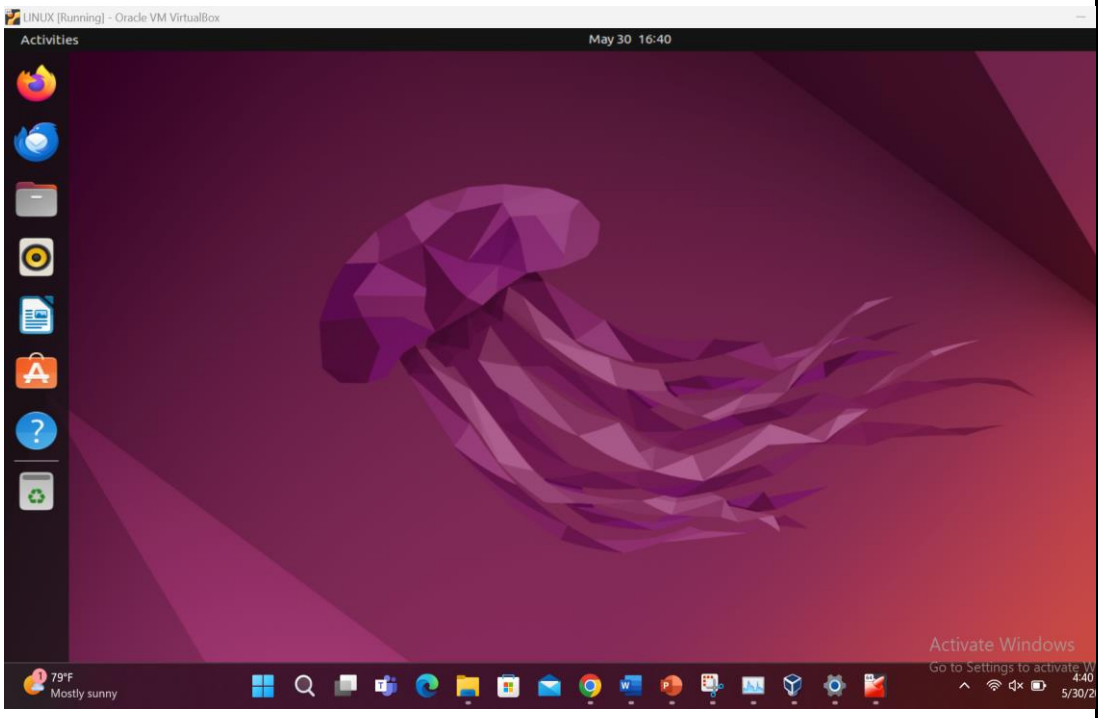
Step 1: create another client machine in your virtual box with any operating system. On our side we are having a virtual machine with UBUNTU linux operating system.



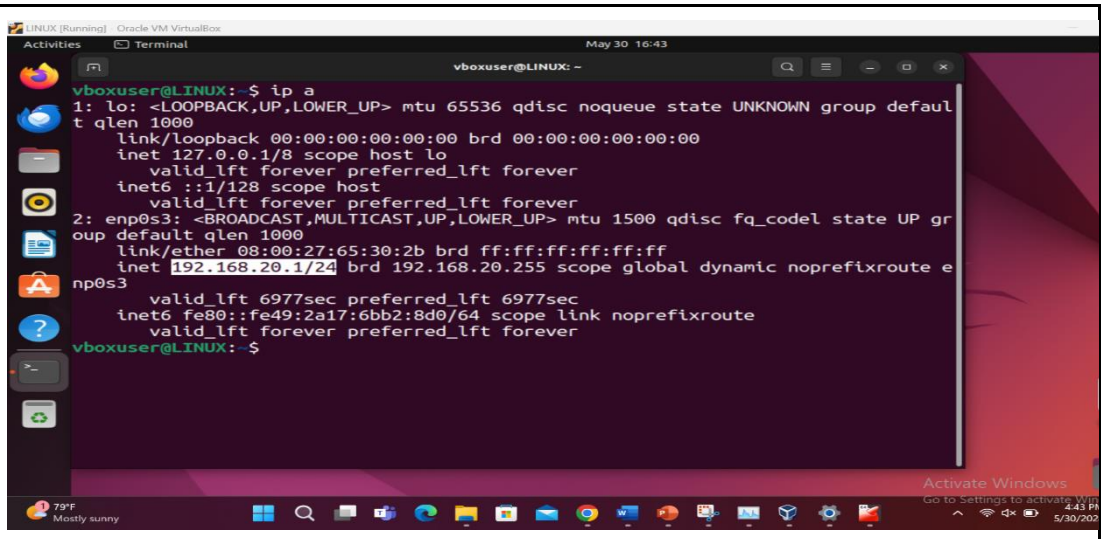
ensure LINUX machine is attached network adapter of "**internal network**" to ensure that is accessing the network from the pfsense firewall.



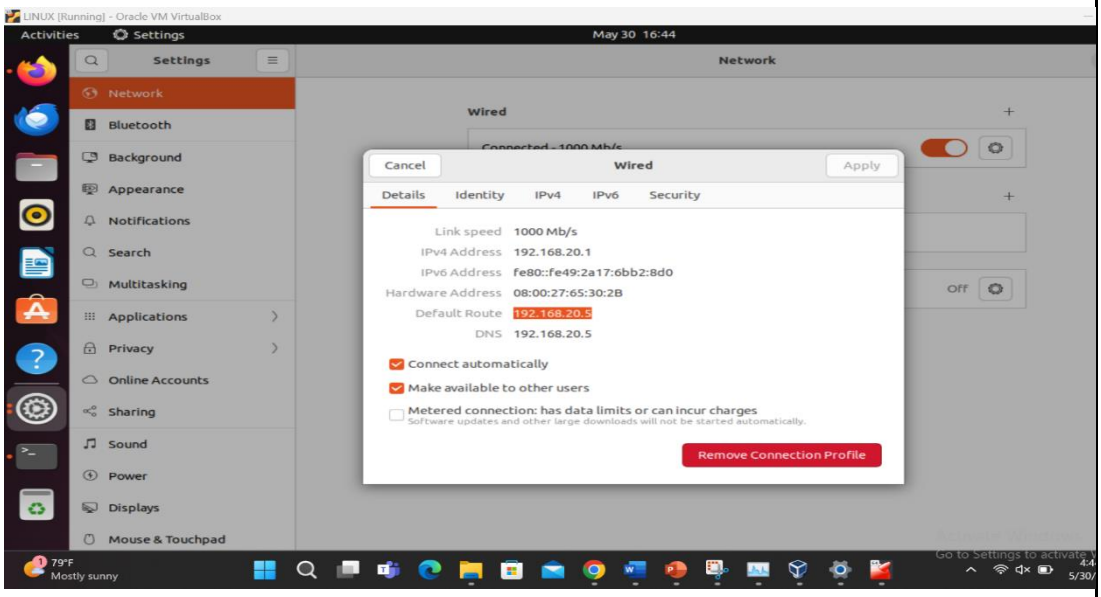
Start your client machine.



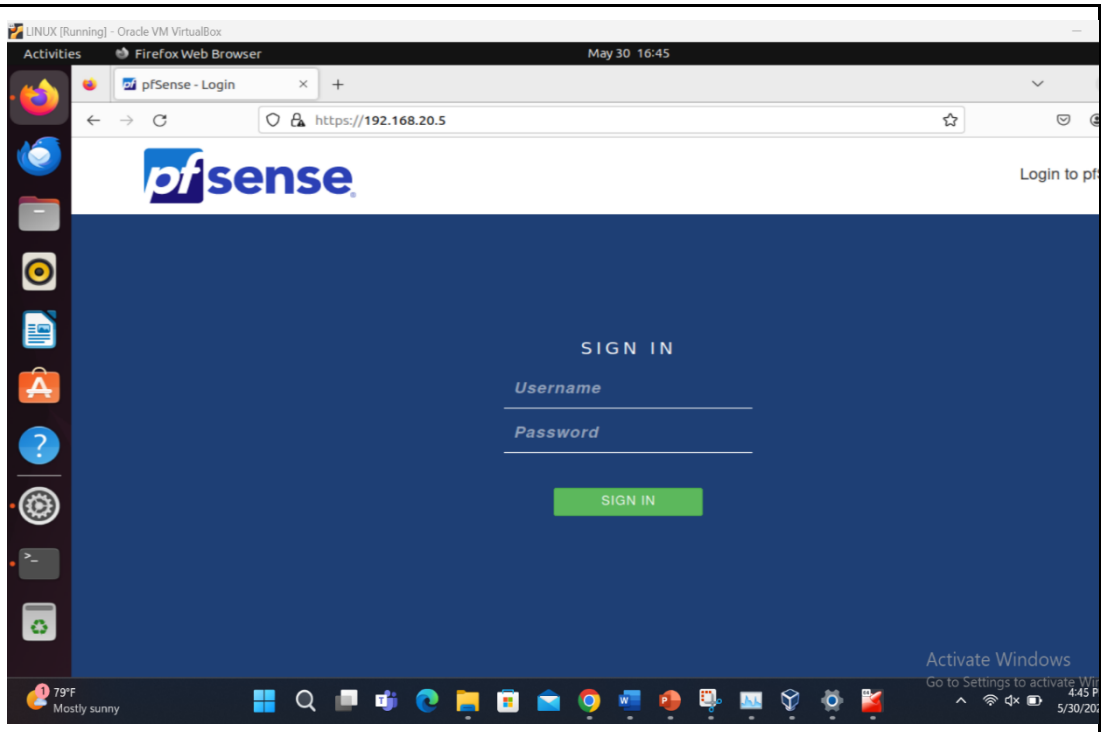
Step 2: Open your terminal and check if your client machine is getting the ip address from the DHCP server of the pfsense firewall. By using (**ip a**) command



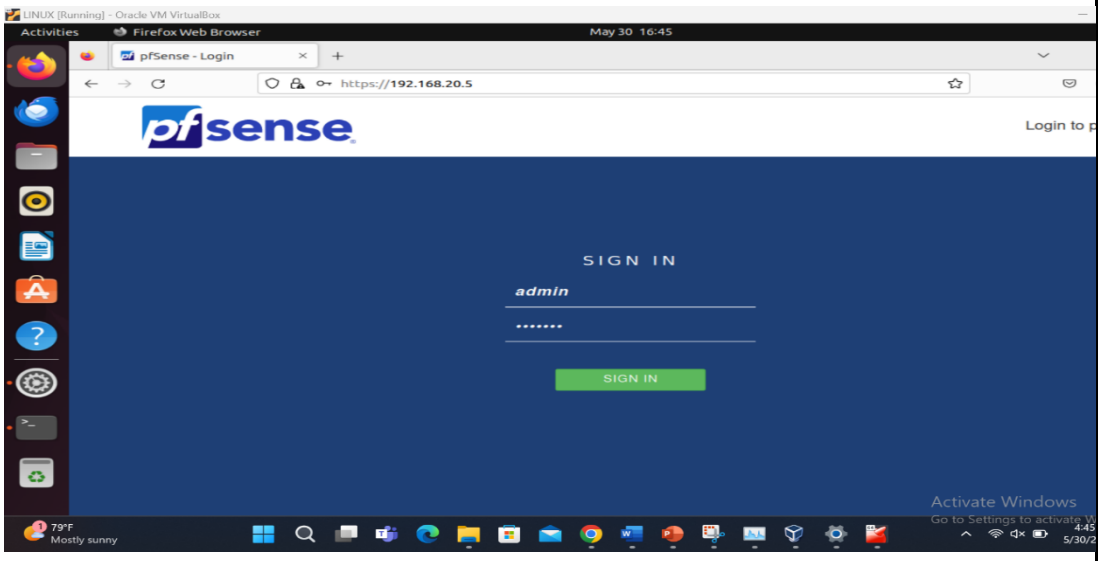
Step 3: Check if your client machine is getting the default route ip of the LAN interface of pfsense firewall. Go to setting, check for "**network**" section and expand wired interface to see the default route if is the same to the pfsense firewall LAN interface.



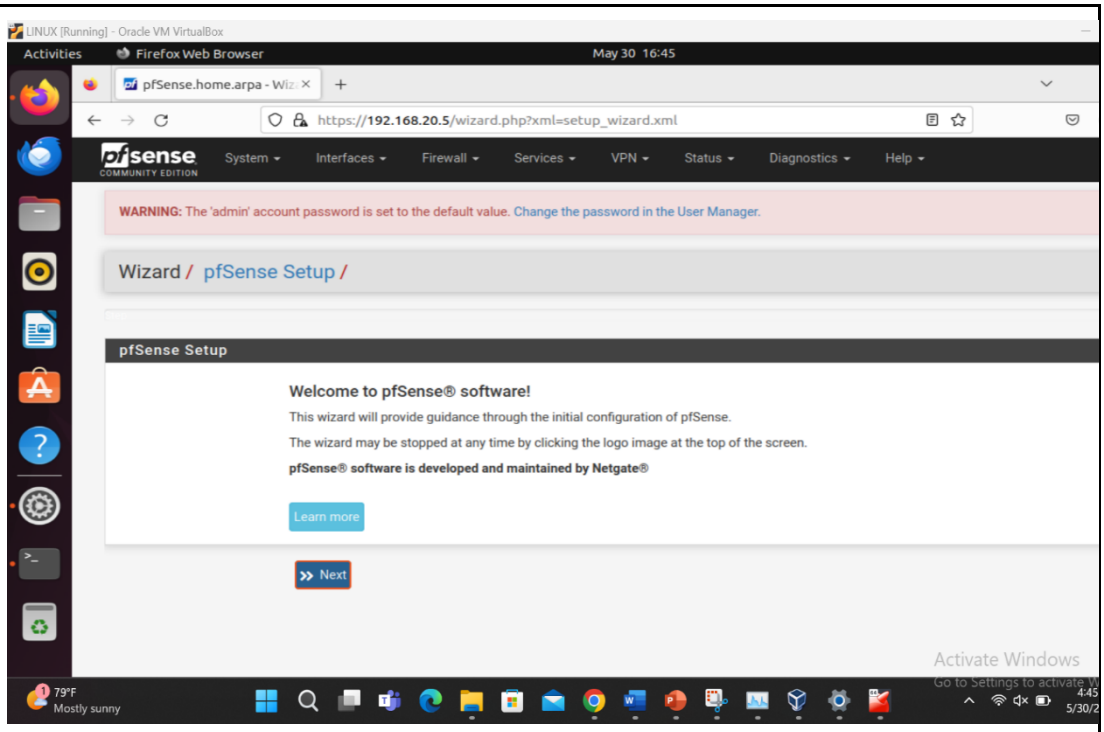
Step 4: open any browser and access the pfsense by using the default route ip(**192.168.20.5**) in the URL.



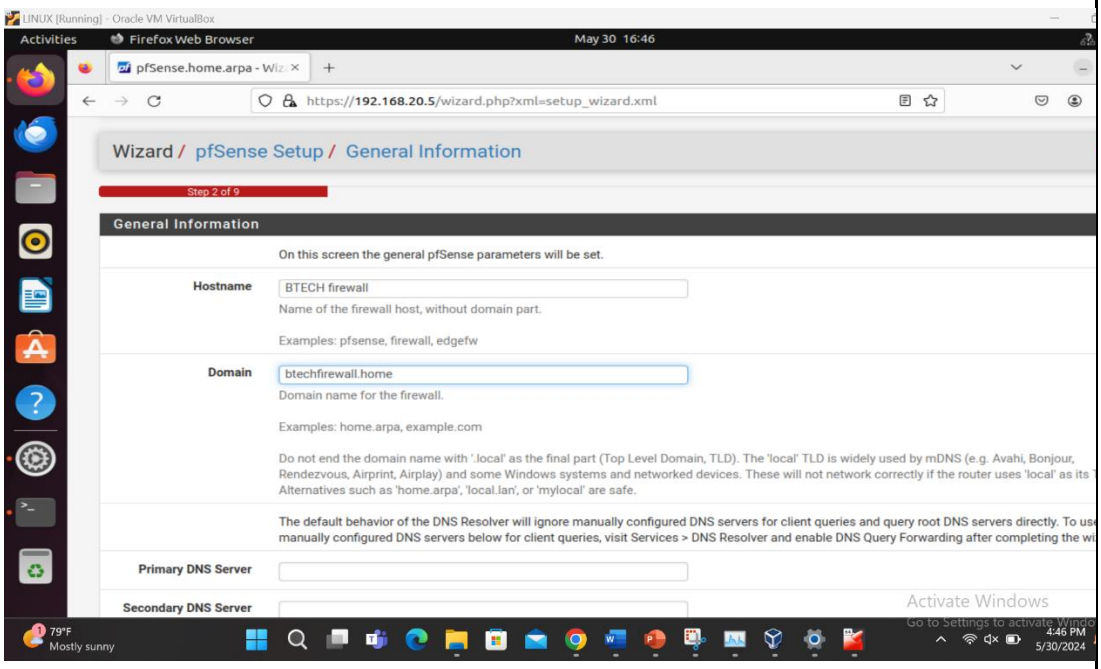
Use username as **Admin** and password as **pfsense** for signing in.



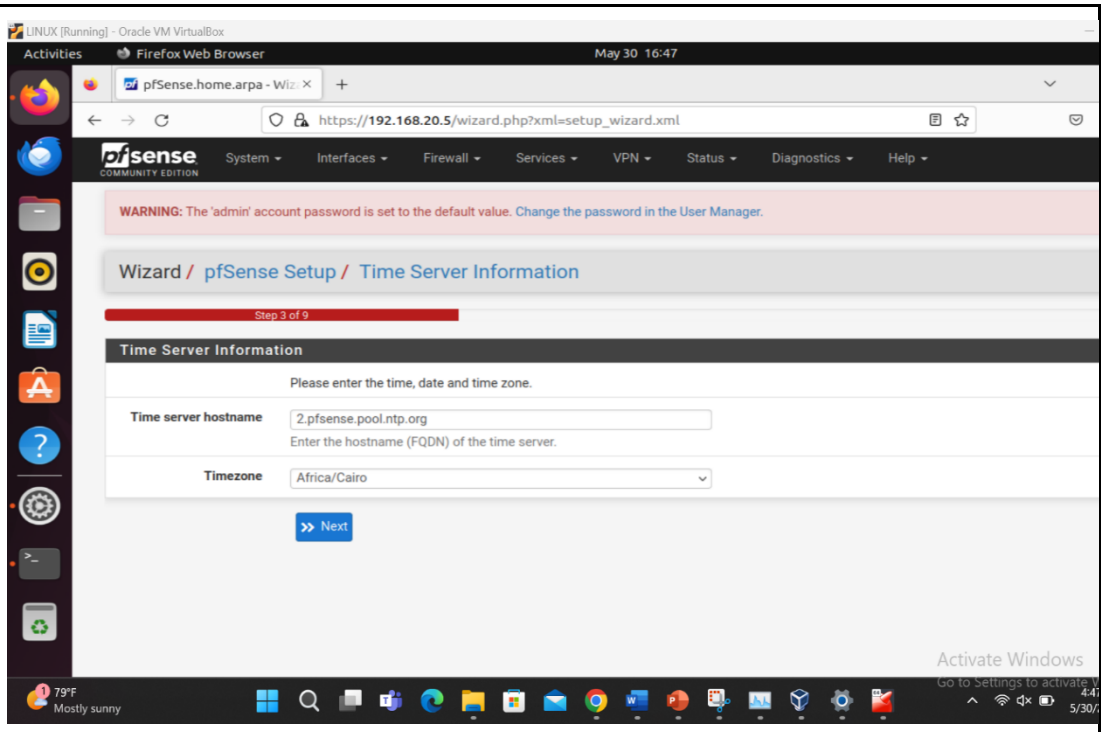
Welcome to the pfsense software ,its time to start setting up the pfsense



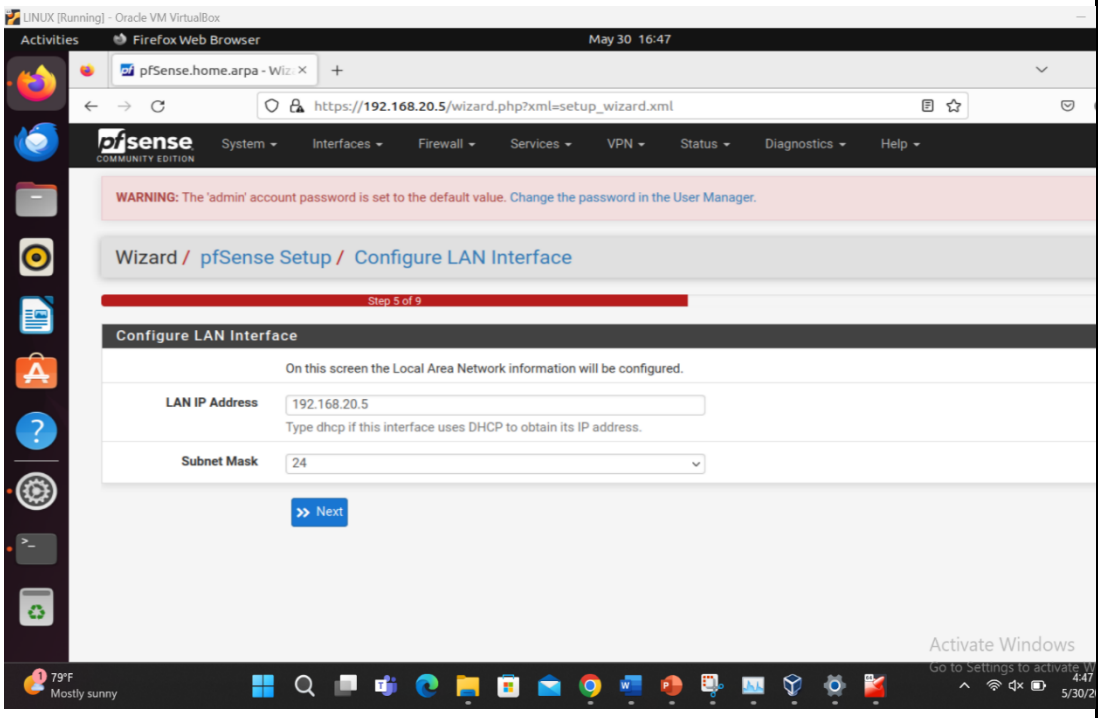
Step 5: click next, and set the hostname of your firewall by "**BTECHFIREWALL"** and set the domain name as **"btechfirewall.home"** as follow and click next.



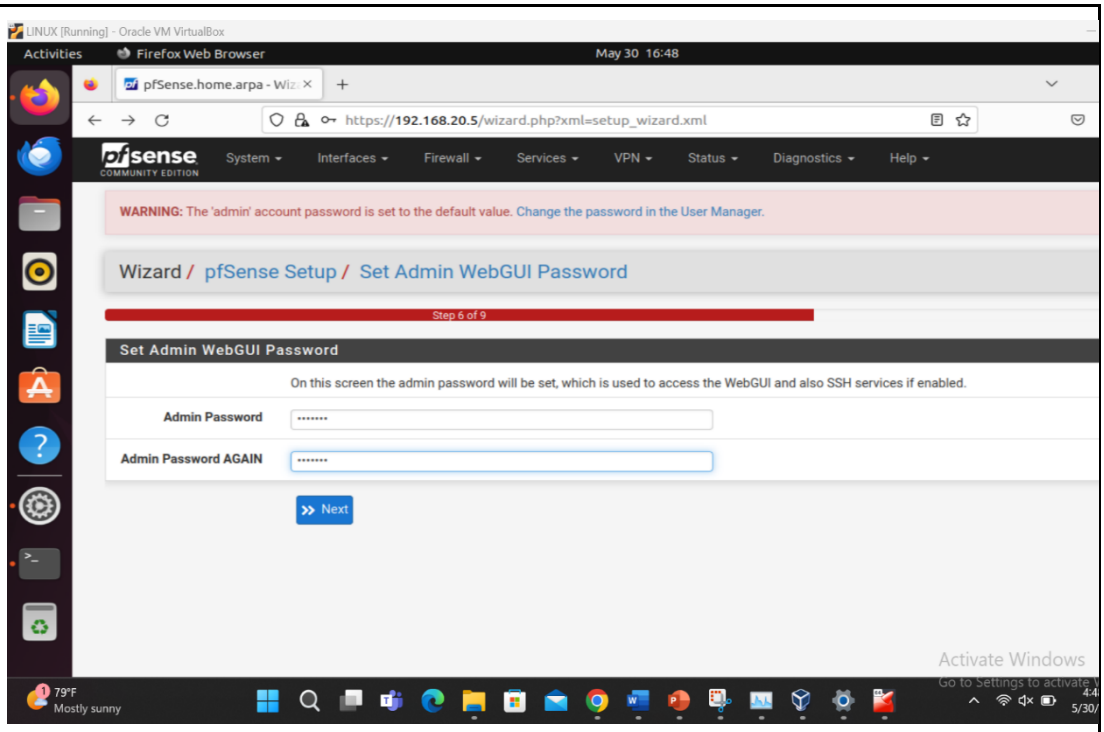
Step 6: set the timezone of your firewall as **Africa/cairo,** and click next



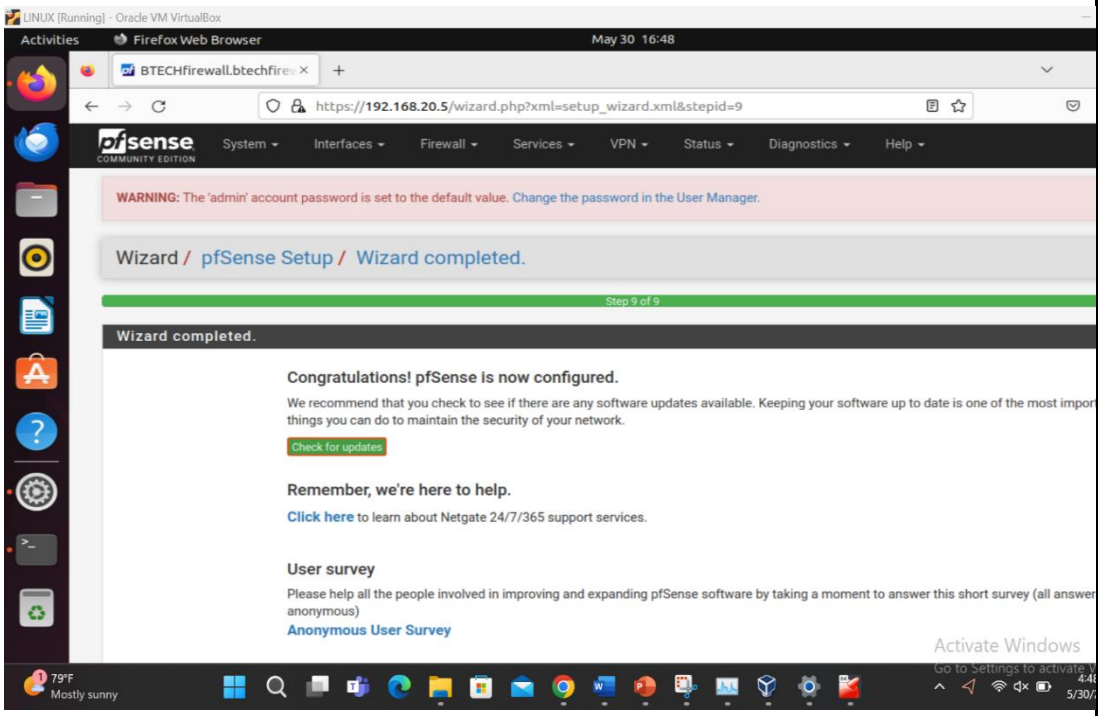
Step 7: set LAN interface IP and the subnet mask or leave it's as the default form the pfsense**,** and click next



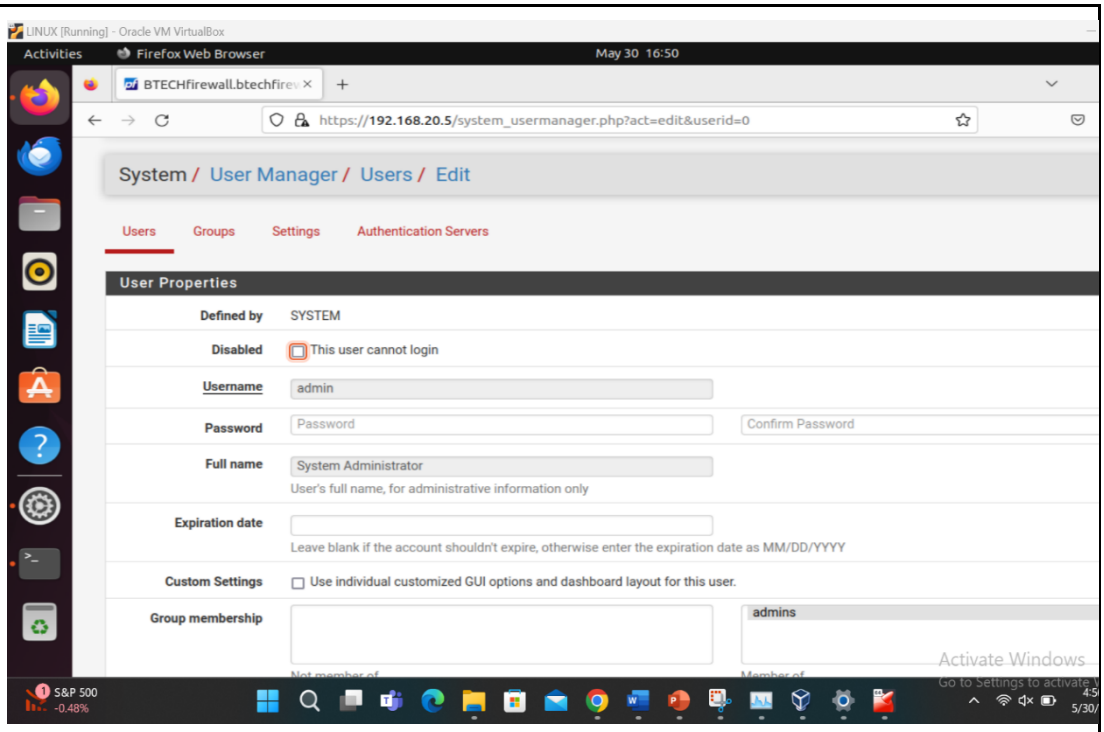
Step 8: set the Admin password to confirm the pfsense configuration**,** and click next



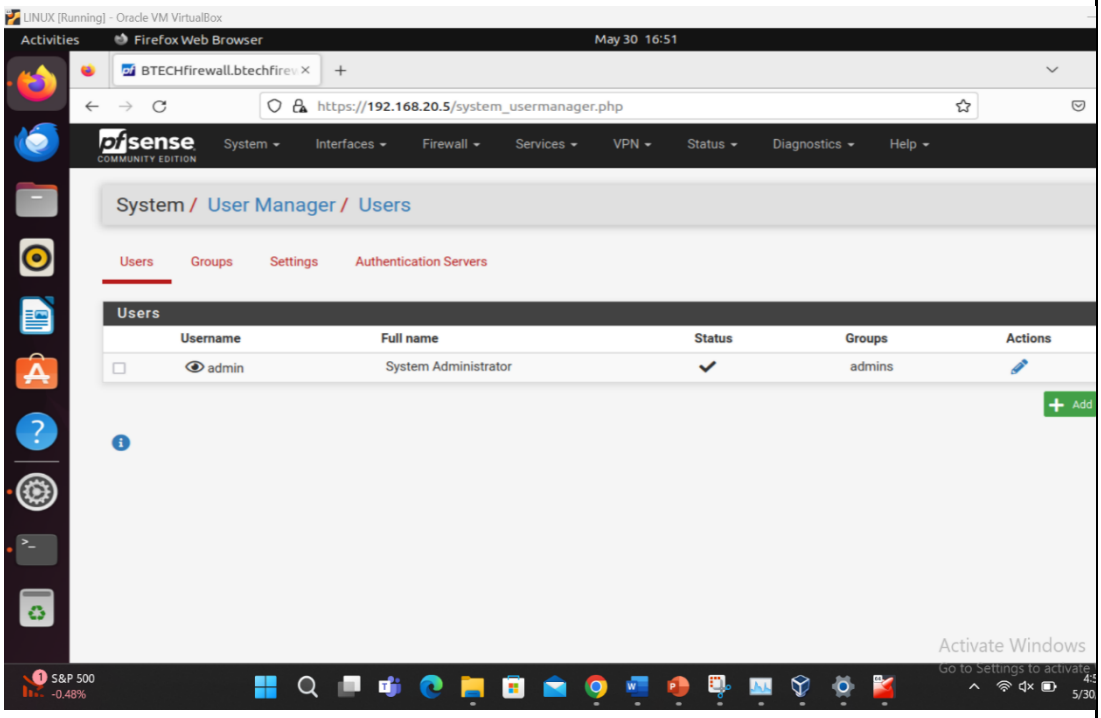
Pfsense wizard is now configured successfully, but the admin account password is needed to be changed from the default.



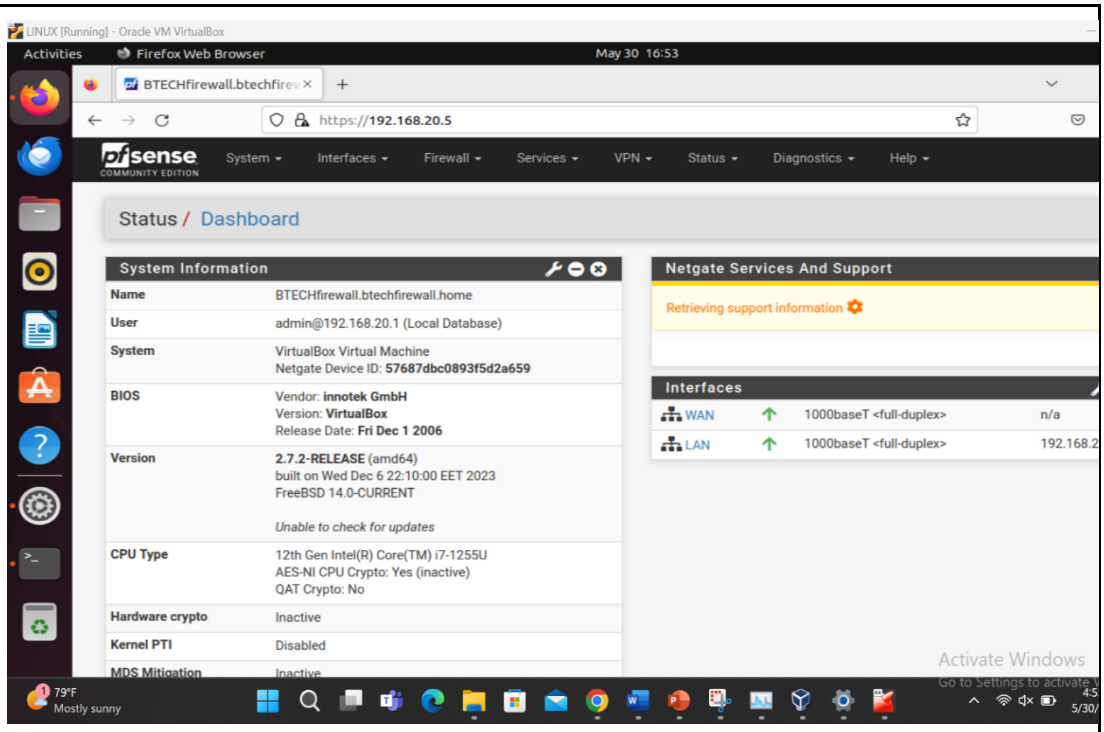
Step 9: by clicking on change the password, set the Admin new password and click next



Admin password successfully updated.

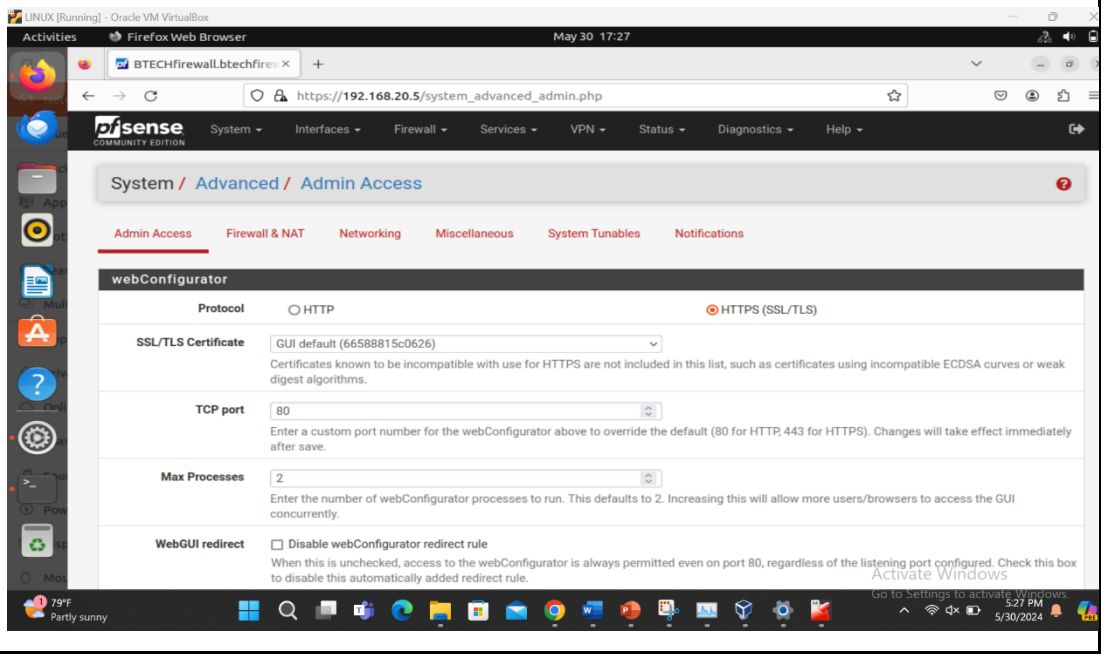


Click on pfsense logo to view the pfsense dashoard.

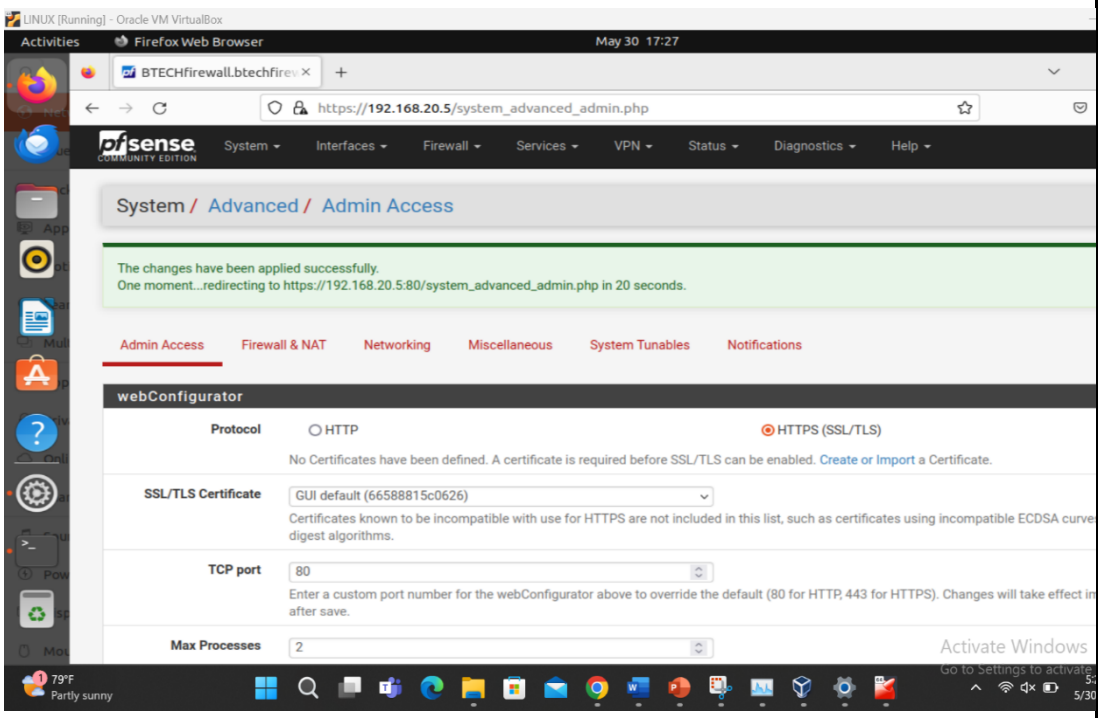


➢ **Configuring the TCP port as the customer port number for the web configurator.**

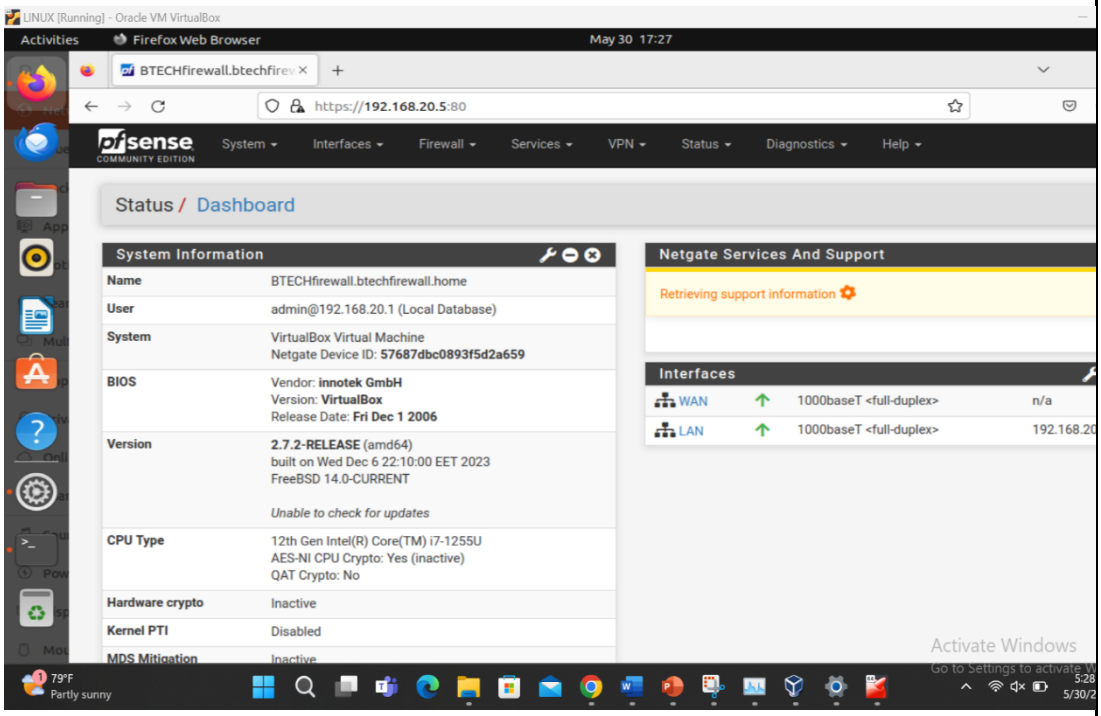
Go to the **system** tab click on **Advanced** sub-tab. Change the TCP port to 80



The changes have been applied successfully.



The new URL will be **(192.168.20.5:80)**



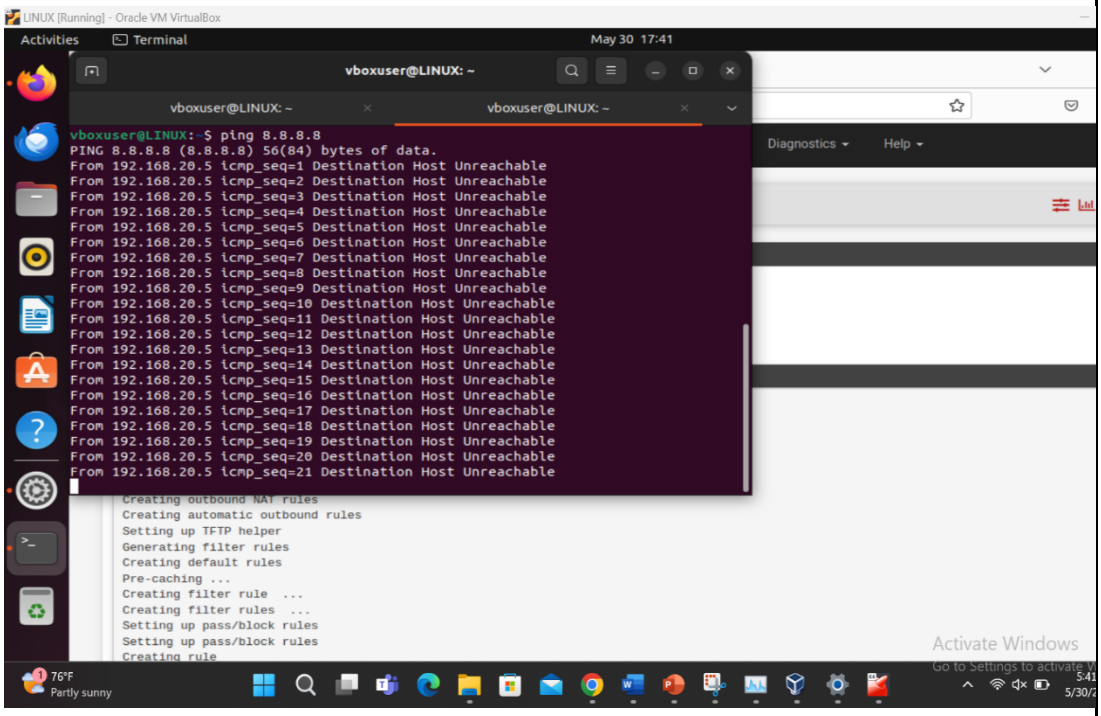
- **Applying different rules in pfsense on LAN interfaces.**

  - each rule is a set of an indicator icons, including:
  - pass (fa-check): allow traffic

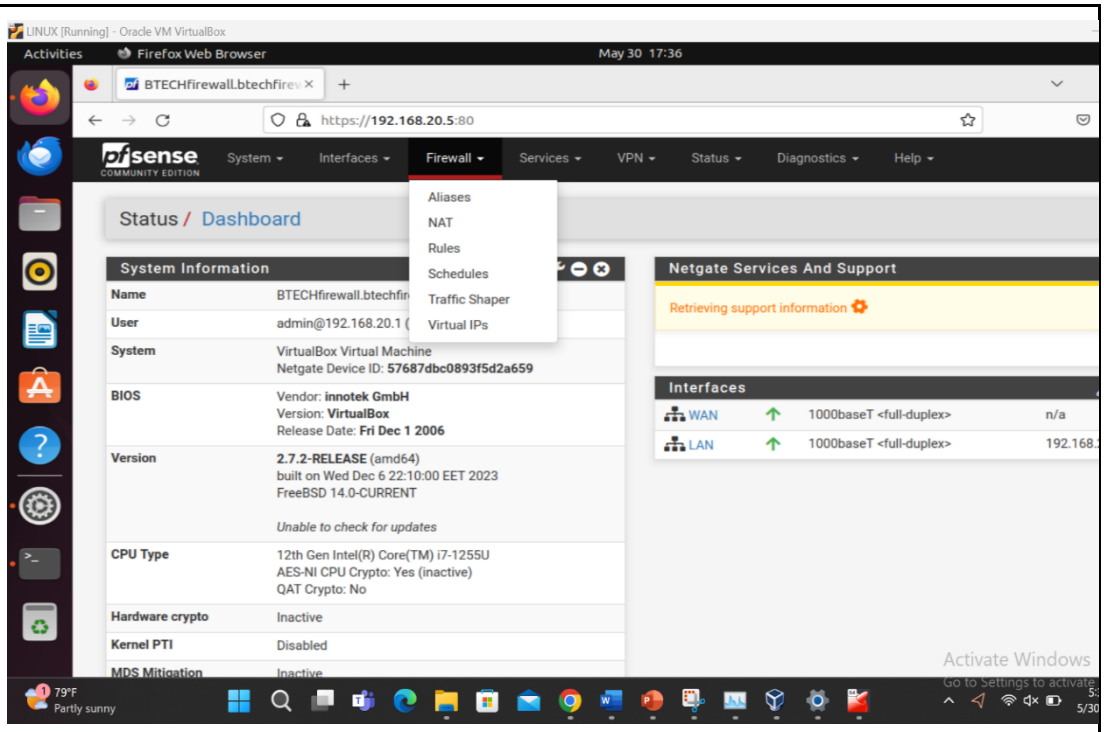
- block (fa-times): deny traffic and don't let the client know it has been dropped.
- reject (fa-hand): deny traffic and let the client know about it

- **rejecting the client for using the ping command to test connectivity between two devices on a network.**

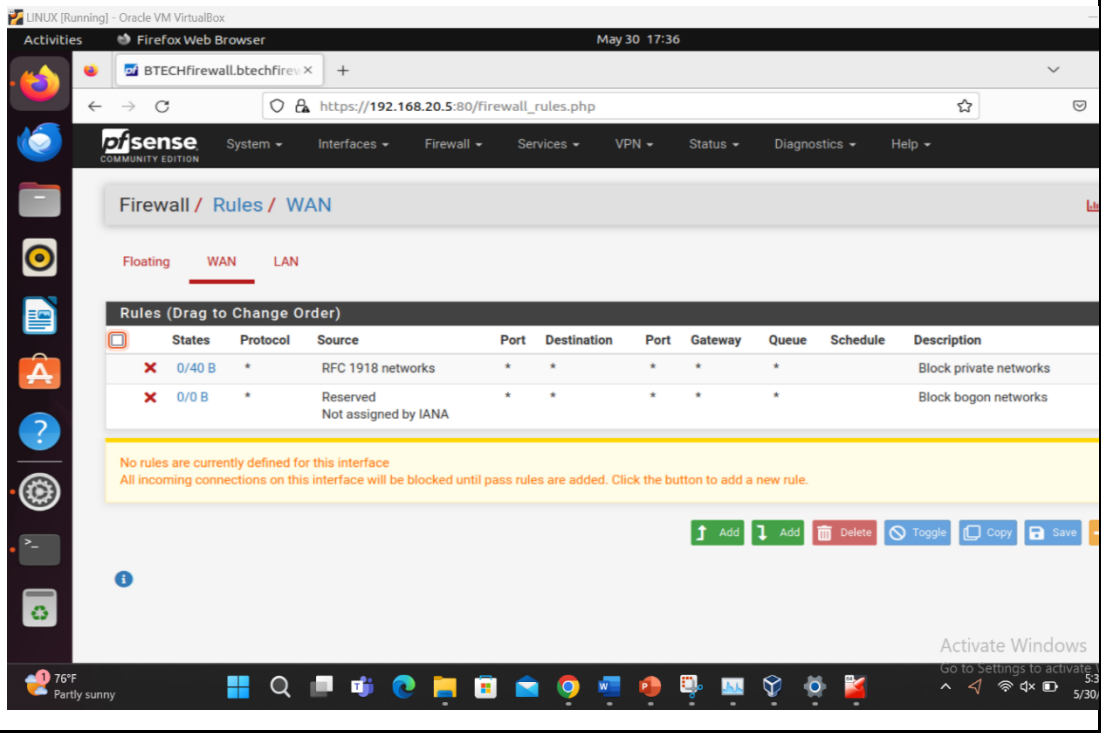
Before setting this rules lets check if the ping services are working properly. By opening the terminal and ping the google address by using **ping 8.8.8.8** command. And as we see below:



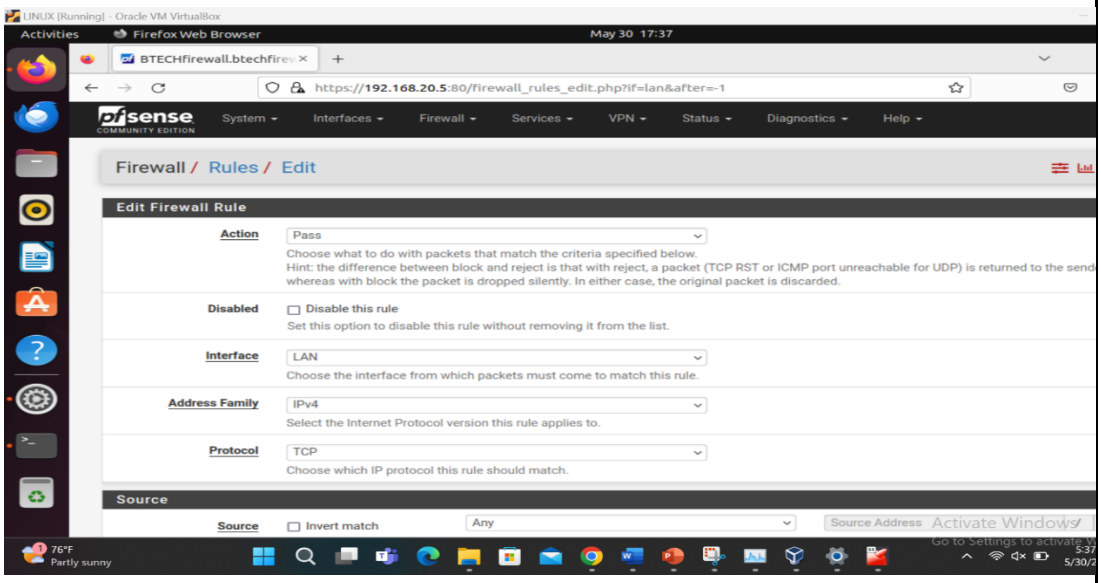
Go to the **Firewall** tab click on **Rules** sub-tab



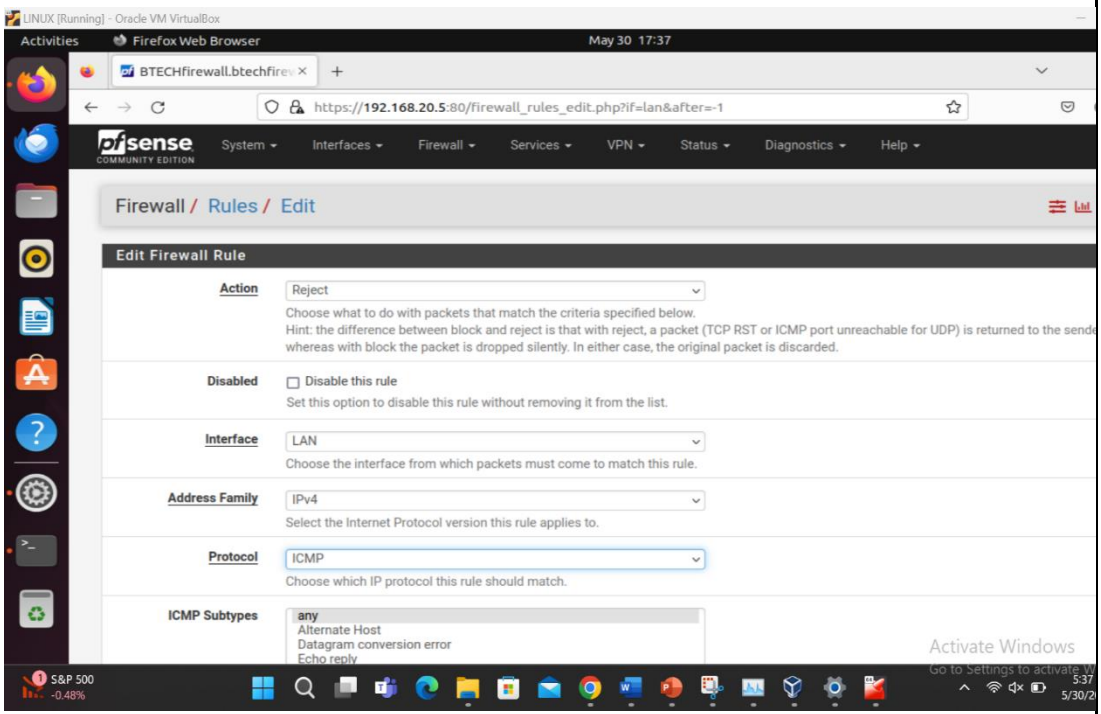
Go to the **LAN** interface



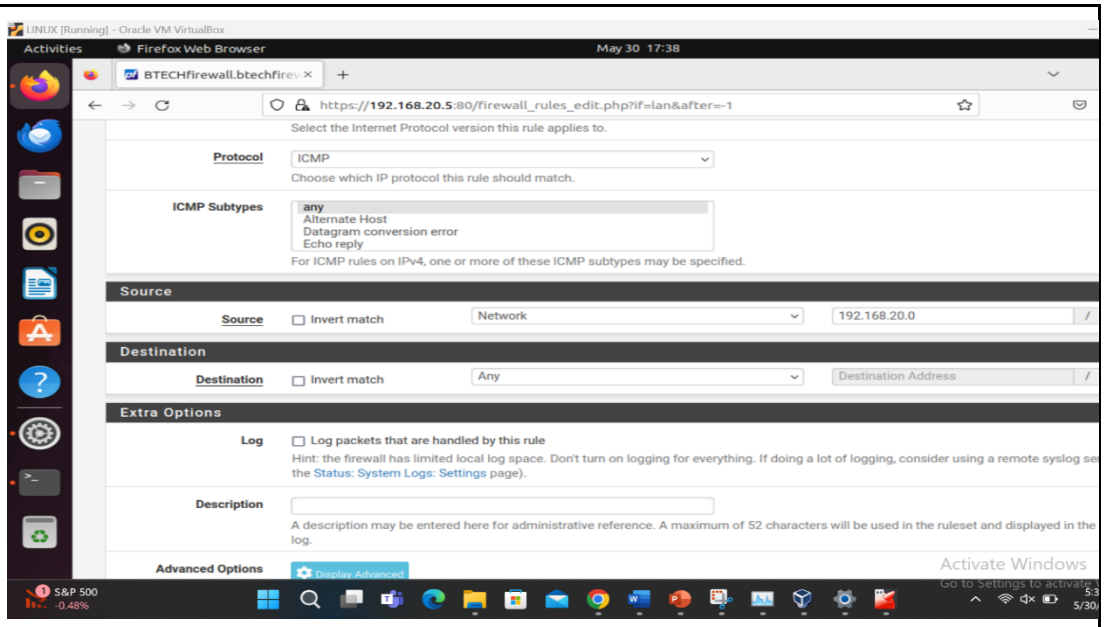
Go to the **Firewall** tab click on **Rules** sub-tab



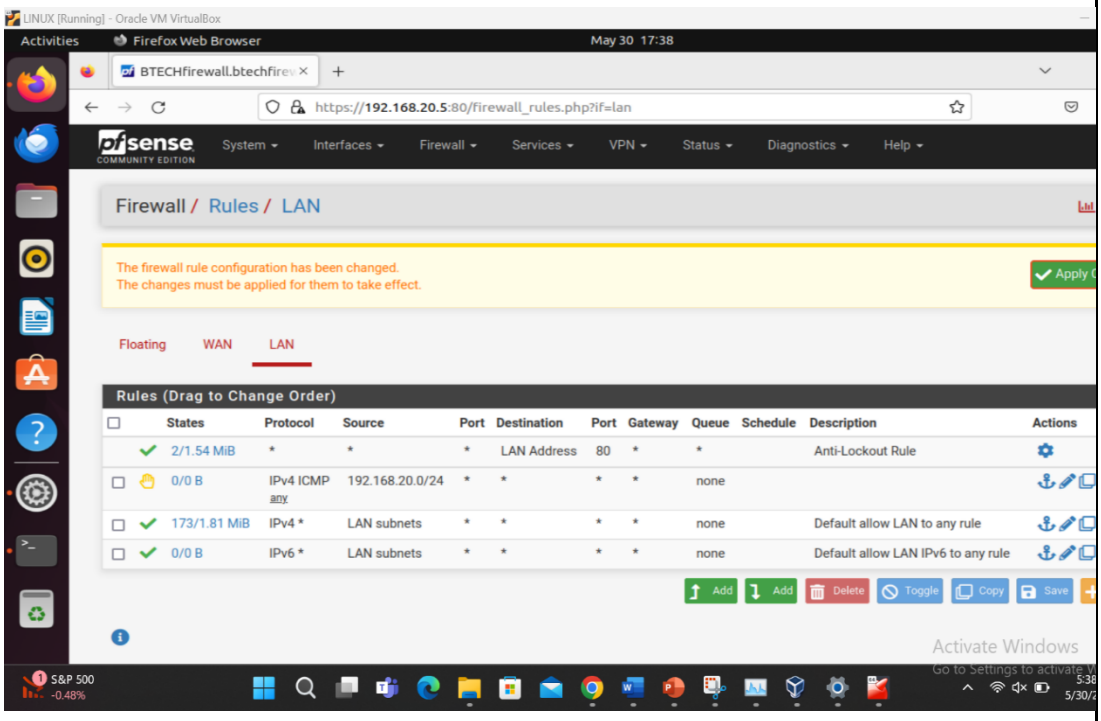
Change the **pass** action to **reject,** and also select the **ICMP** protocol as the protocol that provide the ping services.



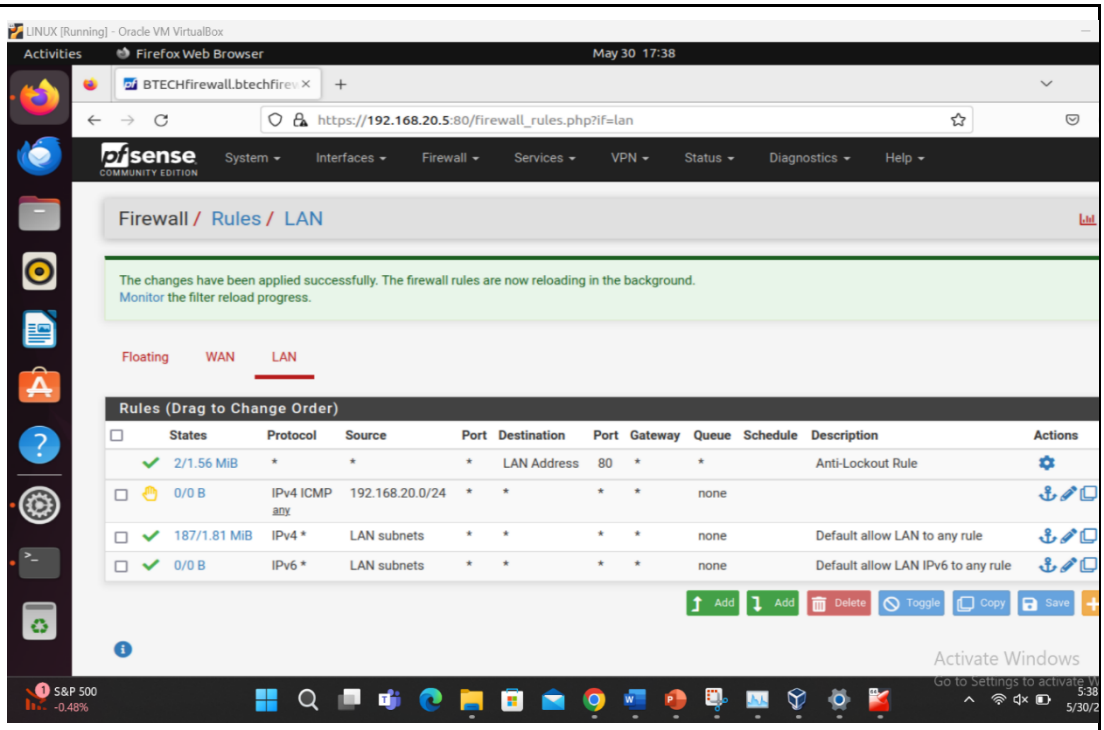
Because we need to reject the entire network, Set the source address as **192.168.20.0/24** , and destination to **any** destination. Save the rule



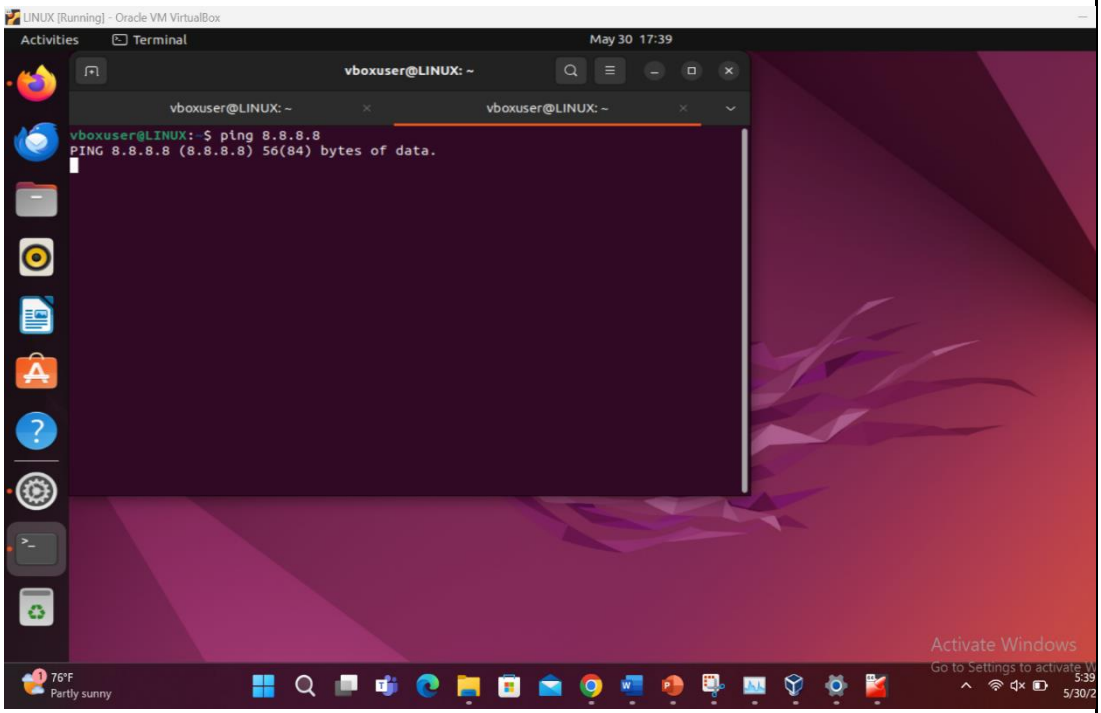
Apply changes to the firewall rule configuration, to allow its to take effect on the system



The changes have been applied successfully , and the firewall are now reloading in the background.



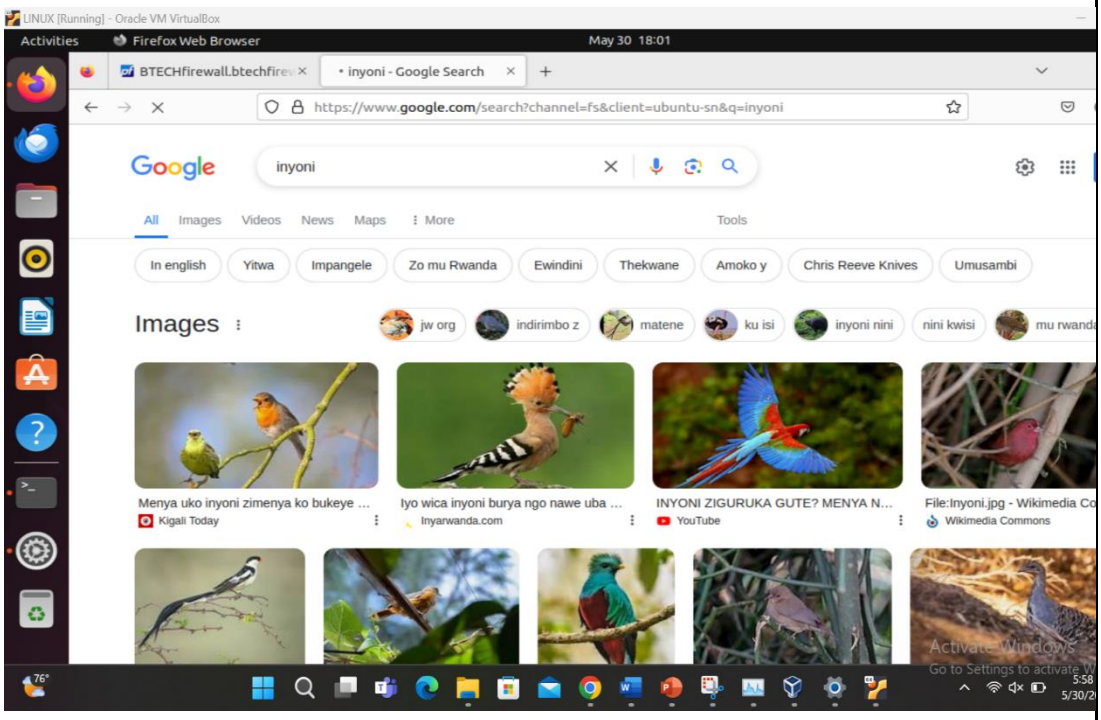
Verifying , if the rules had been working properly as we set. Ping back again the google address and we see if its not working.



1. Rejecting the client for using the HTTP and HTTPS protocol while the client is browsing anything in the browsers on a network.

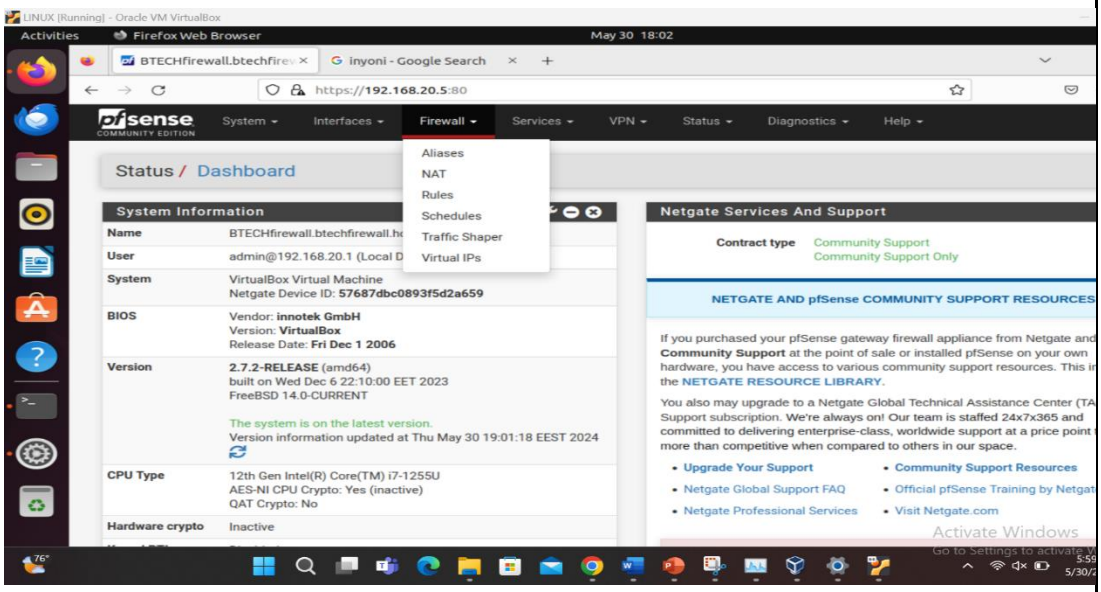
1. Blocking HTTP(80)

Step 1: Before setting this rules lets check if the HTTP and HTTPS services are working properly. By opening any browser and search anything on google . And as we see below is working:

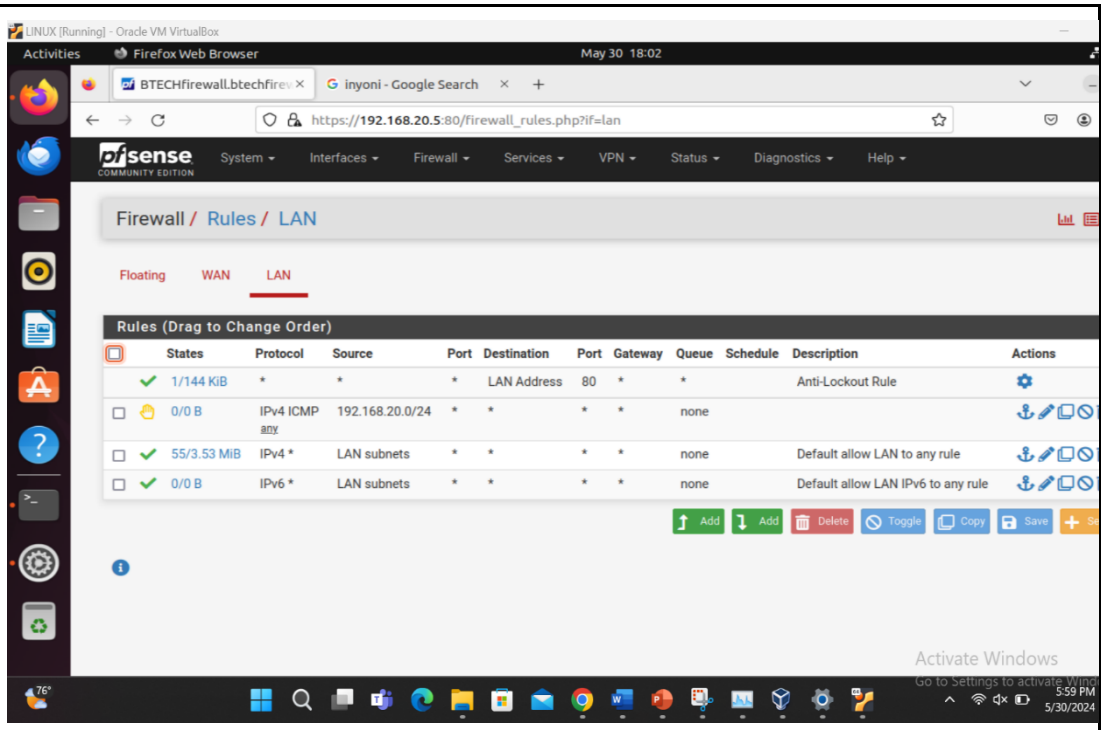


Let block the HTTP protocol first , where the client is not allowed to use it.

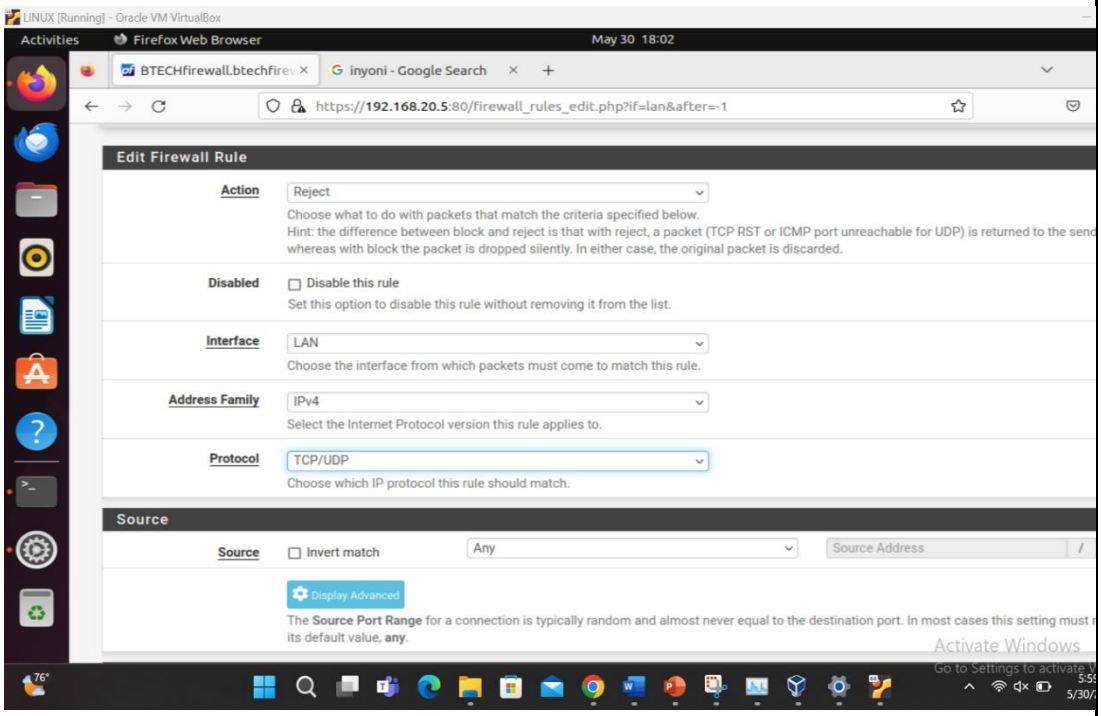
Step 2: Go to the **Firewall** tab click on **Rules** sub-tab



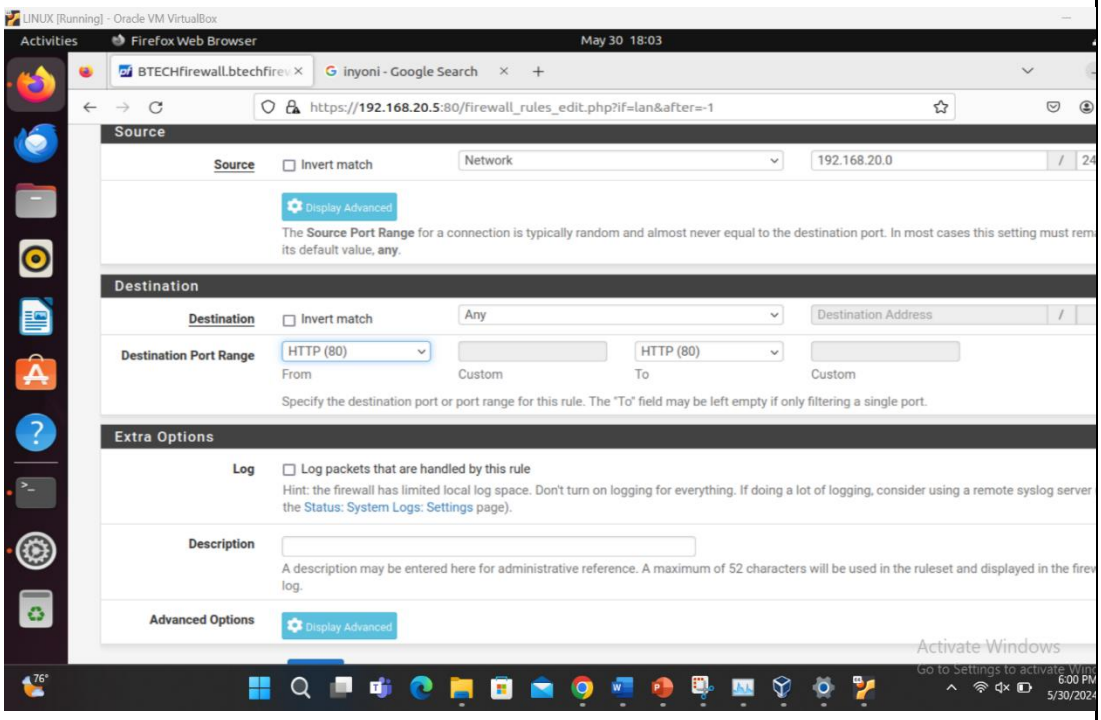
Step 3: Choose the **LAN** interface and **add** the new rules



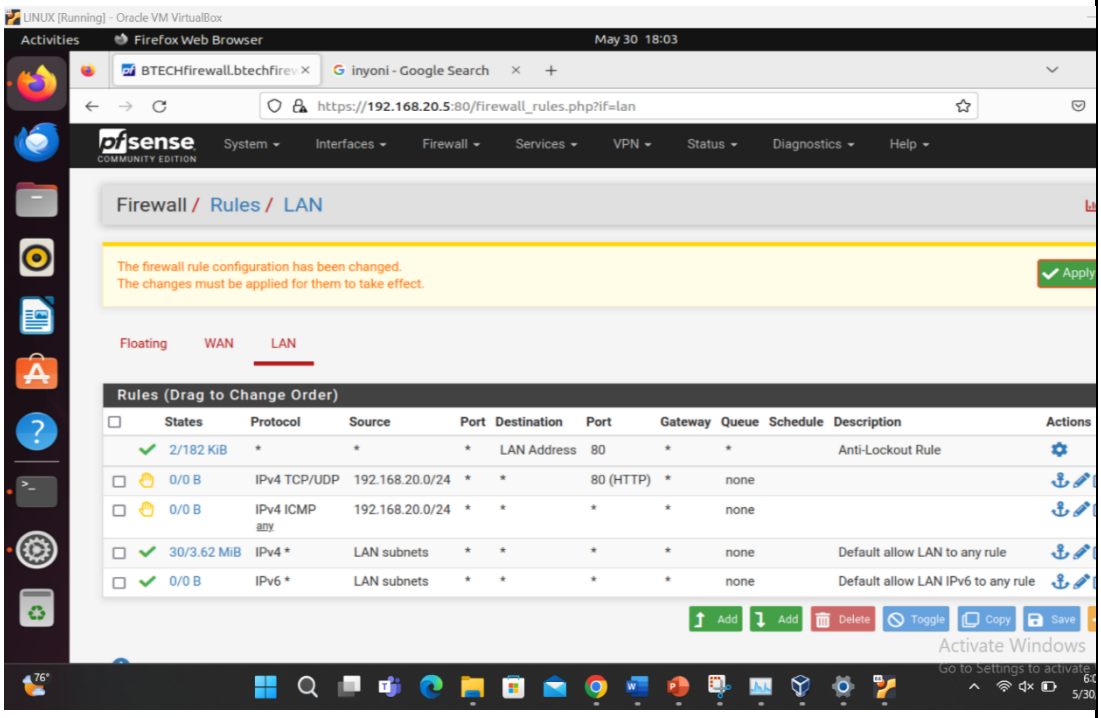
Step 4: Change the **pass** action to **reject,** and also select the **TCP/UDP** protocol as the protocol that provide the HTTP and HTTPS services.



Because we need to block the entire network, Set the source address as **192.168.20.0/24** , and destination to **any** destination. And set the destination port range to **HTTP(80)** , after Save the rule



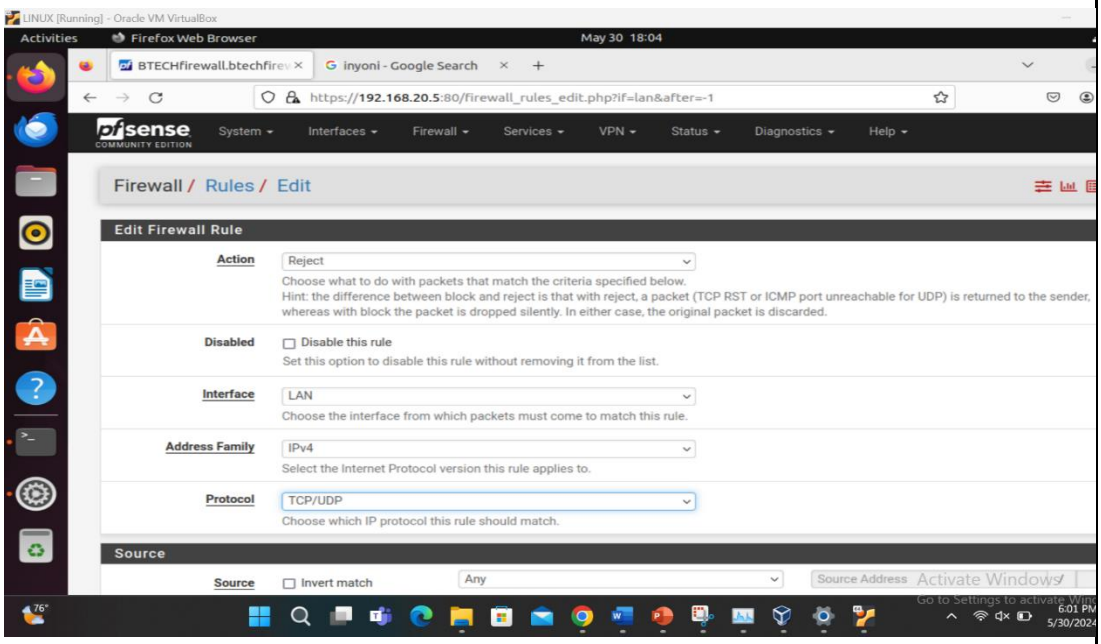
Step5: Apply changes to the firewall rule configuration, to allow its to take effect on the system



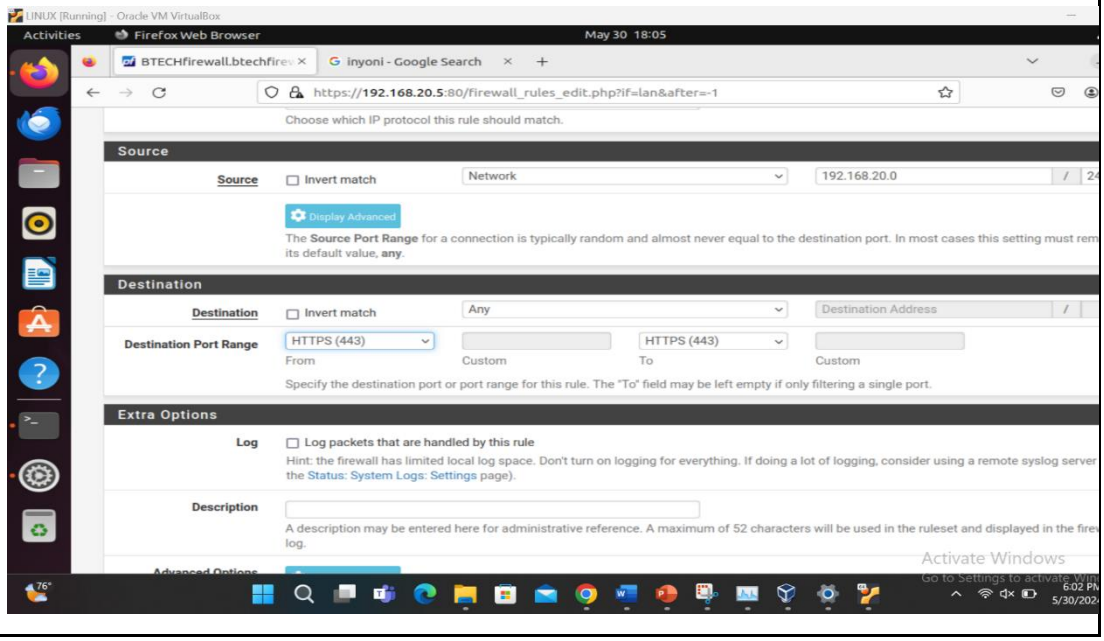
2. Blocking HTTPS(443)

Let block the HTTPS protocol first , where the client is not allowed to use it.

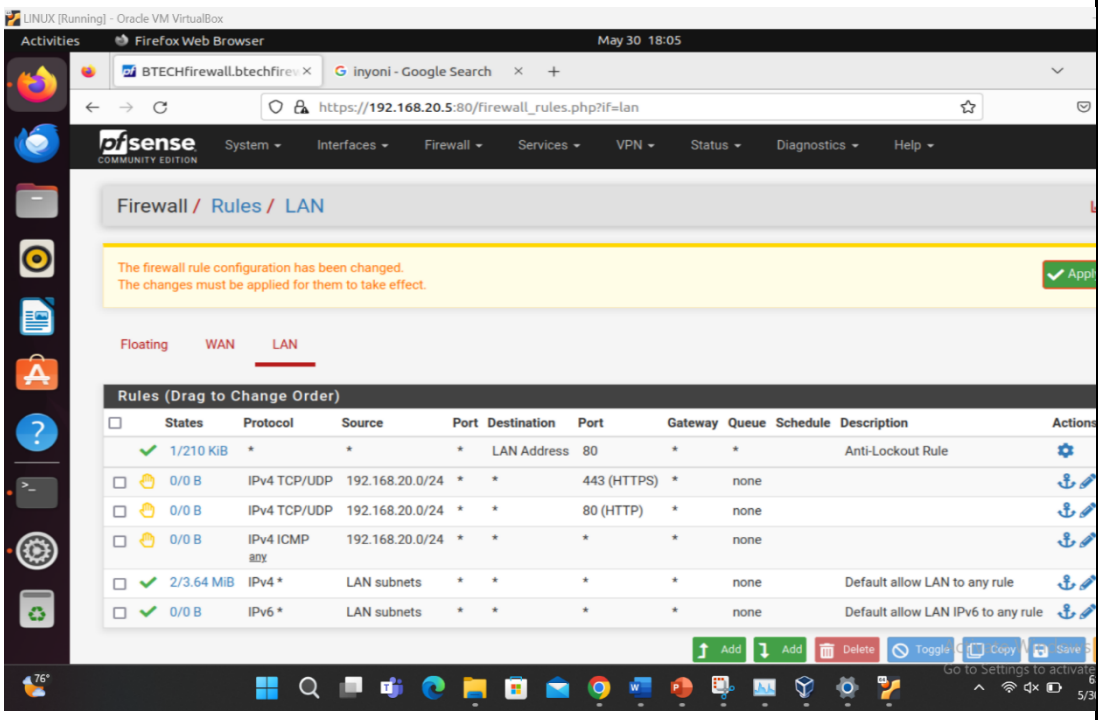
Go to the **Firewall** tab click on **Rules** sub-tab on the **LAN** interfaces **add** a new rules



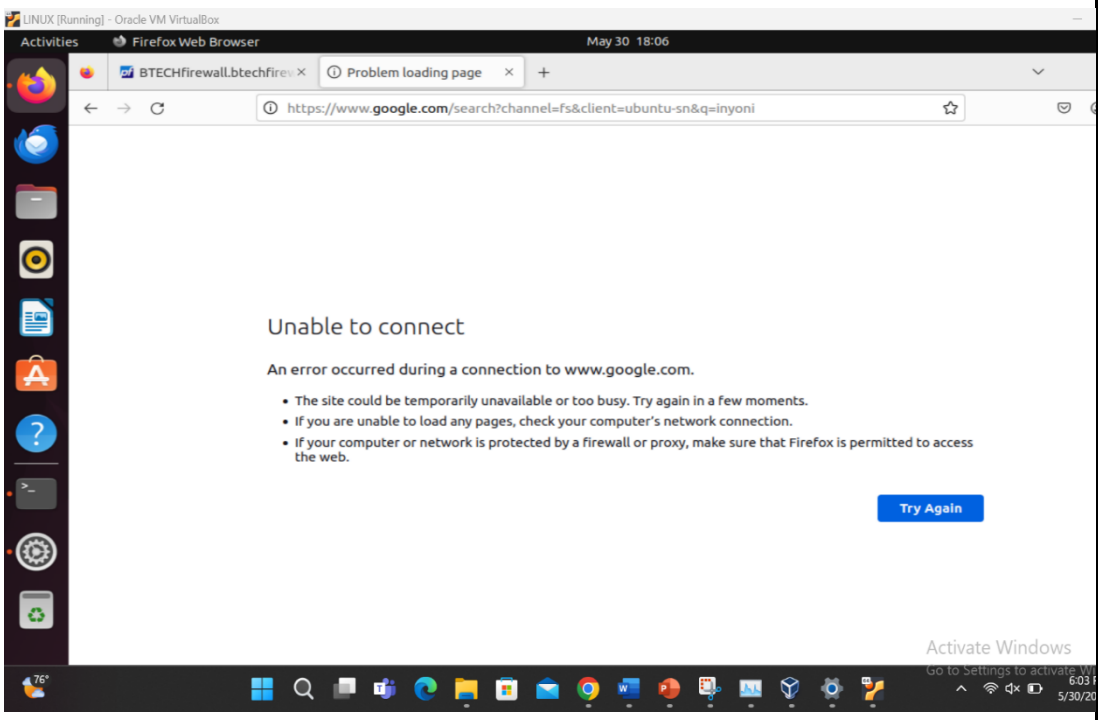
Because we need to block the entire network, Set the source address as **192.168.20.0/24** , and destination to **any** destination. And set the destination port range to **HTTPS(443)** , after Save the rule



Apply changes to the firewall rule configuration, to allow its to take effect on the system



Verifying , if the rules had been working properly as we set. Browse back again anything in your browser and as we see its not working and we are still connected to the internet .

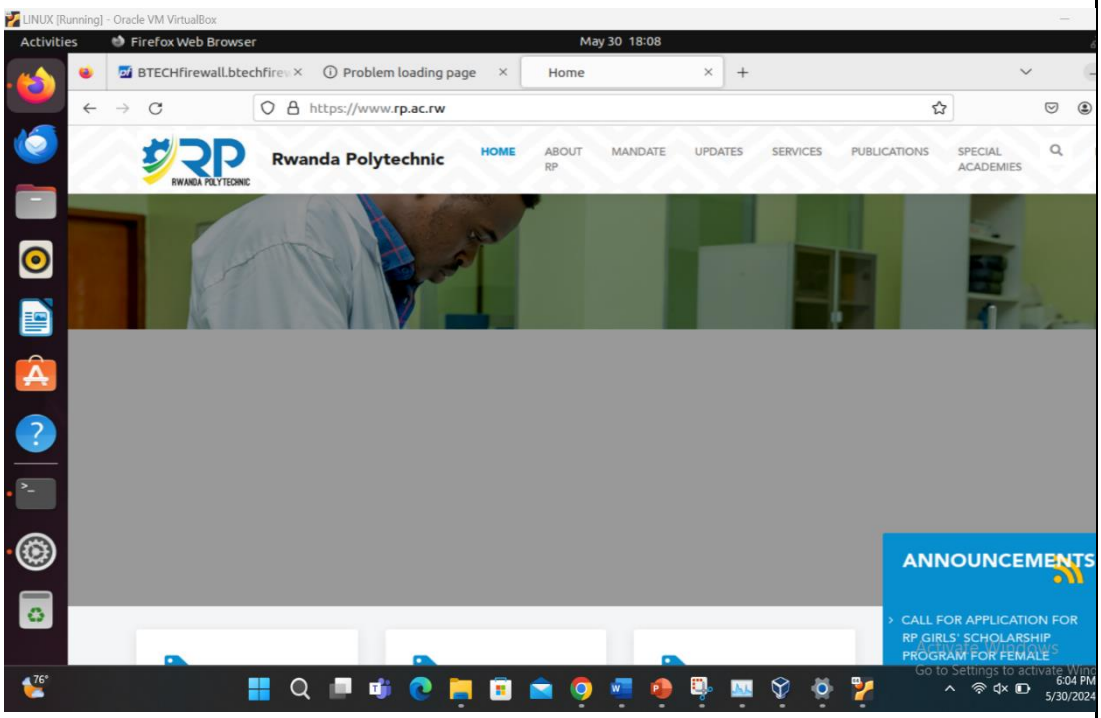


2. Rejecting the client for accessing a certain website or network address by aliases.

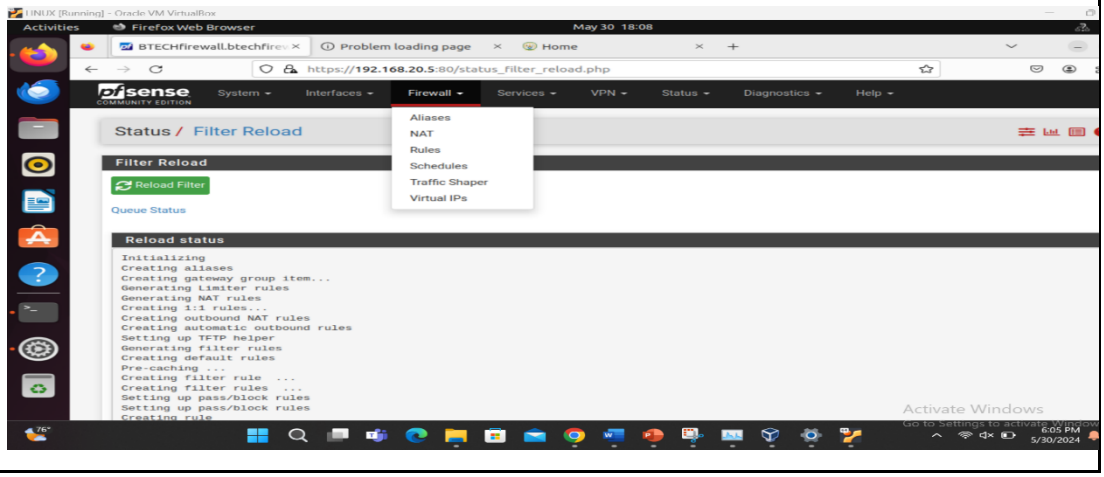
Aliases

Aliases are collections of addresses that allow many hosts to be acted upon by a small number of firewall rules. They can greatly simplify a ruleset and make it easier to understand and manage.

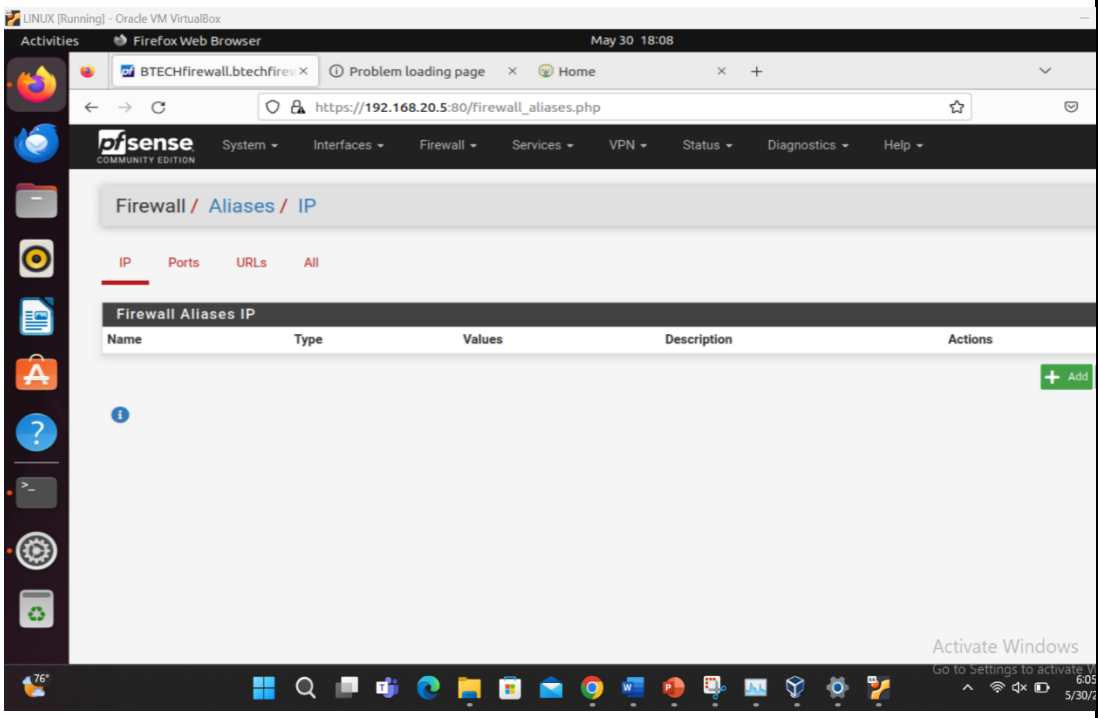
On our task we are going to block the client in our network to access the (**www.rp.ac.rw**) site. As we below now the client can access the site properly:



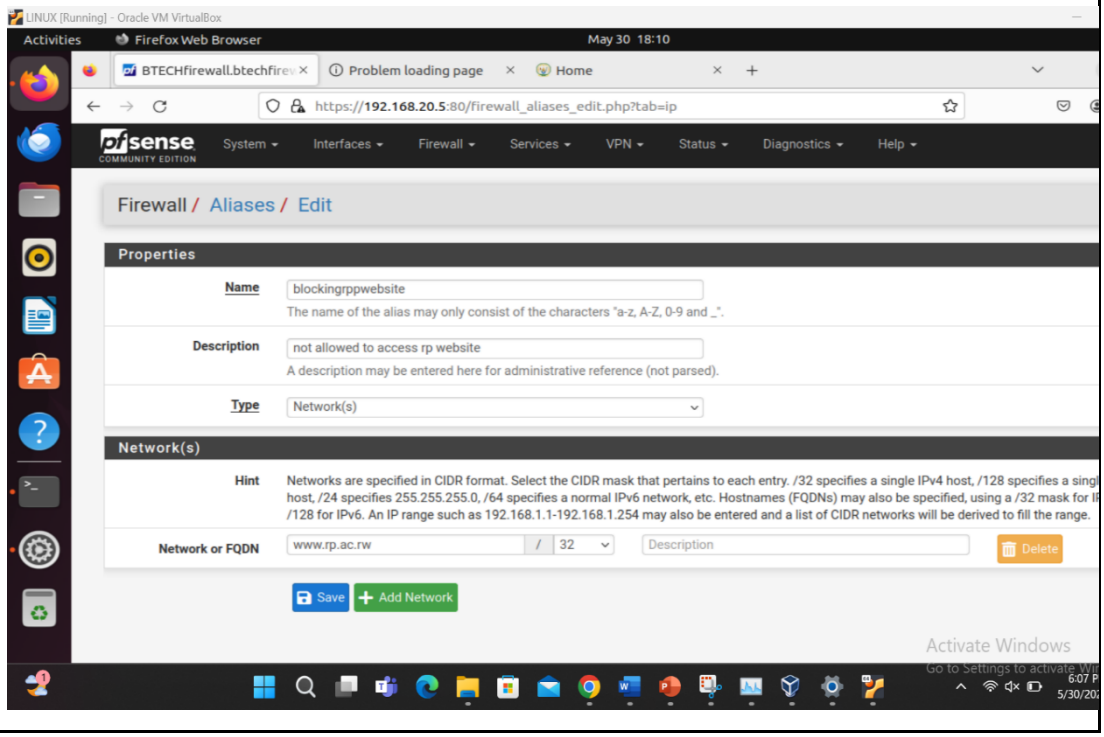
Go to the **Firewall** tab click on **Aliases** sub-tab and to create an aliases.



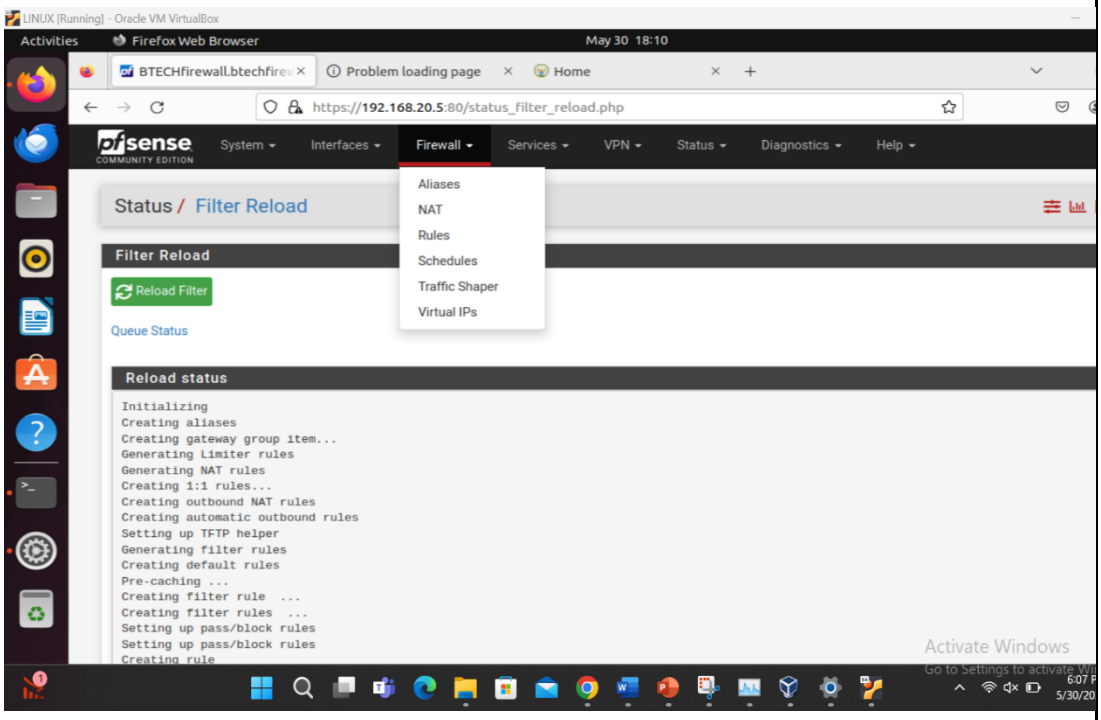
Add a new aliase by clicking on **Add** button in **IP** Tab



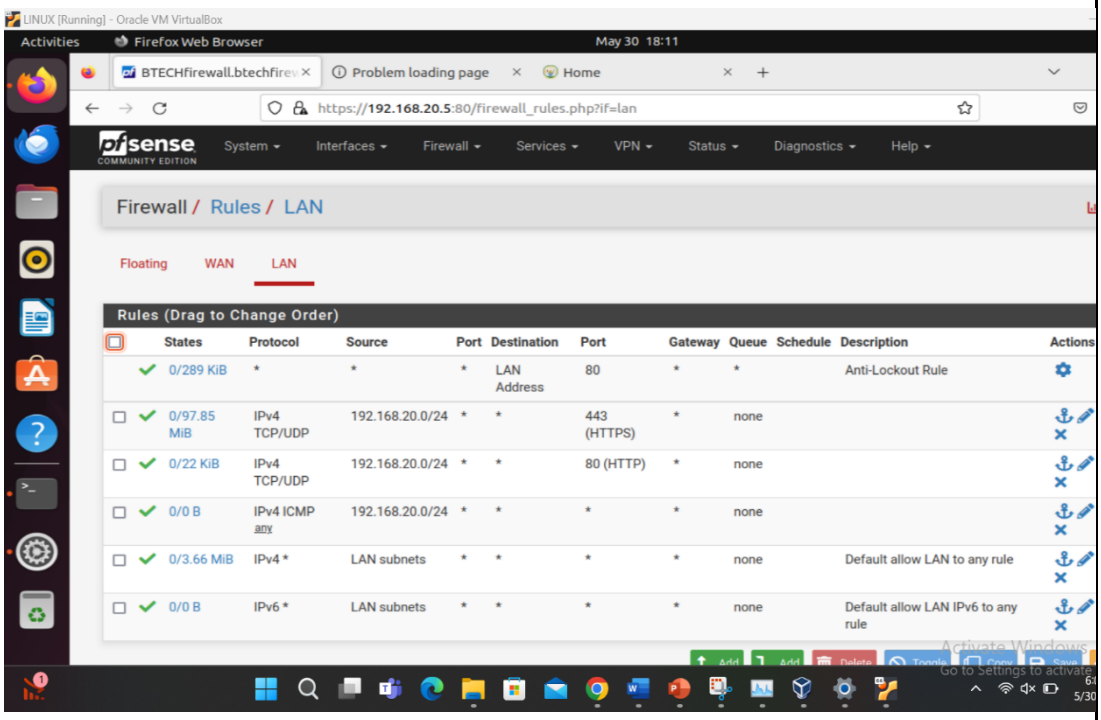
Create the name of the aliases(ex: **blockingrpwebsite**) as that will be used while we are applying rules. And provide any **description** and choose the type as **network(s).** Fill the FQDN(full qualified domain name) that you want to block(ex: www.rp.ac.rw). And Save the aliase.



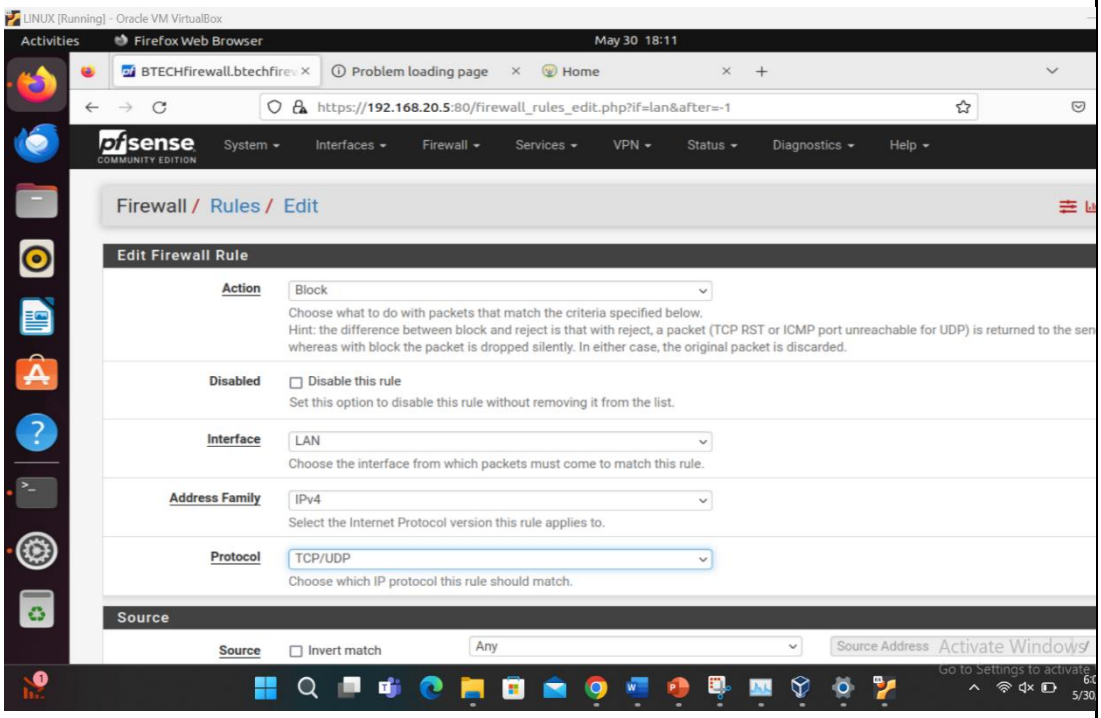
Apply changes to the firewall rule configuration, and **reload filer** to allow its to take effect on the system



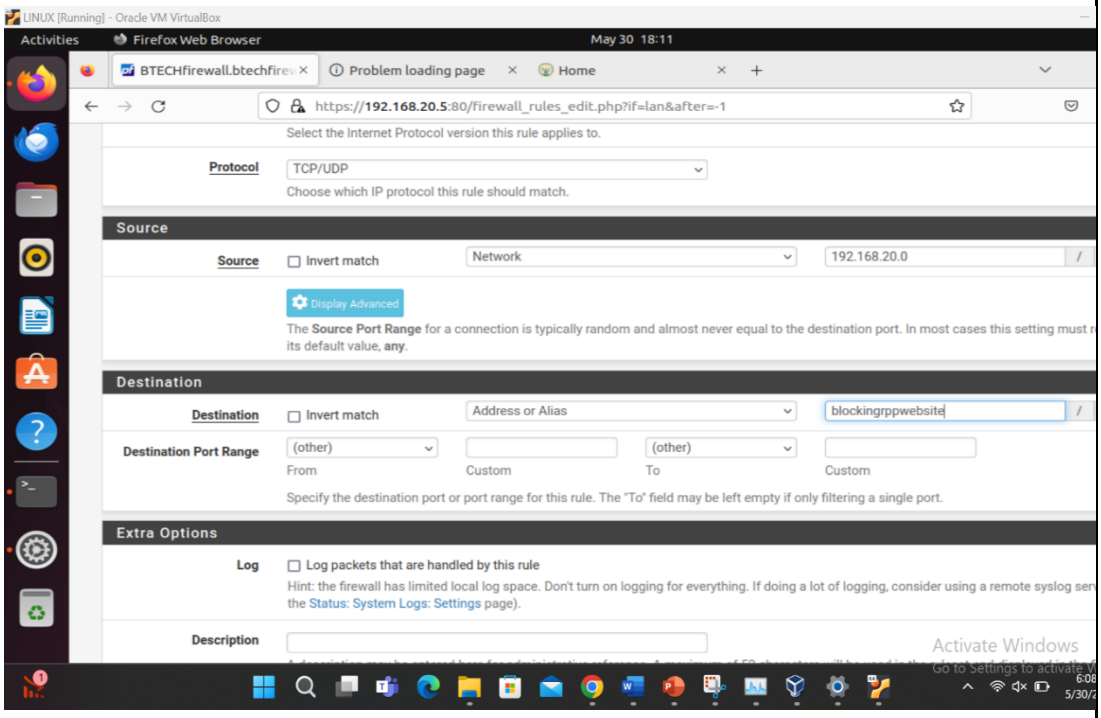
Adding a new rule , on the LAN interface for blocking the client in our netwok to use the www.rp.ac.rw site.



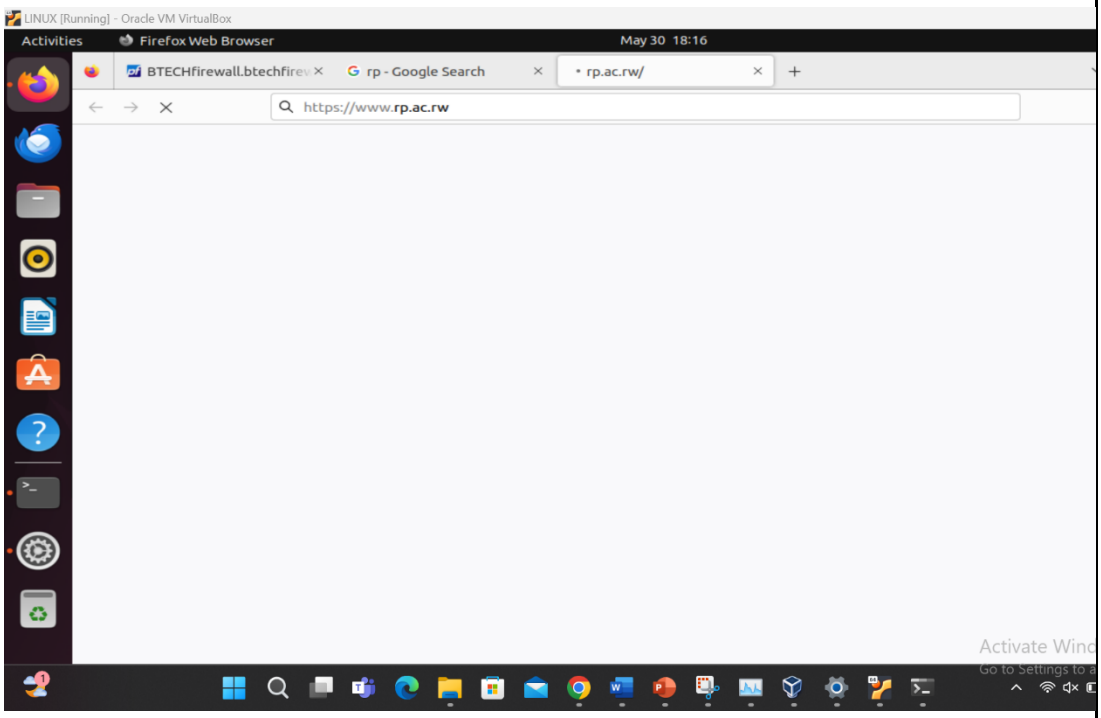
Add anew rule , with the action of **block** and choose **TCP/UDP** protocol as the protocol provide HTTP and HTTPS protocol that used while browsing.



Set the source as **network** by using the our network address **192.168.20.0/24** and destination as **address or alias** with alias name **blockingrpwebsite** that had been created before. Save the rule and apply the changes to allow its to take effect on the system



Verifying the rules, open the brwser and try to access the rp site and as we see the **www.rp.ac.rw** site is not accessed now



Points to Remember

Description of Authorization Mechanisms

- The implementation of authorization mechanisms involves setting up permission models to control user access to resources. Common models include: Discretionary Access Control (DAC), Mandatory Access Control (MAC) and Role-Based Access Control (RBAC)
- Access Control Lists (ACLs) define specific permissions for users or groups, specifying which resources they can access and what actions they can perform.

Steps to Configure ACL in pfSense using virtualization tools

Step 1: Launch VirtualBox and click on "**New**" to create a new virtual machine.

Step 2: Allocate Memory: A minimum of 1GB of RAM is recommended for pfSense,

Step 3: Configuring pfSense Network Settings

Step 4: Installing pfSense

Configuring pfSense network interfaces using the shell

Step 1: Boot up your pfSense virtual machine.

Step 2: Modifying the LAN interface configuration with the actual gateway address provided through the shell with the new address in network address range of (192.168.20.0/24)

Step 3: Enabling the DHCP server on LAN by providing the start address and end address based on your network range address (192.168.20.0/24)

Accessing the pfsense using the web interface and making further configuration.

Step 1: create another client machine in your virtual box with any operating system. On our side we are having a virtual machine with UBUNTU linux operating system.

Step 2: Open your terminal and check if your client machine is getting the ip address from the DHCP server of the pfsense firewall. By using (**ip a**) command

Step 3: Check if your client machine is getting the default route ip of the LAN interface of pfsense firewall

Step 4: open any browser and access the pfsense by using the default route ip(**192.168.20.5**) in the URL.

Step 5: click next, and set the hostname of your firewall by "**BTECHFIREWALL"** and set the domain name as **"btechfirewall.home"** as follow and click next.

Step 6: set the timezone of your firewall as **Africa/cairo,** and click next

Step 7: set LAN interface IP and the subnet mask or leave it's as the default form the pfsense**,** and click next

Step 8: set the Admin password to confirm the pfsense configuration**,** and click next

Step 9: by clicking on change the password, set the Admin new password and click next

Applying different rules in pfsense on LAN interfaces.

(rejecting the client for using the HTTP and HTTPS protocol while the client is browsing anything in the browsers on a network.)

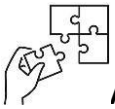
Step1: Before setting this rules lets check if the HTTP and HTTPS services are working properly

Step 2: Go to the **Firewall** tab click on **Rules** sub-tab

Step 3: Choose the **LAN** interface and **add** the new rules

Step 4: Change the **pass** action to **reject,** and also select the **TCP/UDP** protocol as the protocol that provide the HTTP and HTTPS services. **Blocking HTTP(80) and Blocking HTTPS(443)**

Step 5: Apply changes to the firewall rule configuration, to allow its to take effect on the system



Application of learning 2.3.

BPR (Bank Populaire du Rwanda) Headquarter located in Kigali city; it has two branches, one in Nyanza district and another on in Nyagatare district. The employees from Nyanza branch no longer provide efficient services to the customers, but instead they are often busy doing unnecessary activities on the internet. As Network technician; you are requested to make necessary configurations on appropriate router so that the users in Nyanza branch cannot communicate with the web server which is located at headquarter network.

Indicative content 2.4: Implementation of Access Request and Approval Workflow

Duration: 6 hrs

Theoretical Activity 2.4.1: Description of implementation of Access Request and Approval Workflow

Tasks

1: Answer the following questions:

i. Describe Access Request Workflow (Initiating Access Requests, Request Routing and Handling, Requester Responsibilities)?

ii. Describe Access Approval Mechanisms (Approval Authorities and Workflows, Approval Decision Criteria, Escalation and Exception Handling)?

iii. Describe Access Review and Recertification (Access Review Process, Purpose of Access Review, Periodicity of Access Reviews, Reviewer Roles and Responsibilities)?

iv. Describe Recertification Procedure (Identifying and Validating User Permissions, Recertification Reporting and Remediation Actions)?

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 2.4.1.

Key readings 2.4.1.:

Implementation of Access Request and Approval Workflow

his workflow defines how users can request access to resources or systems, ensuring that proper authorization is obtained while maintaining security and compliance

1 Access Request Workflow

The Access Request Workflow defines the steps users must follow to request access to resources or systems within an organization. This process ensures proper authorization before access is granted.

- **Initiating Access Requests**

In the initiating access requests phase, users are required to submit formal requests to gain access to specific resources or information within the

organization. This can be facilitated through various methods, such as online forms or dedicated portals that streamline the submission process, as well as through email requests where users can provide the necessary details. Each request should include critical information such as the user's identity (including name, ID number, and department), the purpose of the access, the duration for which the access is needed (temporary or permanent), and the specific resources or systems the user is requesting access to.

- **Request Routing and Handling**

Once a request is initiated, it enters the request routing and handling phase, where it is automatically assigned to designated approvers based on predefined rules. These rules may take into account factors such as the resource owner or department head responsible for the requested resource. Approvers receive notifications about pending requests, enabling them to act on them promptly. A central management system should track the status of each request, providing a transparent view of its progress. Additionally, this system should include options for approvers to provide comments or seek clarification if needed, ensuring a thorough review process.

- **Requester Responsibilities**

In this workflow, requesters also have specific responsibilities that they must uphold. They must ensure that they provide accurate and complete information when submitting requests, as this aids in a smoother approval process. Requesters are encouraged to monitor the status of their requests actively and respond promptly to any follow-up questions from approvers. Moreover, they must adhere to organizational policies regarding the use of the access granted.

2 Access Approval Mechanisms

The Access Approval Mechanisms ensure that each access request is evaluated fairly and in alignment with organizational policies.

- **Approval Authorities and Workflows**

Within this framework, approval authorities and workflows define who has the authority to approve or deny access requests. These authorities may vary depending on the type of resource or the nature of the request. Common approvers include IT administrators for technical systems, department heads for business applications, and data owners for sensitive data. The established workflows facilitate a streamlined approval process, ensuring that all requests are appropriately reviewed.

- **Approval Decision Criteria**

Approval decisions are based on specific approval decision criteria, which guide the approvers in evaluating each request. Criteria often include factors such as the alignment of the requested access with the requester's role, the business need for the access, and the potential security risks involved. By applying these criteria

consistently, organizations can maintain security while meeting business requirements.

- **Escalation and Exception Handling**

Lastly, an effective workflow includes provisions for escalation and exception handling. If a request cannot be approved at the initial level, or if it is time-sensitive, the process allows for escalation to higher authorities or specialists for further evaluation. This ensures that exceptional cases are addressed promptly, while also requiring thorough documentation and review to prevent misuse or unauthorized access.

3 Access Review and Recertification

The Access Review and Recertification process is critical in maintaining security and compliance within an organization. This process ensures that user access permissions remain appropriate over time, thereby reducing the risk of unauthorized access and enhancing overall data protection.

i. **Access Review Process**

The Access Review Process involves systematically evaluating the access permissions assigned to users. This process typically includes collecting data on all current access rights and determining whether those rights are still appropriate based on the user's role, responsibilities, and the principle of least privilege. Organizations may utilize automated tools to streamline this process, ensuring accuracy and efficiency in reviewing access levels.

ii. **Purpose of Access Review**

The Purpose of Access Review is multifaceted. Primarily, it aims to ensure that users retain only the access necessary for their job functions. By conducting regular reviews, organizations can identify and revoke excessive permissions, thereby minimizing potential security risks. Furthermore, access reviews help ensure compliance with regulatory requirements and internal policies, providing a documented approach to managing user access.

iii. **Periodicity of Access Reviews**

The Periodicity of Access Reviews refers to how often these reviews are conducted. The frequency can vary based on organizational policies and the sensitivity of the resources involved. Common practices include quarterly, biannual, or annual reviews. High-risk systems often require more frequent evaluations to ensure that access levels remain appropriate and to mitigate potential security threats.

iv. **Reviewer Roles and Responsibilities**

In the Reviewer Roles and Responsibilities framework, various stakeholders are involved in the access review process. Typically, reviewers include managers, system owners, and security administrators who are responsible for evaluating user access and ensuring compliance with policies. Their duties may involve

examining access logs, verifying user roles, making decisions on access modifications, and documenting the results of the reviews.

4 Recertification Procedures

Recertification Procedures are essential for ensuring that user permissions are validated and remain relevant. This process involves identifying and confirming that users have the appropriate access required for their roles within the organization.

- **Identifying and Validating User Permissions**

The first step in Identifying and Validating User Permissions involves compiling a comprehensive list of all active permissions assigned to users. Reviewers assess whether these permissions align with the current roles and responsibilities of the users. This validation process is critical for ensuring that any access granted is necessary and justifiable.

- **Recertification Reporting**

Recertification Reporting is a crucial aspect of the recertification process. After validating user permissions, organizations must document the findings and decisions made during the recertification process. This report typically includes details such as which users had their access maintained, adjusted, or revoked, as well as any patterns of excessive access identified. Proper documentation aids in transparency and provides valuable insights for future access management efforts.

- **Remediation Actions**

When inappropriate access is identified during recertification, organizations must implement Remediation Actions. These actions can include revoking unauthorized access, adjusting permissions to align with organizational policies, and potentially implementing additional controls, such as enhanced monitoring or multi-factor authentication (MFA). Timely remediation is essential to mitigate risks and maintain the security integrity of the organization's systems.

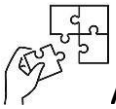


Points to Remember

- The Access Request and Approval Workflow ensures that only authorized users can access specific resources. It starts with users submitting access requests, which are routed to the appropriate authorities for approval. Requesters are responsible for providing accurate information and justifying their need for access
- Access Approval Mechanisms involve designated approvers who review and decide on requests based on set criteria. If needed, requests can be escalated for further review or handled through exception processes.
- Access Review and Recertification involves regularly checking user access to ensure it is still appropriate. Reviewers ensure users only have the permissions needed for their roles,

maintaining security and compliance.

- Recertification Procedures validate user permissions, generate reports, and address any issues found, keeping the system secure and updated.



Application of learning 2.4.

ABC is a company with employees from different department, the company need to manage Access Request and Approval Workflow ensures that only authorized users can access specific resources. Describe Access Request Workflow, Access Approval Mechanisms, Access Review and Recertification and Recertification Procedures in order to help company to manage use access

Indicative content 2.5: Deployment of Firewalls and IDS/IPS

Duration: 6 hrs

Theoretical Activity 2.5.1: Description of Firewalls and IDS/IPS

Tasks

1: Answer the following questions:

i. Describe Firewalls fundamentals
ii. Describe IDS
iii. Describe IPS
iv. What is Proactive Threat Mitigation
v. Describe Rule Management Firewall

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 2.5.1.

Key readings 2.5.1

Deployment of Firewalls and IDS/IPS

1. Firewall Fundamentals

Introduction to Firewalls

A firewall is a network security device that monitors and controls incoming and outgoing network traffic based on predetermined security rules. It acts as a barrier between a trusted internal network and untrusted external networks (such as the internet). Firewalls can be hardware-based, software-based, or a combination of both, and they are essential for protecting networked systems from unauthorized access and cyber threats.

Key Functions:

- **Packet Filtering:** Inspects packets and allows or blocks them based on IP addresses, protocols, and port numbers.
- **Stateful Inspection:** Tracks the state of active connections and determines which packets to allow through the firewall.
- **Proxy Service:** Acts as an intermediary between users and the internet,

preventing direct access to network resources.

2 Intrusion Detection Systems (IDS)
Introduction to IDS
An Intrusion Detection System (IDS) is a device or software application that monitors network or system activities for malicious activities or policy violations. An IDS can provide alerts when potential threats are detected, allowing for timely responses.

Types of IDS:

- **Network-based IDS (NIDS):** Monitors network traffic for suspicious activity.
- **Host-based IDS (HIDS):** Monitors individual devices for signs of compromise.

IDS Deployment
The deployment of an IDS involves several steps:

1. **Planning:** Identify the network architecture and critical assets to determine where to deploy the IDS.
2. **Installation:** Place the IDS at strategic points within the network (e.g., network perimeters, data centers).
3. **Configuration:** Set up detection rules and thresholds to minimize false positives and negatives.
4. **Integration:** Ensure the IDS integrates well with existing security tools (e.g., SIEM systems).
5. **Testing and Tuning:** Regularly test the system and adjust configurations based on performance metrics and threat landscape changes.

3 Intrusion Prevention Systems (IPS)
Introduction to IPS
An Intrusion Prevention System (IPS) is a network security technology that inspects network traffic flows to detect and prevent vulnerability exploits. Unlike an IDS, which only alerts administrators, an IPS takes immediate action to block malicious traffic.

Key Features:

- **Real-time Threat Prevention:** Actively blocks or mitigates threats as they are detected.
-
- **Automated Responses:** Automatically applies predefined policies to manage detected threats.

Proactive Threat Mitigation

Proactive threat mitigation refers to the process of identifying and neutralizing threats before they can exploit vulnerabilities. IPS solutions utilize various techniques for proactive threat mitigation, including:

- **Signature-based Detection:** Identifying known threats through pre-existing signatures.
- **Anomaly-based Detection:** Monitoring network traffic for unusual patterns that may indicate a potential attack.
- **Policy Enforcement:** Implementing strict policies to block unauthorized access and malicious activities.

4 Configuration and Rule Management for Firewalls

Setting Security Policies and Rules

Security policies are a set of rules that define how data is to be handled in a network. They are crucial for guiding the configuration of firewalls. To set effective policies:

1. **Define Objectives:** Understand the organization's security goals and the specific threats it faces.
2. **Draft Policies:** Write clear policies that outline what is permissible and what is not.
3. **Establish Rules:** Create rules that enforce the policies, specifying what traffic should be allowed or blocked.

Configuration of Access Control and Rule Management

Access control involves restricting access to network resources based on user roles, authentication, and authorization. Rule management ensures that the firewall's rules are effective and up-to-date. Key activities include:

- **Regular Review:** Periodically review and update access control lists (ACLs) and firewall rules.
- **Role-Based Access Control (RBAC):** Implement RBAC to ensure users only have access to resources necessary for their roles.
- **Logging and Auditing:** Enable logging to monitor access and rule effectiveness.

Policy Optimization Techniques

Policy optimization involves refining security policies and rules to enhance performance and security. Techniques include:

- **Consolidation:** Combine similar rules to reduce complexity and improve processing speed.
- **Prioritization:** Order rules by importance, ensuring critical rules are evaluated

first.

- **Testing:** Regularly test policies to identify and address weaknesses or conflicts.

Differences Between a Firewall, IDS, and IPS

Intrusion Prevention System vs. Intrusion Detection system vs. Firewall			
Parameter	**Firewall**	**IPS**	**IDS**
Purpose	A network security device that filters incoming and outgoing traffic based on predetermined security rules.	A device that inspects and prevents identified threats in real-time by analyzing traffic.	A system that monitors network or system activities for malicious actions or policy violations.
Operation	Filters traffic based on rules applied to addresses and port numbers.	Examines traffic for real-time attacks and intervenes to stop them on detection.	Observes traffic and looks for attack patterns or anomalies, generating alerts.
Configuration mode	Operates in either inline or transparent mode at the network's boundary.	Typically inline, positioned after the firewall within the network layer.	Generally operates in monitoring mode, not inline with traffic flow.
Traffic path	Should be the primary route of network traffic.	Placed after the firewall to examine filtered traffic.	Analyzes traffic after it has passed through the firewall.
Placement	Located at the network perimeter as the initial defense line.	Positioned right after the firewall, before the internal network.	Resides within the network, typically after the IPS for deeper traffic analysis.

Response to unauthorized traffic	Blocks or permits traffic based on rule evaluation.	Actively prevents the progression of detected threats.	Issues alerts or alarms upon detecting suspicious activities.



Practical Activity 2.5.2: Deploying Firewall and IDS/IPS



Tasks

1: Perform the following activity.

You school decided to implement a firewall, an Intrusion Detection System (IDS), and an Intrusion Prevention System (IPS) to ensure a robust security posture. You need to configure a firewall school, ensuring that security policies are well-defined, deploy an IDS to monitor network traffic and detect potential threats. And Set up an IPS to prevent any malicious traffic from entering the network.

2: Present your findings.

3: Ask any questions you have or clarify any doubts related to the content presented or discussed.

4: Read key readings 2.5.2.



Key readings 2.5.2

standard access list

With the above understanding, we will now show you how to create a standard access list. Now here is the syntax used for creating a standard access list:

Router (config)# access-list (1-99) (permit | deny) source-addr (source-wildcard)

The breakdown of the different parts of the syntax is as follows:

- **<1-99 or 1300-1999>** Specifies the standard ACL IP number range

• **Permit** Specifies packet to forward (to **permit** the configured source IP address traffic)
• **Deny** Specifies packets to reject (i.e. (to **deny** the configured source IP address traffic)
• **Source-addr** The source IP address that must be matched
• **Source-wildcard** The wildcard mask to be applied to the previously configured IP address to indicate the range.

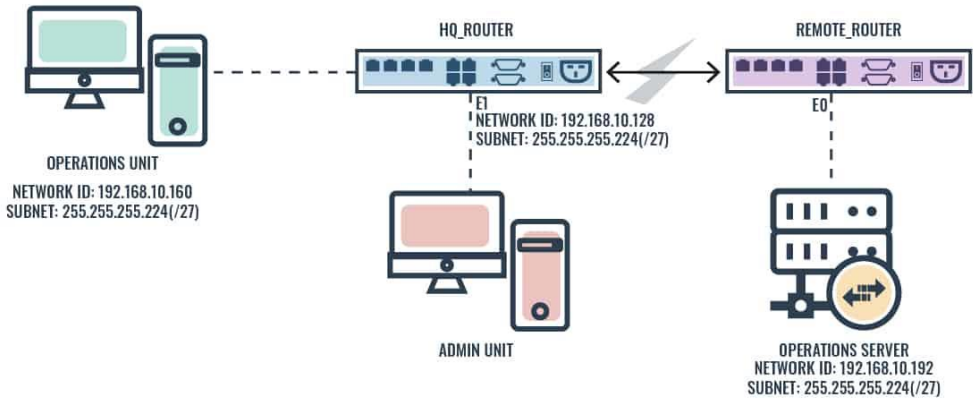


Figure 1.0 Standard access list configuration

Figure 1.0 above shows an internetwork of two routers with three LANs including one serial WAN connection for a logistics company. As the network engineer for this company, you have been asked to use a standard access list to prevent users in the Admin unit from accessing the Operations server attached to the Remote Router while allowing all other users access to that LAN.

First and foremost, you need to figure out the access list wildcard (which is basically the inverse of the subnet mask) and where to place the access list. Standard access lists, by the rule of thumb, are placed closest to the destination—in this case, the E0 interface of the Remote Router. So in order to achieve this implementation, we will configure an access control list and apply it on the E0 outbound interface of the remote Router. Here are the required parameters for this configuration.

• **Network ID:** 192.168.10.128
• **Wildcard:** 255.255.255.255 – 255.255.255.224 = 0.0.0.31

The table below is a breakdown of the access-list commands to be used for this task.

Extended access list

Next we will now show you how to create an extended access list. Here's the command syntax for configuring an extended numbered access control list:

Router (config)# access-list (100-199) (permit | deny) protocol source-addr (source-wildcard)

(operator operand) destination-addr (destination-wildcard) (operator operand) (established)

Router (config)# access-list {100-199} {permit | deny} protocol source-addr {source-wildcard} {operator operand} destination-addr {destination-wildcard} {operator operand} {established}

The breakdown of the different parts of the above syntax is as follows:

- **<100-199 or 2000-2699>** Specifies the standard ACL IP number range
- **Permit or Deny** Specifies whether to permit or deny traffic according to the criteria that follows
- **Protocol** The protocol type, that is, IP, TCP, UDP, ICMP or other IP-sub protocol
- **Source-addr** The source IP address that must be matched
- **Source-wildcard** The wildcard mask to be applied to the previously configured IP address to indicate the range.
- **Destination-addr** The destination IP address that must be matched
- **Destination-wildcard** The associated wildcard mask to be applied.

As the network manager for the network shown in Figure 1.0 above, you have been asked to configure an access list that will stop FTP and Telnet access to the Operations server while allowing other protocols.

This task involves the use of an extended access list. In order to achieve this implementation, we will configure an access control list using the FTP and telnet port numbers and apply it on the E0 outbound interface of the Remote_Router. Here are the required parameters for this configuration:

- **Network ID:** 192.168.10.192
- **Wildcard:** 255.255.255.255 – 255.255.255.224 = 0.0.0.31
- **FTP port number:** 21

- **Telnet port number:** 23

The table below is the breakdown of the access list commands and configurations that can be used to implement this task:

Command	Description
Remote_Router#config t	Enter global configuration mode
Remote_Router(config)#access-list 120 deny tcp any 192.168.10.192 0.0.0.31 eq 21	Deny FTP access to the Operations server on interface E0
Remote_Router(config)#access-list 120 deny tcp any 192.168.10.192 0.0.0.31 eq 23	Deny telnet access to the Operations server on interface E0
Remote_Router(config)#access-list 120 permit ip any	Allow all other packets/protocols
Remote_Route	Enter interface configuration mode for E0

r(config)#interface ethernet 0	
Remote_Router(config-if)#ip access-group 120 out	Apply access list on interface E0 as an outbound list

Remote_Router#config t	Enter global configuration mode
Remote_Router(config)#access-list 10 deny 192.168.10.128 0.0.0.31	Deny Admin LAN access to Operations server
Remote_Router(config)#access-list 10 permit any	Allow everyone else
Remote_Router(config)#interface ethernet 0	Enter interface configuration mode
Remote_Router(config-if)#ip access-group 10 out	Apply access list is on the interface as an outbound list
Confirm access list entry	
Remote_Router#show access-lists	Display all configured access list
Remove access list	
Remote_Router(config)#no access-list 10	Remove the entire access list entry
Remote_Router(config)#end	Return to the previous exec mode
Remote_Router#sh access-lists	Confirm if the access list has been removed
Remote_Router#	Nothing to display, the access list removed

Points to Remember

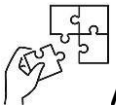
Description of Firewalls and IDS/IPS

- A firewall is a network security tool that controls the flow of traffic between a trusted internal network and untrusted external sources like the internet. It can be hardware or software and helps protect against unauthorized access.
- Intrusion Detection Systems (IDS) An Intrusion Detection System (IDS) monitors network or system activities for signs of malicious behavior. There are two main types: Network-based IDS (NIDS), which monitors network traffic, and Host-based IDS (HIDS), which monitors individual devices

- Intrusion Prevention Systems (IPS) An Intrusion Prevention System (IPS) goes a step further than IDS by automatically blocking or stopping detected threats.
- Firewall Configuration and Rule Management Firewalls must be configured with security policies and rules to control what traffic is allowed or blocked. Regularly reviewing and updating these rules, using Role-Based Access Control (RBAC) to limit access based on roles, and enabling logging to track rule effectiveness are key practices.

Deploying Firewall and IDS/IPS

- To create a standard access list, you use the command syntax on the router, specifying whether to "permit" or "deny" traffic from a source IP address using a source wildcard. The standard ACL range is between 1-99 or 1300-1999, and it is typically placed close to the destination device. For instance, to block Admin LAN users from accessing the Operations server in a given network, you calculate the appropriate wildcard and apply the ACL to the E0 interface of the remote router. Key commands include entering global configuration mode, defining the access list, and applying it to the correct interface.
- For an extended access list, which provides more flexibility, you specify not just the source but also the protocol, destination, and associated port numbers. In this example, to block FTP and Telnet access to the Operations server, the ACL must include the relevant port numbers (21 for FTP, 23 for Telnet) and be applied on the E0 outbound interface of the remote router. Like standard ACLs, you use commands to deny or permit traffic, but with more detailed criteria.
- Once the access list is configured, it can be applied to interfaces, and you can use show commands to review the ACLs in place. If needed, the entire access list can be removed using the "no access-list" command. For both standard and extended access lists, it's important to test and verify their effectiveness after implementation.
- Extended access lists are particularly useful when needing to block specific protocols like FTP or Telnet while allowing other types of traffic, offering greater control over network traffic management.



Application of learning 2.5.

You are part of an IT security team tasked with securing a small business's network infrastructure. The business has a mix of internal and external traffic, and it is critical to protect sensitive customer data and prevent unauthorized access. Your team has decided to implement a firewall, an Intrusion Detection System (IDS), and an Intrusion Prevention System (IPS) to ensure a robust security posture. You need to configure a firewall for the

small business, ensuring that security policies are well-defined, deploy an IDS to monitor network traffic and detect potential threats. And Set up an IPS to prevent any malicious traffic from entering the network.

Indicative content 2.6: Isolate Critical Systems

Duration: 6 hrs

Theoretical Activity 2.6.1: Description of network segmentation.

Tasks

1. Answer the following questions:
   i. What is of Network Segmentation
   ii. Describe Types of Network Segmentation
   iii. What are Benefits of Network Segmentation
   iv. What are ways for identifying Critical Systems
2. Present your group's findings on the discussed topics.
3. Ask clarification if any

4. Read the key readings 2.6.1.

Key readings 2.6.1.:

Isolate Critical Systems

1 Description of Network Segmentation

1.1 Definition of Network Segmentation

Network segmentation is the practice of dividing a computer network into smaller, manageable segments or sub-networks. This approach enhances security, improves performance, and simplifies network management by controlling traffic and limiting exposure to potential threats.

1.2 Types of Network Segmentation

1. **Physical Segmentation:** Involves creating distinct physical networks using separate hardware devices (e.g., switches, routers).
2. **Logical Segmentation:** Utilizes VLANs (Virtual Local Area Networks) to segment networks logically while using the same physical infrastructure.
3. **Virtual Segmentation:** Employs virtualization technologies to isolate network resources on virtual machines.
4. **Application Segmentation:** Divides networks based on applications, controlling access to specific services or applications.

1.3 Benefits of Network Segmentation

- **Enhanced Security:** Limits the attack surface by containing potential breaches within smaller segments.
- **Improved Performance:** Reduces congestion and improves bandwidth management by limiting broadcast traffic.
- **Simplified Management:** Makes it easier to monitor and manage network segments separately.
- **Regulatory Compliance:** Helps organizations comply with regulations by ensuring sensitive data is isolated.

2 Identifying Critical Systems

2.1 Defining Critical Systems

Critical systems are essential components of an organization's infrastructure that are vital for its operations. These systems often handle sensitive data or support core business functions, and their availability and security are paramount.

2.2 Mapping Critical Systems

1. **Inventory Assessment:** Create an inventory of all systems and applications in the organization.
2. **Impact Analysis:** Assess the impact of each system on business operations to identify which are critical.
3. **Prioritization:** Rank systems based on their importance and the sensitivity of the data they handle.

3 Developing a Network Segmentation Plan

3.1 Creating a Segmentation Strategy

Develop a clear strategy that outlines how the organization will segment its network based on its unique requirements and risk assessment. Consider the following:

- Define the segmentation scope.
- Identify stakeholders involved in the segmentation process.
- Establish timelines and milestones.

3.2 Identifying Segmentation Objectives

Clearly define the objectives of the network segmentation plan, such as:

- Improving security posture.
- Enhancing performance and efficiency.
- Complying with regulatory requirements.
- Facilitating incident response and recovery.

3.3 Selecting Segmentation Technologies

Choose appropriate technologies to implement network segmentation, such as:

- **Firewalls:** To control traffic between segments.
- **VLANs:** To create logical segments within a network.
- **Software-Defined Networking (SDN):** For dynamic and automated segmentation.
- **Network Access Control (NAC):** To enforce policies for devices accessing the network.

4 Implementing Network Segmentation Measures

4.1 Implementation Phases

1. **Planning Phase:** Outline the segmentation strategy, objectives, and technologies.
2. **Design Phase:** Develop detailed designs for each network segment.
3. **Execution Phase:** Implement the designed segments and configure necessary controls.
4. **Review Phase:** Evaluate the implementation for effectiveness and identify areas for improvement.

4.2 Configuration and Setup

- Configure network devices (switches, routers, firewalls) to establish segments according to the design.
- Set up access control lists (ACLs) to regulate traffic between segments.
- Ensure that segmentation policies are documented and communicated to relevant stakeholders.

4.3 Continuous Monitoring

Implement continuous monitoring measures to track network traffic and detect anomalies. Use tools such as:

- **Intrusion Detection Systems (IDS):** To monitor for suspicious activity.
- **Network Performance Monitoring Tools:** To assess segment performance and availability.
- **Log Management Solutions:** To analyze logs for potential security incidents.

5 Isolating Critical Systems

5.1 Importance of Critical System Isolation

Isolating critical systems is essential to safeguard sensitive data and maintain operational integrity. It prevents unauthorized access, mitigates the risk of data breaches, and ensures that critical functions remain operational even in the event

of a cyber incident.

5.2 Techniques for Isolation

- **Firewall Rules:** Implement strict firewall rules to control access to critical systems.
- **VLANs:** Use VLANs to separate traffic and restrict access to critical resources.
- **Air-gapping:** Physically isolate critical systems from other networks, especially from the internet.
- **Access Control:** Enforce stringent access controls to ensure that only authorized users can access critical systems.

5.3 Isolation Best Practices

- **Least Privilege Principle:** Grant users the minimum access necessary to perform their tasks.
- **Regular Audits:** Conduct regular audits of access controls and configurations to ensure compliance with security policies.
- **Incident Response Plans:** Develop and test incident response plans specific to isolated critical systems to ensure rapid recovery in case of a breach.
- **User Education:** Provide training for users on the importance of system isolation and security practices.



Practical Activity 2.6.2: Implementing network segmentation measures



Tasks

1: Referring to the previous theoretical activity (2.6.1) you are requested to perform the following activity.

Your school has been tasked with developing and implementing a network segmentation plan for school network to enhance security and compliance. The management is concerned about potential data breaches between staff, trainers and trainee and wants to ensure that critical systems are adequately protected while maintaining efficient network performance.

2: Read the key readings 2.6.2.

3: Asks for clarification if any



Key readings 2.6.2

Implementing network segmentation measures

Steps to Perform network segmentation:

1. **Create a Segmentation Strategy:**

    - Define what parts of the network will be segmented (e.g., departments or types of data).
    - Identify key people involved in the process (e.g., IT staff and management).
    - Set a timeline for completing the segmentation project.

2. **Identify Objectives:**

    - Determine the goals of the segmentation plan

3. **Select Technologies:**

    - Choose technologies to implement segmentation, such as:
        - Firewalls for controlling traffic.
        - VLANs for creating logical segments.
        - Software-Defined Networking (SDN) for flexibility.
        - Network Access Control (NAC) for managing access.

4. **Implement the Plan:**

- **Planning Phase:** Outline your strategy and objectives.
- **Design Phase:** Create a simple design for each network segment.
- **Execution Phase:** Set up the network segments and necessary controls.
- **Review Phase:** Check the implementation for effectiveness and areas to improve.

5. **Configure and Set Up:**

- Set up network devices (switches, routers, firewalls) to create segments.
- Establish access control lists (ACLs) to manage traffic between segments.
- Document the segmentation policies for stakeholders.

6. **Monitor Continuously:**

- Use tools to monitor the network, such as:
    - Intrusion Detection Systems (IDS) for security alerts.
    - Performance monitoring tools for assessing network health.
    - Log management systems for reviewing activity logs.



Practical Activity 2.6.3: Isolating Critical Systems



Tasks

1: Referring to the previous theoretical activity (2.6.1) you are requested to perform the following activity.

You are part of an IT team in an organization that handles sensitive customer data. Your task is to implement network segmentation measures to enhance security and ensure that critical systems are isolated from potential threats.

2: Read the key readings 2.6.3.



Key readings 2.6.3.

Steps to isolate critical system:

1. **Implementation Phases:**

    - **Planning & Design Phase:** Outline your plan for network segmentation, including objectives and a simple design that illustrates how critical systems will be isolated within the network.
    - **Execution & Review Phase:** Implement the design by configuring necessary devices (switches, routers, firewalls) and controls. After implementation, evaluate the setup to ensure it meets objectives and identify any areas for improvement.

2. **Configuration and Setup:**

    - Configure network devices to create segments and set up access control lists (ACLs) to restrict access to critical systems. Ensure all configurations and policies are documented for future reference.

3. **Continuous Monitoring:**

    - Implement monitoring tools to track network activity and detect anomalies, using Intrusion Detection Systems (IDS), performance monitoring tools, and log management solutions to maintain security and assess network health.

4. **Isolating Critical Systems:**

- Recognize the importance of isolating critical systems to protect sensitive data. Apply techniques for isolation, such as using firewalls and VLANs, and follow best practices like implementing the least privilege principle



Points to Remember

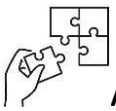
- **Description of network segmentation**
  - Network segmentation is the practice of dividing a computer network into smaller, manageable segments or sub-networks. This approach enhances security by limiting exposure to potential threats, improves performance by controlling traffic flow, and simplifies network management.
  - There are different types of network segmentation. Physical segmentation, Logical segmentation, Virtual segmentation and application segmentation
  - The benefits of network segmentation are significant. It enhances security by reducing the attack surface and containing potential breaches. It also improves network performance by minimizing congestion and optimizing bandwidth usage.
  - Identifying critical systems is essential for effective network segmentation. Critical systems are those vital for business operations and often handle sensitive data. To identify these systems, organizations should create an inventory of all systems and applications, assess the impact of each on business operations, and prioritize them based on their importance and data sensitivity.

Steps to Perform network segmentation:

1. Create a Segmentation Strategy:
2. Identify Objectives
3. Select Technologies
4. Implement the Plan
5. Configure and Set Up
6. Monitor Continuously

Steps to Perform isolation of critical system:

1. Implementation Phases
2. Configuration and Setup
3. Continuous Monitoring
4. Isolating Critical Systems



Application of learning 2.6.

H.D is an organization that processes sensitive customer data collected from various departments, including Marketing, Sales, and Administration. Your task is to implement a network segmentation plan that includes isolating critical systems to enhance security and improve overall network performance. This involves identifying critical systems, creating a segmentation strategy, and ensuring continuous monitoring of the network.

Indicative content 2.7: Encrypt Sensitive Data for Protection

Duration: 6 hrs

Theoretical Activity 2.7.1: Description of Encryption in cyber security

Tasks:

1: Answer the following questions:

i. Describe Encryption

ii. Explain Encryption Terminology (Plaintext, Ciphertext , Encryption Key, Encryption Algorithm, Decryption)

i. Principles of Confidentiality, Integrity, and Availability (CIA) in data Encryption

ii. Differentiate Types of Encryption Algorithms

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 2.7.1

Key readings 2.7.1.:

Encrypt Sensitive Data for Protection

1. Description of Encryption Principles

Encryption is a fundamental cybersecurity measure that converts readable data (plaintext) into an unreadable format (ciphertext) to prevent unauthorized access. By using encryption, organizations ensure that sensitive data remains confidential, integral, and available only to authorized parties.

- **Introduction to Encryption:**

Encryption involves the process of encoding information such that it can only be accessed or decrypted by individuals who have the correct decryption key. It is widely used to protect sensitive information like financial data, personal identifiers, and confidential business documents from unauthorized access.

- **Encryption Terminology:**

Key terms in encryption include:

- **Plaintext:** The original readable data before encryption.

- **Ciphertext:** The encrypted data that is not readable without the decryption key.
- **Encryption Key:** A piece of information used in conjunction with an encryption algorithm to encrypt and decrypt data.
- **Encryption Algorithm:** A mathematical process that transforms plaintext into ciphertext and vice versa.
- **Decryption:** The process of converting ciphertext back into readable plaintext using the correct key.

• **Principles of Confidentiality, Integrity, and Availability (CIA) in Encryption:**

- **Confidentiality:** Encryption ensures that sensitive information remains private and is only accessible to authorized individuals.
- **Integrity:** Encryption helps to verify that data has not been altered during transmission or storage.
- **Availability:** Encryption systems ensure that authorized individuals can access decrypted data when needed while protecting against unauthorized access.

2. Types of Encryption Algorithms

There are several types of encryption algorithms, each with distinct use cases and properties. The most common types include symmetric encryption, asymmetric encryption, and hashing algorithms.

• **Symmetric Encryption:**

Symmetric encryption uses a single key for both encryption and decryption processes. Both the sender and the receiver must have access to the same secret key. Examples include:

- **AES (Advanced Encryption Standard)**
- **DES (Data Encryption Standard)**
- **Blowfish**

Symmetric encryption is faster and efficient for encrypting large amounts of data but requires secure key distribution methods.

• **Asymmetric Encryption:**

Asymmetric encryption uses two keys: a public key (for encryption) and a private key (for decryption). The public key can be shared openly, but the private key must remain confidential. Asymmetric encryption is widely used in secure communications like SSL/TLS for web security. Examples include:

- **RSA (Rivest-Shamir-Adleman)**
- **ECC (Elliptic Curve Cryptography)**

Asymmetric encryption is slower than symmetric encryption but does not require the secure transmission of keys between the sender and receiver.

• **Hashing Algorithms:**

Hashing is a process that converts data into a fixed-size string of characters, which is typically a hash value. Hash functions are used for verifying data

integrity and storing passwords securely. Hashing is one-way and cannot be reversed. Examples include:

- **SHA-256 (Secure Hash Algorithm)**
- **MD5 (Message Digest Algorithm)**

Hashing ensures that data has not been tampered with, providing integrity but not confidentiality.



Theoretical Activity 2.7.2: Identification of Sensitive Data



Tasks:

1: Answer the following questions:

i. How to recognize sensitive data?
ii. Describe Data Classification and Labelling

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 2.7.2.



Key readings 2.7.2:

Identifying Sensitive Data

Before encrypting data, it is essential to identify and classify the types of data that require protection.

- **Recognizing Data Sensitivity:**

Sensitive data typically includes any information that, if disclosed, could harm an individual or organization. This may include:

- Personal identifiable information (PII)
- Financial records
- Health records (protected by laws like HIPAA)

- Intellectual property and trade secrets

Recognizing the sensitivity of data allows organizations to prioritize their encryption efforts to ensure that high-value information is adequately protected.

• **Data Classification and Labeling:**
To manage data effectively, organizations often classify and label their data based on its sensitivity and risk level. Data classification helps in identifying the proper level of encryption needed. Common classification levels include:

- **Public:** Low sensitivity, minimal security requirements.
- **Confidential:** Moderate sensitivity, requires controlled access and encryption.
- **Restricted:** High sensitivity, requires strong encryption and limited access.

Labeling data helps employees understand how to handle different types of data and ensures the right protection level is applied during encryption.



Theoretical Activity 2.7.3: Description Data Encryption Policies



Tasks:

1: Answer the following questions:

i. What are process for Developing Data Encryption Policies?

ii. Define Encryption Scope

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 2.7.3.



Key readings 2.7.3:

Data Encryption Policies

To ensure consistent and effective encryption practices, organizations must establish data encryption policies that define how and when encryption is used.

- **Developing Data Encryption Policies:**

Data encryption policies outline the organization's approach to encrypting sensitive data. Key components include:

  - Identification of sensitive data that requires encryption.
  - Responsibilities for implementing encryption practices.
  - Requirements for key management and secure key storage.
  - Regular auditing and monitoring to ensure compliance with encryption protocols.

- **Defining Encryption Scope:**

The encryption policy should specify the scope of encryption, addressing:

  - **Data at Rest:** Encrypting stored data, such as on databases, file servers, and backups.
  - **Data in Transit:** Encrypting data during transmission across networks, including email, file transfers, and web traffic (e.g., SSL/TLS).
  - **Endpoints:** Encryption of sensitive data on devices like laptops, mobile phones, and USB drives.

By defining the scope, organizations ensure that encryption is applied to the most critical areas of the data lifecycle.



Theoretical Activity 2.7.4: Description Encryption Implementation



Tasks:

1: Answer the following questions:

i. What are Implementing Data Encryption

ii. Describe Securing Data at Rest and in Transit

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 2.7.4.



Key readings 2.7.4:

Describe Encryption Implementation

After developing encryption policies and identifying sensitive data, organizations must implement encryption solutions to protect data in various states.

- **Implementing Data Encryption:**

Data encryption should be implemented using secure, industry-standard encryption algorithms and protocols. Key practices include:

  - Using **AES-256** for data at rest.
  - Employing **TLS** for encrypting data in transit, such as web traffic or email communication.
  - Ensuring that encryption keys are stored securely, ideally in hardware security modules (HSMs) or key management services (KMS).

- **Securing Data at Rest and in Transit:**

To fully protect sensitive data, organizations should ensure encryption covers both data at rest (stored data) and data in transit (moving data):

  - **Data at Rest:** Sensitive data stored in databases, file systems, or backups should be encrypted using strong algorithms like AES.

- **Data in Transit:** Communication channels carrying sensitive information should be encrypted using protocols such as TLS or VPNs to prevent interception and eavesdropping.

Implementing encryption across all critical phases of data transmission and storage strengthens overall security.



Practical Activity 2.7.5: Implementing data encryption



Tasks

1: Referring to the previous theoretical activity (2.7.4) you are requested to perform the following activity.

You are asked to go in computer and select different tools to be used in network monitoring
2: Read the key readings 2.7.5.



Key readings 2.7.5.

Implementing data encryption

Configure BitLocker on Windows 11/10

The BitLocker is preinstalled on hard drives to secure data from unauthorized access by encryption. It provides two approaches hardware-based encryption that employs a **Trusted Platform Module (TPM) chip and software-based encryption** that requires a **password** or USB flash drive as an authentication token.

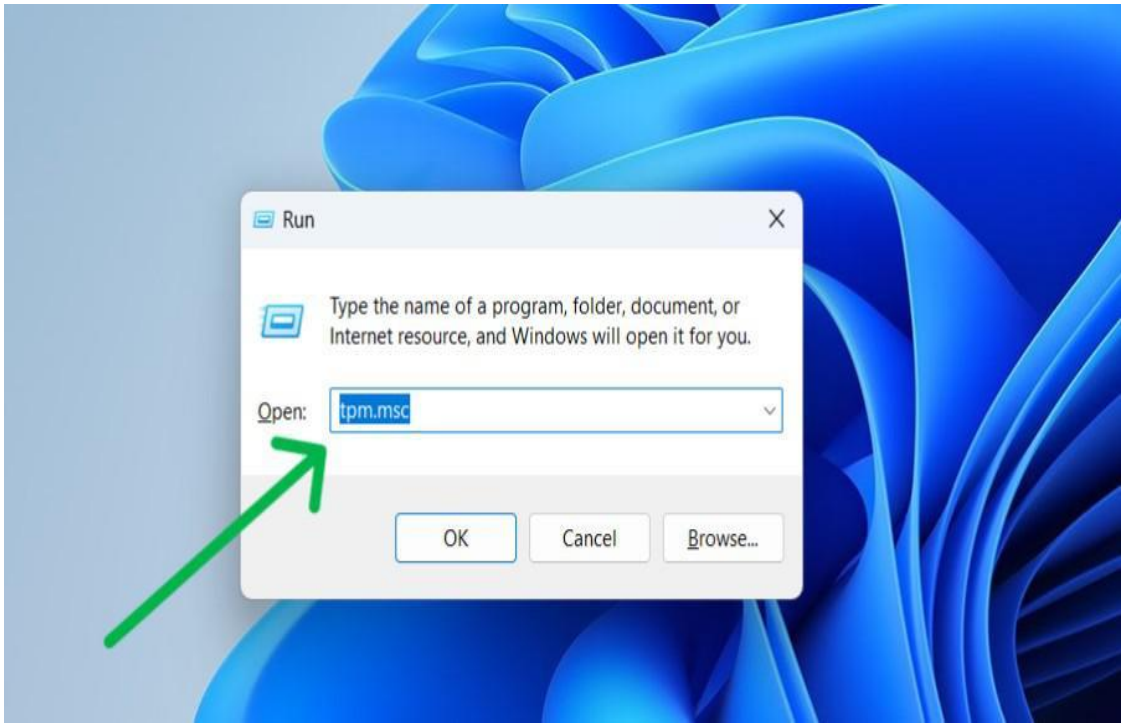
BitLocker safeguards installation drives, secondary storage media, and removable media with "**BitLocker To Go**". Encryption features on Windows devices have existed since the Windows 2000 operating system and have progressed to include entire drives as well as portable drives.

How to check if the device has TPM support to use BitLocker?

If you're wondering whether your computer can use **BitLocker encryption** on Windows 11 or 10, you first need to check if it has TPM support. TPM, or Trusted Platform Module, is a hardware component that provides extra security features. Here's how to check:

Step 1: To launch the Run dialog box, press **Windows Key + R.**

Step 2: Type ***tpm.msc*** and press Enter. **The TPM Management** console will open.



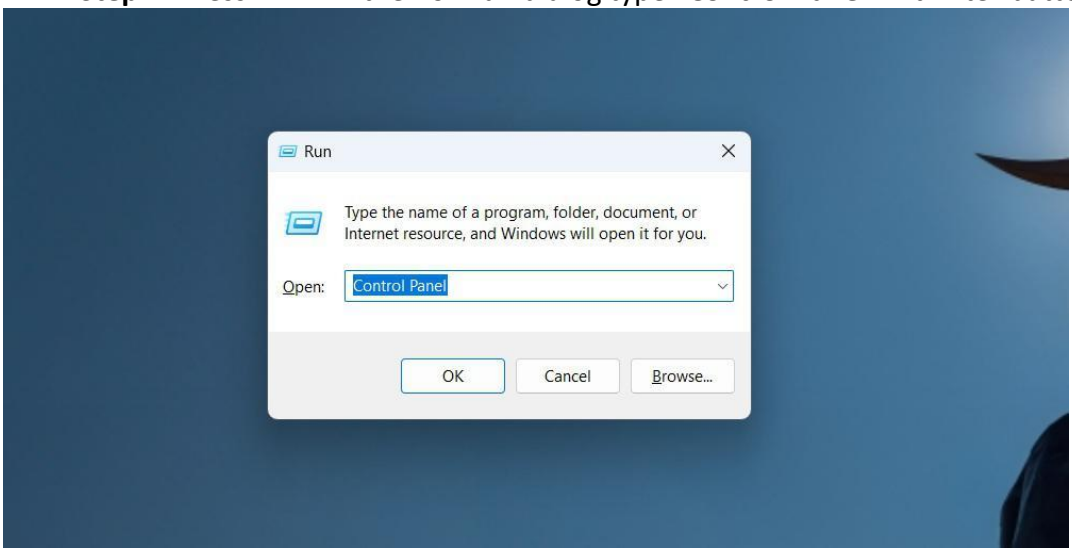
Step 3: Your device will display details about the TPM version and its status if it supports TPM. If it doesn't, a message stating "**Compatible TPM cannot be found**" will appear.

If you find TPM listed in Device Manager and it's version 1.2 or higher, congratulations! Your device supports BitLocker encryption. If not, you might need to enable TPM in BIOS or consider alternative encryption methods.

How To Enable (Hardware) BitLocker On System Drive?

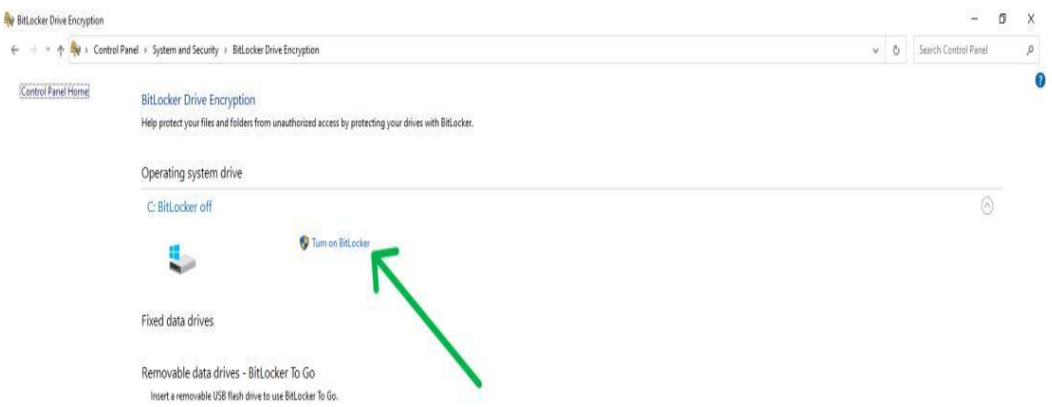
Enabling BitLocker on your system drive, which contains your operating system and important files, is a smart way to protect your data. Follow these simple steps to activate BitLocker on your Windows 11 or 10 system:

Step 1: Press Win + R then on run dialog type "**Control Panel"** hit Enter button

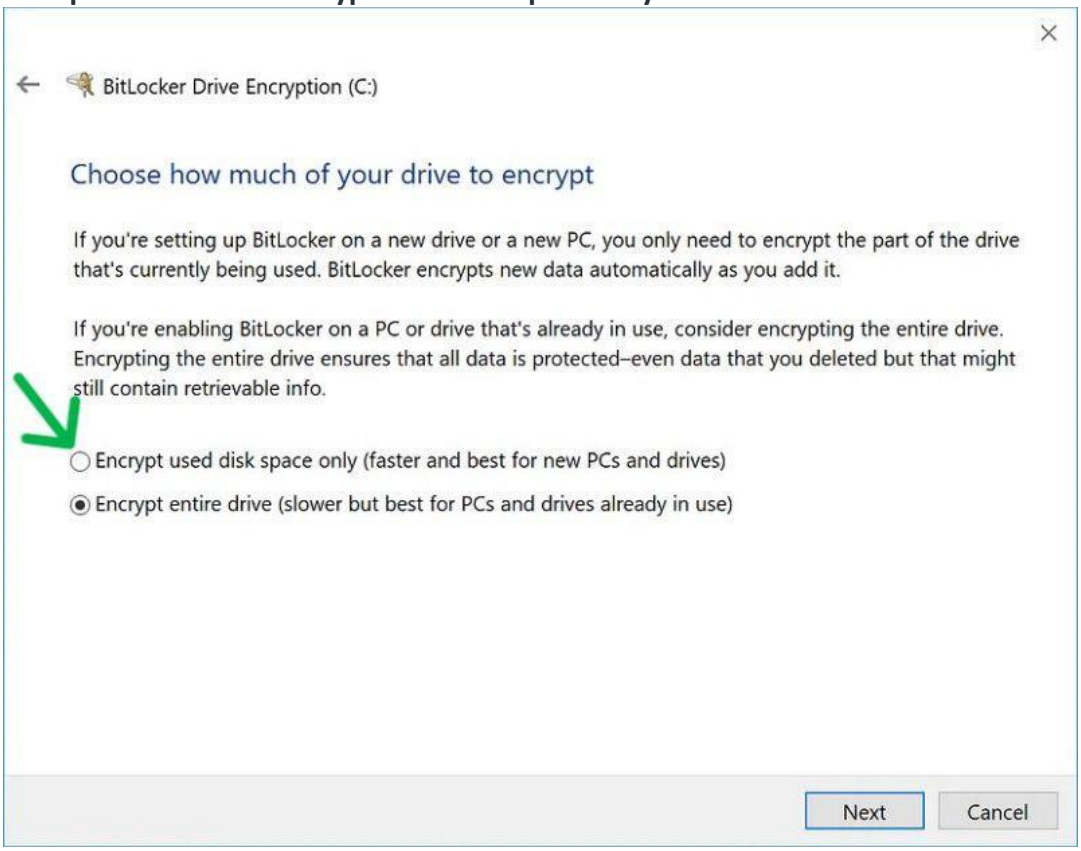


Step 2: Go to "**System and Security**" > "**BitLocker Drive Encryption** ".

Step 3: Under the "**Operating system drive**" section, click the on "**Turn on BitLocker**" option.



Step 4: Select the option to backup the recovery key, such as "**Save to your Microsoft account**."
Step 5: Click the **Next** button.
Step 6: Select the "**Encrypt used disk space only**" checkbox.



S**tep 7**: Click the **Next** button.
Step 8: Choose the "**New encryption mode**" option.
Step 9: Click the **Next** button.
(Optional) Select the "**Run BitLocker system check**" option.
Step 10: Click the **Restart now** button.
That's it! Your system drive is now protected by BitLocker encryption, helping to keep your data safe from unauthorized access.



Points to Remember

Description of Encryption in cyber security

- Encryption is a critical cybersecurity measure used to protect sensitive data by converting readable information (plaintext) into an unreadable format (ciphertext).
- This process ensures confidentiality, integrity, and availability (CIA), making sure that only authorized individuals with the correct decryption key can access or manipulate the data. Encryption is essential for safeguarding personal, financial, and confidential business information from unauthorized access.
- There are different types of encryption algorithms used depending on the specific needs of an organization. Symmetric encryption, Asymmetric encryption and Hashing algorithms.
- For effective implementation, organizations must establish encryption policies, identify sensitive data, and classify it appropriately. Data at rest (e.g., in databases) and data in transit (e.g., during network transmission) must be encrypted using industry-standard algorithms.

Identification of Sensitive Data

- Sensitive data may include personal identifiable information (PII), financial records, health records, and intellectual property. Recognizing data sensitivity helps organizations prioritize encryption efforts to protect high-value information from potential harm, ensuring that sensitive details are secured appropriately.
- Data classification and labeling play a key role in managing sensitive information. Organizations classify data based on its sensitivity and associated risk levels, which can range from public (low sensitivity) to confidential (moderate sensitivity) and restricted (high sensitivity). Labeling ensures that employees handle data correctly and apply the right level of encryption, thereby safeguarding critical information according to its importance.

Description Data Encryption Policies

- Developing data encryption policies is essential for safeguarding sensitive information within an organization. These policies should clearly define which types of data require encryption and assign responsibilities for implementing encryption practices. Key management procedures, including secure storage of encryption keys, must be established to prevent unauthorized access. Additionally, regular auditing and

monitoring are necessary to ensure ongoing compliance with encryption protocols, helping to maintain data security over time.

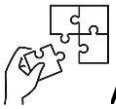
- The encryption policy should also define the scope of encryption, ensuring protection across critical stages of the data lifecycle. This includes encrypting **data at rest** (such as databases and backups), **data in transit** (such as email and web traffic), and securing endpoints like laptops and mobile devices. By setting clear guidelines, organizations can consistently apply encryption to sensitive areas, reducing the risk of data breaches.

Description Encryption Implementation

- Developing data encryption policies is essential for safeguarding sensitive information within an organization. These policies should clearly define which types of data require encryption and assign responsibilities for implementing encryption practices. Key management procedures, including secure storage of encryption keys, must be established to prevent unauthorized access. Additionally, regular auditing and monitoring are necessary to ensure ongoing compliance with encryption protocols, helping to maintain data security over time.
- The encryption policy should also define the scope of encryption, ensuring protection across critical stages of the data lifecycle. This includes encrypting **data at rest** (such as databases and backups), **data in transit** (such as email and web traffic), and securing endpoints like laptops and mobile devices. By setting clear guidelines, organizations can consistently apply encryption to sensitive areas, reducing the risk of data breaches

Steps to perform data encryption in windows 10

Step 1: Press Win + R then on run dialog type "**Control Panel"** hit Enter button
Step 2: Go to "**System and Security**" > "**BitLocker Drive Encryption** ".
Step 3: Under the "**Operating system drive**" section, click the on "**Turn on BitLocker**" option.
Step 2: Go to "**System and Security**" > "**BitLocker Drive Encryption** ".
Step 3: Under the "**Operating system drive**" section, click the on "**Turn on BitLocker**" option.
S**tep 7**: Click the **Next** button.
Step 8: Choose the "**New encryption mode**" option.
Step 9: Click the **Next** button.
(Optional) Select the "**Run BitLocker system check**" option.
Step 10: Click the **Restart now** button.
That's it! Your system drive is now protected by BitLocker encryption, helping to keep your data safe from unauthorized access.



Application of learning 2.7.

ISHEMO is a company with many computers that have Windows 10 installed. The company needs to encrypt data to ensure data confidentiality, integrity, and availability. You are tasked with encrypting the data stored on their secondary storage.

Indicative content 2.8 : Management of encryption keys

Duration: 6 hrs

Theoretical Activity 2.8.1: Description of management of encryption keys

Tasks:

1. Answer the following questions:
   i. Describe Encryption Key Lifecycle
   ii. Describe Key Management Policies
   iii. Describe Secure Key Storage and Distribution
   iv. Describe Key Rotation and Retirement

2.Present your group's findings on the discussed topics.

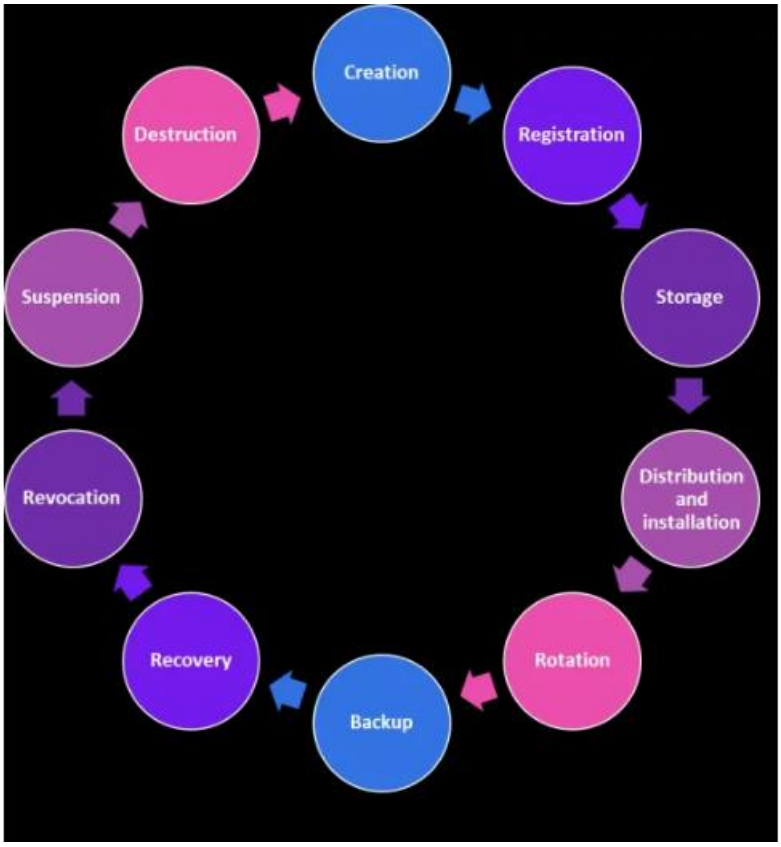
3. Ask clarification if any

4. Read the key readings 2.8.1

Key readings 2.8.1.:

Manage Encryption Keys

Encryption key management is crucial to maintaining the security and integrity of encrypted data. It involves the proper handling of encryption keys throughout their lifecycle, from generation to disposal. Poor key management can undermine the effectiveness of encryption, making data vulnerable to unauthorized access. The following sections outline best practices for managing encryption keys in a secure and structured manner.



1. Encryption Key Lifecycle

- **Key Generation and Initialization**:

Encryption keys must be securely generated using strong algorithms that ensure randomness and uniqueness. This process should take place in a secure environment, typically using hardware security modules (HSMs) or trusted cryptographic libraries to avoid vulnerabilities.

- **Key Usage and Maintenance**:

Once generated, encryption keys should be used for their intended purpose (e.g., encrypting data at rest or in transit) and monitored for any signs of compromise. Maintenance includes ensuring keys are accessible for legitimate use while preventing unauthorized access.

2. Key Management Policies

- **Establishing Key Management Policies**:

Organizations should develop key management policies that outline procedures for key generation, usage, storage, and disposal. These policies should also address key rotation, auditing, and compliance with regulatory requirements (e.g., GDPR, PCI DSS).

- **Policy Enforcement and Auditing**:

Regular audits should be conducted to verify compliance with key management policies. Automated tools can help monitor key usage and detect any policy violations, while enforcement ensures that security practices are followed consistently.

3 Secure Key Storage and Distribution

- **Secure Storage Solutions**:

Encryption keys should be stored in secure environments such as HSMs, cloud-based key management services (KMS), or secure software vaults to prevent unauthorized access. These solutions provide physical and logical protection for keys.

- **Key Distribution Methods**

Keys must be distributed securely to authorized users or systems. Secure methods include using public key infrastructure (PKI) or pre-shared secure channels, ensuring that keys are not exposed to interception during transmission.

4 Key Rotation and Retirement

- **Key Rotation Strategies**:

To minimize the risk of key compromise, keys should be regularly rotated. Key rotation involves replacing old keys with new ones, either on a scheduled basis or following a security incident. Proper coordination is required to avoid service disruptions during rotation.

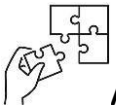
- **Key Retirement and Disposal Procedures**:

When encryption keys are no longer in use, they must be securely retired and destroyed to prevent future misuse. Key disposal should follow stringent processes, ensuring that keys are permanently deleted from all systems and backups.



Points to Remember

- Encryption Key Lifecycle include Key Generation and Initialization, Key Usage and Maintenance
- Key Management Policies deal with Establishing Key Management Policies, Policy Enforcement and Auditing
- Secure Key Storage and Distribution include Secure Storage Solutions and Key Distribution Methods
- Key Rotation and Retirement include Key Rotation Strategies, Key Retirement and Disposal Procedures



Application of learning 2.8.

ISH Corp is a financial services company that handles sensitive customer data, including payment details and personal identification information. To protect this data, ISH Crop uses encryption across its systems. Recently, a security audit highlighted the need for stronger encryption key management practices to prevent unauthorized access and ensure compliance with data protection regulations like GDPR. The company has tasked you to develop a comprehensive encryption key management strategy.

Indicative content 2.9: Update Endpoint Security for maintenance

Duration: 6 hrs

Theoretical Activity 2.9.1: Description of Endpoint security update

Tasks

1. Answer the following questions:
   i. Describe Endpoint Security.
   ii. Describe Endpoint Security solution
   iii. Describe Endpoint Security Configuration
2. Present your group's findings on the discussed topics.
3. Ask clarification if any

4. Read the key readings 2.9.1

Key readings 2.9.1.:

Description of Endpoint security update

An **endpoint** in cybersecurity refers to any device that connects to a network and communicates with other devices, systems, or servers. These devices can be a point of vulnerability, as they provide entry points for cyberattacks. Common examples of endpoints include:

- **Laptops and desktops**
- **Smartphones and tablets**
- **Servers**
- **Printers and scanners**
- **Internet of Things (IoT) devices** like smart thermostats, cameras, and medical devices

Maintaining endpoint security is essential to protect an organization's devices and networks from threats such as malware, unauthorized access, and data breaches. Regular updates to endpoint security measures ensure that all devices connected to the network are secure and comply with the organization’s security policies.

This section focuses on solutions and configuration best practices for maintaining endpoint security.

1. Endpoint Security Solutions

- **Antivirus and Anti-Malware Software**:

Deploying robust antivirus and anti-malware software is the first line of defense. Regular updates to these tools ensure they detect the latest threats. The software should be configured for automatic updates and real-time scanning to catch potential risks early.

- **Endpoint Detection and Response (EDR)**:

EDR solutions provide advanced threat detection and incident response capabilities. By continuously monitoring endpoints, EDR solutions can detect suspicious behavior, isolate compromised devices, and provide in-depth threat analysis.

- **Firewalls**:

Personal firewalls on individual devices help prevent unauthorized access to endpoints. Configuring firewall settings correctly ensures that inbound and outbound traffic is appropriately filtered, reducing the attack surface.

- **Data Loss Prevention (DLP)**:

DLP solutions help monitor and control the movement of sensitive data across endpoints, preventing data leaks. These solutions are especially useful for enforcing data protection policies and ensuring compliance with regulatory requirements.

- **Device Encryption**:

Encrypting data stored on endpoints such as laptops, desktops, and mobile devices ensures that even if the device is lost or stolen, sensitive information remains protected.

2. Endpoint Security Configuration

- **Patching and Software Updates**:

Keeping operating systems, software, and security applications up to date is critical to protecting against vulnerabilities. Automated patch management solutions ensure that all endpoints receive the necessary updates on time.

- **Access Control**:

Configuring endpoint devices with proper access control measures, such as multi-factor authentication (MFA) and strong password policies, minimizes the risk of unauthorized access. Role-based access control (RBAC) can also limit user privileges to what is strictly necessary.

- **Network Segmentation**:

Segmenting the network reduces the potential impact of a compromised endpoint by isolating devices and restricting access to sensitive areas of the network.

- **Endpoint Monitoring and Logging**:

Continuous monitoring of endpoints through logging and alerting systems helps detect unusual activity and potential security breaches. Regular review of logs can reveal patterns or vulnerabilities that require attention.



Practical Activity 2.9.2: Updating Endpoint Security for Maintenance



Task:

1: Referring to the previous theoretical activity (2.9.1) you are requested to perform the following activity.

You are tasked to go in computer lab and update computer that is available In computer lab

2: Read the key readings 2.9.2.

3: Update computer that is available In computer lab

Key readings 2.9.2.

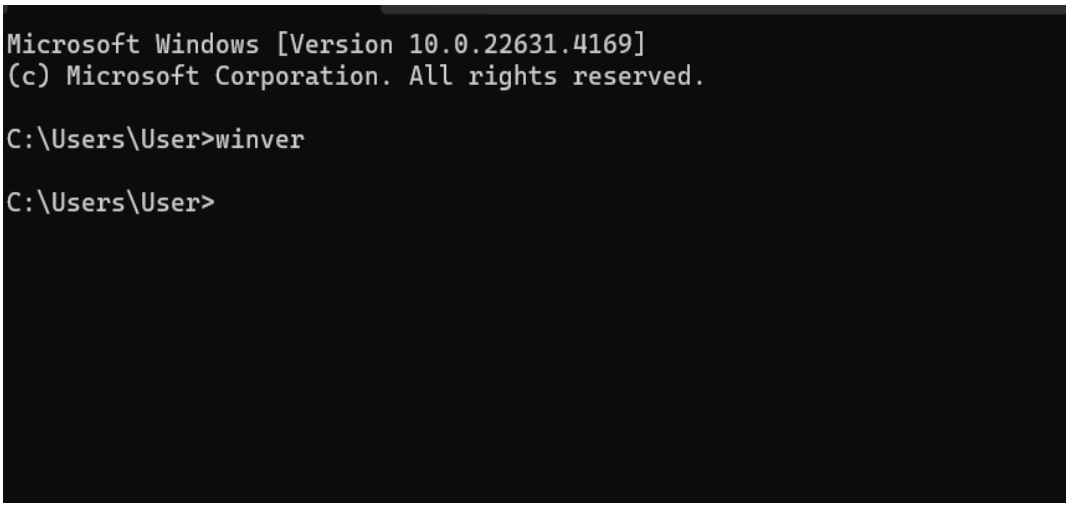
Update your windows 11 for security steps

1. Check your current version

The first step is to check your current version of the operating system and the system software. You can do this by using the command line or the graphical interface of your system. For example, on Windows, you can use the **winver** command or go to Settings > System > About. On Linux, you can use the **uname -a** command or go to System > About This Computer. On Mac, you can use the **sw_vers** command or go to Apple Menu > About This Mac. By checking your current version, you can see if there are any updates available or if you need to upgrade to a newer version.

Using command

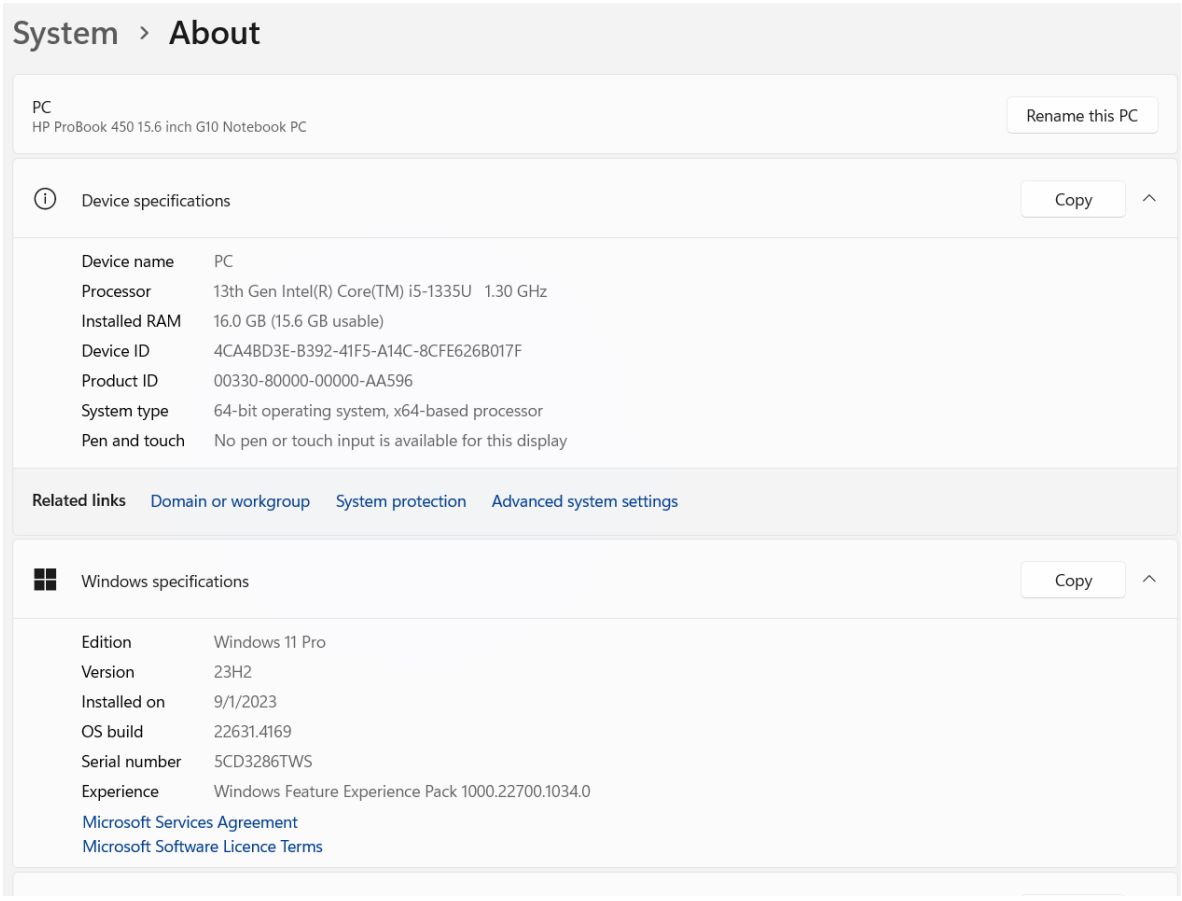
Command



Output



Using GUI

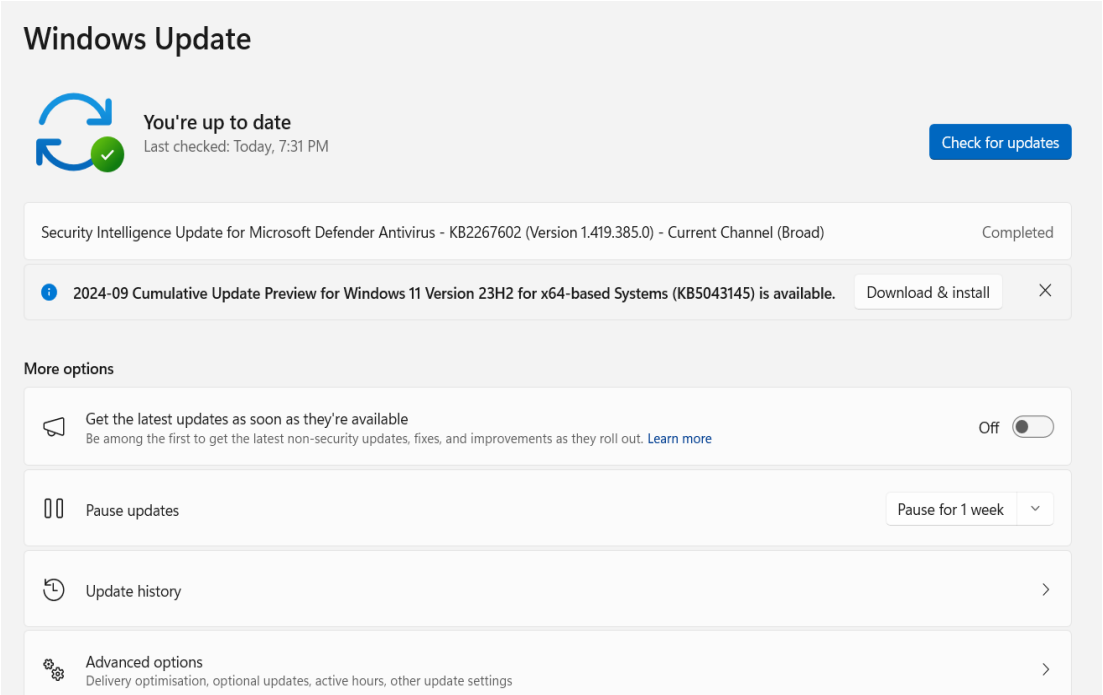


2. Backup your data

The second step is to backup your data before you update your system. This is a good practice to avoid losing any important files or settings in case something goes wrong during the update process. You can backup your data by using an external hard drive, a cloud service, or a network storage device. You can also use the built-in backup tools of your system, such as Windows Backup, Time Machine, or Deja Dup. Make sure your backup your data regularly and keep multiple copies in different locations.

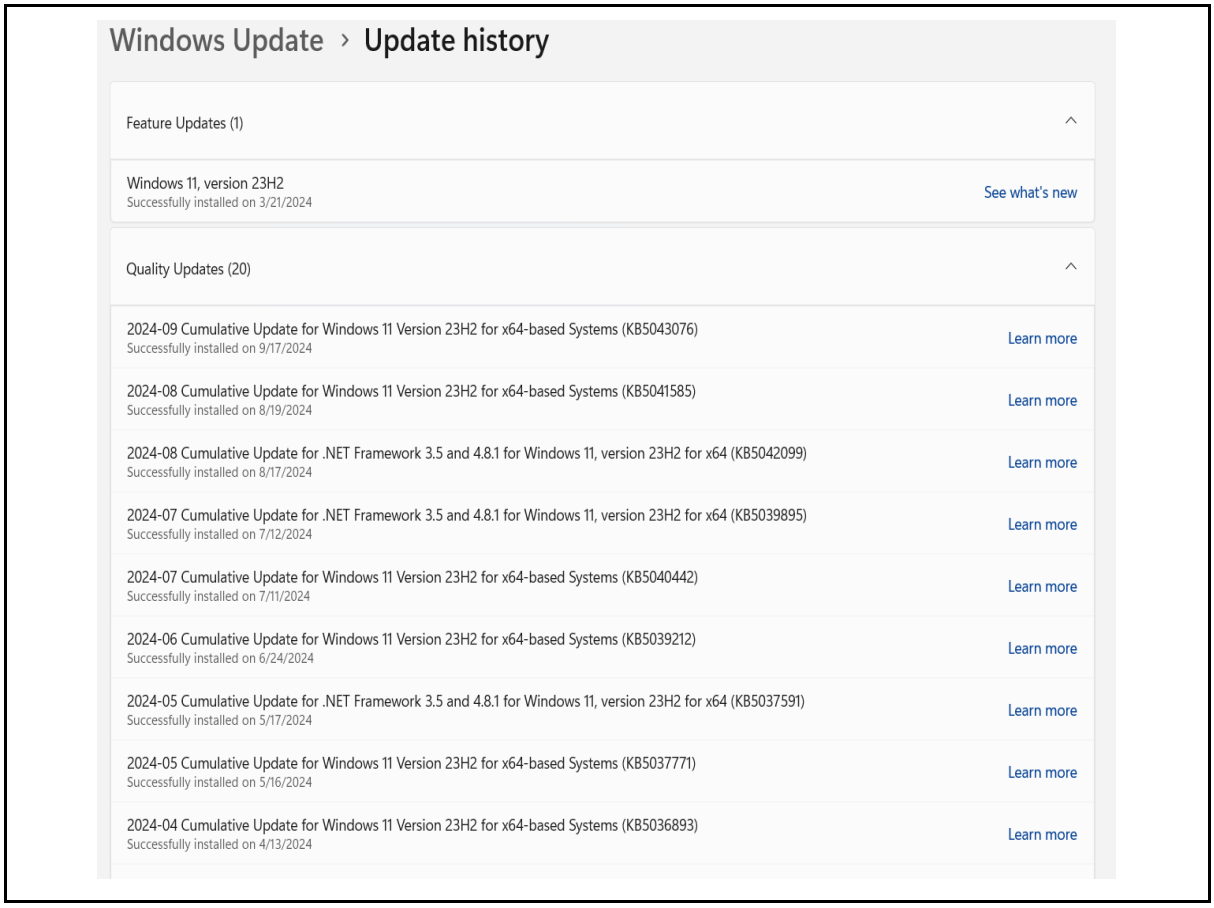
3. Install the updates

The third step is to install the updates for your system. You can do this by using the automatic or manual update options of your system. For example, on Windows, you can go to Settings > Update & Security > Windows Update and click on Check for updates. On Linux, you can use the package manager of your distribution, such as apt, yum, or pacman, and run the update command. On Mac, you can go to Apple Menu > System Preferences > Software Update and click on Update Now. You may need to restart your system after installing the updates.



4. Review the changes

The fourth step is to review the changes that the updates have made to your system. You can do this by checking the release notes, the changelog, or the documentation of the updates. You can also test your system for any errors, bugs, or compatibility issues that may have arisen from the updates. You can use the troubleshooting tools of your system, such as Event Viewer, System Monitor, or Console, to identify and fix any problems. You can also contact the support team of your system or the software vendor if you need any assistance.





Points to Remember

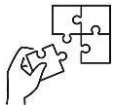
Description of Endpoint security update

- Maintaining endpoint security is crucial to protect an organization's devices from threats like malware and unauthorized access.
- Key solutions for endpoint security include deploying antivirus and anti-malware software, Endpoint Detection and Response (EDR) systems for advanced threat detection, firewalls to filter network traffic, and Data Loss Prevention (DLP) tools to monitor sensitive data

- Proper configuration is essential to maximize endpoint security. This includes applying patches and software updates to fix vulnerabilities, implementing access control measures like multi-factor authentication (MFA) and role-based access control (RBAC), and using network segmentation to isolate devices and minimize risks. Continuous endpoint monitoring and logging provide real-time threat detection, allowing organizations to identify and address potential security issues early on.

Steps to perform data encryption in windows 10

Steps to update windows 11 computers
1. Check your current version
2 Backup your data
3 Install the updates
4 Review the changes



Application of learning 2.9.

HAN is a mid-sized company with various computers running Windows 11. The company needs to enhance its security measures to protect its systems and data. You are assigned the task of updating their computers to improve overall security. This includes implementing necessary updates, security patches, and configurations to safeguard their infrastructure.

Indicative content 2.10: Implement Device Management Policies

Duration: 6 hrs

Theoretical Activity 2.10.1: Description of Device Management Policies

Tasks:

1: Answer the following questions:

i. Define Scope of Device Management?
ii. Describe Device Classification and Inventory
iii. Describe Configuring Device Settings and Access
iv. Describe Policy Enforcement and Compliance
v. Describe User Education on Device Management
vi. Describe Raising Awareness of Device Security
vii. Describe Continuous Policy Monitoring
viii. Describe Adapting Policies to Changing Needs

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 2.10.1

Practical Activity 2.10.2: Implementing Device Management Policies

Task:

1: Referring to the previous theoretical activity (2.10.1) you are requested to perform the following activity.

You are tasked to go in computer and select different tools to be used in network monitoring

2: Read the key readings 2.10.2.



Key readings 2.10.2.

Implement Device Management Policies involves creating rules and guidelines to manage devices in an organization securely. Steps for implementing device management policies

1. **Device Management Scope**: This step defines what devices are included in the management policy, such as computers, mobile phones, and other connected devices. It also involves creating an inventory of all devices and classifying them based on their type, importance, or security requirements.
2. **Device Configuration Policies**: Here, you set and enforce standard configurations for devices to ensure they meet security and operational needs. This includes controlling settings, managing access rights, and ensuring devices comply with the organization's security policies.
3. **User Training and Awareness**: Employees are trained on proper device management practices and made aware of security risks. This step ensures users understand how to handle devices securely and follow the organization's policies.
4. **Policy Monitoring and Adaptation**: Continuous monitoring is crucial to ensure compliance with device policies. Regular reviews are conducted, and policies are adapted as new technologies, threats, or business needs arise, ensuring they remain relevant and effective.



Points to Remember

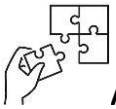
Description of Device Management Policies

- Device management policies help secure all devices connected to an organization's network. The first step is to define the scope, identifying and classifying all devices, such as company-owned computers, mobile devices, and IoT equipment. Keeping an inventory ensures that all devices are tracked and managed properly.
- Secure device configurations are set, including access controls, firewalls, and encryption
- User training is key to device security. Employees need to understand how to use devices securely and recognize potential risks. Regular training and awareness programs ensure that users follow safe practices.

- Device management policies need to be monitored continuously. Regular reviews and automated monitoring help identify issues, and policies should be updated to adapt to new technologies and emerging threats

Steps for Implementing Device Management Policies

1. Device Management Scope
2. Device Configuration Policies
3. User Training and Awareness
4. Policy Monitoring and Adaptation



Application of learning 2.10.

You are the IT administrator at a mid-sized company, tasked with implementing comprehensive device management policies. The company utilizes various devices, including laptops, smartphones, tablets, and desktops, all of which require consistent management to ensure security, compliance, and efficiency. Your goal is to implement and manage device policies that address device classification, configuration, user training, and continuous monitoring.

Indicative content 2.11 : Apply Security Patches for Security Management

Duration: 10 hrs

Theoretical Activity 2.11.1: Description of Security Patches for Security Management

Tasks

1: Answer the following questions:

i. Describe Patch Management Procedures?
ii. Describe Developing Patch Management Procedures
iii. Patch Assessment and Classification
iv. Describe Controlled Testing Environments
v. What are Deployment Strategies and Phases

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 2.11.1

Key readings 2.11.1.:

Describe Security Patches for Security Management

Security Patches for Security Management is focused on maintaining a secure IT environment by keeping systems up to date with the latest security patches. These patches address vulnerabilities that, if left unpatched, could be exploited by malicious actors to compromise the system.

1 Patch Management Procedures

This step outlines how patches are handled within an organization, from assessing their importance to rolling them out across all systems.

- **Developing Patch Management Procedures**: A well-defined procedure is crucial for managing the patching process. This involves setting a schedule for regular patch updates, defining roles and responsibilities for patch management, and determining how patches are tracked and applied to different systems.
- **Patch Assessment and Classification**: Not all patches are equal in priority. Some patches address critical security vulnerabilities, while others are more routine or

minor. Organizations need to assess the risk and urgency of each patch, classifying them based on severity, and then prioritize patches accordingly to minimize potential risks.

2 Testing and Deployment

Before applying patches system-wide, thorough testing and careful deployment are essential to avoid causing unintended issues.

- **Controlled Testing Environments**: Patches should first be tested in a controlled or isolated environment to ensure they do not negatively impact system functionality. Testing helps to detect any compatibility issues or system performance problems before deployment.
- **Deployment Strategies and Phases**: Once tested, patches are rolled out in a phased manner. A phased deployment minimizes risks by applying patches to critical systems first and gradually expanding to less critical systems. This ensures that any issues discovered early in the deployment can be addressed before affecting all systems. Regular monitoring during deployment ensures the success of the patching process.

Incorporating these practices ensures that systems remain secure and up to date without disrupting operations.



Practical Activity 2.11.2: Configuring automatic updates and update service location



Task:

1:Referring to the previous theoretical activity (2.11.1) you are requested to perform the following activity.

i. Your school needs to enable automatic updates for computers connected to its domain by using Windows Server Update Services (WSUS). This will ensure that all systems receive timely updates while allowing centralized control over the update process.

2: Read the key readings 2.11.2.
3: Perform update of school computers



Key readings 2.11.2.

WSUS scalability

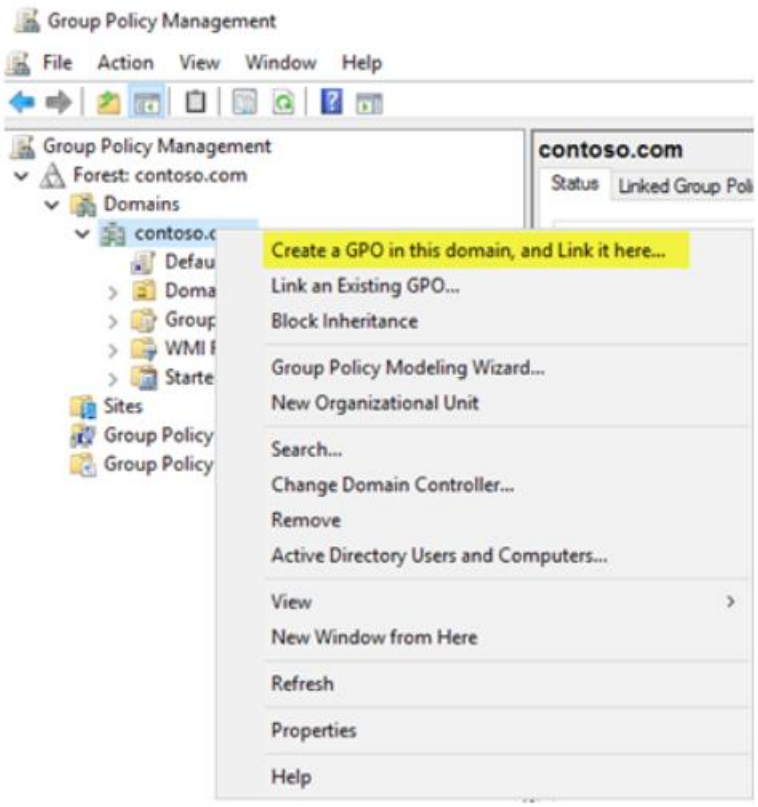
To use WSUS to manage all Windows updates, some organizations may need access to WSUS from a perimeter network, or they might have some other complex scenario. WSUS is highly scalable and configurable for organizations of any size or site layout. For specific information about scaling WSUS, including upstream and downstream server configuration, branch offices, WSUS load balancing, and other complex scenarios, see Deploy Windows Server Update Services.

Configure automatic updates and update service location

When using WSUS to manage updates on Windows client devices, start by configuring the **Configure Automatic Updates** and **Intranet Microsoft Update Service Location** Group Policy settings for your environment. Doing so forces the affected clients to contact the WSUS server so that it can manage them. The following process describes how to specify these settings and deploy them to all devices in the domain.

To configure the Configure Automatic Updates and Intranet Microsoft Update Service Location Group Policy settings for your environment

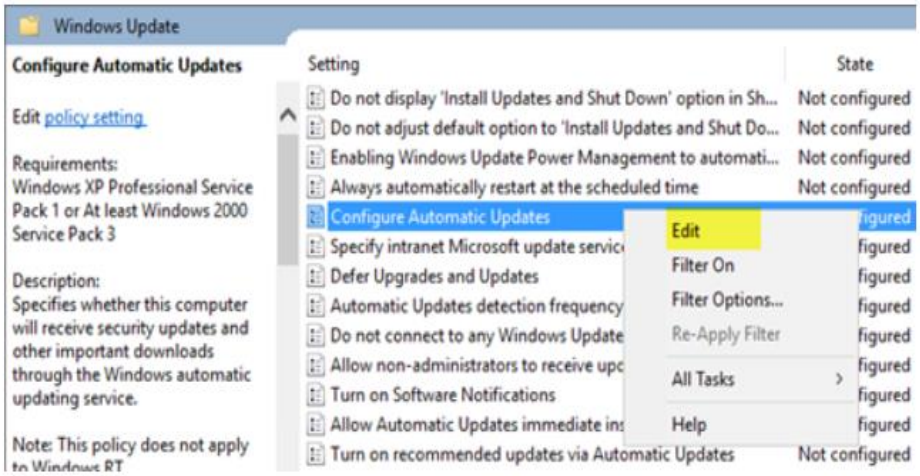
1. Open Group Policy Management Console (gpmc.msc).
2. Expand *Forest**Domains**Your_Domain*.
3. Right-click **Your_Domain**, and then select **Create a GPO in this domain, and Link it here**.



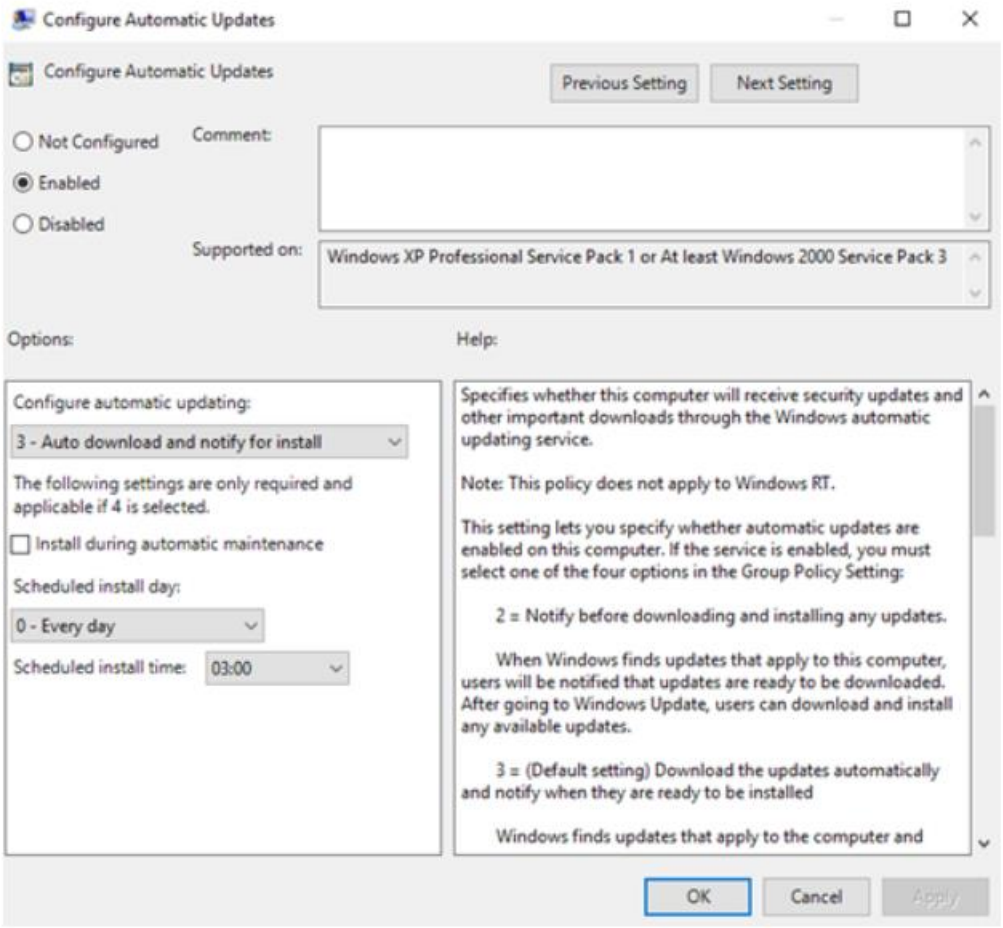
Note

In this example, the **Configure Automatic Updates** and **Intranet Microsoft Update Service Location** Group Policy settings are specified for the entire domain. This is not a requirement; you can target these settings to any security group by using Security Filtering or a specific OU.

4. In the **New GPO** dialog box, name the new GPO **WSUS - Auto Updates and Intranet Update Service Location**.
5. Right-click the **WSUS - Auto Updates and Intranet Update Service Location** GPO, and then select **Edit**.
6. In the Group Policy Management Editor, go to Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Update.
7. Right-click the **Configure Automatic Updates** setting, and then select **Edit**.

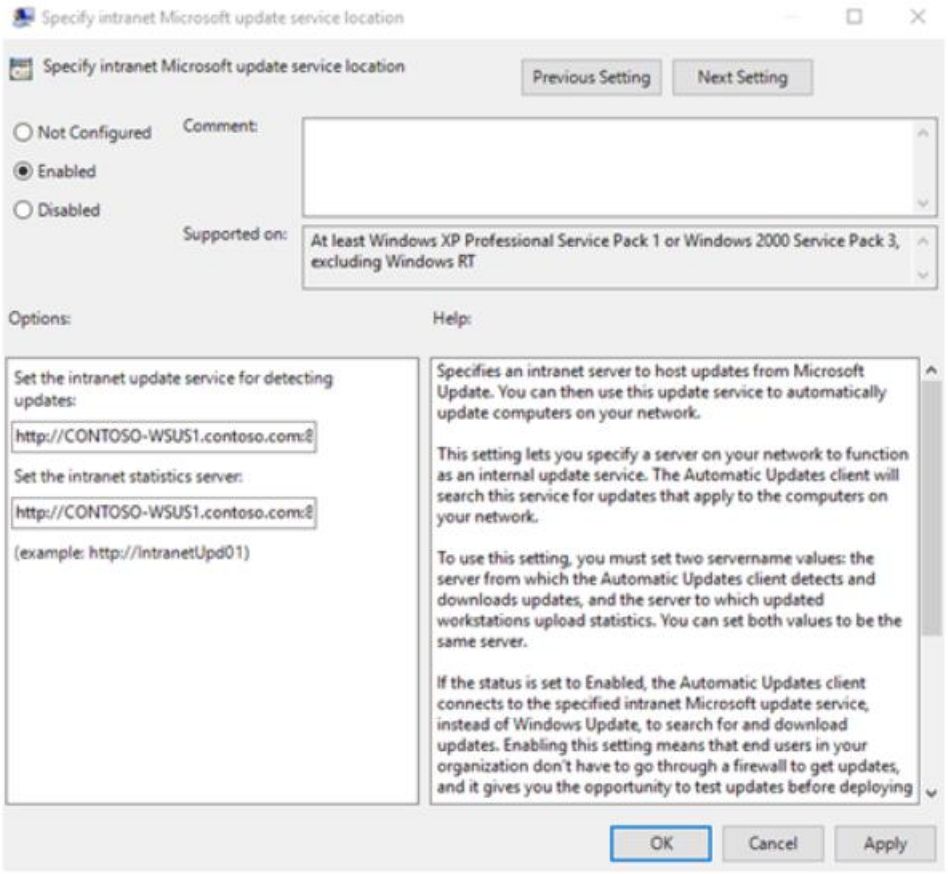


8. In the **Configure Automatic Updates** dialog box, select **Enable**.
9. Under **Options**, from the **Configure automatic updating** list, select **3 - Auto download and notify for install**, and then select **OK**.



.

10. Right-click the **Specify intranet Microsoft update service location** setting, and then select **Edit**.
11. In the **Specify intranet Microsoft update service location** dialog box, select **Enable**.
12. Under **Options**, in the **Set the intranet update service for detecting updates** and **Set the intranet statistics server** options, type http://Your_WSUS_Server_FQDN:PortNumber, and then select **OK**.



Note

The default HTTP port for WSUS is 8530, and the default HTTP over Secure Sockets Layer (HTTPS) port is 8531. (The other options are 80 and 443; no other ports are supported.)

As Windows clients refresh their computer policies (the default Group Policy refresh setting is 90 minutes and when a computer restarts), computers start to appear in WSUS. Now that clients are communicating with the WSUS server, create the computer groups that align with your deployment rings.



Points to Remember

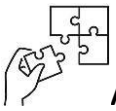
Description of Security Patches for Security Management

- Apply Security Patches for Security Management focuses on keeping systems secure by ensuring that they are up to date with the latest security patches. Patches are essential to fix vulnerabilities that could be exploited by attackers. Implementing a structured approach to patching ensures that systems remain secure and stable.
- Patch Management Procedures outlines the importance of having a clear process for managing patches. This includes developing a schedule, assigning roles, and determining how patches are tracked and applied. Patches must be assessed based on their severity—critical patches that address significant security vulnerabilities are prioritized, while less critical updates may be scheduled for later.
- Testing and Deployment ensures that patches are applied smoothly without causing system disruptions. Patches should be tested in a controlled environment before system-wide deployment to avoid compatibility issues. Once tested, a phased deployment strategy is used to gradually apply patches across systems, starting with critical infrastructure, to minimize risks. Continuous monitoring ensures successful implementation.

To configure the Configure Automatic Updates and Intranet Microsoft Update Service Location Group Policy settings for your environment

1. Open Group Policy Management Console (gpmc.msc).
2. Expand *Forest**Domains**Your_Domain*.
3. Right-click **Your_Domain**, and then select **Create a GPO in this domain, and Link it here**.
4. In the **New GPO** dialog box, name the new GPO **WSUS - Auto Updates and Intranet Update Service Location**.
5. Right-click the **WSUS - Auto Updates and Intranet Update Service Location** GPO, and then select **Edit**.
6. In the Group Policy Management Editor, go to Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Update.
7. Right-click the **Configure Automatic Updates** setting, and then select **Edit**.
8. In the **Configure Automatic Updates** dialog box, select **Enable**.
9. Under **Options**, from the **Configure automatic updating** list, select **3 - Auto download and notify for install**, and then select **OK**.
10. Right-click the **Specify intranet Microsoft update service location** setting, and then select **Edit**.

11. In the **Specify intranet Microsoft update service location** dialog box, select **Enable**.
12. Under **Options**, in the **Set the intranet update service for detecting updates** and **Set the intranet statistics server** options,
    type http://Your_WSUS_Server_FQDN:PortNumber, and then select **OK**.



Application of learning 2.11.

At **H_D Company**, the IT department is responsible for ensuring that all computers connected to the company's domain are regularly updated with the latest security patches, features, and system improvements. To accomplish this, the company has decided to implement **Windows Server Update Services (WSUS)**, a solution that will provide centralized control over the update process, ensuring that all devices are updated automatically while allowing IT to manage update approval and distribution as system administrator you are requested to enable automatic update for their computers.

Learning outcome 2 end assessment

Written assessment

SECTION I: fill the following paragraph with appropriate word from provided word below

Access control mechanisms play a crucial role in ensuring the security of systems and

- Restrict	- single-factor authentication (SFA)
- Role based	- unauthorized
- multi-factor authentication (MFA)	

sensitive information. These mechanisms help to **……** access to data and resources only to authorized users, thereby reducing the risk of breaches and attacks. One common approach is **……** access control, which assigns permissions based on user roles within an organization. Additionally, **……** enhances security by requiring users to verify their identity using two or more verification factors. Properly implemented access control not only prevents **……** access but also helps to maintain integrity and confidentiality across the network.

SECTION II. Read the statement below and answer by TRUE if it is correct or FALSE if it is incorrect

1. Discretionary Access Control (DAC) allows resource owners to control who has access to their resources.
2. In Mandatory Access Control (MAC), users have the flexibility to modify access permissions on their own files.
3. Role-Based Access Control (RBAC) assigns permissions based on the user's role within an organization.
4. Access Control Lists (ACLs) are used to manage both permissions for users and access control for network traffic.

5. ACLs are primarily used for restricting physical access to hardware systems.

6. In RBAC, users can only access the resources that are permitted to the roles they are assigned.

7. Access Control Lists (ACLs) can only be applied to user accounts, not network devices or traffic.

8. RBAC simplifies permission management in large organizations by grouping users into roles with common access needs.

9. In DAC, the permissions associated with a file can be modified by any user, not just the owner of the file.

10. Access Control Lists (ACLs) can be used in firewalls and routers to filter network traffic.

SECTION III. Choose the letter corresponding to the correct answers

1. **What is the first step in the access request workflow?**
   a) Approval decision
   b) Initiating access requests
   c) Escalation handling
   d) Recertification review
2. **Who is responsible for initiating access requests?**
   a) IT Administrator
   b) Requester
   c) Supervisor
   d) Security Officer
3. **Which of the following is a key responsibility of an access request approver?**
   a) Request routing
   b) Approving or denying requests
   c) Logging user activities
   d) Performing access reviews
4. **What is the purpose of an access review?**
   a) To define escalation rules
   b) To verify if users have appropriate access
   c) To initiate access requests
   d) To route access requests
5. **What happens if an access request is not approved in the workflow?**
   a) It is routed to the next level
   b) The request is automatically approved
   c) It is denied
   d) It is escalated or returned to the requester
6. **Which of the following is part of recertification procedures?**
   a) Identifying user permissions
   b) Routing access requests
   c) Approving access requests
   d) Requesting additional privileges

7. **What is the primary function of a firewall?**
   a) To allow all traffic
   b) To monitor and block unauthorized traffic

c) To grant administrative privileges
d) To install security patches

8. **Which type of firewall inspects traffic based on pre-configured rules?**
   a) Packet-filtering firewall
   b) Application firewall
   c) Host-based firewall
   d) Intrusion prevention system
9. **An IDS primarily:**

   a) Blocks traffic in real-time
   b) Detects and alerts on potential intrusions
   c) Prevents access to malicious websites
   d) Configures network policies

10. **Which of the following techniques is used by IPS to stop threats in real-time?**
    a) Signature-based detection
    b) Packet filtering
    c) Role-based access control
    d) Application whitelisting
11. **What should be done after deploying a firewall to ensure its effectiveness?**
    a) Enable default rules
    b) Test and review firewall rules
    c) Disable logging
    d) Implement recertification procedures
12. **Which of the following is a proactive threat mitigation technique used by an IPS?**
    a) Packet filtering
    b) Anomaly-based detection
    c) Enabling default configurations
    d) Approving access requests

13. **What is the primary goal of network segmentation?**
    a) To allow all traffic to pass
    b) To isolate critical systems and improve security
    c) To consolidate user permissions
    d) To allow full network access to administrators
14. **Which type of network segmentation separates users based on department or function?**
    a) Physical segmentation
    b) Logical segmentation
    c) Access segmentation
    d) Role-based segmentation
15. **What is the benefit of isolating critical systems?**
    a) Easier network access for all users
    b) Increased protection against unauthorized access
    c) Decreased network traffic
    d) Reduced need for security reviews

16. **What is an essential step in developing a network segmentation plan?**
    a) Identifying segmentation objectives
    b) Reducing firewall complexity
    c) Recertifying user access
    d) Deploying IDS solutions

17. **What is the primary purpose of encryption?**
    a) To store data in plain text
    b) To protect sensitive data from unauthorized access
    c) To increase file size
    d) To reduce processing power
18. **Which encryption method uses the same key for encryption and decryption?**
    a) Symmetric encryption
    b) Asymmetric encryption
    c) Hashing
    d) Biometric encryption
19. **In which scenario is encryption at rest used?**
    a) Data being transmitted over the network
    b) Data stored on a hard drive
    c) Data being printed
    d) Data used in volatile memory
20. **Which encryption principle ensures data has not been altered?**
    a) Confidentiality
    b) Integrity
    c) Availability
    d) Authentication
21. **What is a critical component of managing encryption keys?**
    a) Key rotation
    b) Access review
    c) Password complexity
    d) Recertification of permissions

22. **What is the role of endpoint security solutions?**
    a) To patch network firewalls
    b) To protect individual devices from threats
    c) To configure access control lists
    d) To manage encryption policies
23. **Which of the following is essential for securing endpoint devices?**
    a) Enabling automatic software updates
    b) Disabling antivirus programs
    c) Storing encryption keys on the device
    d) Allowing all software installations

24. **What is the first step in the patch management process?**
    a) Patch deployment
    b) Patch testing
    c) Patch assessment
    d) Patch removal
25. **Why is patch testing necessary?**
    a) To remove outdated patches
    b) To ensure patches do not cause system issues
    c) To delete unused software
    d) To configure firewalls
26. **Which environment should patches be tested in before deployment?**
    a) Production environment
    b) Controlled testing environment
    c) External network
    d) Internal firewall
27. **Which of the following is a key benefit of patch management?**
    a) Increased system downtime
    b) Protection against known vulnerabilities
    c) Simplified access request workflows
    d) Reduced need for network segmentation

28. **Which phase of the encryption key lifecycle involves securely generating keys?**
    a) Key rotation
    b) Key initialization
    c) Key retirement
    d) Key encryption
29. **How are keys stored securely?**
    a) In plaintext
    b) Using secure storage solutions like HSM (Hardware Security Module)
    c) On user devices
    d) In email attachments
30. **What is the purpose of key retirement?**

    a) To generate new keys

    b) To store keys in a secure database

    c) To securely decommission outdated or compromised keys

    d) To update encryption algorithms

Practical assessment

MP Company Headquarter located in Kigali city; it has three branches, one in Nyanza district, Musanze District and another on in Nyagatare district. The employees from Musanze branch no longer provide efficient services to the customers, but instead they are often busy doing unnecessary activities on the internet. As Network technician; you are requested to make necessary configurations on appropriate router so that the users in Musanze branch cannot communicate with the web server which is located at headquarter network and make necessary IDS configuration to monitor network traffic.



References

Ferraiolo, D. F., Kuhn, D. R., & Chandramouli, R. (2003). *Role-Based Access Control*. Artech House.

FIPS PUB 197. (2001). *Advanced Encryption Standard (AES)*. National Institute of Standards and Technology (NIST).

Fortinet. (n.d.). Configuring Intrusion Detection. *FortiRecorder 7.2.2 Administration Guide*. https://docs.fortinet.com/document/fortirecorder/7.2.2/administration-guide/206849/configuring-intrusion-detection

Harris, S. (2016). *CISSP All-in-One Exam Guide*. McGraw-Hill Education.

ISO/IEC 27001:2013. (2013). *Information technology – Security techniques – Information security management systems – Requirements*. International Organization for Standardization (ISO).

Kent, K., Chevalier, S., Grance, T., & Dang, H. (2006). *Guide to Intrusion Detection and Prevention Systems (IDPS)*. NIST Special Publication 800-94.

Rippling. (2024, August). Role-based access control (RBAC): What it is, benefits, and examples. https://www.rippling.com/blog/role-based-access-control

SolarWinds. (n.d.). What Is Role-Based Access Control (RBAC)? Definition and Benefits . https://www.solarwinds.com/resources/it-glossary/role-based-access-control


WARNING!
SECURITY BREACH!

Indicative contents
3.1 Security Threats Monitoring **3.2 Applying Monitoring Techniques and Threat Intelligence** **3.3 Conducting Methodical Threat Hunting with Intelligence Feeds** **3.4 Monitoring Network and System Logs** **3.5 Systems Scanning and Penetration Testing**

Key Competencies for Learning Outcome 3: Perform monitoring and detection

Knowledge	Skills	Attitudes
• Description of Security Threats Monitoring and Detection • Description of Monitoring Tools • Description of Monitoring Techniques • Description of Advanced Monitoring Techniques • Description of Security Threat Hunting • Description of Network and System Logs • Identification of Logging Tools and Real-time Monitoring • Description of Efficient Systems Scanning • Description of Penetration Testing	• Selecting Cyber Security Monitoring Tools • Conducting Methodical Threat Hunting with Intelligence Feeds • Using Logging Tools for Real-time Monitoring • Conducting Efficient Systems Scanning • Conducting penetration testing	• Having team spirit while working with others. • Being responsible. • Being organized to achieve the required result. • Having Curiosity. • Being Accountable • Being resilience. • Attention to details

Duration: 15 hrs

Learning outcome 3 objectives:

By the end of the learning outcome, the trainees will be able to:

1. Describe clearly Security Threats Monitoring within an organization.
2. Describe clearly Security Threats Detection within an organization
3. Describe Accurately the different types of monitoring tools used in cybersecurity
4. Differentiate Clearly between standard and advanced monitoring techniques
5. Describe properly the process of security threat hunting, using intelligence feeds to actively search for potential threats.
6. Analyze correctly Network and System Logs for detecting suspicious activity
7. Select properly Logging and Monitoring Tools
8. Describe correctly Efficient System Scanning Methods
9. Conduct properly Cybersecurity Penetration Testing
10. Conduct properly System Scanning and Logging for Real-time Threat Monitoring
11. Apply clearly methodical approaches to threat hunting by utilizing intelligence feeds and advanced monitoring techniques.
12. Report correctly Findings from Penetration Testing and Monitoring

Resources

Equipment	Tools	Materials
• Computer	• SIEM • Solar Wind Snort • Wireshark • Nessus • Graylog • Anti-virus	Internet Access

Indicative content 3.1 : Security Threats Monitoring

Duration: 3 hrs

Theoretical Activity 3.1.1: Description of Security Threats Monitoring and Detection

Tasks

1: Answer the following questions:

i. Describe Overview of Security Threats and Attacks
ii. What is Threat Monitoring
iii. What are Importance of Threat Monitoring

2: Present your group's findings on the discussed topics.
3. Ask clarification if any

4: Read the key readings 3.1.1.

Key readings 3.1.1.:
Description of Security Threats Monitoring and Detection

1. **Overview of Security Threats and Attacks**

To effectively monitor threats, it's essential to understand the different types of security threats and attacks that organizations may face. Here is an overview of the common security threats:

- **Malware:** Malicious software, including viruses, worms, ransomware, spyware, and Trojans, is one of the most widespread forms of attack. Malware can infiltrate a system to steal data, damage files, or take control of devices.
- **Phishing Attacks:** Attackers use phishing techniques to trick users into providing sensitive information such as usernames, passwords, or financial details. These attacks often occur via email, but can also happen through malicious websites or text messages.

- **Denial-of-Service (DoS) and Distributed Denial-of-Service (DDoS) Attacks:** DoS and DDoS attacks aim to overwhelm systems, networks, or servers with excessive traffic, causing them to crash and become unavailable to legitimate users.
- **Insider Threats:** Insider threats occur when employees or contractors intentionally or unintentionally compromise security. This could involve leaking sensitive information, mishandling data, or using privileges to access restricted areas of the system.
- **SQL Injection:** SQL injection attacks target web applications by injecting malicious SQL queries into the database via input fields. This can allow attackers to gain access to sensitive data, manipulate databases, or even execute system commands.
- **Man-in-the-Middle (MitM) Attacks:** In MitM attacks, attackers secretly intercept and alter communications between two parties, often to steal sensitive information or inject malicious code.
- **Advanced Persistent Threats (APTs):** APTs are highly sophisticated, prolonged attacks aimed at compromising specific targets, often for purposes of espionage or stealing valuable data. APTs involve multiple attack vectors and are often hard to detect due to their stealthy nature.
- **Zero-Day Exploits:** Zero-day vulnerabilities are software flaws that are unknown to the software vendor and have no existing fix. Attackers exploit these vulnerabilities before they can be patched, which makes them highly dangerous.
- **Brute Force Attacks:** These attacks involve attempting various combinations of passwords until the correct one is found. Brute force attacks can lead to unauthorized access to systems and sensitive data.

2. Categories of Security Threats:

1. **External Threats:** These threats originate from outside the organization, often involving hackers or cybercriminal groups. Common external threats include malware, DDoS attacks, and phishing.
2. **Internal Threats:** Internal threats arise from within the organization and often involve employees or contractors misusing their access. Insider threats can be intentional (malicious insiders) or accidental (negligence or human error).
3. **Targeted vs. Opportunistic Attacks:**
   - **Targeted Attacks:** These attacks are aimed at specific organizations or individuals, often for the purpose of stealing valuable data or causing disruption. Advanced persistent threats (APTs) are examples of targeted attacks.
   - **Opportunistic Attacks:** These attacks are not targeted at specific victims but rather exploit widespread vulnerabilities or misconfigurations that attackers can easily find.

3. Introduction to Security Threats Monitoring and Detection

Monitoring security threats is an essential part of any cybersecurity strategy. By detecting potential threats early, organizations can take timely action to prevent breaches, protect sensitive data, and maintain the integrity of their systems. This process involves continuously observing network traffic, system logs, and user activities to identify any abnormal or suspicious behavior that might indicate a cyberattack or other security incidents.

4. Importance of Threat Monitoring

Threat monitoring is critical to maintaining a secure environment for the following reasons:

- **Early Detection of Attacks:** Continuous monitoring helps in identifying attacks as soon as they occur or before they fully exploit vulnerabilities. This early detection allows security teams to respond quickly and minimize potential damage.
- **Preventing Data Breaches:** Organizations that monitor threats can prevent unauthorized access to sensitive information. Detecting threats early can stop attackers from extracting confidential data, such as customer records, financial details, or intellectual property.
- **Minimizing Damage from Threats:** Even when an attack occurs, monitoring helps in mitigating its impact. By responding swiftly to detected threats, organizations can reduce the spread of malware, limit system downtime, and prevent further exploitation.
- **Compliance with Regulations:** Many regulatory frameworks, such as GDPR, HIPAA, and PCI DSS, mandate security threat monitoring as part of compliance. Organizations that fail to monitor their networks and systems effectively may face legal consequences and penalties.
- **Improved Incident Response:** Security threat monitoring provides the data necessary for informed incident response. It allows organizations to understand the nature of the threat, its origin, and how it affects the system, thereby improving the efficiency of incident management teams.
- **Threat Intelligence and Proactive Defense:** By collecting and analyzing threat intelligence through monitoring, organizations can predict potential attacks and strengthen their defenses. Historical data from past incidents helps in creating patterns of behavior that indicate emerging threats.



Theoretical Activity 3.1.2: Description of Monitoring Tools



Tasks:

1: Answer the following questions:

i. Describe Intrusion Detection Systems (IDS) tools
ii. What are Security Information and Event Management (SIEM) Tools
iii. How can you Identify the Right IDS Tools and Right SIEM Tools?

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 3.1.2.



Key readings 3.1.2.:

Description of Monitoring Tools

Monitoring tools are essential in detecting and responding to security threats. Two key tools for monitoring network security are Intrusion Detection Systems (IDS) and Security Information and Event Management (SIEM) tools.

1. Intrusion Detection Systems (IDS)

An **Intrusion Detection System (IDS)** monitors network traffic and system activities for suspicious behavior or known patterns of attacks. If a potential threat is detected, the IDS generates an alert to notify the security team. IDS can be classified into two types:

- **Network-based IDS (NIDS):** Monitors network traffic for signs of attacks across the entire network.
- **Host-based IDS (HIDS):** Monitors activity on individual devices or systems, such as file modifications or unauthorized access attempts.

IDS tools are essential for identifying attacks like malware, unauthorized access, or denial-of-service (DoS) attacks before they cause significant damage.

Examples of IDS Tools:

A. **Snort**

- An open-source, free IDS that performs real-time traffic analysis and packet logging. Snort is widely used for detecting a wide range of attacks, including buffer overflows and stealth port scans.

B. **Suricata**

- A high-performance open-source IDS that can also function as an intrusion prevention system (IPS). It offers multi-threading support and is known for its speed and efficiency.

C. **OSSEC**

- A host-based IDS (HIDS) that monitors individual devices for suspicious activities. It's free and open-source, with features such as file integrity checking, rootkit detection, and log analysis.

D. **Bro (Zeek)**

- A powerful, open-source IDS that goes beyond simple signature detection by providing detailed network traffic analysis. Bro is often used in academic and research environments.

E. **Cisco Secure IPS**

- An enterprise-level IDS/IPS tool offered by Cisco that integrates with other Cisco security products to provide a robust solution for detecting and preventing threats.

2. Security Information and Event Management (SIEM) Tools

SIEM Tools are advanced monitoring systems that collect, analyze, and correlate data from various sources like network devices, applications, and servers. They centralize logs and security events, providing a comprehensive view of an organization's security posture.

SIEM tools are highly effective in:

- **Detecting security incidents in real-time** by analyzing data patterns.
- **Centralizing event logs** from various systems for better visibility.
- **Correlating multiple events** to identify complex attacks or breaches.

Reporting and compliance management by generating automated reports for regulatory purposes.

Selecting Cybersecurity Monitoring Tools

Choosing the right tools is crucial for effective threat detection and response. Organizations must carefully assess their needs before selecting the appropriate IDS and SIEM tools.

A. Identifying the Right IDS Tools

When selecting IDS tools, consider the following factors:

- **Coverage:** Ensure the IDS can monitor all critical parts of the network (e.g., NIDS for network monitoring or HIDS for device-level security).
- **Signature vs. Anomaly Detection:** Choose between signature-based IDS, which detects known threats, or anomaly-based IDS, which can detect unknown threats by recognizing abnormal behavior.
- **Performance and Scalability:** The IDS should handle the network's size and traffic volume without slowing down performance.
- **Integration:** Ensure that the IDS can integrate with existing security tools, such as firewalls or SIEM systems.

B. Identifying the Right SIEM Tools

When choosing a SIEM solution, key factors to consider include:

- **Log Collection and Analysis:** The SIEM should collect logs from a wide variety of sources, including servers, firewalls, and applications, and provide real-time analysis of those logs.
- **Event Correlation:** The SIEM must correlate data from different sources to detect complex attacks that involve multiple systems or stages.
- **Scalability and Performance:** The SIEM should scale with your organization's growth and handle the volume of data generated by your network.
- **Ease of Use:** The tool should have an intuitive dashboard and provide easy-to-understand reports for both technical and non-technical users.
- **Compliance and Reporting:** Ensure the SIEM can generate reports required for regulatory compliance (e.g., GDPR, PCI-DSS, HIPAA).

C. Examples of SIEM Tools:

- **Splunk**
  - One of the most popular SIEM tools, Splunk collects and analyzes logs from various sources. It's known for its scalability, real-time search capabilities,

and custom dashboards, making it highly effective for security monitoring and compliance.

- **IBM QRadar**
  - A robust SIEM platform designed to identify and prioritize security threats across the entire organization. It offers powerful event correlation and log management, along with real-time alerts and reporting.
- **ArcSight (Micro Focus)**
  - A well-known SIEM tool that provides real-time threat detection and analytics. ArcSight can handle massive amounts of data and is often used in large enterprises for its scalability and comprehensive security monitoring.
- **AlienVault (AT&T Cybersecurity)**
  - A more affordable SIEM solution that integrates threat detection, incident response, and compliance management. It's popular for smaller organizations looking for a full-featured SIEM without the complexity.
- **LogRhythm**
  - A comprehensive SIEM platform that combines log management, event correlation, and advanced analytics to detect and respond to security incidents in real-time. It's known for its user-friendly interface and advanced forensic capabilities.



Practical Activity 3.1.3: Selecting Cyber Security Monitoring Tools



Task:

1:Referring to the previous theoretical activity (3.1.2) you are requested to perform the following activity.

You are tasked to go in computer and select different tools to be used in network monitoring

2: Read the key readings 3.1.3.



Key readings 3.1.3.

Selecting the cybersecurity monitoring tools

Selecting the right cybersecurity monitoring tools is a crucial step in ensuring effective protection against security threats. Here is a simplified process to help guide the selection of the right tools, such as IDS and SIEM systems:

1. Assess Organizational Needs

- **Understand the Environment:** Identify your network size, complexity, and existing infrastructure.
- **Define Security Goals:** Clarify your key security objectives, such as detecting threats early, meeting compliance requirements, or improving incident response capabilities.
- **Evaluate Specific Threats:** Determine the type of threats you are most likely to face (e.g., malware, insider threats, advanced persistent threats).

2. Define Functional Requirements

- **Monitoring Coverage:** Ensure the tool can monitor all critical network segments, devices, and applications.
- **Real-time Alerts:** Choose tools that provide real-time detection and alerting capabilities for fast response.
- **Data Collection & Integration:** Select tools that can collect logs and data from various sources and integrate with other systems like firewalls, endpoint security, and identity management.
- **Reporting & Compliance:** Ensure the tool supports reporting features for regulatory compliance, such as GDPR, HIPAA, or PCI-DSS.

3. Evaluate Tool Types

- **Intrusion Detection System (IDS):** Consider whether you need a Network-based IDS (NIDS) or Host-based IDS (HIDS) based on the specific areas you want to monitor.
- **Security Information and Event Management (SIEM):** If you need broader log analysis and event correlation, choose a SIEM tool. SIEMs provide a centralized view of security logs and help identify complex, multi-step attacks.
- **Scalability and Performance:** Ensure the tools can handle the data volume and performance demands of your organization as it grows.

4. Consider Ease of Use and Management

- **User Interface & Usability:** Look for tools with intuitive dashboards and reporting systems, especially if your security team lacks extensive technical expertise.
- **Automation Capabilities:** Prioritize tools that can automate routine tasks like threat detection, log analysis, and report generation.
- **Support & Maintenance:** Choose tools with reliable vendor support, regular updates, and strong documentation for ease of use and long-term management.

5. Test & Compare Tool Options

- **Run Proof of Concept (PoC):** Test potential tools in your environment to see how they perform with your actual data and network traffic.
- **Compare Performance:** Assess key factors such as accuracy (low false positives/negatives), detection speed, and impact on system performance.
- **Vendor Reputation:** Research the reliability, reputation, and customer support of the vendors behind the tools.

6. Budget and Total Cost of Ownership

- **Initial Cost:** Compare the initial investment of each tool, including licensing fees.
- **Maintenance and Support:** Consider long-term costs for updates, maintenance, and support contracts.
- **Return on Investment (ROI):** Evaluate the tool's cost against the value it adds in terms of enhanced security, compliance, and incident response efficiency.

7. Select and Implement the Tool

- Once you have tested and compared different options, select the tool that best fits your requirements, budget, and security goals.
- Develop a phased implementation plan to roll out the tool across your network without disrupting operations.



Points to Remember

Description of Security Threats Monitoring and Detection

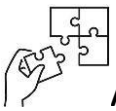
- There are many types of threats such us Malware, Phishing Attacks, Distributed Denial-of-Service (DDoS), Insider Threats, SQL Injection, Man-in-the-Middle (MitM) Attacks, Advanced Persistent Threats (APTs), Zero-Day Exploits, Brute Force Attacks
- Security threats monitoring involves keeping a close watch on network activities, system logs, and user behaviour to detect any suspicious or harmful actions.
- The goal is to identify potential threats early so that organizations can respond quickly, prevent data breaches, and protect their systems from attacks.

Description of Monitoring Tools

- Intrusion Detection Systems (IDS) monitor network traffic and system activity for signs of attacks or suspicious behaviour. They alert security teams when something unusual is detected. There are two types: Network-based IDS (NIDS) and Host-based IDS (HIDS).
- Security Information and Event Management (SIEM) Tools gather and analyze security data from various sources like network devices and servers. SIEM tools provide a complete view of security events in real time, help identify complex threats, and generate reports for compliance with regulations.
- When selecting IDS tools, it's important to ensure the tool covers all necessary areas, such as network or device monitoring. It should be able to detect both known threats (using signature-based methods) and new, unknown threats (through anomaly detection.
- SIEM tools, organizations need to choose one that can easily collect and analyze data from multiple sources, detect patterns of complex attacks, and grow with the network. The SIEM tool should be user-friendly and help meet compliance requirements by generating reports needed for audits.

Steps to selecting the right cybersecurity monitoring tools

1. Assess Organizational Needs
2. Define Functional Requirements
3. Evaluate Tool Types
4. Consider Ease of Use and Management.
5. Test & Compare Tool Options
6. Budget and Total Cost of Ownership
7. Select and Implement the Tool



Application of learning 3.1.

H.D is a company with many employees across different departments. The company needs to monitor its network traffic, and you are tasked with selecting tools that can help achieve this goal.

Indicative content 3.2: Applying Monitoring Techniques and Threat Intelligence

Duration: 3 hrs

Theoretical Activity 3.2.1: Description of Monitoring Techniques

Tasks:

1: Answer the following questions:

i. Describe to Monitoring Techniques
ii. What is Indicator of Compromise (IoC) Monitoring
iii. What is Behaviour-Based and Signature-Based Monitoring

2: Present your group's findings on the discussed topics.
3. Ask clarification if any

4: Read the key readings 3.2.1.

Key readings 3.2.1.:

Introduction to Monitoring Techniques

Monitoring techniques are essential for identifying and responding to security threats in real-time. They encompass various strategies and tools used to detect, analyze, and respond to potential threats within an organization's network. Effective monitoring not only enhances an organization's security posture but also aids in compliance with regulatory standards.

1. Indicator of Compromise (IoC) Monitoring

Indicators of Compromise (IoCs) are critical pieces of forensic data that identify potentially malicious activities on a system or network. IoCs can include unusual file modifications, abnormal outbound traffic, or known malicious IP addresses. By continuously monitoring for these indicators, organizations can detect intrusions early and take appropriate action to mitigate potential damage. Tools that support

IoC monitoring often integrate threat intelligence feeds to provide up-to-date information on emerging threats.

2. Signature-Based Monitoring

Signature-based monitoring relies on predefined patterns of known threats to detect intrusions, making it effective against known attacks but less effective against new, unknown threats.

3. Behavior-Based Monitoring

Behavior-based monitoring analyzes user and entity behavior to identify deviations from normal patterns. This approach can help detect anomalous activities, such as unusual login times or access to sensitive files, which may indicate a potential security breach.



Theoretical Activity 3.2.2: Description of Advanced Monitoring Techniques



Tasks:

1: Answer the following questions:

i. Describe Zero-Day, Phishing, and Malware Attacks Monitoring
ii. What is Vulnerability Monitoring
iii. Explain Threat Hunting and Incident Response

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 3.2.2.



Key readings 3.2.2.:

Advanced monitoring techniques

Advanced monitoring techniques are crucial for detecting sophisticated threats such as **zero-day exploits**, **phishing attempts**, and **malware attacks**

1. Zero-Day, Phishing, and Malware Attacks Monitoring

Phishing attacks trick users into revealing sensitive information, while malware can compromise systems and exfiltrate data. Implementing monitoring solutions that utilize machine learning and behavioral analytics can enhance the ability to detect these types of attacks in real-time.

2. Vulnerability Monitoring

Vulnerability monitoring involves continuously scanning systems and applications for known vulnerabilities that could be exploited by attackers. This proactive approach helps organizations prioritize remediation efforts based on the severity of the vulnerabilities detected. Regular vulnerability assessments and patch management are vital components of a robust security strategy, ensuring that systems remain protected against the latest threats.

3. Threat Hunting and Incident Response

Threat hunting is an active, proactive approach to identifying and mitigating potential threats before they can cause harm. It involves searching for anomalies and indicators of compromise that may not be detected by traditional monitoring tools. Incident response, on the other hand, focuses on responding to and managing security incidents when they occur. A well-defined incident response plan outlines the steps to take during an incident, helping organizations minimize damage and recover quickly. Integrating threat hunting with incident response enhances an organization's ability to adapt to evolving threats and improve overall security posture.



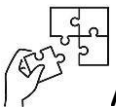
Points to Remember

Description of Monitoring Techniques

- Monitoring techniques are vital for the real-time identification and response to security threats within an organization's network. These techniques include various strategies and tools designed to detect, analyze, and address potential threats, thereby improving security and ensuring compliance with regulatory standards.
- Indicators of Compromise (IoCs), which are forensic data points that signal potentially malicious activities, such as unusual file changes or abnormal traffic. Continuous monitoring for IoCs allows organizations to detect intrusions early and take action to reduce potential harm, often utilizing tools that integrate threat intelligence feeds for current threat information.
- Signature-based monitoring detects known threats using predefined patterns
- Behavior-based monitoring focuses on analyzing deviations from normal user and entity behavior to identify anomalies that may indicate security breaches.

Description Advanced Monitoring Techniques

- Advanced monitoring techniques are crucial for detecting sophisticated threats, including zero-day exploits, phishing attacks, and malware.
- Zero-day exploits take advantage of vulnerabilities unknown to vendors, while phishing tricks users into revealing sensitive information, and malware can compromise systems and exfiltrate data
- vulnerability monitoring plays a key role by continuously scanning systems for known vulnerabilities, allowing organizations to prioritize remediation efforts based on severity. Regular vulnerability assessments and effective patch management are essential to maintaining robust security.
- Threat hunting proactively identifies potential threats, while incident response focuses on managing security incidents when they occur, minimizing damage and facilitating rapid recovery. Integrating both practices enhances an organization's adaptability to evolving threats and strengthens its overall security posture.



Application of learning 3.2.

XYZ Corporation is enterprise, Recently, the company has faced increased threats, including phishing attacks and potential vulnerabilities in its systems. To enhance its security posture, XYZ Corporation aims to implement advanced monitoring techniques. As a cybersecurity analyst at XYZ Corporation, you are tasked to explain both basic and advanced monitoring techniques.

Indicative content 3.3: Conducting Methodical Threat Hunting with Intelligence Feeds

Duration: 3 hrs

Theoretical Activity 3.3.1: Description Threat Hunting

Tasks:

1: Answer the following questions:

i. Describe Security Threat Hunting Methods

ii. What are threat hunting process (Collecting and Analyzing Threat Intelligence, Identifying and Validating Threats, Incident Response Procedures, Documentation and Reporting)

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 3.3.1.

Key readings 3.3.1.:

Description Threat Hunting

1. **Overview of Security Threat Hunting Methods**

Security threat hunting is a proactive approach to identifying and mitigating threats before they cause harm. Unlike traditional security measures that react to detected incidents, threat hunting seeks to discover threats based on hypotheses and indicators of compromise (IoCs). The primary methods of threat hunting include:

• **Hypothesis-Driven Hunting**: This method involves forming hypotheses about potential threats based on knowledge of the environment and past incidents. Hunters then search for evidence to confirm or refute these hypotheses.

- **Indicator-Based Hunting**: This approach relies on known IoCs, such as file hashes, IP addresses, or URLs associated with malicious activities, to search for signs of compromise in the network.
- **Behavioral Analysis**: This technique focuses on identifying anomalies and deviations from normal user behavior. It helps detect threats that may not be identified by signature-based solutions.
- **Machine Learning and Automation**: Incorporating machine learning algorithms can enhance the hunting process by automating the analysis of vast amounts of data and identifying patterns indicative of potential threats.

2. Threat hunting process

Conducting methodical threat hunting with intelligence feeds is essential for proactively identifying and mitigating cybersecurity threat. Threat hunting process include

2.1 Collecting and Analyzing Threat Intelligence

Collecting and analyzing threat intelligence is a foundational step in effective threat hunting. This process includes:

- **Gathering Intelligence**: Collect data from various sources, including threat intelligence feeds, open-source intelligence (OSINT), security advisories, and information sharing communities.
- **Analyzing Data**: Once collected, the data must be analyzed to extract actionable insights. This involves identifying relevant IoCs, understanding threat actor tactics, techniques, and procedures (TTPs), and correlating the intelligence with the organization's environment.
- **Prioritizing Intelligence**: Assess the relevance and credibility of the collected intelligence to prioritize which threats to address based on their potential impact on the organization.

2.2 Identifying and Validating Threats

Identifying and validating threats is crucial for ensuring that resources are focused on genuine risks. This process involves:

- **Threat Identification**: Use the analyzed threat intelligence to pinpoint potential threats that could affect the organization's systems. This includes mapping IoCs to the organization’s assets and monitoring systems.

• **Validation of Threats**: Validate identified threats to ensure they are credible and relevant. This may involve cross-referencing with other security data, conducting further analysis, or using automated tools to confirm the presence of threats.
• **Risk Assessment**: Assess the potential impact and likelihood of validated threats to prioritize response efforts effectively.

2.3. Incident Response Procedures

Incident response procedures outline the actions to be taken when a potential threat is detected. Key components include:

• **Preparation**: Develop and maintain an incident response plan that includes roles, responsibilities, and communication strategies.
• **Detection and Analysis**: Implement processes to detect incidents using threat intelligence and established monitoring tools. Analyze the incident to determine its scope and potential impact.
• **Containment, Eradication, and Recovery**: Quickly contain the threat to prevent further damage, eradicate the root cause of the incident, and restore affected systems to normal operations.
• **Post-Incident Review**: Conduct a review after an incident to identify lessons learned, assess the effectiveness of the response, and improve future incident handling.

2.4. Documentation and Reporting

Documentation and reporting are critical for effective threat hunting and incident management. This involves:

• **Comprehensive Documentation**: Maintain detailed records of threat hunting activities, including collected intelligence, identified threats, and incident responses. Documenting each step provides a clear audit trail.
• **Reporting Findings**: Summarize and report findings to stakeholders, including management and IT teams. Effective reporting should communicate the significance of threats and the organization's response efforts.
• **Continuous Improvement**: Use documentation and reports to identify trends, improve threat-hunting strategies, and enhance the overall security posture of the organization.

Conducting methodical threat hunting with intelligence feeds is essential for proactively identifying and mitigating cybersecurity threats. By understanding the various hunting methods, collecting and analyzing threat intelligence, validating

threats, establishing incident response procedures, and maintaining thorough documentation, organizations can enhance their ability to defend against evolving cyber threats effectively.



Practical Activity 3.3.2: Conducting Methodical Threat Hunting with Intelligence Feeds



Task:

1: Referring to the previous theoretical activity (3.3.1) you are requested to perform the following activity.

You are tasked to go in computer and use Malware Information Sharing Platform for threat hunting

2: Read the key readings 3.3.2.



Key readings 3.3.2.

Conducting Methodical Threat Hunting with Intelligence

Using MISP (Malware Information Sharing Platform) for threat hunting involves several key steps to effectively gather, analyze, and act on threat intelligence. Here's a structured approach to leveraging MISP in your threat-hunting efforts:

1. **Setup and Configuration**

- **Configure Users and Roles**: Set up user accounts and define roles to control access to different features and data.
- **Integrate Threat Intelligence Feeds**: Connect MISP to various threat intelligence feeds (e.g., AlienVault OTX, Open Threat Exchange) to enrich your data.

2. **Data Collection**

- **Gather Indicators of Compromise (IoCs)**: Collect IoCs relevant to your environment, such as file hashes, IP addresses, domains, and URLs associated with known threats.
- **Import Threat Intelligence**: Use MISP's import features to add external threat intelligence data, including reports and IoCs from trusted partners.

3. **Creating Attributes and Events**

• **Create Events**: Organize related IoCs and threat information into MISP events. Each event can represent a specific incident, threat campaign, or research findings.
• **Add Attributes**: Within each event, add attributes that detail the specific IoCs and contextual information (e.g., descriptions, references, analysis).

4. **Data Analysis and Correlation**

• **Analyze Threat Data**: Use MISP's built-in tools to analyze the collected threat data, looking for patterns, trends, and anomalies.
• **Correlate with Internal Data**: Cross-reference MISP data with your internal logs, alerts, and previous incidents to identify potential threats in your environment.

5. **Threat Hunting**

• **Search and Query**: Utilize MISP's search functionality to find relevant IoCs and events that may indicate ongoing or emerging threats.
• **Hunt for Anomalies**: Analyze your network and systems for deviations that align with the IoCs from MISP, such as unusual outbound traffic or unexpected file changes.

6. **Collaboration and Information Sharing**

• **Share Findings**: If you identify significant threats or incidents, share your findings with trusted partners or within your organization using MISP's sharing capabilities.
• **Participate in Communities**: Engage with MISP community groups or industry-specific groups to exchange threat intelligence and insights.

7. **Documentation and Reporting**

• **Document Threats**: Maintain detailed records of any threats identified during the hunting process, including IoCs, analysis results, and response actions taken.
• **Generate Reports**: Use MISP's reporting tools to create reports on your threat-hunting activities and findings for stakeholders.

8. **Continuous Improvement**

• **Review and Refine Processes**: After completing a threat-hunting cycle, review the process to identify improvements and update your IoCs and hunting methodologies.

• **Update MISP with New Findings**: Feed any new IoCs or insights gained during the hunt back into MISP to enhance future threat intelligence and hunting efforts.

9. **Automation (Optional)**

• **Integrate with Security Tools**: Connect MISP with SIEMs, EDRs, and other security tools to automate the threat-hunting process and enhance real-time detection capabilities.
• **Implement Playbooks**: Develop and use automated playbooks in conjunction with MISP to streamline incident response when threats are detected.



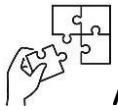
Points to Remember

Description Threat Hunting

- The primary methods of threat hunting include: Hypothesis-Driven Hunting**,** Indicator-Based Hunting**,** Behavioural Analysis**,** Machine Learning and Automation
- threat hunting process include Collecting and Analyzing Threat Intelligence, Identifying and Validating Threats, Incident Response Procedures, Documentation and Reporting.

Steps for using MISP (Malware Information Sharing Platform) for threat hunting:

1. Setup and Configuration
2. Data Collection
3. Creating Attributes and Events
4. Data Analysis and Correlation
5. Threat Hunting
6. Collaboration and Information Sharing
7. Documentation and Reporting
8. Continuous Improvement
9. Automation (Optional)



Application of learning 3.3.

In VITAL financial institution, the security team has identified an uptick in phishing attempts targeting their employees. To enhance their threat-hunting efforts, they decide to utilize MISP to share, analyze, and respond to relevant threat intelligence.

Indicative content 3.4: Monitoring Network and System Logs

Duration: 3 hrs

Theoretical Activity 3.4.1: Description of Network and System Logs

Tasks:

1: Answer the following questions:

i. Describe Network and System Logs Monitoring
ii. What are Role of Logs in Security?
iii. Describe of Logging Policies and Standards?

2: Present your group's findings on the discussed topics.
3. Ask clarification if any

4: Read the key readings 3.4.1.

Key readings 3.4.1.:

Description of Network and System Logs

Network and System Logs Monitoring refers to the process of collecting, analyzing, and reviewing log data generated by an organization's network devices, servers, applications, and systems. These logs contain records of activities and events that occur within the network, such as user access, configuration changes, network traffic, and system errors. By monitoring these logs, organizations can detect security threats, performance issues, and operational irregularities in real time.

1. Role of Logs in Security

Logs play a crucial role in cybersecurity by recording system activities, user interactions, and network events. They provide a detailed history of what happens across an organization's network, applications, and systems, which is essential for:

• **Detecting Anomalies**: Logs help identify suspicious behavior, potential breaches, and unusual activities that may indicate a security incident.

- **Incident Response**: In the event of a breach, logs provide evidence and help security teams understand how the attack occurred, enabling more effective containment and recovery.
- **Compliance**: Many regulatory standards require organizations to maintain logs for auditing purposes. Logs are essential for demonstrating compliance with security standards and legal requirements.
- **Forensic Investigations**: Logs offer historical data that investigators can analyze to uncover the root cause of an attack or anomaly.

2. Description of Logging Policies and Standards

Logging policies and standards outline how logs should be generated, stored, and managed within an organization. Proper logging practices ensure that all critical activities are recorded and that the logs are protected from tampering. Key aspects of logging policies include:

- **Data Retention**: Defining how long logs should be kept based on business needs, compliance requirements, and legal obligations.
- **Log Integrity**: Ensuring logs are protected from unauthorized access or modification, typically using encryption or access controls.
- **Log Generation**: Specifying which systems, applications, and devices must generate logs and what events must be logged.
- **Audit and Review**: Periodically reviewing logs to ensure the organization adheres to its logging policy and to identify areas for improvement.

3. Common standards related to logging

- **NIST (National Institute of Standards and Technology)**: Provides guidelines on log management and security in NIST Special Publication 800-92.
- **ISO/IEC 27001**: Contains requirements for monitoring and logging information security events as part of an organization's Information Security Management System (ISMS).



Theoretical Activity 3.4.2: Identification of Logging Tools and Real-time Monitoring



Tasks:

1: Answer the following questions:

i. What are criteria for Selecting of Logging Tools
ii. How can you Implementing Log Management for Real-time Monitoring?
iii. How can you Implementing Automated Alerts and Thresholds?

2: Present your group's findings on the discussed topics.
3. Ask clarification if any
4. Read the key readings 3.4.2.



Key readings 3.4.2:

Identification of Logging Tools and Real-time Monitoring

1. Selection of Logging Tools

Selecting the right logging tools is critical for effective log management and monitoring. A wide range of logging tools are available, each offering different features based on organizational needs. Key factors to consider when selecting logging tools include:

- **Scalability**: The tool should be able to handle the volume of logs generated by an organization's infrastructure.
- **Centralized Log Management**: A good logging tool consolidates logs from various sources (servers, applications, network devices) into a centralized location, making it easier to manage and analyze.
- **Search and Analysis**: The tool should support easy searching, filtering, and analyzing of logs, allowing security teams to quickly detect anomalies and potential threats.
- **Integration with Other Security Tools**: The logging tool should integrate well with other cybersecurity solutions, such as Security Information and Event Management (SIEM) systems and Intrusion Detection Systems (IDS).

Some widely used logging tools include:

- **Syslog**: A standard for sending system log messages across a network, used primarily for Unix-based systems.
- **Windows Event Viewer**: The default log viewer for Windows-based systems.
- **Splunk**: A robust platform for searching, monitoring, and analyzing machine-generated data.
- **Graylog**: An open-source log management tool offering powerful log collection and analysis capabilities.

2. Implementing Log Management for Real-time Monitoring

Real-time monitoring of network and system logs involves continuously analyzing logs as they are generated to detect security incidents or performance issues as they occur. To implement effective real-time log management, organizations should:

- **Centralize Logs**: Collect logs from all systems, devices, and applications into a centralized logging platform. This allows for a unified view of all activities across the organization.
- **Set Up Log Normalization**: Ensure that logs from different systems are standardized into a common format, making it easier to analyze them together.
- **Define Log Retention Policies**: Set up automated processes for archiving or deleting older logs, while maintaining compliance with any relevant legal or regulatory requirements.
- **Use SIEM Systems**: Integrate Security Information and Event Management (SIEM) solutions for real-time analysis of logs. SIEM tools collect, analyze, and correlate log data from multiple sources, providing a comprehensive view of an organization's security posture.

3. Implementing Automated Alerts and Thresholds

Automated alerts and thresholds are essential for real-time log monitoring, allowing security teams to be promptly notified when suspicious activities or potential threats are detected. Setting up automated alerts involves:

- **Defining Thresholds**: Establish thresholds that trigger alerts when abnormal activities occur. For example, repeated failed login attempts or unauthorized access to sensitive files might trigger an alert.
- **Configuring Alerts**: Configure the log management system or SIEM tool to send automated alerts when thresholds are exceeded. Alerts can be delivered via email, SMS, or integrated into security dashboards.

- **Tuning Alerts**: Regularly review and adjust alert thresholds to minimize false positives while ensuring real threats are detected. It's important to balance sensitivity with the volume of alerts, so the security team isn't overwhelmed by unnecessary warnings.
- **Response Mechanisms**: Ensure that alerts trigger a well-defined response. The response plan should include immediate actions such as investigation, containment, or escalation to the incident response team.



Practical Activity 3.4.3: Using Logging Tools for Real-time Monitoring



Task:

1: Referring to the previous theoretical activity (3.4.2) you are requested to perform the following activity.

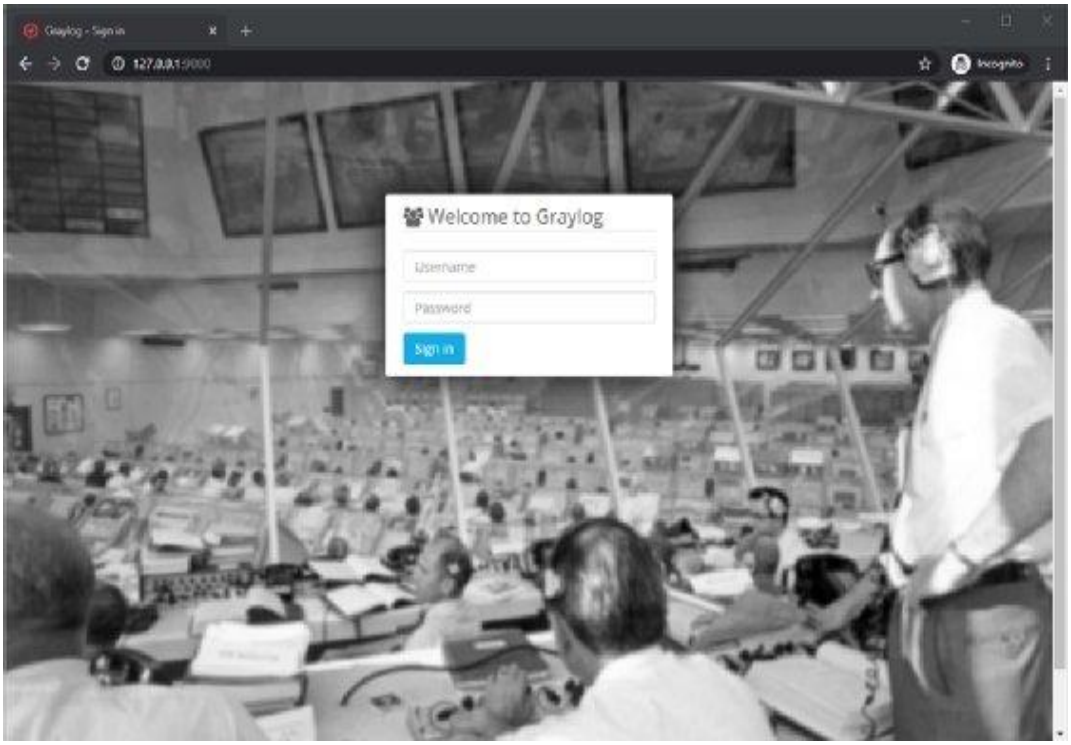
You are tasked help school to monitor network and system logs by using Graylog tools
2: Read the key readings 3.4.3.

Key readings 3.4.3.

Using Logging Tools for Real-time Monitoring

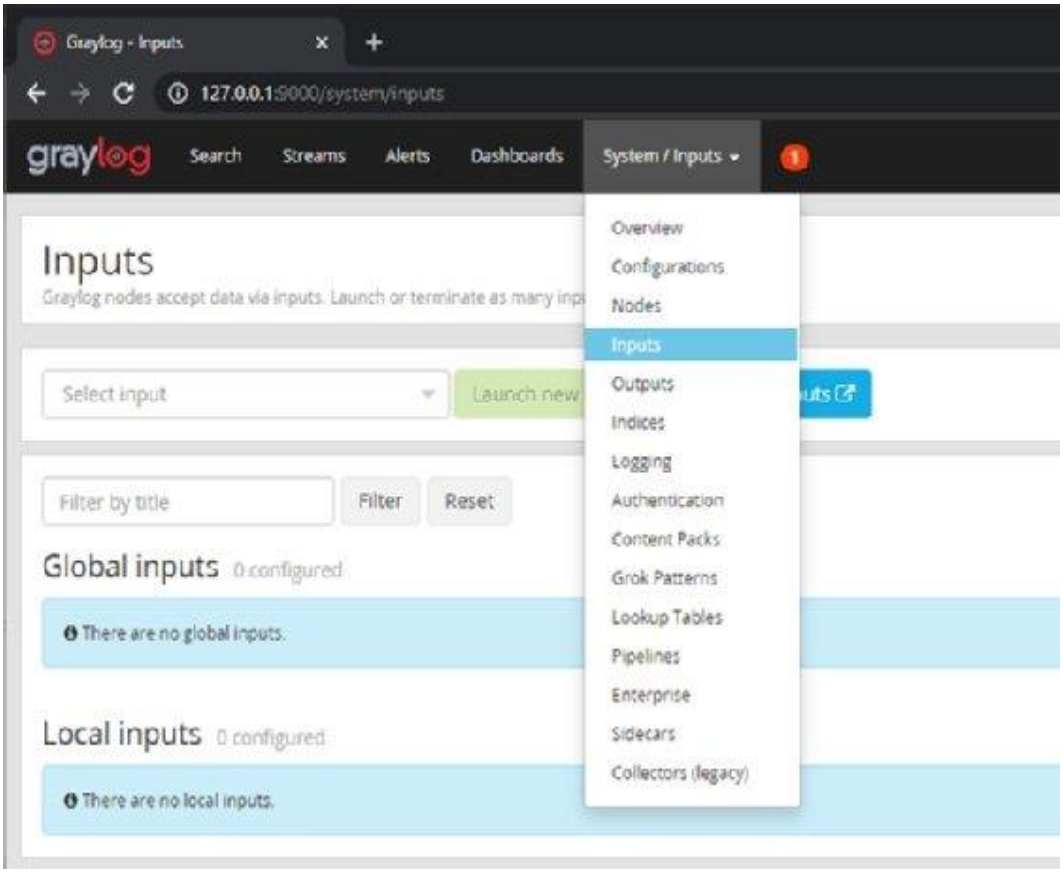
Steps for using Graylog tools for monitoring

Step 1: On the sign-in screen, enter the default **admin** username and password to navigate to the dashboard.



Click on **Dismiss Guide** to show the main Search screen.

Step 2: click on **System/Inputs** to configure a Global input to listen to incoming messages.

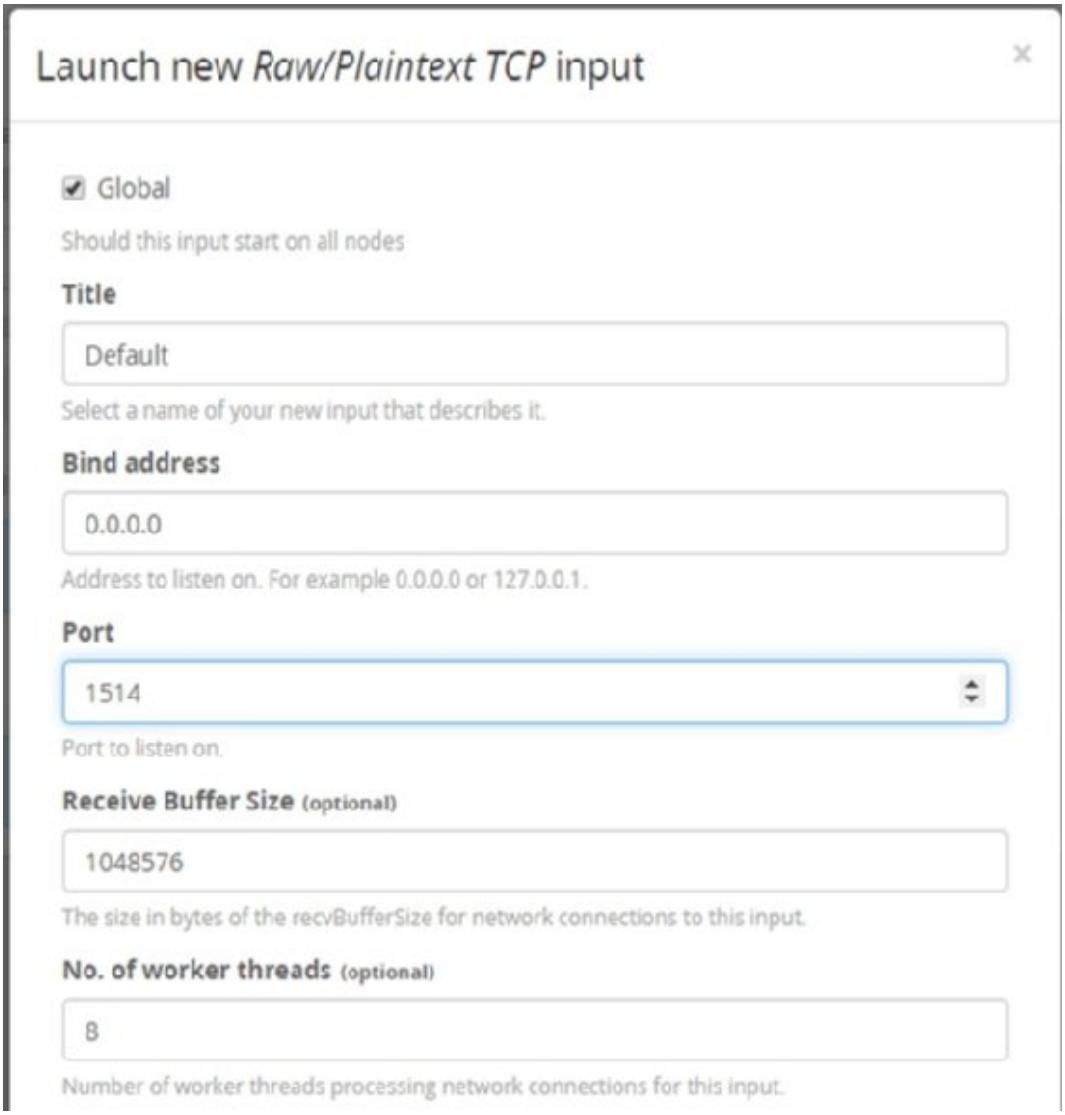


Step 3: Select **Raw/Plaintext TCP** from the drop-down selection and click on **Launch new input** to open the configuration page for the Global input.



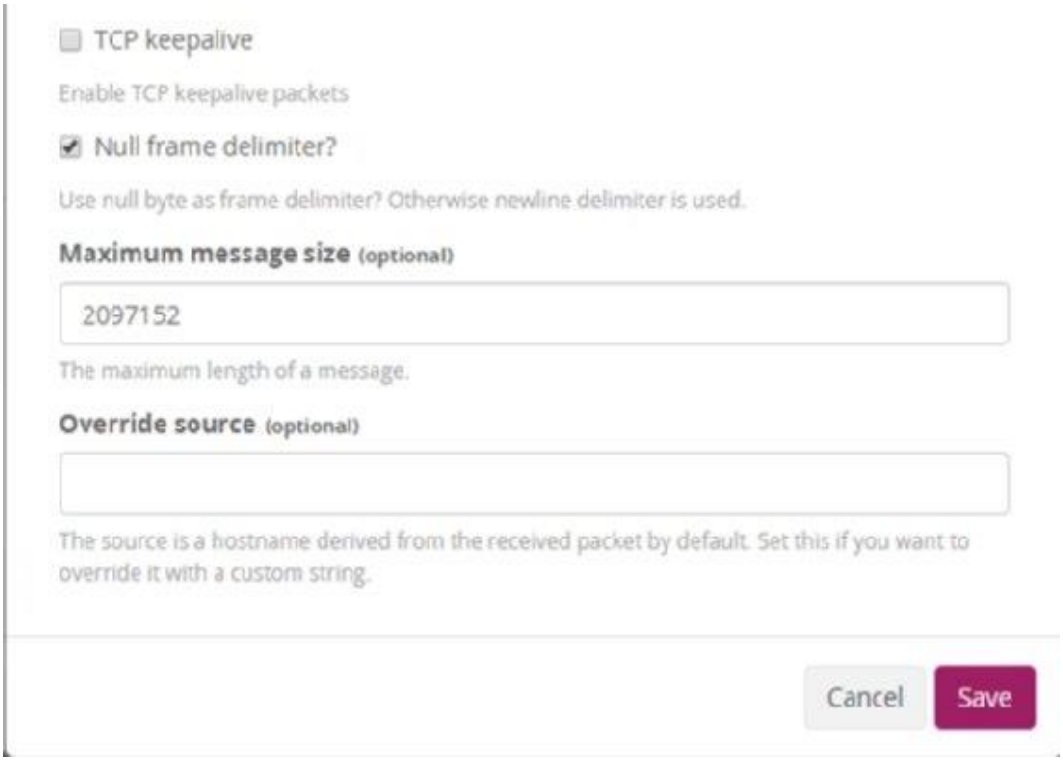
ADAM BERTRAM
Figure 3

Set the configurations shown in Figure 4.



Step 4: Leave all TLS settings as their defaults

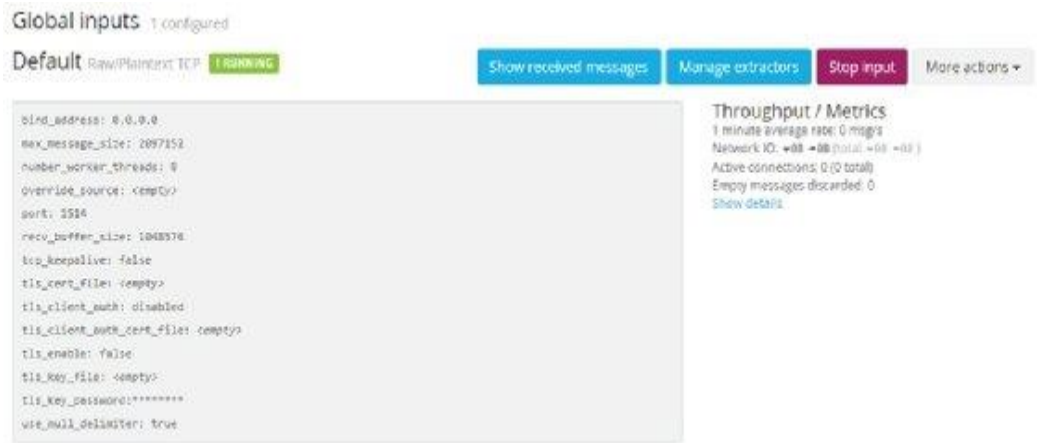
Finally, select **Null frame delimiter?** and leave all other values as their defaults. Then, click **Save**.



ADAM BERTRAM

Figure 5

After saving the configuration, the input should look like the Figure 6 screenshot and be set as running.



Step 5: Send a message via the command line

If you use Linux, or Windows Subsystem for Linux, use the following command to send a test message into Graylog:

```
echo 'First CLI Log Message!' | nc -N localhost 1514
```

It is more complicated to send a message using PowerShell, but it's doable, as demonstrated below. Normally, this set of commands would be wrapped in an easy-to-use function, but here, we show the core code only:

```
$Server  = "127.0.0.1"

$Port    = 1514

$Message = 'First PowerShell Message!'

$Encoded = ([System.Text.Encoding]::UTF8.GetBytes($Message)) + [Byte]0x00

$TCPClient  = New-Object System.Net.Sockets.TcpClient

$TCPConnect = $TCPClient.ConnectAsync($Server,$Port)

$TCPConnect.Wait(500) | Out-Null

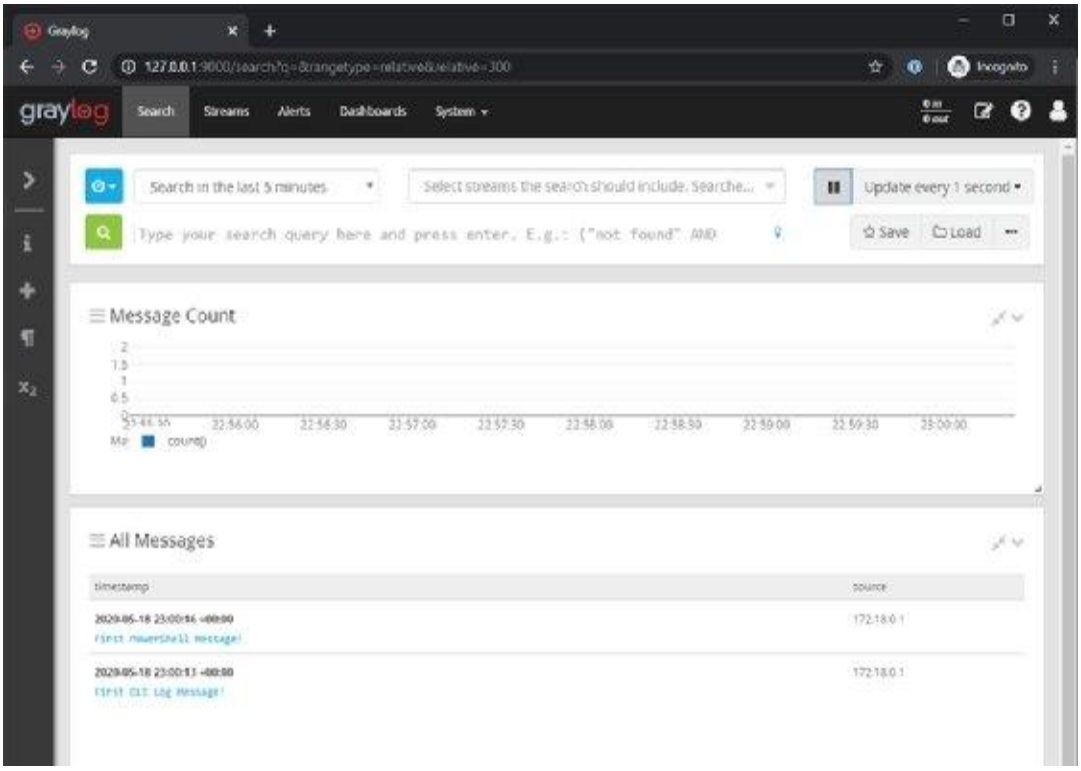
$TCPStream  = $TCPClient.GetStream()

$TCPStream.Write($Encoded, 0, $Encoded.Length)

$TCPStream.Close()

$TCPClient.Close()
```

The messages are displayed as shown in Figure 7. Click the **Run** button to update the Search pane, otherwise you might not see the messages you have sent in.



Step 6 : Data collection and organization

Graylog can ingest different types of structured data -- both log messages and network traffic -- from sources and formats including:

- Syslog
- Graylog Extended Log Format (GELF)
- AWS CloudWatch Logs and CloudTrail
- Beats/Logstash
- Common Event Format (CEF)
- JSONPath from HTTP API
- NetFlow
- Plain/raw text

Step 7: Configure Rsyslog messages

For most Linux systems, admins configure Rsyslog to send in all system logging messages. To do this, use the following configuration file -- just be sure to restart Rsyslog once done.

```
# /etc/rsyslog.d/graylog.conf

# Double @@ is for TCP whereas a single @ is for UDP

*.* @@yourgraylog.example.org:514;RSYSLOG_SyslogProtocol23Format
```

Consider using the User Datagram Protocol (UDP) to handle a large number of log messages; the Transmission Control Protocol (TCP) might result in more reliable messages, with a sacrifice in speed.



Points to Remember

Description of Network and System Logs

- Monitoring Network and System Logs involves collecting, analyzing, and reviewing log data from network devices, servers, applications, and systems to detect security threats, performance issues, and operational irregularities. Logs capture critical events like user access, configuration changes, and network errors, helping organizations identify potential risks in real time.
- Role of Logs in Security is essential for detecting anomalies, supporting incident response, and ensuring compliance. Logs provide a detailed history of system activities, assisting in identifying suspicious behavior and breaches, aiding forensic investigations, and helping organizations meet regulatory requirements.
- Logging Policies and Standards define how logs should be generated, stored, and managed. These policies cover data retention, log integrity, log generation, and audit reviews. Protecting logs from tampering and ensuring they are reviewed regularly is critical for maintaining security.
- Common standards, like NIST Special Publication 800-92 and ISO/IEC 27001, provide guidelines for effective log management and monitoring, helping organizations follow best practices for security and compliance.

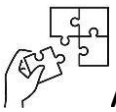
Identification of Logging Tools and Real-time Monitoring

- Selection of Logging Tools is crucial for effective log management. When choosing a logging tool, consider factors like scalability, ensuring it can handle your organization's log volume, and centralized log management, which consolidates logs from different sources into one place. It should support search and analysis to help quickly detect anomalies and integrate with other security tools like SIEM or IDS. Common tools include Syslog (for Unix systems), Windows Event Viewer, Splunk, and Graylog for log collection and analysis.

- Implementing Log Management for Real-time Monitoring involves continuously analyzing logs to detect issues as they occur. This process requires centralizing logs, ensuring log normalization for easy analysis, setting log retention policies, and using SIEM systems to provide a comprehensive view of network security. These steps ensure logs are efficiently managed and monitored.
- Automated Alerts and Thresholds are vital for real-time log monitoring. They notify security teams when suspicious activities arise by defining thresholds (e.g., for failed logins), configuring alerts to trigger notifications via email or SMS, and tuning alerts to balance between sensitivity and false positives. Response mechanisms should be in place, outlining actions when alerts are triggered, like investigation or incident escalation.

Steps for using Greylog for network and system logs monitoring

Step 1: On the sign-in screen, enter the default admin username and password to navigate to the dashboard.
Step 2: click on System/Inputs to configure a Global input to listen to incoming messages.
Step 3: Select Raw/Plaintext TCP from the drop-down selection and click on Launch new input to open the configuration page for the Global input
Step 4: Leave all TLS settings as their defaults
Step 5: Send a message via the command line
Step 6 : Data collection and organization
Step 7: Configure Rsyslog messages



Application of learning 3.4.

You have been tasked by INET's IT department to help monitor their network and system logs to improve cybersecurity. The company wants to ensure timely identification and response to any security incidents. Your role is to implement Graylog for centralized log management, collect logs from key network devices and systems, and configure Graylog to generate alerts for suspicious activities or anomalies.

Indicative content 3.5: Systems Scanning and Penetration Testing

Duration: 3 hrs

Theoretical Activity 3.5.1: Description of Efficient Systems Scanning

Tasks:

1: Answer the following questions:

i. What is Efficient Systems Scanning
ii. Importance of Efficient Systems Scanning
iii. Describe Explaining the Significance of Efficient Scanning
iv. Describe Well-Established Cybersecurity Principles
v. Explain Methods for Efficient Systems Scanning
vi. Describe of Vulnerability Scanning Tools and Management
vii. Explain Regular Compliance Scanning and Patch Management

2: Present your group's findings on the discussed topics.
3. Ask clarification if any

4: Read the key readings 3.5.1.

Key readings 3.5.1.:

Systems Scanning

Description of Efficient Systems Scanning

1. Importance of Efficient Systems Scanning

1.1. Explaining the Significance of Efficient Scanning

Efficient systems scanning is a critical aspect of cybersecurity, allowing organizations to identify vulnerabilities, weaknesses, and misconfigurations in their systems before they can be exploited by malicious actors. It ensures that an organization's infrastructure is continuously assessed for potential risks and

security gaps. The faster and more efficiently systems are scanned, the quicker the organization can respond to threats, minimizing potential damage.

Efficient scanning enhances the ability to:

- Detect vulnerabilities in real-time.
- Comply with security standards and regulations.
- Ensure that systems are operating as intended and are secure from unauthorized access.
- Improve the overall security posture by identifying weak points that require mitigation or patching.

1.2. Describing Well-Established Cybersecurity Principles

Efficient systems scanning is grounded in several well-established cybersecurity principles:

- **Confidentiality**: Scanning ensures that sensitive data remains secure by identifying and addressing vulnerabilities that could lead to data breaches.
- **Integrity**: Scanning helps verify that system configurations and data have not been tampered with or corrupted.
- **Availability**: Through regular scanning, potential threats that could disrupt system functionality are detected and resolved, ensuring that systems remain operational.
- **Risk Management**: Regular scanning helps organizations identify and prioritize risks, allowing them to allocate resources effectively to mitigate the most critical vulnerabilities.

Organizations that follow these principles during scanning maintain a proactive stance against security threats, reducing the chance of system compromise and data breaches.

2. Methods for Efficient Systems Scanning

2.1 Asset Inventory Methods

Before conducting any scan, organizations must know what assets they possess. Asset inventory is the process of cataloging all hardware, software, network devices, and data within the organization's IT environment. Proper inventory ensures that no critical assets are missed during scans.

There are two common asset inventory methods:

1. **Manual Asset Inventory**: This involves physically documenting all assets, their configuration, and their current security status. While time-consuming, this method is thorough and gives deep insight into each system's function and purpose.
2. **Automated Asset Discovery Tools**: These tools automatically scan the network to discover and categorize devices, software, and other IT assets. They save time and ensure comprehensive coverage.

2.2. Description of Vulnerability Scanning Tools and Management

Vulnerability scanning tools are software solutions that automate the process of checking systems for known vulnerabilities. These tools use databases of known exploits and weaknesses to detect potential security gaps in systems, networks, and applications.

Some common **vulnerability scanning tools** include:

- **Nessus**: One of the most widely used vulnerability scanners, known for its comprehensive detection capabilities.
- **OpenVAS**: An open-source tool that offers extensive vulnerability scanning features.
- **QualysGuard**: A cloud-based service that scans for vulnerabilities and ensures compliance.
- **Rapid7 Nexpose**: A commercial vulnerability management solution with deep integrations for detecting vulnerabilities.

Effective Vulnerability Management includes:

- Regularly updating the vulnerability database to ensure new threats are detected.
- Scanning systems frequently to detect new vulnerabilities.
- Prioritizing vulnerabilities based on their severity and impact on the business.
- Remediating vulnerabilities through patching, configuration changes, or mitigating controls.

2.3 Regular Compliance Scanning and Patch Management

Compliance scanning is the process of continuously checking systems to ensure they meet internal policies, industry regulations, and legal requirements. Many compliance frameworks, such as PCI DSS, HIPAA, and GDPR, mandate that

organizations conduct regular vulnerability scans to identify and address security issues.

Effective compliance scanning includes:

- Regularly conducting scans to ensure that the organization's infrastructure adheres to industry-specific security requirements.
- Documenting the results of each scan for auditing purposes.
- Identifying and remediating non-compliance issues promptly to avoid penalties.

Patch Management is the process of applying software updates (patches) to address vulnerabilities, improve functionality, or fix bugs. It is crucial to maintain the security of systems and ensure they are not vulnerable to known threats. Patch management involves:

- Continuously monitoring for newly released patches from software vendors.
- Prioritizing patches based on the severity of the vulnerabilities they address.
- Testing patches before deployment to ensure they do not cause disruptions or compatibility issues.
- Applying patches in a timely manner to mitigate risk.

Efficient systems scanning combined with regular compliance scanning and patch management strengthens the overall security of an organization by ensuring that vulnerabilities are identified, remediated, and that systems remain in compliance with security standards.



Theoretical Activity 3.5.2 Description of Penetration Testing



Tasks:

1: Answer the following questions:

i. Describe Penetration Testing
ii. What are Importance of Penetration Tests
iii. Identify Tools for Penetration Tests
iv. Implementing Effective Penetration Tests

2: Present your group's findings on the discussed topics.
3. Ask clarification if any

4: Read the key readings 3.5.2.



Key readings 3.5.2:

Description of penetration testing

1. Introduction to Penetration Testing

Penetration testing, often referred to as ethical hacking, is a simulated cyber attack against an organization's computer systems, networks, or web applications. The primary objective is to identify and exploit vulnerabilities in order to assess the security posture of the organization. This process mimics the tactics, techniques, and procedures used by real attackers, allowing organizations to uncover weaknesses before they can be exploited maliciously. Penetration tests can be conducted manually or through automated tools, and they provide valuable insights into an organization's security strengths and weaknesses.

2. Importance of Penetration Tests

Penetration testing is crucial for several reasons:

- **Vulnerability Identification**: It helps organizations identify security flaws that may not be visible through regular security assessments or automated scans.
- **Risk Assessment**: By simulating real-world attacks, penetration tests allow organizations to understand the potential impact and likelihood of various vulnerabilities being exploited.
- **Regulatory Compliance**: Many industry regulations and standards, such as PCI DSS and HIPAA, require organizations to conduct penetration tests regularly as part of their compliance obligations.
- **Improving Security Posture**: The insights gained from penetration testing enable organizations to prioritize remediation efforts, thereby strengthening their overall security framework.
- **Testing Security Controls**: It evaluates the effectiveness of existing security measures, such as firewalls, intrusion detection systems, and access controls, ensuring they function as intended.

3. Identifying Tools for Penetration Tests

There are numerous tools available to assist in conducting penetration tests. These tools can automate certain processes and provide comprehensive analysis capabilities. Some popular penetration testing tools include:

- **Metasploit**: A widely used framework that provides tools for discovering vulnerabilities and launching exploits against target systems.
- **Nessus**: A vulnerability scanning tool that identifies potential vulnerabilities in systems and networks, often used in conjunction with penetration testing.
- **Burp Suite**: A platform for web application security testing that allows testers to identify vulnerabilities such as SQL injection and cross-site scripting.
- **OWASP ZAP (Zed Attack Proxy)**: An open-source web application security scanner designed to find vulnerabilities in web applications.
- **Kali Linux**: A Linux distribution specifically designed for penetration testing, equipped with numerous pre-installed tools for various types of testing.

4. Implementing Effective Penetration Tests

To implement effective penetration tests, organizations should follow a structured approach:

- **Planning**: Define the scope of the test, including the systems, applications, and networks to be tested. Establish rules of engagement and obtain necessary permissions to conduct the test.
- **Reconnaissance**: Gather information about the target systems, such as IP addresses, domain names, and network architecture. This phase may involve both passive and active techniques.
- **Scanning and Enumeration**: Utilize tools to identify open ports, services, and potential vulnerabilities within the target environment. This can include network scanning and vulnerability scanning.
- **Exploitation**: Attempt to exploit identified vulnerabilities to gain unauthorized access or perform unauthorized actions. This phase tests the effectiveness of security controls and can reveal the potential impact of successful attacks.
- **Post-Exploitation**: Once access is obtained, assess the extent of the compromise, gather additional information, and identify potential data that could be exfiltrated.
- **Reporting**: Document findings, including vulnerabilities discovered, methods used, and recommendations for remediation. Present the report to relevant stakeholders and ensure that actionable steps are outlined to address the identified vulnerabilities.

- **Remediation**: Collaborate with IT and security teams to implement necessary fixes, such as patching vulnerabilities, enhancing configurations, or strengthening access controls.
- **Retesting**: After remediation efforts are completed, conduct follow-up tests to verify that vulnerabilities have been effectively mitigated.

Practical Activity 3.5.3: Conducting system scanning penetration testing

Task:

1: Referring to the previous theoretical activity (3.5.2) you are requested to perform the following activity.

You are tasked to help school for system and network scanning and conduction penetration testing by using Kali Linux

2: Read the key readings 3.5.3.

Key readings 3.5.3.

Here's a comprehensive overview of the steps for network scanning and conducting penetration testing using Kali Linux:

1. Planning and Preparation

- **Define the Scope**: Determine which systems, networks, or applications will be tested.
- **Gather Information**: Collect information about the target, such as IP addresses, domain names, and network architecture.

2. Reconnaissance

- **Passive Reconnaissance**: Use publicly available information to gather data about the target, such as WHOIS databases or social media profiles.
- **Active Reconnaissance**: Use tools like Nmap to discover live hosts and services on the target network.

3. Network Scanning

- **Port Scanning**: Use Nmap to identify open ports and services running on the target:

nmap -sS -p- [target IP]

- **Service Enumeration**: Identify services running on open ports using Nmap:

nmap -sV [target IP]

• **OS Detection**: Determine the operating system of the target:
nmap -O [target IP]

4. Vulnerability Scanning

• **Use Vulnerability Scanners**: Employ tools like OpenVAS or Nessus to identify vulnerabilities in the systems:
  ○ For OpenVAS, set up and configure the scanner, then run a scan on the target.
• **Review Results**: Analyze the output to understand potential vulnerabilities.

5. Exploitation

• **Use Metasploit Framework**:

  ○ Launch Metasploit: msfconsole
  ○ Use the search command to find exploits relevant to the identified vulnerabilities.
  ○ Use [exploit] to select an exploit, then configure it with set commands.
  ○ Launch the exploit using the exploit command.

6. Post-Exploitation

• **Assess Compromised Systems**: After successfully exploiting a system, gather additional information (e.g., user accounts, passwords).
• **Privilege Escalation**: Attempt to gain higher access levels if necessary using local exploits.

7. Reporting

• **Document Findings**: Compile all findings, including vulnerabilities discovered, exploits used, and the data accessed.
• **Recommendations for Remediation**: Provide actionable steps for securing the identified vulnerabilities.

8. Remediation and Retesting

• **Collaborate with IT Teams**: Work with the organization's IT or security teams to implement fixes.

• **Retesting**: Conduct follow-up scans and tests to verify that vulnerabilities have been adequately addressed.



Points to Remember

Description of Efficient Systems Scanning

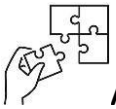
- Efficient systems scanning is essential for identifying vulnerabilities, weaknesses, and misconfigurations in an organization's infrastructure, enabling faster responses to security threats. It improves overall security by detecting risks in real-time and ensuring compliance with standards.
- Effective scanning is based on cybersecurity principles such as confidentiality, integrity, and risk management.
- Methods for efficient scanning include maintaining an asset inventory, using vulnerability scanning tools like Nessus and OpenVAS, and implementing strong vulnerability management practices.
- Regular compliance scanning helps organizations meet regulatory requirements, while patch management ensures timely remediation of vulnerabilities. Together, these practices strengthen an organization's security posture and protect it from emerging threats.

Description of penetration testing

- Penetration testing, or ethical hacking, simulates cyber attacks on an organization's systems, networks, or web applications to identify and exploit vulnerabilities, thereby assessing the security posture of the organization. This process mimics the tactics of real attackers, helping organizations discover weaknesses before they can be maliciously exploited.
- The importance of penetration testing includes identifying security flaws not detected in regular assessments, evaluating the risk of vulnerabilities, ensuring compliance with regulations like PCI DSS and HIPAA, improving overall security, and testing the effectiveness of existing security measures.
- Various tools assist in penetration testing, such as Metasploit, Nessus, Burp Suite, OWASP ZAP, and Kali Linux, which automate processes and provide analysis capabilities.
- Effective penetration tests follow a structured approach, including planning, reconnaissance, scanning, exploitation, post-exploitation, reporting, remediation, and retesting. By adhering to this approach, organizations can enhance their security posture and address vulnerabilities effectively.

Steps for using kali linux for scanning and penetration testing

Step 1: Planning and Preparation
Step 2: Reconnaissance
Step 3: Network Scanning
Step 4: Vulnerability Scanning
Step 5: Exploitation
Step 6 : Post-Exploitation
Step 7: Reporting
Step 8: Remediation and Retesting



Application of learning 3.5.

ICP Company has identified the need to enhance its cybersecurity posture due to recent security incidents. As part of this initiative, they have decided to conduct a thorough penetration test using Kali Linux to identify vulnerabilities in their network infrastructure. The penetration testing team will follow a structured approach to ensure all aspects of the test are covered, from planning to remediation.

Learning outcome 3 end assessment

Written assessment

SECTION I. Choose the letter corresponding to the correct answers

1. **What is the primary purpose of security threat monitoring?**

   a) To prevent data loss
   b) To detect and respond to security threats
   c) To create security policies
   d) To perform regular backups

2. **Which of the following is a key component of an Intrusion Detection System (IDS)?**

   a) Network segmentation
   b) User authentication
   c) Traffic analysis
   d) Firewall rules

3. **What does SIEM stand for in the context of cybersecurity?**

   a) Security Information and Event Management
   b) Security Incident and Emergency Management
   c) Security Infrastructure and Event Monitoring
   d) Security Integration and Event Management

4. **Which type of monitoring focuses on known malicious behaviors?**

   a) Behavior-Based Monitoring
   b) Signature-Based Monitoring
   c) IoC Monitoring
   d) Vulnerability Monitoring

5. **What is an Indicator of Compromise (IoC)?**

    a) A threat detection system
    b) A piece of forensic evidence
    c) A malicious actor's IP address
    d) A signature of a known threat

6. **Which of the following techniques helps in identifying potential security threats before they materialize?**

    a) Signature-Based Monitoring
    b) Behavior-Based Monitoring
    c) Threat Hunting
    d) Log Analysis

7. **What is a zero-day attack?**

    a) An attack that occurs after a vulnerability is patched
    b) An attack that exploits a previously unknown vulnerability
    c) An attack that occurs on the first day of a new system
    d) An attack that uses outdated software

8. **Which of the following is NOT a common tool used for security monitoring?**

    a) IDS
    b) SIEM
    c) Antivirus Software
    d) Firewall

9. **What does threat intelligence refer to?**

    a) Information about current and potential security threats
    b) User access levels and permissions
    c) Data encryption methods
    d) System backup strategies

10. **Which of the following is an example of a phishing attack?**

    a) Sending an email that looks legitimate but leads to a malicious site
    b) Exploiting a software vulnerability to gain unauthorized access
    c) Using social engineering to manipulate an insider
    d) Distributing malware via a USB device

11. **What is the main objective of conducting vulnerability monitoring?**

    a) To identify and fix software bugs
    b) To ensure compliance with security policies
    c) To discover weaknesses in systems that could be exploited
    d) To enhance system performance

12. **Which method is used to validate the effectiveness of security controls?**

    a) Incident Response
    b) Penetration Testing
    c) Threat Hunting
    d) Vulnerability Scanning

13. **What is the role of automated alerts in security monitoring?**

    a) To create user accounts
    b) To provide notifications of potential security incidents
    c) To manage user access permissions
    d) To perform data backups

14. **What type of monitoring technique involves analyzing system and network logs?**

    a) Behavioral Monitoring
    b) Signature-Based Monitoring
    c) IoC Monitoring
    d) Log Analysis

15. **Which of the following best describes incident response procedures?**

    a) Steps taken to monitor system activity
    b) Actions taken to address and manage the aftermath of a security incident
    c) Guidelines for user behavior
    d) Techniques for vulnerability scanning

16. **Which tool is primarily used to aggregate and analyze security data from multiple sources?**

    a) IDS
    b) SIEM
    c) Antivirus
    d) Firewall

17. **What does behavior-based monitoring rely on?**

    a) Known attack signatures
    b) User and entity behavior analytics
    c) Real-time system updates
    d) Historical performance data

18. **In the context of threat hunting, what is the purpose of collecting threat intelligence?**

    a) To prepare budget estimates for security tools
    b) To understand the tactics, techniques, and procedures of threat actors
    c) To classify user roles
    d) To perform compliance audits

19. **Which term describes malicious software designed to disrupt or damage a computer system?**

    e) Phishing
    a) Malware
    b) Ransomware
    c) Spyware

20. **What is a primary benefit of using SIEM tools in security monitoring?**

    a) Simplified software installation
    b) Comprehensive threat detection and analysis
    c) Reduced need for user training
    d) Faster system performance

SECTION II. Read the statement below and answer by TRUE if it is correct or FALSE if it is incorrect

1. Network and system logs play a critical role in identifying and responding to security incidents.

2. Logging policies and standards are irrelevant to the effectiveness of log monitoring.

3. Real-time monitoring of logs allows organizations to detect security threats as they occur.

4.Implementing automated alerts and thresholds is an optional step in log management that does not significantly enhance security monitoring.

5. The selection of logging tools is crucial for ensuring that log data is captured and analyzed effectively.

6. Network and system logs can only provide historical data and do not assist in real-time threat detection.

7. Comprehensive logging practices contribute to regulatory compliance and help in audits.

SECTION III. Match Systems Scanning and Penetration Testing topics in column A with their correct description in column B

Answers	**COLUMN A**	**COLUMN B**
1. ……	1. Asset Inventory Methods	A. Regular evaluations of systems to ensure compliance with security policies
2. ……	2. Penetration Tests	B. Techniques used to simulate attacks on a system to identify security vulnerabilities.
3. ……	3. Vulnerability Scanning Tools	C. The process of identifying and managing hardware and software assets.
4. ……	4. Compliance Scanning and Patch Management	D. Tools used to assess vulnerabilities in applications and systems

Practical assessment

AGZA is organization. Recently, the organization has experienced an increase in security incidents, including phishing attempts and potential malware infections. An organization has decided to enhance its security posture by implementing security threat monitoring strategies. You are tasked To set up an effective monitoring system using Intrusion Detection Systems (IDS) and Security Information and Event Management (SIEM) tools, apply monitoring techniques, conduct threat hunting, monitor logs, and perform penetration testing.



References

Manning, K., & Williams, D. (2017). *Security Operations Center: Building, Operating, and Maintaining Your SOC*. Syngress.

Scarfone, K., & Mell, P. (2007). *Guide to Intrusion Detection and Prevention Systems (IDPS)*. National Institute of Standards and Technology (NIST) Special Publication 800-94.

Wang, C. (2020). *Cybersecurity Monitoring and Threat Intelligence: A Practical Guide*. CRC Press.

Zhao, W. (2019). *Penetration Testing: A Hands-On Introduction to Hacking*.

Montclair State University. (2024, July 5). *Cybersecurity Awareness Training*. Retrieved from https://www.montclair.edu/information-technology/security/cybersecurity-awareness-training/

SentinelOne. (n.d.). *Cyber Security Monitoring: Definition and Best Practices*. Retrieved from https://www.sentinelone.com/cybersecurity-101/cybersecurity/cyber-security-monitoring/

Exabeam. (2024, January 5). *Threat Detection and Response: Technologies and Best Practices*. Retrieved from https://www.exabeam.com/explainers/new-scale-siem/threat-detection-and-response-technologies-and-best-practices/

Cyvent. (2024, January 5). *Choosing the Right Cybersecurity Monitoring System: Tips and Tools*. Retrieved from https://www.cyvent.com/blog/choosing-the-right-cybersecurity-monitoring-system

ECCU. (2024, January 5). *Methods and Technologies to Detect Cyber Attacks*. Retrieved from https://www.eccu.edu/blog/methods-technologies-detect-cyber-attacks/

SISA Infosec. (2024, January 5). *4 Types Of Cyber Threat Hunting Tools In 2024*. Retrieved from https://www.sisainfosec.com/blogs/4-types-of-cyber-threat-hunting-tools/

Exabeam. (2024, January 5). *SOC and SIEM: The Role of SIEM Solutions in the SOC*. Retrieved from https://www.exabeam.com/explainers/siem-security/the-soc-secops-and-siem/


Recovery
65%
Cancel

Indicative contents
4.1 Developing Incident Response Plan **4.2 Developing Incident Recovery Plan** **4.3 Identification of Security Incident** **4.4 Isolation of Affected System** **4.5 Conducting Methodical Forensic Analysis** **4.6 Restoring System and Data**

Key Competencies for Learning Outcome 4: Perform Incident Response and Recovery

Knowledge	Skills	Attitudes
• Description Incident Response Planning. • Description of Develop in Incident Response Plans. • Description of Plan Incident Recovery. • Description of Developing Incident Recovery Plans • Description of Security Incident. • Identification of Incident Detection Techniques. • Description of response and reporting in security incident. • Description of threat intelligence integration for incident classification and prioritization. • Description of Immediate Action and Communication in isolation of affected system. • Description system isolation techniques and analysis of affected systems. • Description of recovery planning and communication.	• Creating Incident Response Policy. • Assessing risk and Business Impact Analysis (BIA). • Developing Incident Recovery Plans. • Testing of Incident Recovery. • Applying response in security incident. • Developing System Isolation Techniques • Analysing affected systems. • Conducting Forensic Analysis. • Restoring and validating of system and data. • Auditing and Compliance Checks of system and data restoration	• Being mind set focused. • Being Commitment. • Being Collaboration. • Being resilience. • Attention to details

• Description of fundamentals forensic Analysis. • Description of evidence documentation and analysis. • Description of quality assurance and legal aspects. • Description of System and Data Restoration. • Description of post-restoration actions and documentation.		



Duration: 15 hrs

Learning outcome 4 objectives:



By the end of the learning outcome, the trainees will be able to:

1. Describe clearly Security Threats Monitoring within an organization.
2. Describe clearly Security Threats Detection within an organization
3. Describe Accurately the different types of monitoring tools used in cybersecurity
4. Differentiate Clearly between standard and advanced monitoring techniques
5. Describe properly the process of security threat hunting, using intelligence feeds to actively search for potential threats.
6. Analyze correctly Network and System Logs for detecting suspicious activity
7. Select properly Logging and Monitoring Tools
8. Describe correctly Efficient System Scanning Methods
9. Conduct properly Cybersecurity Penetration Testing
10. Conduct properly System Scanning and Logging for Real-time Threat Monitoring
11. Apply clearly methodical approaches to threat hunting by utilizing intelligence feeds and advanced monitoring techniques.
12. Report correctly Findings from Penetration Testing and Monitoring



Resources

Equipment	Tools	Materials
• Computer • External HDD	• Cuckoo Sandbox • Virus Total • Wireshark • SolarWinds • QRadar • CrowdStrike • Carbon Black • Autopsy • Proofpoint • Veeam • Acronis • Firewalls	Internet Access

Indicative content 4.1: Developing Incident Response Plan

Duration: 3 hrs

Theoretical Activity 4.1.1: Description of Incident Response Planning.

Tasks:

1: Answer the following questions:

i. What is importance of incident response?
ii. Identify Key Stakeholders in Incident Response.
iii. Define Scope and Objectives.

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 4.1.1.

Key readings 4.1.1.:

Description of Incident Response Planning

An **Incident Response Plan (IRP)** is a detailed set of procedures and guidelines designed to help an organization detect, respond to, and recover from cybersecurity incidents such as data breaches, malware infections, and insider threats.

1.Importance of Incident Response

The **importance of incident response** cannot be overstated. A well-executed IRP can help mitigate the damage caused by security breaches, reduce downtime, and protect sensitive information. Here are some key reasons why incident response is crucial:

1. **Minimizing Damage**: A fast and effective response can reduce the impact of an incident, saving the organization time, money, and reputation.
2. **Reducing Downtime**: Proper incident management helps ensure quick containment and recovery, preventing prolonged business disruption.
3. **Legal and Regulatory Compliance**: Organizations must meet certain legal requirements for incident reporting and management, especially in industries governed by regulations like GDPR, HIPAA, or PCI-DSS.
4. **Protecting Reputation**: A swift and controlled response to incidents helps preserve customer trust and the organization's reputation.

5. **Mitigating Future Risks**: Incident response allows an organization to learn from incidents and implement stronger security measures to avoid future occurrences.

2. Key Stakeholders in Incident Response

To effectively respond to cybersecurity incidents, an **Incident Response Team (IRT)** should include key stakeholders from various departments within the organization. These stakeholders collaborate to ensure that incidents are handled efficiently and comprehensively.

Key stakeholders typically include:

1. **IT Security Team**: Technical experts who detect, investigate, and mitigate the threat.
2. **Legal/Compliance Team**: Ensures compliance with legal obligations and assists with potential litigation or regulatory reporting.
3. **Public Relations (PR) Team**: Manages communication with external parties, including customers, the media, and investors.
4. **Human Resources (HR) Team**: Engages when employees or internal stakeholders are involved in the incident.
5. **Executive Management**: Oversees the response, provides strategic direction, and makes key decisions.
6. **Third-Party Vendors**: Includes security partners, forensic investigators, and consultants who may assist with incident response and recovery.

The coordination between these stakeholders ensures that the response is swift, compliant, and minimizes damage to the organization.

3. Defining Scope and Objectives

Scope: The IRP should define the types of incidents it covers, such as data breaches, malware attacks, and denial-of-service (DoS) attacks.

Objectives: The plan should outline the goals of incident response, such as minimizing damage, restoring operations quickly, and complying with legal requirements.

Scope of the IRP:

- The IRP should cover **all types of cybersecurity incidents**, such as:
    - Malware infections (e.g., ransomware)
    - Insider threats (intentional or accidental)
    - Denial-of-Service (DoS) attacks
    - Data breaches (e.g., unauthorized access to sensitive information)
    - Phishing attacks
- It should define which systems, networks, and assets are under the IRP's protection.

- The IRP should also include guidelines for escalating incidents that may affect critical infrastructure or data.

Objectives of the IRP:

1. **Timely Detection and Response**: Ensure that incidents are quickly detected, reported, and addressed.
2. **Effective Containment**: Contain the threat to prevent further damage.
3. **Incident Eradication and Recovery**: Eliminate the threat and restore normal operations as soon as possible.
4. **Minimal Disruption**: Ensure that the business can continue to operate during the incident response process.
5. **Compliance and Reporting**: Ensure that any regulatory or legal obligations are met in terms of incident reporting and management.
6. **Continuous Improvement**: Use insights from incidents to refine the IRP and improve organizational security posture.



Theoretical Activity 4.1.2: Description of Incident Response Plans development



Tasks:

1: Answer the following questions:

i. Describe incident response policy
ii. Identify incident detection and reporting
iii. What is response procedures
iv. What is incident containment
v. What is eradication and recovery
vi. Give Legal and Regulatory Compliance
vii. Explain Documentation and Record Keeping
viii. Describe Training and Awareness
ix. What is Post-Incident Analysis
x. Describe Board and Executive Reporting
xi. Describe Public Relations and Reputation Management
xii. Describe DR/BCP Integration

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 4.1.2.



Key readings 4.1.2.:

Description of Incident Response Plans development

An **Incident Response Plan (IRP)** is essential for managing security incidents in an organized way. It helps organizations detect, respond to, and recover from security breaches while minimizing damage and downtime. The IRP ensures that everyone knows their roles and responsibilities and that a structured process is followed during an incident.

1. Creating an Incident Response Policy

The **Incident Response Policy** sets the foundation for how incidents will be handled. It defines the procedures for identifying, reporting, and managing security incidents. This policy outlines who is responsible for taking action and ensures that all employees understand how to respond when an incident occurs.

2. Incident Detection and Reporting

Incident detection is about spotting threats quickly using tools like **Intrusion Detection Systems (IDS)** or monitoring tools. Once an incident is detected, it must be reported immediately through a clear reporting process. Fast reporting helps the team respond quickly and reduce the impact.

3. Response Procedures

Response procedures provide step-by-step actions to take once an incident is reported. These actions are designed to contain and mitigate the threat, protecting important assets and ensuring that critical systems continue to operate smoothly. The team prioritizes incidents based on their severity.

4. Incident Containment

Incident containment involves isolating the problem to prevent further damage. This can include actions like disconnecting compromised systems from the network or blocking malicious traffic. The aim is to keep the incident from spreading while a long-term solution is implemented.

5. Eradication and Recovery

After containment, **eradication** is focused on removing the cause of the incident, such as deleting malware or closing security holes. **Recovery** means restoring systems to their normal state, often using backups or patches. Systems are closely monitored to ensure they are secure before resuming normal operations.

6. Communication Plan

A clear **communication plan** is essential for keeping stakeholders informed during an incident. Internally, the team provides updates to leadership, and externally, they may need to communicate with customers or regulators. This helps manage expectations and maintain trust.

7. Legal and Regulatory Compliance

During an incident, it is important to ensure **compliance** with laws and regulations, such as **GDPR** or **HIPAA**. Legal counsel should be involved to guide actions and ensure that required reporting to authorities is completed on time to avoid penalties.

8. Documentation and Record Keeping

Every step of the response must be **documented** for future reference. This documentation helps in analyzing the incident, supports legal investigations, and improves future responses. Incident reports detail the actions taken and the outcomes of each phase of the response.

9. Training and Awareness

Regular **training and awareness programs** ensure that employees know how to detect and report incidents. Simulated incident response exercises help test the team's preparedness and improve response times. Continuous training keeps everyone updated on new threats and best practices.

10. Post-Incident Analysis

After an incident, a **post-incident analysis** helps the organization learn from what happened. By reviewing the response, teams can identify what worked well and what can be improved. These lessons are used to refine the incident response plan and avoid similar incidents in the future.

11. Board and Executive Reporting

Incident response teams must provide regular **reports to senior leadership**, highlighting the impact of the incident and the actions taken to resolve it. These reports help decision-makers understand the situation and what resources might be needed to prevent future incidents.

12. Public Relations and Reputation Management

Managing the organization's **public reputation** during an incident is critical. A clear communication strategy ensures transparency and reassures the public that the organization is taking appropriate measures to handle the breach. This helps preserve the company's reputation after the incident.

13. DR/BCP Integration (Disaster Recovery / Business Continuity Planning)

An incident response plan should be linked to the organization's **Disaster Recovery (DR)** and **Business Continuity Plans (BCP)**. This ensures that critical services continue to operate during an incident, with strategies in place for recovering data and systems. This integration helps minimize operational disruptions.

Conclusion

A well-developed Incident Response Plan ensures a quick and organized reaction to security incidents, minimizing damage and downtime. Clear policies, regular training, and strong communication are key to maintaining security and protecting the organization's reputation and assets.



Practical Activity 4.1.3: Creating Incident Response Policy



Task:

1: Referring to the previous theoretical activity (4.1.2) you are requested to perform the following activity.

By ensuring that all trainer and trainee are aware of their roles and responsibilities, creating incident response policy that formalize set of guidelines and procedures to govern the school's response to security incidents.

2: Read the key readings 4.1.3.

3: Creating incident response policy



Key readings 4.1.3.

Creating Incident Response Policy

1.Authority and Review

Document Control and Review

Document Control	
Author	
Owner	
Date created	
Last reviewed by	
Last date reviewed	
Endorsed by and date	
Next review due date	

Version Control

Version	**Date of Approval**	**Approved By**	**Description of Change**

2. Purpose and Objectives
Purpose of the IRP
Objectives of the CIRP
3. Standards and Framework
4. Common Security Incidents and Responses
4.1 Common Threat Vectors

The following table contains common threat vectors from the NIST Computer Security Incident Handling Guide.

Type	Description
External/Removable Media	An attack executed from removable media or a peripheral device (e.g. malicious code spreading onto a system from an infected USB flash drive).
Attrition	An attack that employs brute force methods to compromise, degrade, or destroy systems, networks, or services (e.g. a DDoS intended to impair or deny access to a service or application or a brute force attack against an authentication mechanism, such as passwords).
Web	An attack executed from a website or web-based application (e.g. a cross-site scripting attack used to steal credentials or a redirect to a site that exploits a browser vulnerability and installs malware).
Email	An attack executed via an email message or attachment (e.g. exploit code disguised as an attached document or a link to a malicious website in the body of an email).
Supply Chain Interdiction	An antagonistic attack on hardware or software assets utilizing physical implants, Trojans or backdoors, by intercepting and modifying an asset in transit from the vendor or retailer.
Impersonation	An attack involving replacement of something benign with something malicious (e.g. spoofing, man in the middle attacks, rogue wireless access points, and SQL injection attacks all involve impersonation).
Improper usage	Any incident resulting from violation of an organization's acceptable usage policies by an authorized user, excluding the

	above categories (e.g. a user installs file sharing software, leading to the loss of sensitive data).
Loss or Theft of Equipment	The loss or theft of a computing device or media used by an organization (e.g. a laptop, smartphone or authentication token).

4.2 Common Cyber Incidents

The following table provides a list of common cyber incident types and corresponding initial response activities.

Type/Description	Response
Denial of Service (DoS) and Distributed Denial of Service (DDoS): overwhelming a service with traffic, sometimes impacting availability.	
Phishing: deceptive messaging designed to elicit users' sensitive information (such as banking logins or business login credentials) or used to execute malicious code to enable remote access.	
Ransomware: a tool used to lock or encrypt victims' files until a ransom is paid.	
Malware: a Trojan, virus, worm, or any other malicious software that can harm a computer system or network.	

Data breach: unauthorised access and disclosure of information.	
Industrial Control System compromise: unauthorised access to ICS.	

5. Roles and Responsibilities

This section includes details of the roles and responsibilities of core individuals and teams responsible for incident response and decision making, including the operational level Cyber Incident Response Team (CIRT) and the strategic level Senior Executive Management Team (SEMT).

All personnel listed here should be familiar with their responsibilities in this plan and practise their response.

5.1 Points of Contact for Reporting Cyber Incidents

Primary and secondary (backup) internal points of contact to report cyber incidents to over a 24/7 period.

Name	Hours of Operation	Contact Details	Role Title	Responsibilities

5.2 Cyber Incident Response Team (CIRT)

CIRT members responsible for managing responses to cyber incidents:

Name	Organisation Role	Contact Details	CIRT Role Title	CIRT Responsibilities

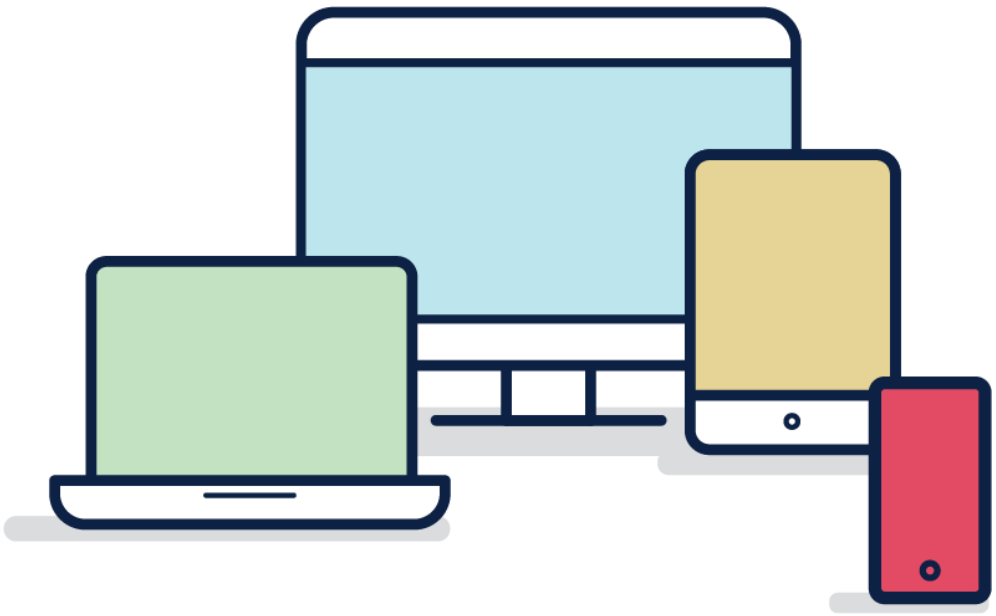
For more significant cyber security incidents the CIRT could be expanded to include:

Name	Organisation Role	Contact Details	CIRT Role Title	CIRT Responsibilities

6. Communications

6.1 Internal Communications

6.2 External Communications



7. Incident Notification and Reporting

Processes for internal and external incident notification and reporting include:

Incident type/ threshold	Organisation/agency to receive notification or report	Contact details for the notifying organisation/agency	Key notifying/reporting requirements and link to organisation/agency information	Personnel responsible

8. Containment

Containment actions are implemented in order to minimise the damage, prevent the incident from spreading or escalating, and prevent the attacker from destroying evidence of their attack.

When planning containment actions, consider:

- Any additional impacts there could be to systems/services
- Time and resources required to contain the incident
- Effectiveness of the containment solution (e.g. partial vs full containment)
- Duration that the solution will remain in place (e.g. temporary vs permanent solution)

9. Documentation

All incidents should be documented. For each incident, identify the responsible personnel, recipients of the information, and timeframes. using Log template.

Situation reports may contain the following information:

- Incident date and time
- Status of the incident
- Incident type and classification
- Scope and Impact
- Severity
- External assistance required
- Actions taken to resolve the incident
- Contact details for incident manager and key CIRT personnel
- Date and time of the next update



Points to Remember

Description of Incident Response Planning

- An incident response plan (IRP) is a structured approach to handling and mitigating security breaches and other cyber incidents
- Key stakeholders in incident response are IT Security Team, Legal/Compliance Team, Public Relations (PR) Team, Human Resources (HR) Team, Executive Management, Third-Party Vendors
- The IRP should define the types of incidents it covers, such as data breaches, malware attacks, and denial-of-service (DoS) attacks.
- The plan should outline the goals of incident response, such as minimizing damage, restoring operations quickly, and complying with legal requirements.

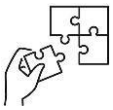
Description of Incident Response Plans development

- An Incident Response Plan (IRP) helps an organization respond to security incidents quickly and efficiently. It outlines steps to detect, manage, and recover from incidents to reduce damage and downtime.
- The Incident Response Policy explains how incidents will be handled. It lists the steps for reporting, responding to, and resolving security incidents, ensuring everyone understands their role.
- Incident detection involves identifying threats using tools like Intrusion Detection Systems (IDS). Once detected, incidents should be reported immediately, so the response team can act quickly.
- Response procedures are step-by-step actions the team takes to manage an incident. The goal is to limit the damage and ensure critical systems continue to function.
- Incident containment focuses on stopping the spread of the incident. For example, compromised systems may be disconnected from the network to prevent further harm.
- Once contained, the focus shifts to eradication, which involves removing the cause of the incident, such as malware. Then, the team works on recovery, restoring systems to normal operation.
- A communication plan ensures that everyone, including staff and external stakeholders, is informed during the incident. Clear communication builds trust and helps manage the situation.
- It's important to follow legal and regulatory guidelines during an incident. Organizations must ensure they comply with laws like GDPR or HIPAA, reporting incidents when required.
- Keeping detailed records during an incident helps with future analysis and legal reporting. Proper documentation ensures that every action taken is tracked.

- Training and awareness programs help employees recognize and report incidents. Regular training ensures everyone is prepared to respond when necessary.
- After an incident, a post-incident analysis reviews what happened and identifies ways to improve the response for the future.
- The incident response team must provide reports to leadership, explaining the incident's impact and actions taken to resolve it.
- Managing public communication during an incident is crucial. A clear public relations strategy ensures the organization's reputation is protected.
- The incident response plan should be integrated with the organization's Disaster Recovery (DR) and Business Continuity Plans (BCP) to ensure the company continues operating during an incident.

While creating incident response policy you must consider key point:

1. Authority and Review
2. Purpose and Objectives
3. Standards and Frameworks
4. Common Security (Common Threat Vectors and Common Cyber Incidents)
5. Roles and Responsibilities
6. Communications
7. Incident Notification and Reporting
8. Containment
9. Documentation



Application of learning 4.1.

IGN, a growing sales company, relies heavily on its digital infrastructure to manage customer data, sales transactions, and vendor communications. Recently, there has been a noticeable rise in phishing emails targeting staff, resulting in a few incidents where unauthorized access to company emails was granted. You are tasked to develop a formal incident response policy to manage these security threats efficient.

Indicative content 4.2: Developing Incident Recovery Plan

Duration: 3 hrs

Theoretical Activity 4.2.1: Description of Plan Incident Recovery.

Tasks:

1: Answer the following questions:

i. Identify key Stakeholders
ii. Describe Objectives and Scope
iii. Describe Risk Assessment and Business Impact Analysis (BIA)
iv. Explain Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs)

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 4.2.1.

Key readings 4.2.1.:

Plan Incident Recovery

Incident Recovery Plan is a critical aspect of cybersecurity that focuses on how an organization can recover from a security incident, such as a cyberattack or system failure. This plan outlines steps to restore normal operations while minimizing the impact on business functions and ensuring a quick and efficient recovery process. When planning for incident recovery, organizations must focus on a few essential elements to ensure a seamless transition from disruption back to normal operations.

1. Identifying Key Stakeholders

Identifying key stakeholders is a crucial first step in incident recovery planning. Stakeholders include individuals or teams who have a direct role or responsibility in the recovery process. These could range from

IT teams, cybersecurity experts, and management to legal departments, human resources, and external service providers.

Stakeholders need to be aware of their specific roles in coordinating recovery efforts and ensuring resources are available for the successful execution of the recovery plan.

2. Defining Objectives and Scope

The objectives and scope of the recovery plan outline the key goals of incident recovery, including restoring services, protecting sensitive data, and minimizing financial losses.

The scope defines which systems, processes, and functions are critical and need immediate attention during recovery. It also defines the boundaries of the recovery efforts, ensuring the focus remains on the most important aspects of the business that need to be restored quickly.

3. Risk Assessment and Business Impact Analysis (BIA)

- **Risk assessment** identifies potential threats and vulnerabilities that could affect the company,
- **BIA** evaluates the impact of these threats on the business's critical functions.

BIA helps prioritize the recovery of essential services and systems, ensuring the company can mitigate the effects of the incident while protecting the most valuable assets.

4. Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs)

Recovery Time Objectives (RTOs) and **Recovery Point Objectives (RPOs)** are two important metrics in incident recovery.

- **RTO** refers to the maximum acceptable amount of time a system or process can be down before it significantly affects business operations. It sets a deadline for when the recovery must be completed.
- **RPO** defines the acceptable amount of data loss measured in time—essentially how far back in time the data should be restored after an incident. Both RTOs and RPOs help ensure the organization can restore critical services and data within a timeframe that minimizes operational disruption.



Theoretical Activity 4.2.2: Description of Incident Recovery Plans development



Tasks:

1: Answer the following questions:

i. What is incident response integration?
ii. Describe communication and notification in incident recovery plans?
iii. What are recovery procedures?
iv. What is the purpose of testing and validation?
v. Define Resource allocation.
vi. Explain documentation and reporting in incident recovery plans?
vii. What is Regulatory and legal compliance
viii. Why we need employee training and awareness in incident recovery Plans
ix. What is continuous improvement?
x. What is review and approval?
xi. What is business continuity integration
xii. Difference between public relations and reputation management?
xiii. Define post-incident analysis and improvement

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 4.2.2.



Key readings 4.2.2.:

Developing Incident Recovery Plans

An **Incident Recovery Plan** is vital for organizations to effectively respond to and recover from security incidents. It establishes a structured approach to restore operations, protect sensitive information, and maintain business continuity. Below are the critical components of developing an effective Incident Recovery Plan

1. Incident Response Integration

Integrating incident response within the recovery plan ensures that all actions taken during an incident align with the overall recovery strategy. This includes establishing clear communication channels and protocols among the response teams to facilitate a coordinated effort during an incident.

2. Communication and Notification

Effective communication is crucial during a security incident. The recovery plan should outline notification procedures, including who to notify internally and

externally during an incident. It should also specify the communication tools and platforms that will be used and establish regular updates on the incident status for stakeholders.

3. Recovery Procedures

This section details the specific steps to recover systems and data. Key components include system restoration procedures for restoring affected systems from backups, data recovery processes for recovering lost or compromised data, and plans for resuming critical services in order of priority.

4. Testing and Validation

Testing the recovery plan ensures its effectiveness. This can include conducting regular drills and simulations to practice the recovery procedures and validating that all tools and technologies function as intended during an incident.

5. Resource Allocation

Identifying the resources required for effective recovery is essential. This includes human resources, such as personnel needed to execute the recovery plan; technological resources, including hardware, software, and tools required for recovery efforts; and financial resources to support the recovery actions.

6. Documentation and Reporting

Thorough documentation is essential for accountability and future reference. This includes keeping detailed incident logs that record the incident, recovery actions taken, and timelines, as well as post-incident reports summarizing the incident, recovery efforts, and outcomes.

7. Regulatory and Legal Compliance

Ensuring that the recovery plan adheres to relevant legal and regulatory requirements is crucial. This involves compliance with data protection laws governing the handling of personal and sensitive data and adherence to industry-specific regulations that may impact recovery processes.

8. Employee Training and Awareness

Regular training sessions help ensure that employees understand their roles in the recovery plan. This includes workshops and seminars that educate employees on the recovery procedures and their responsibilities, as well as awareness campaigns that promote knowledge about cybersecurity threats and the importance of the recovery plan.

9. Continuous Improvement

A commitment to continuous improvement helps organizations adapt to evolving threats. This involves implementing feedback mechanisms to collect input from stakeholders post-incident and reviewing best practices to stay informed about industry standards, integrating them into the recovery plan.

10. Review and Approval

The incident recovery plan should undergo regular reviews and approvals by key stakeholders to ensure its relevance and effectiveness. This includes periodic reviews to update the plan based on new risks or changes in the organization and ensuring that leadership endorses the recovery plan and its procedures.

11. Business Continuity Integration

The recovery plan should align with the organization's business continuity plan (BCP) to ensure that recovery efforts support overall business objectives. Key considerations include identifying shared resources that can be leveraged for both recovery and continuity efforts and ensuring that incident recovery efforts do not conflict with ongoing business operations.

12. Public Relations and Reputation Management

Addressing public perception is vital during and after an incident. The recovery plan should include a crisis communication strategy detailing how to communicate with the public and stakeholders during an incident and establishing strategies for rebuilding trust and confidence after an incident.

13. Post-Incident Analysis and Improvement

After recovering from an incident, organizations should conduct a thorough analysis to identify lessons learned. This includes reviewing the recovery effectiveness to assess what worked well and what did not during the recovery process, along with implementing necessary adjustments to the recovery plan based on findings from the post-incident analysis.

14.Testing and Documentation

Finally, regular testing and documentation of the recovery plan are essential for maintaining readiness. This involves conducting routine tests of the recovery procedures to ensure efficiency and regularly updating the recovery plan documentation to reflect any changes in procedures or organizational structure.



Points to Remember

Description of Plan Incident Recovery

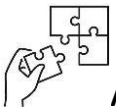
- The Incident Recovery Plan is an essential part of cybersecurity that outlines how an organization can recover from security incidents like cyberattacks or system failures. This plan focuses on restoring normal operations while minimizing the impact on business functions.
- Identify the key stakeholders involved in the recovery process. This includes IT teams, cybersecurity experts, management, legal departments, and external service provider.

- Clearly define the objectives of the recovery plan, such as restoring services, protecting sensitive data, and minimizing financial losses.
- Conduct a risk assessment to identify potential threats and vulnerabilities. Perform a Business Impact Analysis (BIA) to evaluate how these threats could affect business operations.
- RTO specify the maximum time allowed for a system or process to be down before it disrupts business operations.
- RPO specify he maximum acceptable amount of data loss, indicating how far back in time data should be restored after an incident.

Description of Incident Recovery Plans development

- An Incident Recovery Plan outlines how an organization can recover from security incidents, such as cyberattacks or system failures.
- Incident Response Integration ensures that the incident response efforts align with the recovery plan.
- Communication and Notification is critical during a security incident. The recovery plan should specify who needs to be notified, both internally and externally, and outline the tools and methods for communication.
- Recovery Procedures should detail the steps to recover affected systems and data. This includes restoring systems from backups, recovering lost data, and prioritizing the resumption of critical services.
- Regular testing of the recovery plan is essential to ensure it works as intended. This can involve conducting drills and simulations to practice recovery procedures and confirm that all necessary tools and technologies function correctly.
- Identifying the necessary resources for recovery is important. This includes personnel, technology, and financial resources needed to execute the recovery plan successfully.
- Documentation and Reporting includes maintaining logs of the incident and recovery actions, as well as post-incident reports summarizing what occurred and how it was handled.
- The recovery plan must adhere to relevant laws and regulations. This includes data protection laws and industry-specific requirements that may affect recovery processes.
- Regular training helps employees understand their roles in the recovery plan. This can include workshops and awareness campaigns to educate staff about cybersecurity threats and recovery procedures.
- Organizations should strive for continuous improvement by gathering feedback after incidents and updating the recovery plan based on new threats and best practices.

- The recovery plan should be regularly reviewed and approved by key stakeholders to ensure it remains relevant and effective. This includes updating the plan based on changes in the organization or emerging risks.
- The recovery plan should align with the organization's overall business continuity plan (BCP). This ensures that recovery efforts support broader business objectives and do not interfere with ongoing operations.
- Managing public perception is essential during an incident. The recovery plan should include strategies for communicating with the public and stakeholders and rebuilding trust afterward.
- After recovering from an incident, a thorough analysis should be conducted to identify lessons learned. This involves reviewing the recovery process to assess effectiveness and making necessary adjustments to improve future responses.
- Regularly testing and updating the recovery plan documentation helps maintain readiness and ensures that procedures reflect current organizational needs.



Application of learning 4.2.

The sales company HD has recently experienced a data breach that compromised sensitive customer information and disrupted normal operations. In light of this incident, you are requested to develop a comprehensive Incident Recovery Plan (IRP) to address potential future incidents, ensure rapid recovery, and safeguard against similar threats.

Indicative content 4.3: Identification of Security Incident

Duration: 3 hrs

Theoretical Activity 4.3.1: Description of Security Incident

Tasks:

1: Answer the following questions:

i. List Common incident categories?
ii. What are detection tools and systems used to monitor security incident?
iii. Describe baseline normal behaviour.

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 4.3.1.

Key readings 4.3.1.:

Description of Security Incident

Identifying security incidents involves recognizing events that may compromise the confidentiality, integrity, or availability of information systems. By categorizing incidents and utilizing detection tools, organizations can respond effectively.

1. Incident Categories

Security incidents can be classified into several categories based on their nature and impact. Common categories include:

- **Malware Incidents**: This includes viruses, worms, ransomware, and spyware that infiltrate systems and disrupt normal operations.
- **Phishing Attacks**: Incidents where attackers deceive users into providing sensitive information, often through fraudulent emails or websites.
- **Unauthorized Access**: Attempts by individuals to gain access to systems or data without permission, potentially leading to data breaches.
- **Denial of Service (DoS)**: Attacks aimed at making a service unavailable to intended users by overwhelming it with traffic or requests.
- **Insider Threats**: Incidents caused by employees or trusted individuals misusing their access to compromise systems or data.

2. Incident Detection Tools and Systems

To effectively identify security incidents, organizations rely on various detection tools and systems, including:

- **Intrusion Detection Systems (IDS)**: These systems monitor network traffic for suspicious activities and alert administrators to potential threats. They can be host-based or network-based.

Examples: Snort and Suricata

- **Security Information and Event Management (SIEM) Tools**: SIEM tools aggregate and analyze security data from various sources, enabling real-time monitoring and incident detection.

Examples: Splunk and I BM QRadar

- **Endpoint Detection and Response (EDR)**: EDR solutions focus on endpoint devices, monitoring them for unusual behavior and potential threats.

Examples: Carbon Black and CrowdStrike Falcon

- **Firewalls**: Modern firewalls include intrusion prevention capabilities, which can detect and block known attack patterns.

Examples: Cisco ASA

- **Network Traffic Analysis Tools**: These tools analyze network traffic for anomalies that may indicate a security incident.

Examples: Wireshark and Darktrace

3. Baseline Normal Behavior

Establishing a baseline of normal behavior within an organization is crucial for effective incident detection. This involves:

- **Monitoring User Activities**: Understanding typical user behavior patterns helps in identifying deviations that may indicate an incident, such as unusual login times or accessing unauthorized data.
- **Network Traffic Patterns**: Analyzing standard network traffic can help detect anomalies, such as spikes in data transfer that may signify a DoS attack or data exfiltration.
- **System Performance Metrics**: Establishing what constitutes normal system performance (CPU usage, memory consumption, etc.) allows for the identification of potential incidents, such as malware causing resource spikes.



Theoretical Activity 4.3.2: Identification of Incident Detection Techniques



Tasks:

1: Answer the following questions:

i. What is Anomaly Detection
ii. What is Signature-Based Detection
iii. What is User and Entity Behavior Analytics (UEBA)
iv. Describe Incident Reporting

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 4.3.2.



Key readings 4.3.2:

Describing Incident Detection Techniques

Incident detection techniques are essential for identifying potential security incidents in an organization's environment. Here's an overview of four key techniques used to detect anomalies and threats.

1. Anomaly Detection

Anomaly detection involves monitoring network traffic, system behavior, and user activities to identify deviations from established baselines of normal behavior. This technique relies on statistical analysis and machine learning algorithms to spot unusual patterns that may indicate a security incident. Anomaly detection is particularly effective for identifying zero-day attacks or insider threats, as it does not rely on known attack signatures. However, it can generate false positives if legitimate changes in behavior occur, such as increased traffic during peak hours.

2. Signature-Based Detection

Signature-based detection identifies security incidents by comparing incoming data against a database of known threat signatures or patterns. This technique is widely used in antivirus software and intrusion detection systems (IDS). If a match is found, an alert is generated to indicate a potential security threat. While signature-based detection is effective for recognizing known threats, it may struggle with detecting new or unknown threats that do not have established signatures, making it less effective against advanced persistent threats (APTs) and zero-day vulnerabilities.

3. User and Entity Behavior Analytics (UEBA)

User and Entity Behavior Analytics (UEBA) leverages machine learning and advanced analytics to monitor and analyze the behavior of users and entities (such as devices or applications) within a network. UEBA establishes a baseline of normal behavior for each user and entity, allowing it to detect deviations that may signal a potential security incident, such as unusual login times, access to sensitive data, or unusual transaction patterns. This technique is particularly effective in identifying insider threats and compromised accounts, as it focuses on behavioral changes rather than predefined rules.

4. Incident Reporting

Incident reporting is a critical process in incident detection and response. It involves documenting and communicating information about detected security incidents to relevant stakeholders, including IT and security teams. Effective incident reporting includes details such as the nature of the incident, the systems affected, the time of detection, and any immediate actions taken. Clear and timely incident reporting ensures that organizations can respond quickly and effectively to security incidents, facilitating coordination among response teams and enhancing overall incident management processes.



Theoretical Activity 4.3.3: Description of accident response and reporting



Tasks:

1: Answer the following questions:

i. What is Security information sharing?
ii. Describe Logging and Monitoring.
iii. What is Security awareness training?
iv. Describe Incident Response Playbooks.
v. Give types of Third-Party Services
vi. Describe Compliance with Regulations

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 4.3.3.

Key readings 4.3.3:

Incident response and reporting

Incident response and reporting are critical components of a robust cybersecurity strategy. They help organizations effectively manage security incidents and enhance overall security posture. Below are key elements involved in incident response and reporting:

1. Security Information Sharing

Security information sharing involves collaborating with other organizations, industry groups, and governmental bodies to share data about security threats and incidents. This collective intelligence helps organizations stay informed about emerging threats and effective response strategies. By sharing information, organizations can improve their defenses and enhance their incident response capabilities.

2. Logging and Monitoring

Logging and monitoring are essential for detecting and analyzing security incidents. Logging refers to the systematic recording of events and actions taken within an IT environment, while monitoring involves real-time analysis of these logs to identify suspicious activities. Effective logging and monitoring enable organizations to respond quickly to incidents, conduct thorough investigations, and improve future defenses based on learned experiences.

3. Security Awareness Training

Security awareness training educates employees about cybersecurity risks, best practices, and their roles in protecting the organization. By increasing awareness and understanding of security threats, employees can recognize potential incidents and respond appropriately. Regular training sessions help create a security-conscious culture and reduce the likelihood of human errors that could lead to security breaches.

4. Incident Response Playbooks

Incident response playbooks are documented procedures that outline how to handle specific types of security incidents. These playbooks provide detailed step-by-step instructions for responding to incidents, including containment, eradication, recovery, and communication protocols. Having predefined playbooks ensures a consistent and efficient response to incidents, minimizing confusion and improving response times.

5. Third-Party Services

Organizations may utilize third-party services for incident response, threat detection, or security monitoring. These services can provide specialized expertise, resources, and tools that enhance the organization's incident response capabilities. Third-party providers can offer managed security services, incident

response support, or threat intelligence, which can be valuable, especially for organizations with limited in-house resources.

6. Compliance with Regulations

Compliance with industry regulations and standards is crucial for incident response and reporting. Many organizations are subject to laws and regulations that dictate how they must manage security incidents, such as data breach notification requirements. Understanding and adhering to these regulations ensures that organizations meet legal obligations and protect sensitive data, which can enhance trust among customers and stakeholders.



Theoretical Activity 4.3.4: Description of threat intelligence integration for incident classification and prioritization



Tasks:

1: Answer the following questions:

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 4.3.4.



Key readings 4.3.4:

Threat Intelligence Integration for Incident Classification and Prioritization

Threat intelligence refers to the collection, analysis, and application of information about potential or actual cyber threats to an organization. It includes details about attackers, their tools, techniques, and procedures (TTPs), as well as insights into emerging vulnerabilities and active threat actors. The primary purpose of threat intelligence is to help organizations anticipate and prevent potential attacks, enhance their security posture, and respond more effectively to security incidents.

ii. Steps for Integration of Threat Intelligence into Incident Classification and Prioritization

1. **Collecting Threat Intelligence Data** The first step is gathering relevant threat intelligence from both internal and external sources. These sources can include threat feeds, vulnerability databases, security alerts, industry reports, and information shared by other organizations or cybersecurity communities.

2. **Analyzing Threat Intelligence** After collecting data, organizations must analyze the intelligence to identify trends, patterns, and key insights. This analysis helps in

understanding the nature of threats, such as the tools, techniques, and procedures used by attackers. Threats are categorized based on their severity, potential targets, and impact.

3. **Integrating Threat Intelligence into Detection Systems** Organizations integrate the analyzed threat intelligence into their security tools, such as SIEM systems, Intrusion Detection Systems (IDS), and Endpoint Detection and Response (EDR) solutions. These tools can then automatically detect and respond to threats based on the intelligence, improving real-time detection.

4. **Classifying Incidents Using Threat Intelligence** During an incident, the threat intelligence is used to classify the type and severity of the threat. Incidents are categorized based on the information gathered about the attackers' motives, methods, and targets. This ensures that the organization understands the nature of the incident and can take appropriate action.

5. **Prioritizing Incidents Based on Threat Intelligence** Once incidents are classified, they are prioritized according to the potential risk they pose to the organization. Threat intelligence helps determine which incidents are most critical and require immediate attention. Factors such as the type of attack, potential impact, and likelihood of further damage are considered during prioritization.

6. **Continuous Improvement and Updates** Threat intelligence is constantly evolving, and organizations must continuously update their systems and processes. Regularly integrating new intelligence allows for improved incident detection, classification, and prioritization, making the organization more resilient against emerging threats.

Threat intelligence and threat hunting are both critical components of cybersecurity, but they serve distinct purposes and employ different methodologies.

Threat Intelligence

- **Focus:** Gathering, analyzing, and disseminating information about threats to cybersecurity.
- **Methodology:** Primarily relies on external sources like industry reports, open-source intelligence, and threat feeds.
- **Goal:** To provide proactive insights into potential threats and help organizations prepare for attacks.

Threat Hunting

- **Focus:** Actively searching for malicious activity within an organization's network.
- **Methodology:** Employs techniques like anomaly detection, signature-based analysis, and behavioral analytics.
- **Goal:** To identify and disrupt threats that may have evaded traditional security controls.

Key Differences

Feature	Threat Intelligence	Threat Hunting
Focus	Proactive threat prevention	Reactive threat detection
Methodology	External intelligence	Internal analysis
Goal	Prepare for attacks	Disrupt active threats



Practical Activity 4.3.5: Applying Incident Response and Reporting



Task:

1: Referring to the previous theoretical activity (4.3.5) you are requested to perform the following activity.

The school has experiences a ransomware attack, how school must respond swiftly to minimize the damage, restore operations, and ensure customer data remains protected.

2: Read the key readings 4.3.5.



Key readings 4.3.5.

1. Identify how to recognize the ransomware attack

✓ **Detection**: The SOC (Security Operations Center) identifies unusual file encryption activity across several servers, accompanied by ransom notes left on affected machines.

✓ **Alerts**: The SIEM system sends alerts about abnormal file system changes and unauthorized encryption processes. Multiple failed backup attempts are also flagged.

✓ **Employee Reporting**: Employees report being locked out of their systems and seeing ransom messages demanding payment in crypto currency.

2. Containment immediate actions to limit the spread

Network Segmentation: The SOC team isolates infected systems from the rest of the network to prevent further spread of the ransomware.

Shutdown Critical Systems: Critical servers that have not yet been affected are temporarily taken offline to avoid being infected.

Disable Network Shares: Shared drives and network file systems are disconnected to prevent the encryption of files across the network.

3. Eradication: Removing the ransomware and eliminating its root cause

Identify Entry Point: Investigate how the ransomware was introduced (likely through a phishing email or vulnerability) and close the vector of entry.

Malware Removal: Use malware removal tools to clean affected systems of ransomware components. This includes scanning for remnants of the ransomware to prevent reinfection.

Patching and Updates: Apply necessary security patches to vulnerabilities that the attackers exploited.

4. Recovery for restoring operations and ensuring system integrity

Data Restoration: The IT team restores encrypted data from secure backups, ensuring they are clean and uncompromised.

System Validation: After restoration, all systems are tested for proper functioning and integrity. Ensure no traces of malware are left behind.

Reinforce Security Measures: Implement enhanced security controls, including stricter access management and multi-factor authentication (MFA).

5.Post-incident analysis and prevention

Post-Incident Review: Conduct a full review of how the ransomware entered the network, how it spread, and what could have been done to prevent it.

Security Awareness Training: Implement training sessions for employees to recognize phishing attempts and suspicious emails.

Update Incident Response Playbooks: Update the ransomware playbook based on this attack and ensure all response teams are trained on new procedures.



Points to Remember

Description of Security Incident

- Identifying a security incident involves recognizing and classifying events that may threaten the integrity, confidentiality, or availability of information.
- Incidents can be categorized based on their nature and impact. Common categories include: Malware Attacks, Phishing Attacks, Unauthorized Access, Denial of Service and Insider Threats
- To effectively identify security incidents, organizations rely on various detection tools and systems, including Intrusion Detection Systems (IDS), Security Information and Event Management (SIEM) Tools, Endpoint Detection and Response (EDR), Firewalls and Network Traffic Analysis Tools
- Baseline Normal Behavior refers to the standard patterns of activity within an organization's systems, networks, and applications under normal operating conditions

Identification of Incident Detection Techniques

- Anomaly detection monitors network and user activities to find unusual behavior compared to what is considered normal.
- Signature-based detection works by comparing data against a database of known threat signatures or patterns.
- UEBA analyzes the behavior of users and devices within a network. It establishes a baseline of normal behavior and looks for deviations that might signal a security issue, such as unusual login times or access to sensitive information.
- Incident reporting involves documenting and sharing details about detected security incidents with relevant teams

Description of accident response and reporting

- Sharing information about security threats and incidents with other organizations and government bodies helps improve overall security. By collaborating, organizations can stay updated on emerging threats and enhance their responses.
- Logging involves recording events and actions in an IT environment. Monitoring is the real-time analysis of these logs to spot suspicious activities.
- Training employees on cybersecurity risks and best practices increases awareness. Educated employees can recognize potential incidents and respond correctly, reducing the likelihood of human errors that could lead to breaches.
- These are documented procedures that guide teams on how to handle specific security incidents. Playbooks provide clear steps for response, ensuring a consistent and efficient approach, which minimizes confusion during incidents.

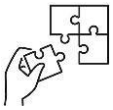
- Organizations can engage third-party services for additional expertise in incident response and threat detection. These providers can offer managed security services and support, enhancing the organization's overall capabilities.
- Adhering to industry regulations is crucial for incident management. Organizations must understand and follow legal requirements regarding incident reporting and data protection, which builds trust with customers and stakeholders.

Description of threat intelligence integration for incident classification and prioritization

- Threat intelligence is the process of gathering, analyzing, and using information about potential or actual cyber threats. It helps organizations understand who is attacking them, how they are being attacked, and what the attackers are trying to achieve.
- Steps for Integration of Threat Intelligence into Incident Classification and Prioritization: Collecting Threat Data, Analyzing Threats, Integrating into Detection Systems, Classifying Incidents, Prioritizing Incidents, continuous Updates.

While apply response in security incident you follow the following steps:

1. Identify how to recognize the ransomware attack
2. Containment immediate actions to limit the spread
3. Eradication: Removing the ransomware and eliminating its root cause
4. Recovery for restoring operations and ensuring system integrity
5. post-incident analysis and prevention



Application of learning 4.3.

Our school experiences a phishing attack where an employee unknowingly clicks on a malicious email link. This leads to the compromise of their account, and the attacker gains access to sensitive customer information stored in cloud services. The attacker begins exfiltrating customer data. How our school must respond swiftly to contain the breach, minimize damage, and ensure compliance with regulatory requirements.

Indicative content 4.4: Isolation of Affected System

Duration: 2 hrs

Theoretical Activity 4.4.1: Description of Immediate Action and Communication in isolation of affected system

Tasks:

1: Answer the following questions:

i. What are immediate action upon incident detection?

ii. Describe establishing communication procedures.

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 4.4.1.

Key readings 4.4.1.:

Description of Immediate Action and Communication in isolation of affected system

The isolation of affected systems is a critical step in incident response to prevent the spread of cyber threats. When a security breach or attack occurs, it is essential to quickly isolate the compromised system from the rest of the network. This limits the ability of the attacker to access sensitive data or infect additional systems and helps contain the damage while recovery efforts are planned.

Immediate Action and Communication

1. Immediate Action upon Incident Detection

The first response to an incident is to take immediate action to contain the threat. This can include shutting down the affected system, disconnecting it from the network, or disabling its internet access. The goal is to stop any ongoing malicious activity as quickly as possible to minimize damage and prevent the threat from escalating.

2. Establishing Communication Procedures

Effective communication is essential during an incident. As soon as the issue is detected, it is critical to inform all relevant stakeholders, such as the incident response team, IT staff, and company management. Establishing a clear communication procedure ensures that everyone is aware of their roles and

responsibilities in the incident response process. It also helps ensure that key decision-makers receive timely updates, allowing them to take appropriate actions. Communication with external stakeholders, such as third-party service providers or legal authorities, may also be necessary, depending on the severity of the incident.



Theoretical Activity 4.4.2: Description system isolation techniques and analysis of affected systems.



Tasks:

1: Answer the following questions:

i. Describe the system isolation techniques (Network Segmentation, Disable Network Ports, Firewall Rules and Isolation Switches)
ii. identify analysis of affected systems (Incident Analysis, Impact Assessment, Validation of Isolation and Logging and Documentation)

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 4.4.2.

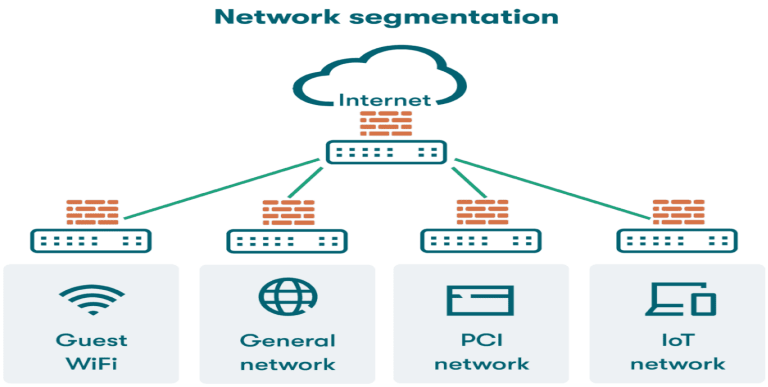
Key readings 4.4.2:

Description system isolation techniques and analysis of affected systems.

Several techniques can be used to isolate the affected systems during a security incident:

1. Network Segmentation

Network segmentation is a preventive technique that involves dividing the network into smaller, isolated segments. If one segment is compromised, the isolation limits the spread of the threat to other parts of the network. During an incident, network administrators can also further restrict access to certain segments to contain the attack within a specific area of the network.



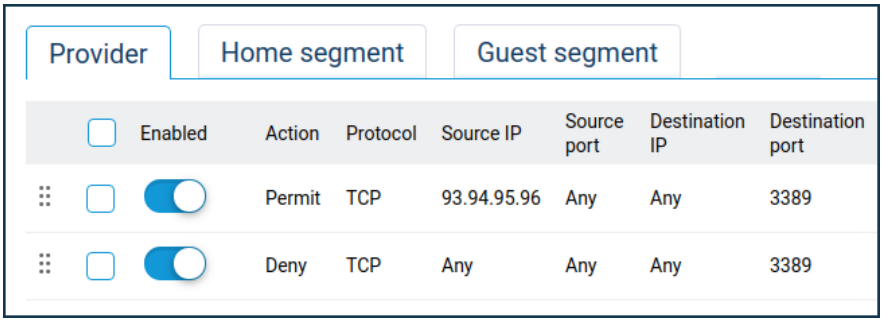
2. Disable Network Ports

Disabling network ports on compromised systems is an effective way to stop an attacker from using those ports to send or receive malicious traffic. By closing off these entry and exit points, the organization's security team can contain the threat and prevent it from spreading to other systems.



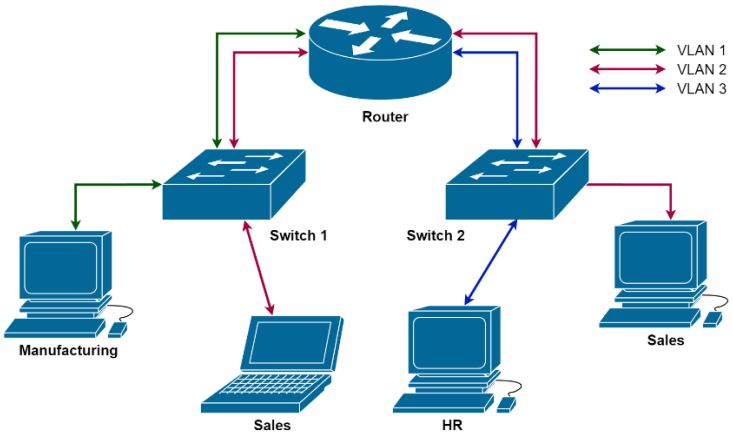
3. Firewall Rules

Adjusting or enforcing firewall rules is another method to isolate affected systems. By updating firewall settings, administrators can block all incoming or outgoing traffic from the compromised device or network segment. Firewalls can serve as a powerful defense to stop attackers from moving laterally through the network or exfiltrating data.



4. Isolation Switches

Isolation switches are physical or software-based mechanisms that allow systems or network segments to be quickly disconnected from the rest of the network. In the event of an incident, activating an isolation switch can sever the affected system's connection, effectively quarantining it to stop the spread of malware or prevent further attacks.



Analysis of Affected Systems

When an incident occurs, analyzing the affected systems is crucial to understand the extent of the damage, the root cause of the incident, and the appropriate steps to recovery. This process involves various activities that ensure a thorough examination and documentation of the security breach.

1. Incident Analysis

Incident analysis focuses on identifying how the security event occurred, the vulnerabilities exploited, and the attack vectors used. This analysis helps the incident response team understand the source and method of the attack. By closely examining system logs, network traffic, and other relevant data, the team

can reconstruct the sequence of events leading to the compromise. The analysis phase is crucial for uncovering hidden threats and ensuring that no aspect of the attack is overlooked.

2. Impact Assessment

Impact assessment evaluates the damage caused by the security incident. This involves determining which systems, data, or operations were affected and estimating the severity of the impact on business functions. The assessment also looks at potential long-term effects on the company, including financial loss, reputational damage, and regulatory implications. A detailed impact assessment helps prioritize the recovery efforts based on the criticality of the affected assets.

3. Validation of Isolation

Once systems have been isolated, it is important to validate that the isolation has been successful and that the threat has been contained. This step ensures that the compromised systems are no longer communicating with other parts of the network and that the attack cannot spread further. Validation often involves continuous monitoring of the isolated system to ensure there is no residual malicious activity.

4. Logging and Documentation

Throughout the incident analysis and recovery process, logging and documentation play a vital role. Every action taken, including isolation, analysis, and recovery steps, should be logged and documented in detail. This provides a clear record of the incident for later review and is essential for legal and regulatory compliance. Proper documentation also aids in post-incident analysis, allowing the organization to learn from the event and improve future response plans.



Theoretical Activity 4.4.3: Description of recovery planning and communication



Tasks:

1: Answer the following questions:

i. Describe recovery planning
ii. Describe Communication and Reporting
iii. Describe Remediation and System Restoration
iv. Describe Policy and Procedural Updates

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 4.4.3.



Key readings 4.4.3:

Description of recovery planning and communication

Effective recovery planning and communication are critical components of a robust incident response strategy, ensuring organizations can minimize the impact of cybersecurity incidents and restore normal operations efficiently. This handout details four essential components: recovery planning, communication and reporting, remediation and system restoration, and policy and procedural updates.

1. Recovery Planning

Recovery planning serves as the foundation for responding effectively to cybersecurity incidents. The process begins with a thorough impact assessment to identify the systems, applications, and data affected by the incident. Understanding the extent of the damage is essential for guiding recovery efforts and prioritizing actions based on operational needs.

Central to recovery planning are two key concepts: Recovery Time Objective (RTO) and Recovery Point Objective (RPO). The RTO defines the maximum acceptable duration for restoring operations after an incident, while the RPO establishes the maximum acceptable amount of data loss, measured in time. By defining these objectives, organizations can create a targeted recovery strategy that aligns with their operational requirements.

2. Communication and Reporting

Effective communication is essential during recovery efforts, as it helps keep all stakeholders informed and engaged throughout the incident response process. Establishing clear internal communication channels among the incident response team, IT staff, and management is crucial for coordinating recovery efforts efficiently. Regular updates on the progress of recovery help maintain alignment among team members and foster collaboration.

External communication is equally important. Organizations must notify affected stakeholders—such as customers, partners, and regulatory bodies—of the incident as necessary. Transparent communication helps manage the organization's reputation and builds trust with stakeholders during challenging times. Additionally, it is essential to prepare public statements that convey the organization's commitment to resolving the incident and safeguarding sensitive information.

3. Remediation and System Restoration

Once immediate recovery efforts are complete, organizations must focus on remediation and system restoration. The first step in this process is to identify and address the vulnerabilities that led to the incident. Remediation may involve applying software patches, reconfiguring systems, or enhancing security measures

to fortify defenses against future threats. This proactive approach is essential to preventing similar incidents from occurring in the future.

System restoration typically requires recovering data from backups. During this phase, organizations must ensure the integrity and security of the restored data to prevent further issues. Thorough testing of restored systems is necessary to verify that all components are

4. Policy and Procedural Updates

The post-incident phase necessitates a thorough review and update of existing policies and procedures. Conducting a post-incident review allows organizations to assess their current security policies and identify weaknesses that contributed to the incident. This process is crucial for preventing future incidents and strengthening the overall security posture of the organization.

Once vulnerabilities are identified, organizations must update their policies to address these gaps. This may involve revising security practices, access controls, and incident reporting protocols to ensure they are robust and effective. Additionally, it is essential to conduct training and awareness initiatives for staff, ensuring they understand the revised policies and the importance of adhering to them.



Points to Remember

Description of Immediate Action and Communication in isolation of affected system

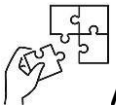
- The isolation of affected systems is a crucial part of incident response to prevent the spread of cyber threats. When a security breach or attack occurs, it is essential to quickly isolate the compromised system from the rest of the network
- The first step in incident response is to take immediate action to contain the threat. This could involve shutting down the affected system, disconnecting it from the network, or disabling its internet access. The goal is to quickly stop any ongoing malicious activity, minimizing damage and preventing the threat from worsening.
- Effective communication is critical during an incident. As soon as the issue is detected, it is important to inform all relevant stakeholders, such as the incident response team, IT staff, and company management. A clear communication procedure ensures everyone knows their roles and responsibilities in responding to the incident. Identifying a security incident involves recognizing and classifying events that may threaten the integrity, confidentiality, or availability of information.

Description system isolation techniques and analysis of affected systems.

- Four techniques used to isolate affected systems are Network segmentation divides a network into smaller, isolated sections, disabling network ports on compromised systems cuts off the attacker's ability to use those ports for malicious activity, adjust firewall rules, administrators can block all traffic to and from a compromised device or segment of the network and Isolation switches can quickly disconnect affected systems or network segments from the larger network.
- After a security incident, analyzing the affected systems is essential for understanding the extent of the damage and planning the recovery process. This analysis involves several key steps: Incident Analysis**,** Impact Assessment**,** Validation of Isolation**,** Logging and Documentation

Description of recovery planning and communication

- Recovery planning is the first step in responding to cybersecurity incidents. It starts with assessing the impact to identify affected systems and data. This understanding helps prioritize recovery actions.
- Effective communication keeps everyone informed during recovery. Clear internal channels among the incident response team and management ensure efficient coordination. Regular updates on recovery progress maintain alignment.
- Once immediate recovery efforts are done, organizations should focus on fixing vulnerabilities.
- After an incident, organizations need to review and update their policies and procedures. This review helps identify weaknesses that contributed to the incident.



Application of learning 4.4.

You've just been alerted to a potential data breach in your organization. What are the immediate actions you will take to respond to the incident, and how will you establish effective communication procedures across your team, identify system isolation techniques will you employ to contain the threat and prevent it from spreading?

Indicative content 4.5. Conducting Methodical Forensic Analysis

Duration: 2hrs

Theoretical Activity 4.5.1: Description of fundamentals forensic Analysis

Tasks:

1: Answer the following questions:

i. What is Planning and Preparation?
ii. Define Legal Considerations?
iii. Discuss on evidence preservation?
iv. Differentiate Isolation and Segmentation?
v. What is Data Collection
vi. Explain Forensic Imaging

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 4.5.1.

Key readings 4.5.1.:

Description of fundamentals forensic Analysis

1. fundamentals forensic Analysis

- **Planning and Preparation**

Before conducting any forensic analysis, it is crucial to have a comprehensive plan in place. This plan should outline the steps to be taken, define roles and responsibilities, and establish clear objectives. Effective planning ensures that the response to a cyber incident is organized, minimizes errors, and increases the chances of success.

***Example**:* A cybersecurity team creates a checklist to follow when collecting evidence during a data breach.

- **Legal Considerations:**

Forensic investigations must comply with legal and regulatory requirements. Ensuring that all actions are within legal boundaries is essential to avoid compromising evidence, breaching privacy laws, or violating data protection regulations. Investigators should always consider the legal ramifications of collecting, analyzing, and presenting digital evidence.

***Example**:* Consulting with legal counsel before investigating a data breach to ensure compliance with data protection laws (e.g., GDPR).

2. Conducting Forensic Analysis

- **Evidence Preservation:**

The integrity of digital evidence is a top priority in forensic analysis. It is important to avoid altering or damaging the evidence during collection and analysis. Evidence must be preserved in its original form to maintain its credibility in legal proceedings.

***Example**:* Creating a forensic image (bit-by-bit copy) of a compromised hard drive to preserve the original data.

- **Isolation and Segmentation:**

When a system is suspected of being compromised, isolating it from the rest of the network is a key step in preventing further damage, such as the spread of malware or data loss. Segmentation allows investigators to focus on the affected system without interference

***Example**:* Segregating an infected server from the network to contain the malware.

- **Data Collection**

Forensic analysis requires the collection of various forms of data, such as log files, network traffic, and system memory dumps. This data helps to trace the attacker's actions, understand the nature of the breach, and identify what data may have been accessed or exfiltrated.

***Example**:* Collecting log files from firewalls and intrusion detection systems (IDS) to trace the attack.

- **Forensic Imaging**

Forensic imaging involves creating exact copies of digital data, such as hard drives or memory, for analysis. This ensures that the original data is not altered during the investigation and allows forensic experts to conduct their work on a replica. Imaging is vital for preserving the original evidence while enabling detailed forensic examinations.

***Example**:* Using a forensic tool to make a clone of a suspect's computer drive for analysis.



Theoretical Activity 4.5.2: Description of evidence documentation and analysis



Tasks:

1: Answer the following questions:

i. What is Evidence Documentation?
ii. Discuss the Analysis and Examination?
iii. What is the difference between Artifact and Event Reconstruction?

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 4.5.2.



Key readings 4.5.2:

Description of evidence documentation and analysis

- **Evidence Documentation:** Maintain a detailed record of all steps taken during forensic analysis to ensure a clear chain of custody.
  - *Example:* Logging who handled the evidence, when it was collected, and how it was stored.
- **Analysis and Examination:** Analyze the collected data to understand the nature and scope of the incident.
  - *Example:* Examining file timestamps to detect unauthorized changes during an attack.
- **Artifact and Event Reconstruction:** Reconstruct events to understand how the breach occurred and identify vulnerabilities.
  - *Example:* Analyzing malware to determine how it infiltrated the system.



Theoretical Activity 4.5.3: Description of quality assurance and legal aspects



Tasks:

1: Answer the following questions:

i. Define Documentation and Reporting
ii. What is Quality Assurance
iii. Discuss on Legal Support

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 4.5.3.



Key readings 4.5.3:

. Quality Assurance and Legal Aspects

• **Documentation and Reporting:** Prepare a detailed report summarizing the findings and conclusions from the forensic analysis.

Example*:* Writing a final incident report with technical details and recommendations for mitigation.

• **Quality Assurance:** Ensure that forensic analysis follows best practices and industry standards.

Example: Having a peer review of the forensic investigation to ensure the accuracy of findings.

• **Legal Support:** Collaborate with legal teams to ensure the forensic analysis is admissible in court if needed.

Example*:* Working with legal counsel to verify that all evidence handling procedures meet legal requirements for litigation.

Practical Activity 4.5.4: Conducting Forensic Analysis in Cyber security

Task:

1: Referring to the previous theoretical activity (4.5.3) you are requested to perform the following activity.

You are requested to conduct forensic analysis to determine how the breach occurred, recover deleted data, and analyze the compromised systems.

2: Read the key readings 4.5.4.

Key readings 4.5.4.

Conduct Forensic Browser using Autopsy in Kali Linux

Step 1 : Installation of Autopsy

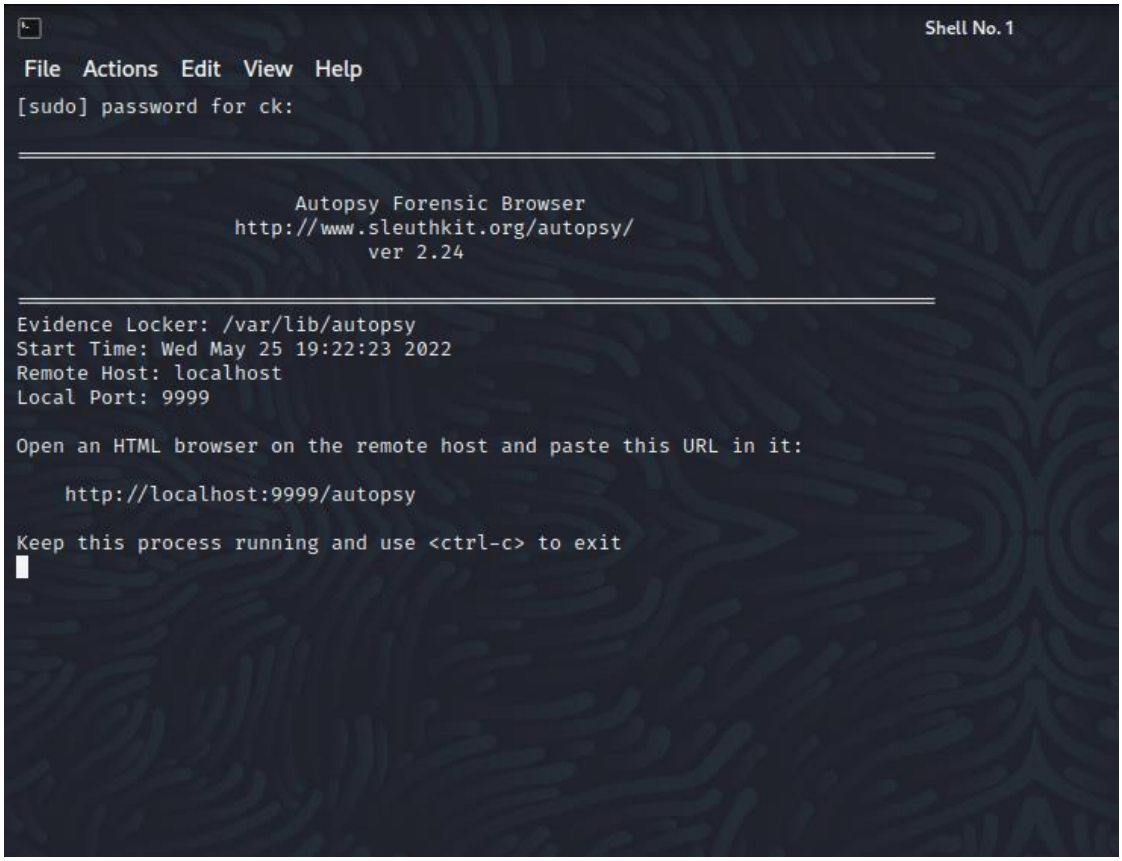
Execute the below command in the terminal for installing the Autopsy browser on the Linux system.

```
sudo apt-get install autopsy
```

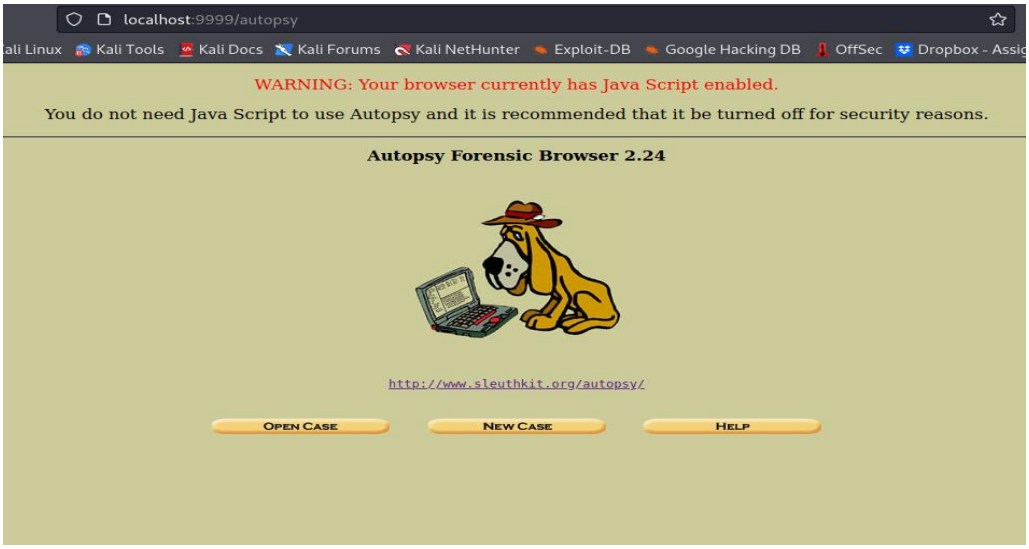
Usage of Autopsy Browser

Step 2: Opening Autopsy by typing the command in the terminal.

- Click on Applications in Kali Linux
- Search for autopsy
- Enter the password in autopsy(root)



Step 3: Launching Autopsy through the browser.
Click on the link of localhost from the autopsy shell to launch autopsy in the default browser.

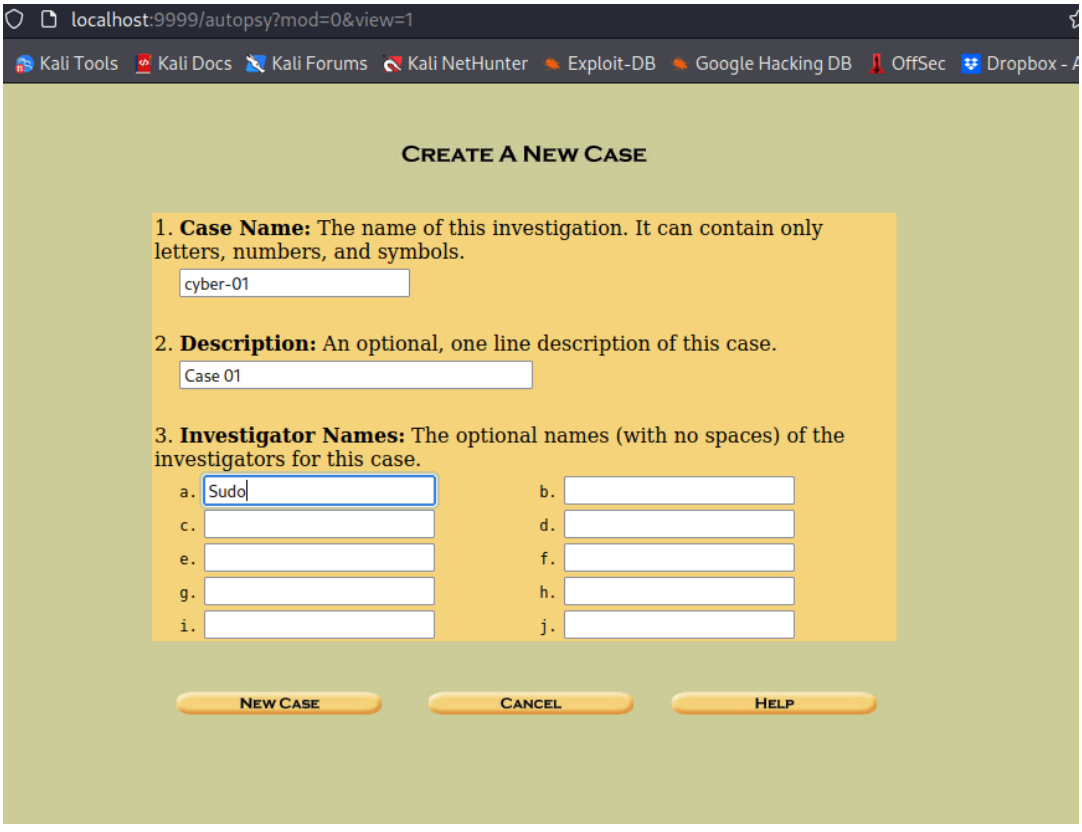


Now, we will select the name from the list. Here, we have selected the name **Sudo**.



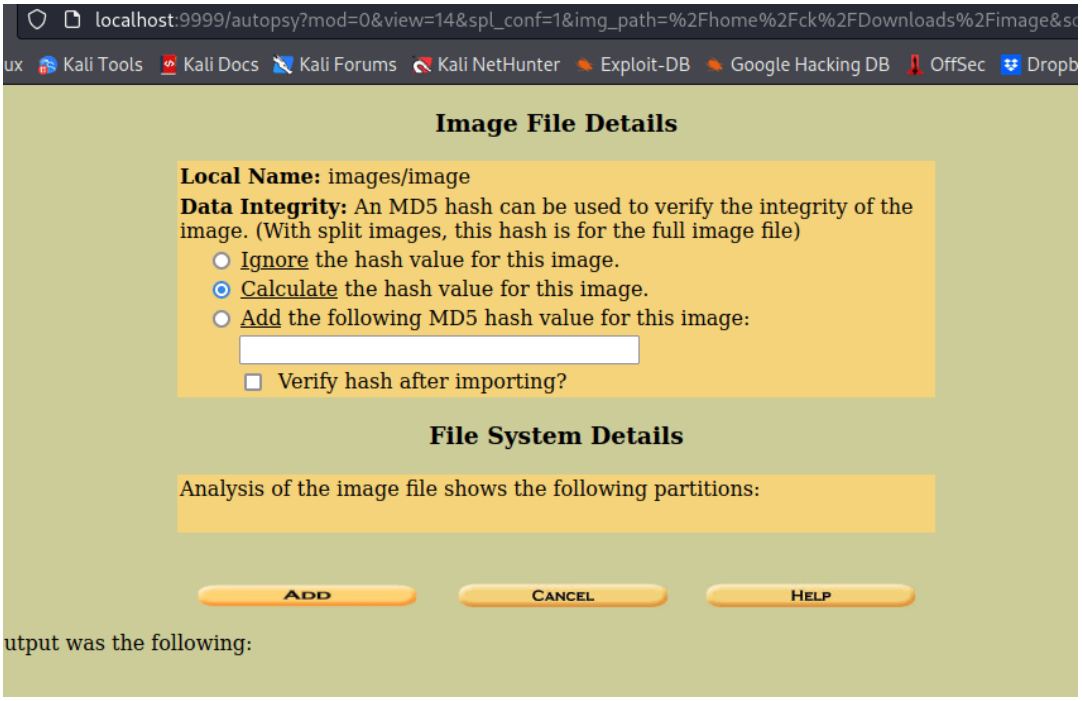
Step 4: Adding Host.

- Start a new case.
- Add a new host or select any previously created firewall.



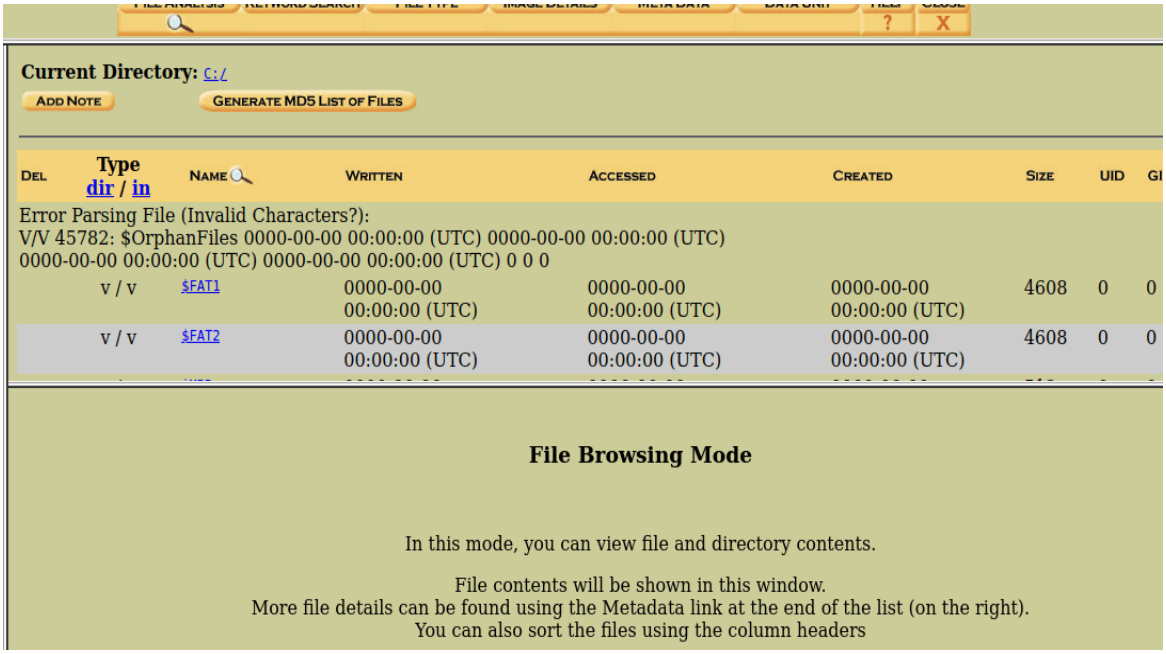
Step 5: Adding Image.

After creating the host, upload the image of the drive(generally have an extension of .dd).



Step 6: Analyzing Files.

After this click on **FILE ANALYSIS**.





Points to Remember

Description of fundamentals forensic Analysis

- Planning and Preparation: refers to the proactive steps an organization takes to be ready for potential incidents before they occur.
- Legal Considerations: refer to the laws, regulations, and compliance requirements that organizations must adhere to during and after an incident.
- Evidence preservation: refers to the process of securing and maintaining the integrity of digital and physical evidence collected during an incident investigation. It ensures that the evidence remains unaltered, making it admissible in legal proceedings.
- Isolation and Segmentation: Isolation is an emergency response action taken during or after an incident to immediately disconnect or cut off compromised systems from the rest of the network to prevent the spread of threats.Where as Segmentation is strategy that divides a network into smaller, more secure zones or segments to limit lateral movement of threats within a network. Each segment can have its own security controls.
- Data Collection: is the process of gathering relevant information during an incident response or investigation to understand the nature, scope, and impact of the incident.
- Forensic Imaging: is the process of creating an exact bit-by-bit copy of a digital storage device, such as a hard drive, SSD, or USB drive, for forensic analysis.

Description of evidence documentation and analysis

- **Evidence Documentation:** is the process of meticulously recording all steps, activities, and details related to the collection, handling, and analysis of evidence during an incident investigation.
- **Analysis and Examination:** are critical stages in the forensic investigation of an incident, where collected evidence is scrutinized to uncover relevant information.
- **Artifact**: refers to a piece of digital data or a trace left behind by a system or user action. This could be files, logs, registry keys, memory contents, or network traffic captures.
- **Event Reconstruction:** is the process of piecing together the sequence of events that occurred during an incident by analyzing various artifacts and other evidence sources.

Description of quality assurance and legal aspects

- **Documentation** involves maintaining accurate and detailed records of all actions taken during an incident or investigation.
- **Reporting** is the process of summarizing the investigation's results or incident response actions in a clear, structured format to inform various stakeholders, such as management, legal teams, regulatory authorities, or external partners. Reports can be technical (e.g., for IT teams) or high-level (e.g., for executives).

- **Quality Assurance (QA)** is a systematic process designed to ensure that products, services, or procedures meet defined standards of quality.
- **Legal Support** in incident response refers to the involvement of legal professionals to guide the organization through the legal aspects of managing a cybersecurity incident.

While conduct forensic analysis using Autopsy in kali Linux you follow the following steps:

Step 1 : Installation of Autopsy

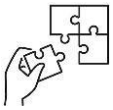
Step 2: Opening Autopsy by typing the command in the terminal.

Step 3: Launching Autopsy through the browser.

Step 4: Adding Host.

Step 5: Adding Image.

Step 6: Analyzing Files.



Application of learning 4.5.

IRWANDA is a large technology services company that recently experienced a suspected data breach. Sensitive customer data may have been exfiltrated, and there are signs that the breach may have involved deleted files. You are requested a thorough forensic investigation to determine how the breach occurred, recover deleted data, and analyze the compromised systems.

Indicative content 4.6. Restoring System and Data

Duration: 2 hrs

Theoretical Activity 4.6.1: Description of System and Data Restoration.

Tasks:

1: Answer the following questions:

i. What is recovery plan?
ii. Why we prioritize system and data for restoration?
iii. Identify hardware and infrastructure needed in restoration preparation.
iv. Discuss on RPOs and RTOs
v. What is Data Restoration
vi. Discuss on System Restoration
vii. Identify Testing and Validation
viii. What is User and Stakeholder Communication

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 4.6.1.

Key readings 4.6.1.:

Restoring System and Data

System and Data Restoration

• **Referring to the Recovery Plan:** Restoration efforts should follow the predefined incident recovery plan, focusing on minimizing downtime.

Example*:* Referring to a disaster recovery plan to restore operations after a ransomware attack.

• **Prioritizing Systems and Data for Restoration:** Identify the most critical systems and data that need to be restored first.

Example*:* Restoring an organization's financial systems before less critical applications after an attack.

• **Hardware and Infrastructure Preparation:** Ensure that the necessary infrastructure is ready for restoration, including servers and network hardware.

Example*:* Verifying that backup servers are ready to be brought online after a hardware failure.

- **Recovery Point Objectives (RPOs) and Recovery Time Objectives (RTOs):** Define the acceptable amount of data loss (RPO) and the maximum allowable downtime (RTO) to guide the restoration process.

***Example**:* Recovering a system to the state it was in 24 hours before an attack to meet the organization's RPO.

Data and System Restoration

- **Data Restoration:** Restore data from backups or other recovery methods.

***Example**:* Restoring encrypted files from a backup after a ransomware attack.

- **System Restoration:** Recover systems, applications, and services to full functionality.

***Example**:* Rebuilding and patching a compromised server to eliminate vulnerabilities before reconnecting it to the network.

- **Testing and Validation:** Ensure that restored systems and data are functioning correctly and meet operational requirements.

***Example**:* Running tests on a restored web server to confirm it is performing normally and securely.

- **User and Stakeholder Communication:** Inform stakeholders about the progress of the recovery and any potential impacts.

Example*:* Notifying executives and users about the expected downtime during system restoration.



Theoretical Activity 4.6.2: Description of post restoration actions and documentation



Tasks:

1: Answer the following questions:

i. Define Documentation in Cybersecurity.
ii. What are Parallel Operations in Cybersecurity Incident Response?
iii. What is Post-Restoration Monitoring?
iv. Describe the purpose and importance of User Training and Support in Cybersecurity.
v. How do you conduct a Review and identify Lessons Learned after a Cybersecurity Incident?
vi. Describe the process of Documentation Updates in a Cybersecurity Program.
vii. What are Audit and Compliance Checks, and how are they implemented in Cybersecurity?

2: Present your group's findings on the discussed topics.

3. Ask clarification if any

4: Read the key readings 4.6.2.



Key readings 4.6.2:

Description of post restoration actions and documentation

- **Documentation:**

After the restoration process, it's essential to update all relevant documentation to reflect any changes or updates made during the recovery. This ensures that future recovery efforts are informed by current, accurate information and that lessons learned from the incident are integrated into the response process.

Example*:* Updating the recovery plan to include lessons learned from the recent incident.

- **Parallel Operation**

In cases where full system restoration may take time, it may be necessary to run temporary or parallel systems to maintain essential business functions. This approach ensures that the organization can continue operating while the main system is being restored.

Example*:* Using a temporary cloud-based email service while the main system is being restored.

- **Post-Restoration Monitoring**

After restoring systems, continuous monitoring is vital to detect any signs of re-infection, lingering malware, or newly exposed vulnerabilities. Enhanced monitoring should be in place to ensure that restored systems remain secure and any potential threats are quickly identified and mitigated

***Example**:* Implementing enhanced monitoring after a malware attack to ensure no further threats persist.

- **User Training and Support:**

Following a restoration, it's important to provide training to users on any changes to systems or new security measures that were implemented during the recovery. This helps prevent future incidents by ensuring that users are aware of updated security protocols and best practices.

***Example**:* Offering refresher training on password policies after a breach caused by weak credentials.

- **Review and Lessons Learned:**

A post-incident review should be conducted to evaluate what went well and what can be improved. This review, often referred to as a "post-mortem," provides valuable insights that can enhance future incident response and recovery efforts.

***Example**:* Holding a post-mortem meeting to discuss the effectiveness of the response to a security breach.

- **Documentation Updates:**

Incident response plans and protocols should be regularly updated based on the lessons learned from the incident. These updates ensure that the organization's response is aligned with the latest security threats and recovery practices.

***Example**:* Revising incident response procedures to address new attack vectors identified during the breach.

- **Audit and Compliance Checks:**

After systems have been restored, it is essential to perform audit and compliance checks to ensure that all security measures are in place and that the systems meet regulatory and industry standards. This step is critical for organizations that operate under strict regulatory requirements

***Example**:* Conducting an audit to confirm that security measures are in place after a significant incident.

Practical Activity 4.6.3: Restoring and validating of system and data.

Task:

1: Referring to the previous theoretical activity (4.6.2) you are requested to perform the following activity.

You are requested to conduct forensic analysis to determine how the breach occurred, recover deleted data, and analyze the compromised systems.

2: Read the key readings 4.6.3.

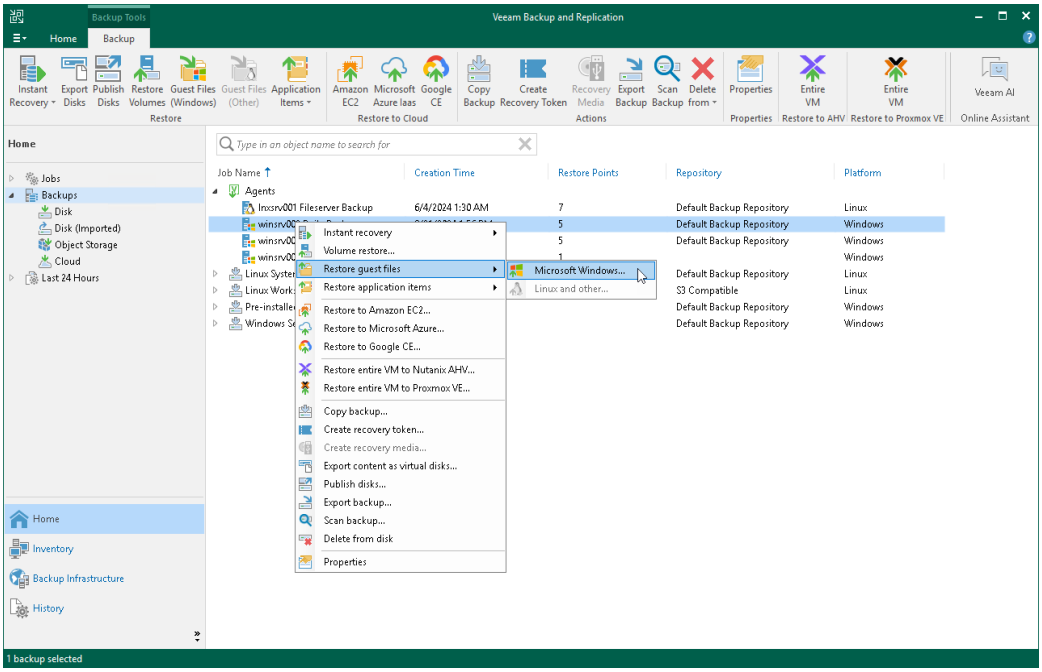
Key readings 4.6.3.

Restoring and validating of system and data using Veeam

Step 1. Launch File Level Restore Wizard

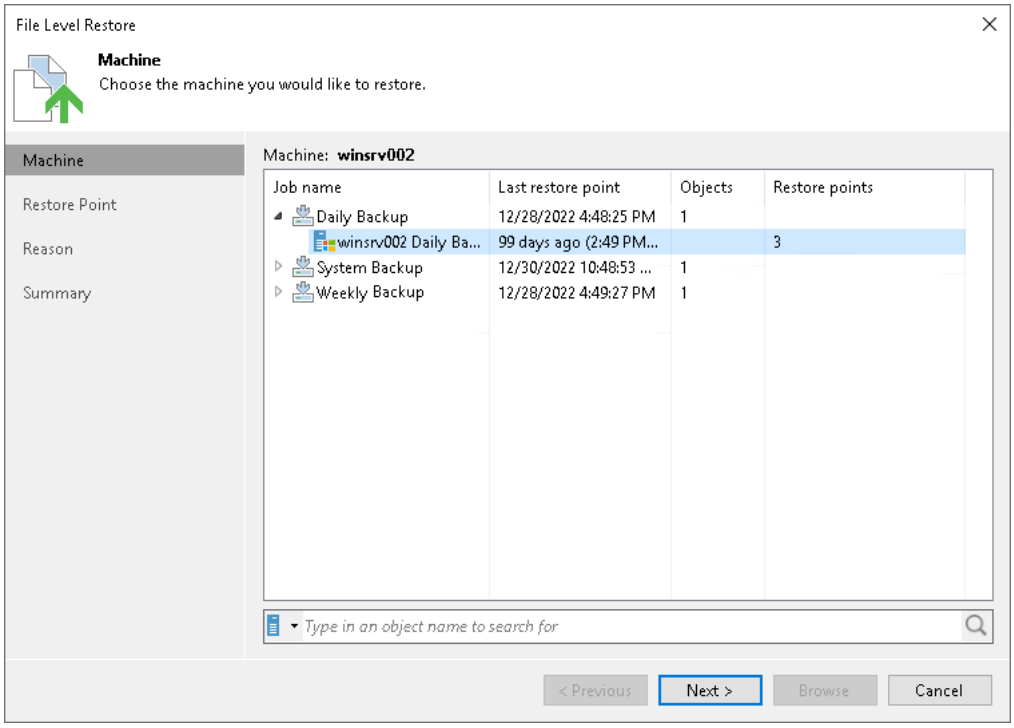
To launch the **File Level Restore** wizard, do either of the following:

- Open the **Home** tab and click **Restore** > **Agent** > **Guest files restore** > **Microsoft Windows**. In this case, you will be able to select a Veeam Agent computer whose files and folders you want to restore at the Machine step of the wizard.
- Open the **Home** view. In the inventory pane, click the **Backups** node. In the working area, expand the necessary Veeam Agent backup, select the necessary computer in the backup and click **Guest Files (Windows)** on the ribbon. Alternatively, right-click the computer and select **Restore guest files** > **Microsoft Windows**. In this case, you will proceed immediately to the Restore Point step of the wizard.



Step 2. Select Machine

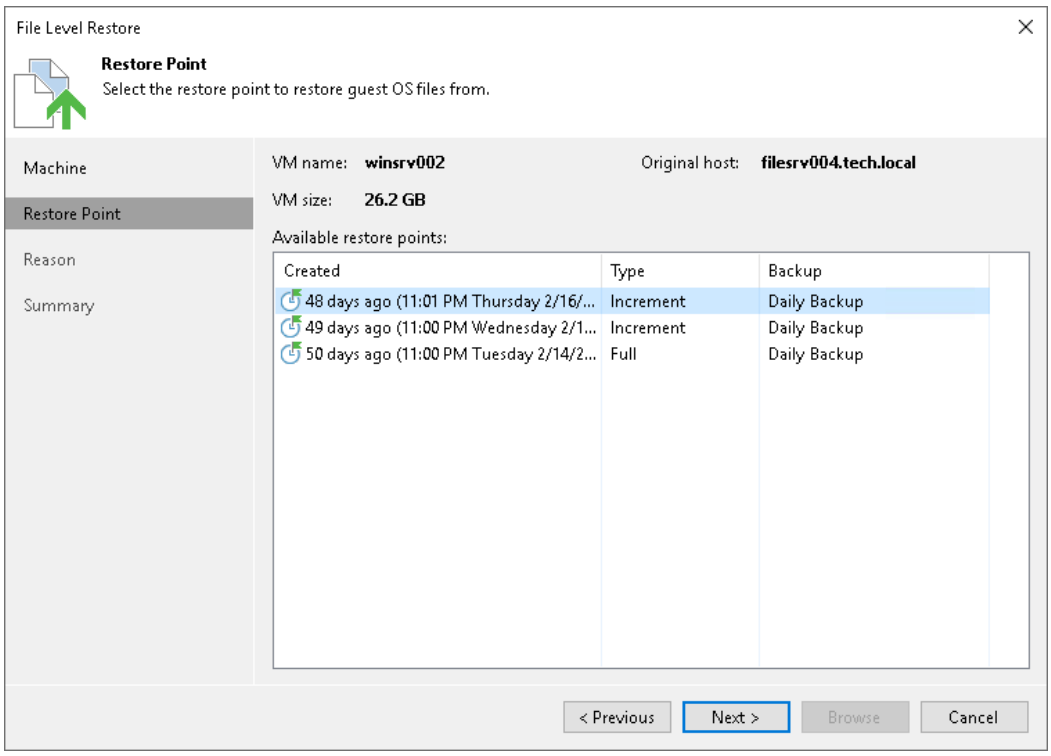
At the **Machine** step of the wizard, select a backup from which you want to recover data. To quickly find the necessary backup, use the search field at the bottom of the window: enter a Veeam Agent computer name or a part of it in the search field and click the **Start search** button on the right or press [Enter].



Step 3. Select Restore Point

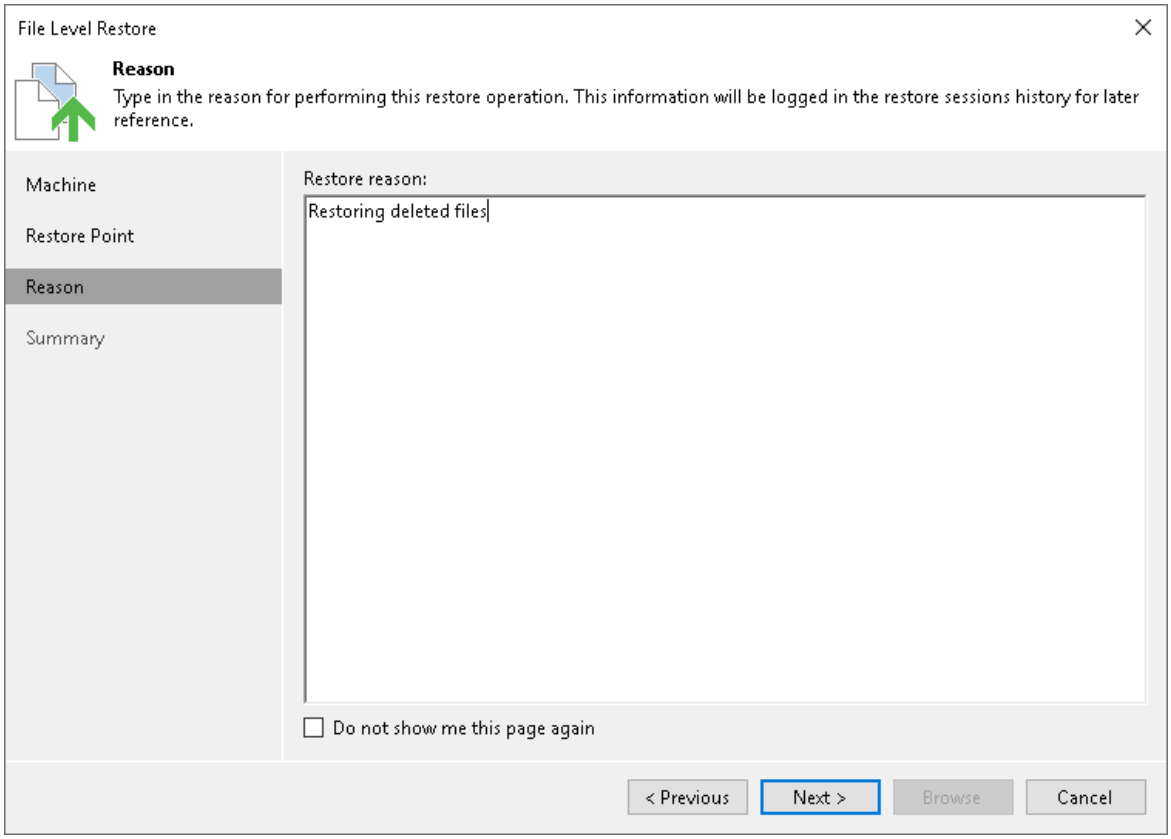
At the **Restore Point** step of the wizard, select a restore point from which you want to recover data.

By default, Veeam Backup & Replication uses the latest restore point. However, you can select any valid restore point to recover data from.



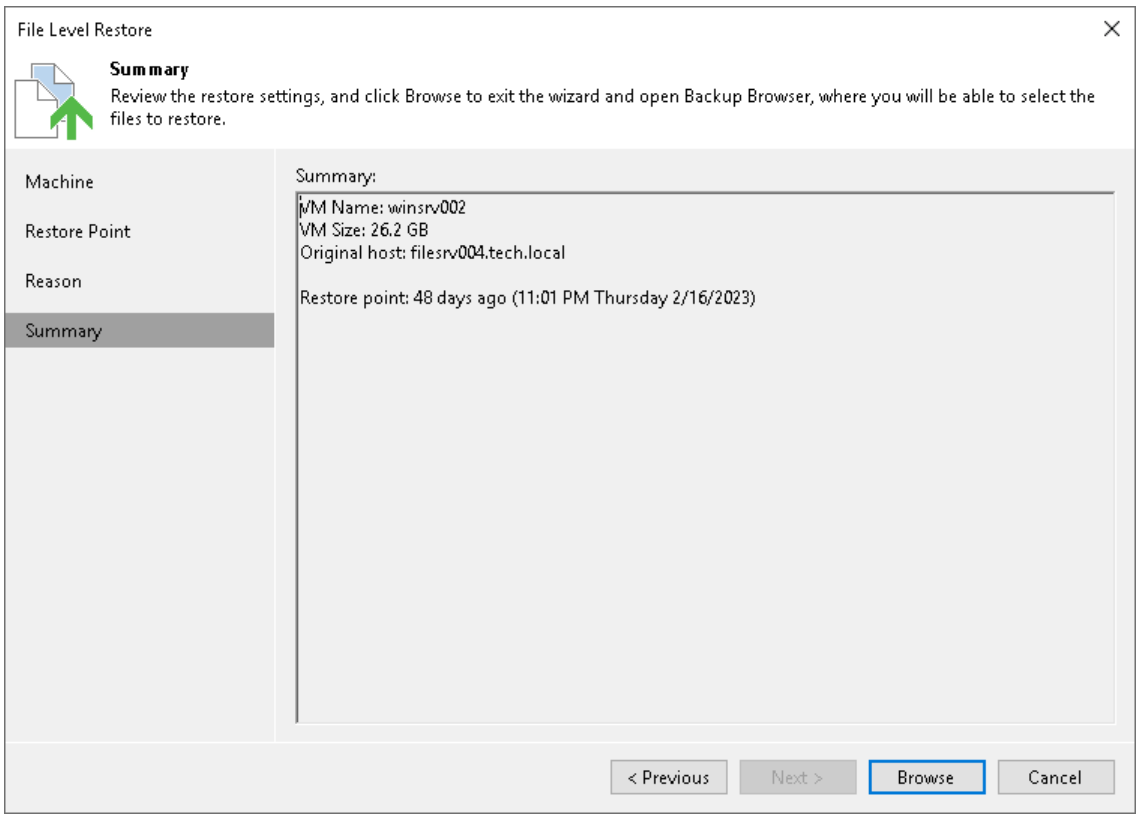
Step 4. Specify Restore Reason

At the **Reason** step of the wizard, enter a reason for restoring data.



Step 5. Verify Restore Settings

At the **Summary** step of the wizard, check details of the restore task and click **Browse** to close the wizard and open the Veeam Backup browser.



Step 6. Finalize Restore

After you close the wizard, Veeam Backup & Replication opens the Veeam Backup browser with the file system tree of the restored Veeam Agent computer.



Points to Remember

Description of System and Data Restoration

- Recovery plan: is a comprehensive document that outlines the steps to be taken to restore systems and data after a disaster or security incident.
- Prioritize system and data for restoration: Prioritizing systems and data for restoration is crucial for several reasons: Business Continuity,Data Loss Prevention,Regulatory Compliance.
- The hardware and infrastructure needed for restoration preparation, include: Backup servers, Storage devices,Network equipment,Servers
- Recovery Point Objective (RPO): This is the maximum amount of data loss that an organization can tolerate. It defines the point in time to which data should be restored. Recovery Time Objective (RTO): This is the maximum amount of time that an organization can be without a particular system or data before it impacts business operations.
- Data restoration : is the process of recovering lost or corrupted data from backups or other sources.
- System restoration: involves bringing a system back to a functional state after a failure or disruption.
- Testing and validation:are essential steps in system and data restoration. Testing ensures that restored systems and data are functioning correctly and that all necessary components are in place. Validation verifies that the restored systems and data meet the organization's requirements and expectations.
- User and stakeholder communication: is critical during and after system and data restoration. It involves informing users about the restoration process, providing updates on progress, and addressing any concerns.

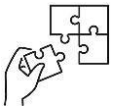
Description of post restoration actions and documentation

- Documentation in cybersecurity refers to the creation and maintenance of records related to all aspects of cybersecurity, including incident response, risk management, and compliance.
- Parallel operations in cybersecurity incident response refer to the ability to continue critical business functions on alternate systems or data centers while the primary systems are being restored or repaired.
- Post-restoration monitoring involves closely observing restored systems and data for signs of issues or problems.
- User Training and Support User training and support are essential for ensuring that employees are aware of cybersecurity best practices and can effectively use security tools. Training can help prevent incidents by educating employees about phishing scams, social engineering attacks, and other threats.

- A review and lessons learned process involves analyzing the incident to understand what happened, identify root causes, and determine how to prevent similar incidents in the future. This may involve conducting interviews, reviewing logs, and analyzing data.
- Documentation updates are necessary to ensure that cybersecurity policies, procedures, and records are accurate and up-to-date. This may involve updating incident response plans, reviewing risk assessments, and documenting changes to security controls.
- Audit and compliance checks are used to verify that an organization is meeting its cybersecurity obligations and complying with relevant regulations. This may involve internal audits, external assessments, or compliance reviews.

While Restoring and validating of system and data you follow the following steps:

Step1. Launch File Level Restore Wizard
Step2. Select Machine
Step3. Select Restore Point
Step4. Specify Restore Reason
Step5. Verify Restore Settings
Step6. Finalize Restore



Application of learning 4.6.

You are the incident response manager for a BWIZA Company that has recently experienced a ransomware attack. The attackers have encrypted critical systems and data, disrupting business operations. Based on the provided guidelines, using Veeam software for restoring systems and data, ensuring minimal downtime and maintaining compliance with relevant regulations.



Learning outcome 4 end assessment

Written assessment

SECTION I. Read the statement below and answer by TRUE or FALSE if it is correct or incorrect.

1. Is it important to include key stakeholders when developing an Incident Response Plan?
2. An Incident Response Policy is not necessary as long as you have response procedures in place.
3. Incident containment should occur before eradication and recovery in the Incident Response Plan.
4. Training and awareness are not part of an effective Incident Response Plan.
5. Post-incident analysis is crucial to improving future incident response efforts.
6. A Communication Plan is unnecessary in the context of an Incident Response Plan.

7. A Business Impact Analysis (BIA) helps in defining Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

8. The recovery plan should be tested and validated regularly to ensure effectiveness.

9. Documentation and reporting are not required when developing an Incident Recovery Plan.

10. Anomaly detection is a technique used for identifying incidents.

11. System isolation techniques, such as disabling network ports and using firewalls, are key to controlling the spread of an incident.

12. The validation of isolation is not required once a system is affected.

13. Incident analysis and impact assessment are critical after isolating the affected system.

14. Forensic analysis involves evidence preservation and data collection following an incident.

15. Legal considerations should be ignored when conducting forensic analysis.

16. Restoring systems and data after an incident should follow the recovery plan and prioritize critical systems first.

17. Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs) are not relevant in system restoration efforts.

18. Parallel operations should be monitored post-restoration to ensure system integrity.

19. Reviewing and updating documentation is an unnecessary step after system and data restoration.

SECTION II: fill the following paragraph with appropriate word from provided word

1.The process of creating a framework to handle and mitigate security incidents is known as developing an _____.

A. Incident Response Plan
B. External Plan
C. Stakeholders
D. Recovery

2. A key element in incident response is the involvement of _____ to ensure smooth coordination and decision-making.

A. Incident Response
B. Backup Plan
C. Key Stakeholders
D. Recovery process

3. _____ and Reporting are critical for quickly identifying and managing a cybersecurity breach.

A. Restoration
B. Documentation
C. Incident Detection
D. Network Segmentation

4. The step taken after identifying a cybersecurity breach to prevent it from spreading is called _____.

A. Communication
B. Incident Containment
C. Incident Response
D. Firewall

5. To ensure proper communication during a cybersecurity incident, an organization must establish a _____ Plan.

A. Documentation
B. Monitoring
C. Communication
D. Testing and Validation
E. System Restoration

6. After a cybersecurity incident, organizations must perform a _____ to understand what went wrong and how to improve future responses**.**

A. Security Incident
B. Public Relations
C. Incident Detection
D. Post-Incident Analysis

7. Combining incident response and disaster recovery ensures better handling of both scenarios, which is referred to as _____ Integration.

A. Reputation Management
B. DR/BCP
C. Regulatory Compliance
D. Executive Reporting

8. Recovery Time Objectives (RTOs) and _____ are key measures used to define recovery goals in incident recovery plans.

A. Recovery Point Objectives (RPOs)
B. Objectives and Scope
C. Recovery Joint Objectives
D. Incident Recovery Plans

9. The use of _____ techniques, such as anomaly detection or signature-based detection, helps in identifying cybersecurity incidents.

13. Incident Detection
14. Risk Assessment
15. Value Detection
16. Normal Behavior

10. The process of ensuring an organization meets legal and industry standards after a breach is called _____.

A. Employee Training
B. Resource Allocation
C. Regulatory and Legal Compliance
D. Continuous Improvement

11. To avoid further damage during an incident, affected systems must undergo _____ techniques like network segmentation or disabling network ports**.**

A. Impact Assessment
B. Recovery Planning
C. System Isolation
A. Logging and Documentation

12. Ensuring that the isolation of systems is successful requires _____ and documentation.

A. Logging
B. Restoration
C. Collection
D. Validation

13. A thorough investigation into a cybersecurity incident involves _____ and Data Collection to preserve evidence.

A. Evidence Documentation
B. Legal Considerations
C. Forensic Imaging
D. Forensic Analysis

14. After gathering data, the process of reconstructing artifacts and events for deeper analysis is known as _____.

A. Evidence Documentation
B. Examination
C. Event Reconstruction
D. Quality Assurance

15. Once systems are restored, organizations must engage in _____ to monitor the effectiveness of recovery.

A. Documentation
B. Parallel Operations
C. Post-Restoration Monitoring
D. Incident Analysis

16. Conducting _____ of incidents is crucial for understanding the severity and impact of the attack.

A. Parallel Operations
B. Data Restoration
C. Documentation Updates
D. Incident Analysis

17. After restoring systems, an organization must review and update their _____ to reflect lessons learned.

A. Review and Lessons Learned
B. Documentation
C. Stakeholder Communication
D. System Restoration

18. The process of performing checks to ensure an organization remains compliant with cybersecurity standards is called _____.

A. Audit and Compliance Checks
B. Documentation Updates
C. User Training and Support

SECTION III. Choose the letter corresponding to the correct answers from Colum A and Column B.

ANSWER	COLUMN A	COLUMN B
	A. Incident Response Plan	1.The process of identifying and reporting potential security incidents
	B. Incident Detection and Reporting	2.A documented, organized approach to handling and managing cybersecurity incidents.
	C. Incident Containment	3.A review process to evaluate how an incident was handled and lessons learned
	D. Post-Incident Analysis	4.Limiting the damage of a security breach to prevent further harm.
	E. Legal and Regulatory Compliance	5. Guidelines for how and when to communicate with stakeholders during an incident.
	F. Communication Plan	6.Ensuring incident response and recovery procedures meet legal and regulatory standards
	G. Recovery Time Objectives (RTOs)	7.Verifying that incident response and recovery processes align with internal policies and external regulations.
	H. Baseline Normal Behavior	8.The maximum acceptable amount of data loss in a recovery scenario
	I. Firewall Rules	9. Technology used to detect security incidents, such as intrusion detection systems (IDS).
	J. Recovery Point Objectives (RPOs)	10.The target time to recover systems after an incident
	K. Incident Detection Tools and Systems	11.A standard of expected system behavior used to detect anomalies.
	L. Network Segmentation	12. A set of policies defining what traffic is allowed or blocked in a network.
	M. Disaster Recovery (DR) and Business Continuity Planning (BCP) Integration	13. Incorporating response and recovery plans into broader business continuity strategies
	N. Audit and Compliance Checks	14. Dividing a network into smaller segments to limit the spread of incidents.

Practical assessment

BELL Company Ltd has experienced a major security incident involving a ransomware attack. You are a member of the incident response team responsible for managing the incident and restoring business operations. Your task is to implement a complete incident response and recovery plan, ensuring that all necessary steps are taken to contain, recover, analyze the incident and provide documentation report



References

Miller, R. (2021). *Network security monitoring and analysis: A comprehensive guide to intrusion detection systems and security information and event management*. Wiley.

Northcutt, S., & Novak, W. (2020). *Intrusion detection: A practical guide to the techniques and technologies*. Pearson Education.

Skoudis, E., & Liston, T. (2020). *Counter Hack Reloaded: A step-by-step guide to computer attacks and effective defenses*. Pearson Education.

Jones, A., & Sawyerr, K. (2021). *Cyber incident response and recovery: A comprehensive guide for businesses*. CRC Press.

Cisco. (n.d.). *Cybersecurity awareness month*.Cisco. https://www.cisco.com/c/en/us/products/security/cybersecurity-awareness-month.html#~additional-resources

National Cyber Security Centre. (n.d.). *Developing your plan*. National Cyber Security Centre. https://www.ncsc.gov.uk/collection/incident-management/cyber-incident-response-processes/developing-your-plan

Palo Alto Networks. (n.d.). *Managed detection and response*. Palo Alto Networks. https://www.paloaltonetworks.com/unit42/respond/managed-detection-response

SANS Institute. (n.d.). *Cyber security courses*. SANS Institute. https://www.sans.org/cyber-security-courses/?focus-area=cloud-security,cyber-defense,cyber-security-it-essentials,digital-forensics

Veeam. (n.d.). *File-level restore before you begin*. Veeam. https://helpcenter.veeam.com/docs/agentforwindows/userguide/files_restore_before.html?ver=60

RTB | RWANDA TVET BOARD

October 2024